

CIS Microsoft Intune for Windows 11 Benchmark

v2.0.0 - 10-20-2023

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	19
Intended Audience.....	19
Consensus Guidance	20
Typographical Conventions.....	21
Recommendation Definitions.....	22
Title.....	22
Assessment Status.....	22
Automated	22
Manual.....	22
Profile	22
Description.....	22
Rationale Statement	22
Impact Statement.....	23
Audit Procedure.....	23
Remediation Procedure.....	23
Default Value.....	23
References	23
CIS Critical Security Controls® (CIS Controls®)	23
Additional Information.....	23
Profile Definitions	24
Acknowledgements	26
Recommendations	27
1 Account Policies.....	27
1.1 Password Policy	27
1.1.1 (L1) Ensure 'Enforce password history' is set to '24 or more passwords' (Automated)	28
1.1.2 (L1) Ensure 'Maximum password age' is set to '365 or fewer days, but not 0' (Automated).....	32
1.1.3 (L1) Ensure 'Minimum password age' is set to '1 or more day(s)' (Automated).....	36
1.1.4 (L1) Ensure 'Minimum password length' is set to '14 or more characters' (Automated)	40
1.1.5 (L1) Ensure 'Password must meet complexity requirements' is set to 'Numbers and lowercase' (Automated)	44
2 Local Policies.....	48
2.1 Audit Policy	48
2.2 User Rights Assignment	48
2.2.1 (L1) Ensure 'Access Credential Manager as a trusted caller' is set to 'No One' (Automated)	49

2.2.2 (L1) Ensure 'Access this computer from the network' is set to 'Administrators, Remote Desktop Users' (Automated)	53
2.2.3 (L1) Ensure 'Act as part of the operating system' is set to 'No One' (Automated)	57
2.2.4 (L1) Ensure 'Allow log on locally' is set to 'Administrators, Users' (Automated)	61
2.2.5 (L1) Ensure 'Back up files and directories' is set to 'Administrators' (Automated)	65
2.2.6 (L1) Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE' (Automated)	69
2.2.7 (L1) Ensure 'Create a pagefile' is set to 'Administrators' (Automated)	74
2.2.8 (L1) Ensure 'Create a token object' is set to 'No One' (Automated)	78
2.2.9 (L1) Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)	82
2.2.10 (L1) Ensure 'Create permanent shared objects' is set to 'No One' (Automated)	86
2.2.11 (L1) Configure 'Create symbolic links' is set to 'Administrators' (Automated)	90
2.2.12 (L1) Ensure 'Debug programs' is set to 'Administrators' (Automated)	94
2.2.13 (L1) Ensure 'Deny access to this computer from the network' to include 'Guests, Local account' (Automated)	98
2.2.14 (L1) Ensure 'Deny log on as a service' to include 'Guests' (Automated)	102
2.2.15 (L1) Ensure 'Deny log on locally' to include 'Guests' (Automated)	106
2.2.16 (L1) Ensure 'Deny log on through Remote Desktop Services' to include 'Guests, Local account' (Automated)	110
2.2.17 (L1) Ensure 'Enable computer and user accounts to be trusted for delegation' is set to 'No One' (Automated)	114
2.2.18 (L1) Ensure 'Force shutdown from a remote system' is set to 'Administrators' (Automated)	118
2.2.19 (L1) Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE' (Automated)	122
2.2.20 (L1) Ensure 'Impersonate a client after authentication' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)	126
2.2.21 (L1) Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group' (Automated)	130
2.2.22 (L1) Ensure 'Load and unload device drivers' is set to 'Administrators' (Automated)	134
2.2.23 (L1) Ensure 'Lock pages in memory' is set to 'No One' (Automated)	138
2.2.24 (L1) Ensure 'Manage auditing and security log' is set to 'Administrators' (Automated)	142
2.2.25 (L1) Ensure 'Modify an object label' is set to 'No One' (Automated)	146
2.2.26 (L1) Ensure 'Modify firmware environment values' is set to 'Administrators' (Automated)	150
2.2.27 (L1) Ensure 'Perform volume maintenance tasks' is set to 'Administrators' (Automated)	154
2.2.28 (L1) Ensure 'Profile single process' is set to 'Administrators' (Automated)	158
2.2.29 (L1) Ensure 'Restore files and directories' is set to 'Administrators' (Automated)	162
2.2.30 (L1) Ensure 'Take ownership of files or other objects' is set to 'Administrators' (Automated)	166
2.3 Security Options	170
2.3.1 Accounts	170
2.3.1.1 (L1) Ensure 'Accounts: Block Microsoft accounts' is set to 'Blocked' (Automated)	171
2.3.1.2 (L1) Ensure 'Accounts: Guest account status' is set to 'Disabled' (Automated)	175
2.3.1.3 (L1) Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled' (Automated)	179
2.3.1.4 (L1) Configure 'Accounts: Rename administrator account' (Automated)	183
2.3.1.5 (L1) Configure 'Accounts: Rename guest account' (Automated)	187
2.3.2 Audit	190
2.3.3 DCOM	190
2.3.4 Devices	190
2.3.4.1 (L2) Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled' (Automated)	191
2.3.5 Domain controller	195
2.3.6 Domain member	195
2.3.7 Interactive logon	195
2.3.7.1 (L1) Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled' (Automated)	196

2.3.7.2 (L1) Ensure 'Interactive logon: Don't display last signed-in' is set to 'Enabled' (Automated)	198
2.3.7.3 (L1) Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0' (Automated)	201
2.3.7.4 (L1) Configure 'Interactive logon: Message text for users attempting to log on' (Automated)	205
2.3.7.5 (L1) Configure 'Interactive logon: Message title for users attempting to log on' (Automated)	208
2.3.7.6 (L1) Ensure 'Interactive logon: Smart card removal behavior' is set to 'Lock Workstation' or higher (Automated)	211
2.3.8 Microsoft network client	214
2.3.8.1 (L1) Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled' (Automated)	215
2.3.8.2 (L1) Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled' (Automated)	219
2.3.8.3 (L1) Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled' (Automated)	223
2.3.9 Microsoft network server	227
2.3.9.1 (L1) Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled' (Automated)	228
2.3.9.2 (L1) Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled' (Automated)	232
2.3.10 Network access	237
2.3.10.1 (L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (Automated)	238
2.3.10.2 (L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (Automated)	241
2.3.10.3 (L1) Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled' (Automated)	244
2.3.10.4 (L1) Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (Automated)	247
2.3.11 Network security	250
2.3.11.1 (L1) Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled' (Automated)	251
2.3.11.2 (L1) Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' is set to 'Disabled' (Automated)	254
2.3.11.3 (L1) Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled' (Automated)	258
2.3.11.4 (L1) Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)	262
2.3.11.5 (L1) Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption' (Automated)	267
2.3.12 Recovery console	271
2.3.13 Shutdown	271
2.3.14 System cryptography	271
2.3.15 System objects	271
2.3.16 System settings	271
2.3.17 User Account Control	271
2.3.17.1 (L1) Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled' (Automated)	272
2.3.17.2 (L1) Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop' or higher (Automated)	276
2.3.17.3 (L1) Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests' (Automated)	280
2.3.17.4 (L1) Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled' (Automated)	283
2.3.17.5 (L1) Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled' (Automated)	286

2.3.17.6 (L1) Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled' (Automated)	289
2.3.17.7 (L1) Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled' (Automated)	293
2.3.17.8 (L1) Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled' (Automated)	296
3 Event Log	298
4 Restricted Groups	298
5 System Services	298
5.1 (L1) Ensure 'Xbox Accessory Management Service (XboxGipSvc)' is set to 'Disabled' (Automated)	299
5.2 (L1) Ensure 'Xbox Live Auth Manager (XblAuthManager)' is set to 'Disabled' (Automated)	302
5.3 (L1) Ensure 'Xbox Live Game Save (XblGameSave)' is set to 'Disabled' (Automated)	304
5.4 (L1) Ensure 'Xbox Live Networking Service (XboxNetApiSvc)' is set to 'Disabled' (Automated)	307
6 Registry	309
7 File System	309
8 Wired Network (IEEE 802.3) Policies	309
9 Windows Firewall with Advanced Security	309
9.1 Domain Profile	309
9.1.1 (L1) Ensure 'Windows Firewall: Domain: Firewall state' is set to 'Enabled' (Automated)	310
9.1.2 (L1) Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block' (Automated)	313
9.1.3 (L1) Ensure 'Windows Firewall: Domain: Outbound connections' is set to 'Allow' (Automated)	316
9.1.4 (L1) Ensure 'Windows Firewall: Domain: Settings: Display a notification' is set to 'Block' (Automated)	319
9.2 Private Profile	322
9.2.1 (L1) Ensure 'Windows Firewall: Private: Firewall state' is set to 'Enabled' (Automated)	323
9.2.2 (L1) Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block' (Automated)	326
9.2.3 (L1) Ensure 'Windows Firewall: Private: Outbound connections' is set to 'Allow' (Automated)	329
9.2.4 (L1) Ensure 'Windows Firewall: Private: Settings: Display a notification' is set to 'Block' (Automated)	332
9.3 Public Profile	335
9.3.1 (L1) Ensure 'Windows Firewall: Public: Firewall state' is set to 'Enabled' (Automated)	336
9.3.2 (L1) Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block' (Automated)	339
9.3.3 (L1) Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Allow' (Automated)	342
9.3.4 (L1) Ensure 'Windows Firewall: Public: Settings: Display a notification' is set to 'Block' (Automated)	345
9.3.5 (L1) Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No' (Automated)	348
10 Network List Manager Policies	351
11 Wireless Network (IEEE 802.11) Policies	351
12 Public Key Policies	351
13 Software Restriction Policies	351
14 Network Access Protection NAP Client Configuration	351
15 Application Control Policies	351
16 IP Security Policies	351
17 Advanced Audit Policy Configuration	351
17.1 Account Logon	351

17.1.1 (L1) Ensure 'Audit Credential Validation' is set to 'Success and Failure' (Automated)	352
17.2 Account Management	356
17.2.1 (L1) Ensure 'Audit Application Group Management' is set to 'Success and Failure' (Automated)	357
17.2.2 (L1) Ensure 'Audit Security Group Management' is set to include 'Success' (Automated)	361
17.2.3 (L1) Ensure 'Audit User Account Management' is set to 'Success and Failure' (Automated)	365
17.3 Detailed Tracking	369
17.3.1 (L1) Ensure 'Audit PNP Activity' is set to include 'Success' (Automated)	370
17.3.2 (L1) Ensure 'Audit Process Creation' is set to include 'Success' (Automated)	374
17.4 DS Access	378
17.5 Logon/Logoff	378
17.5.1 (L1) Ensure 'Audit Account Lockout' is set to include 'Failure' (Automated)	379
17.5.2 (L1) Ensure 'Audit Group Membership' is set to include 'Success' (Automated)	383
17.5.3 (L1) Ensure 'Audit Logoff' is set to include 'Success' (Automated)	387
17.5.4 (L1) Ensure 'Audit Logon' is set to 'Success and Failure' (Automated)	391
17.5.5 (L1) Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure' (Automated)	395
17.5.6 (L1) Ensure 'Audit Special Logon' is set to include 'Success' (Automated)	399
17.6 Object Access	403
17.6.1 (L1) Ensure 'Audit Detailed File Share' is set to include 'Failure' (Automated)	404
17.6.2 (L1) Ensure 'Audit File Share' is set to 'Success and Failure' (Automated)	408
17.6.3 (L1) Ensure 'Audit Other Object Access Events' is set to 'Success and Failure' (Automated)	412
17.6.4 (L1) Ensure 'Audit Removable Storage' is set to 'Success and Failure' (Automated)	416
17.7 Policy Change	420
17.7.1 (L1) Ensure 'Audit Audit Policy Change' is set to include 'Success' (Automated)	421
17.7.2 (L1) Ensure 'Audit Authentication Policy Change' is set to include 'Success' (Automated)	425
17.7.3 (L1) Ensure 'Audit Authorization Policy Change' is set to include 'Success' (Automated)	429
17.7.4 (L1) Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure' (Automated)	433
17.7.5 (L1) Ensure 'Audit Other Policy Change Events' is set to include 'Failure' (Automated)	437
17.8 Privilege Use	441
17.8.1 (L1) Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure' (Automated)	442
17.9 System	446
17.9.1 (L1) Ensure 'Audit IPsec Driver' is set to 'Success and Failure' (Automated)	447
17.9.2 (L1) Ensure 'Audit Other System Events' is set to 'Success and Failure' (Automated)	452
17.9.3 (L1) Ensure 'Audit Security State Change' is set to include 'Success' (Automated)	456
17.9.4 (L1) Ensure 'Audit Security System Extension' is set to include 'Success' (Automated)	460
17.9.5 (L1) Ensure 'Audit System Integrity' is set to 'Success and Failure' (Automated)	464
18 Administrative Templates (Computer)	468
18.1 Control Panel	468
18.1.1 Personalization	468
18.1.1.1 (L1) Ensure 'Prevent enabling lock screen camera' is set to 'Enabled' (Automated)	469
18.1.1.2 (L1) Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled' (Automated)	473
18.1.2 Regional and Language Options	476
18.1.2.2 (L1) Ensure 'Allow users to enable online speech recognition services' is set to 'Disabled' (Automated)	477
18.1.3 (L2) Ensure 'Allow Online Tips' is set to 'Disabled' (Automated)	480
18.2 Desktop	482
18.3 LAPS	482
18.3.1 (L1) Ensure LAPS AdmPwd GPO Extension / CSE is installed (Automated)	483
18.3.2 (L1) Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (Automated)	486
18.3.3 (L1) Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (Automated)	489

18.3.4 (L1) Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (Automated)	492
18.3.5 (L1) Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (Automated) ..	495
18.3.6 (L1) Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 30 or fewer' (Automated)	498
18.4 MS Security Guide	501
18.4.1 (L1) Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (Automated)	502
18.4.2 (L1) Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)' (Automated)	505
18.4.3 (L1) Ensure 'Configure SMB v1 server' is set to 'Disabled' (Automated)	508
18.4.4 (L1) Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled' (Automated)	512
18.4.5 (L1) Ensure 'WDigest Authentication' is set to 'Disabled' (Automated)	516
18.5 MSS (Legacy)	520
18.5.1 (L1) Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled' (Automated)	521
18.5.2 (L1) Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)	524
18.5.3 (L1) Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)	527
18.5.4 (L2) Ensure 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved' is set to 'Enabled' (Automated)	530
18.5.5 (L1) Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled' (Automated)	533
18.5.6 (L2) Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)' (Automated)	537
18.5.7 (L1) Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled' (Automated)	540
18.5.8 (L1) Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled' (Automated)	543
18.5.9 (L2) Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled' (Automated)	546
18.5.10 (L1) Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds' (Automated)	549
18.5.11 (L2) Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)	552
18.5.12 (L2) Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)	555
18.5.13 (L1) Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less' (Automated)	558
18.6 Network	561
18.6.1 Background Intelligent Transfer Service (BITS)	561
18.6.2 BranchCache	561
18.6.3 DirectAccess Client Experience Settings	561
18.6.4 DNS Client	561
18.6.4.1 (L1) Ensure 'Turn off multicast name resolution' is set to 'Enabled' (Automated)	562
18.6.5 Fonts	565
18.6.5.1 (L2) Ensure 'Enable Font Providers' is set to 'Disabled' (Automated)	566
18.6.6 Hotspot Authentication	569
18.6.7 Lanman Server	569
18.6.8 Lanman Workstation	569
18.6.8.1 (L1) Ensure 'Enable insecure guest logons' is set to 'Disabled' (Automated)	570

18.6.9 Link-Layer Topology Discovery	573
18.6.9.1 (L2) Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled' (Automated)	574
18.6.9.2 (L2) Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled' (Automated)	576
18.6.10 Microsoft Peer-to-Peer Networking Services	578
18.6.11 Network Connections	578
18.6.11.2 (L1) Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled' (Automated)	579
18.6.11.3 (L1) Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled' (Automated)	583
18.6.11.4 (L1) Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled' (Automated)	586
18.6.12 Network Connectivity Status Indicator	588
18.6.13 Network Isolation	588
18.6.14 Network Provider	588
18.6.14.1 (L1) Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares' (Automated)	589
18.6.15 Offline Files	592
18.6.16 QoS Packet Scheduler	592
18.6.17 SNMP	592
18.6.18 SSL Configuration Settings	592
18.6.19 TCPIP Settings	592
18.6.20 Windows Connect Now	593
18.6.20.1 (L2) Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled' (Automated)	594
18.6.20.2 (L2) Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled' (Automated)	597
18.6.21 Windows Connection Manager	600
18.6.21.1 (L1) Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (Automated)	601
18.6.21.2 (L1) Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled: 3 = Prevent Wi-Fi when on Ethernet' (Automated)	604
18.6.22 Wireless Display	606
18.6.23 WLAN Service	606
18.6.23.2.1 (L1) Ensure 'Allow Windows to automatically connect to suggested open hotspots, to networks shared by contacts, and to hotspots offering paid services' is set to 'Disabled' (Automated)	607
18.7 Printers	610
18.7.1 (L1) Ensure 'Allow Print Spooler to accept client connections' is set to 'Disabled' (Automated)	611
18.7.2 (L1) Ensure 'Point and Print Restrictions: When installing drivers for a new connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)	613
18.7.3 (L1) Ensure 'Point and Print Restrictions: When updating drivers for an existing connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)	615
18.8 Start Menu and Taskbar	617
18.8.1 Notifications	617
18.8.1.1 (L2) Ensure 'Turn off notifications network usage' is set to 'Enabled' (Automated)	618
18.9 System	621
18.9.1 Access-Denied Assistance	621
18.9.2 App-V	621
18.9.3 Audit Process Creation	621
18.9.3.1 (L1) Ensure 'Include command line in process creation events' is set to 'Enabled' (Automated)	622
18.9.4 Credentials Delegation	625
18.9.4.1 (L1) Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients' (Automated)	626
18.9.4.2 (L1) Ensure 'Remote host allows delegation of non-exportable credentials' is set to 'Enabled' (Automated)	629

18.9.5 Device Guard	632
18.9.5.1 (NG) Ensure 'Turn On Virtualization Based Security' is set to 'Enabled' (Automated)	633
18.9.5.2 (NG) Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot' or higher (Automated)	637
18.9.5.3 (NG) Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (Automated)	641
18.9.5.4 (NG) Ensure 'Turn On Virtualization Based Security: Secure Launch Configuration' is set to 'Enabled' (Automated)	645
18.9.6 Device Health Attestation Service	648
18.9.7 Device Installation	648
18.9.7.1.1 (BL) Ensure 'Prevent installation of devices that match any of these device IDs' is set to 'Enabled' (Automated)	649
18.9.7.1.2 (BL) Ensure 'Prevent installation of devices that match any of these device IDs: Prevent installation of devices that match any of these device IDs' is set to 'PCI\CC_0C0A' (Automated)	652
18.9.7.1.3 (BL) Ensure 'Prevent installation of devices that match any of these device IDs: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)	655
18.9.7.1.4 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes' is set to 'Enabled' (Automated)	658
18.9.7.1.5 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)	660
18.9.7.1.6 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Prevent installation of devices using drivers for these device setup' is set to 'IEEE 1394 device setup classes' (Automated)	663
18.9.7.2 (L1) Ensure 'Prevent device metadata retrieval from the Internet' is set to 'Enabled' (Automated)	667
18.9.8 Device Redirection	670
18.9.9 Disk NV Cache	670
18.9.10 Disk Quotas	670
18.9.11 Display	670
18.9.12 Distributed COM	670
18.9.13 Driver Installation	671
18.9.14 Early Launch Antimalware	671
18.9.14.1 (L1) Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good, unknown and bad but critical' (Automated)	672
18.9.15 Enhanced Storage Access	676
18.9.16 File Classification Infrastructure	676
18.9.17 File Share Shadow Copy Agent	676
18.9.18 File Share Shadow Copy Provider	676
18.9.19 Filesystem (formerly NTFS Filesystem)	676
18.9.20 Folder Redirection	677
18.9.21 Group Policy	677
18.9.21.1 (L1) Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE' (Automated)	678
18.9.21.2 (L1) Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE' (Automated)	680
18.9.21.3 (L1) Ensure 'Continue experiences on this device' is set to 'Disabled' (Automated)	682
18.9.21.4 (L1) Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled' (Automated)	684
18.9.22 Internet Communication Management	686
18.9.22.1.1 (L2) Ensure 'Turn off access to the Store' is set to 'Enabled' (Automated)	687
18.9.22.1.2 (L1) Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled' (Automated)	690
18.9.22.1.3 (L2) Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)	693
18.9.22.1.4 (L1) Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled' (Automated)	696

18.9.22.1.5 (L2) Ensure 'Turn off printing over HTTP' is set to 'Enabled' (Automated)	700
18.9.22.1.6 (L2) Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)	704
18.9.22.1.7 (L2) Ensure 'Turn off Search Companion content file updates' is set to 'Enabled' (Automated)	707
18.9.22.1.8 (L2) Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled' (Automated)	710
18.9.22.1.9 (L2) Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled' (Automated)	713
18.9.22.1.10 (L2) Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled' (Automated)	716
18.9.22.1.11 (L2) Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled' (Automated)	719
18.9.22.1.12 (L2) Ensure 'Turn off Windows Error Reporting' is set to 'Enabled' (Automated)	722
18.9.23 iSCSI	726
18.9.24 KDC	726
18.9.25 Kerberos	726
18.9.25.1 (L2) Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic' (Automated)	727
18.9.26 Kernel DMA Protection	729
18.9.26.1 (BL) Ensure 'Enumeration policy for external devices incompatible with Kernel DMA Protection' is set to 'Enabled: Block All' (Automated)	730
18.9.27 Locale Services	734
18.9.27.1 (L2) Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled' (Automated)	735
18.9.28 Logon	737
18.9.28.1 (L1) Ensure 'Block user from showing account details on sign-in' is set to 'Enabled' (Automated)	738
18.9.28.2 (L1) Ensure 'Do not display network selection UI' is set to 'Enabled' (Automated)	740
18.9.28.3 (L1) Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled' (Automated)	743
18.9.28.4 (L1) Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (Automated)	745
18.9.28.5 (L1) Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled' (Automated)	748
18.9.28.6 (L1) Ensure 'Turn off picture password sign-in' is set to 'Enabled' (Automated)	751
18.9.28.7 (L1) Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled' (Automated)	754
18.9.29 Mitigation Options	757
18.9.30 Net Logon	757
18.9.31 OS Policies	757
18.9.31.1 (L2) Ensure 'Allow Clipboard synchronization across devices' is set to 'Disabled' (Automated)	758
18.9.31.2 (L2) Ensure 'Allow upload of User Activities' is set to 'Disabled' (Automated)	760
18.9.32 Performance Control Panel	762
18.9.33 PIN Complexity	762
18.9.34 Power Management	762
18.9.34.6.1 (L1) Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled' (Automated)	764
18.9.34.6.2 (L1) Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled' (Automated)	767
18.9.34.6.3 (BL) Ensure 'Allow standby states (S1-S3) when sleeping (on battery)' is set to 'Disabled' (Automated)	770
18.9.34.6.4 (BL) Ensure 'Allow standby states (S1-S3) when sleeping (plugged in)' is set to 'Disabled' (Automated)	773
18.9.34.6.5 (L1) Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled' (Automated)	776
18.9.34.6.6 (L1) Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled' (Automated)	779

18.9.35 Recovery	782
18.9.36 Remote Assistance	782
18.9.36.1 (L1) Ensure 'Configure Offer Remote Assistance' is set to 'Disabled' (Automated).....	783
18.9.36.2 (L1) Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled' (Automated)	787
18.9.37 Remote Procedure Call.....	791
18.9.37.1 (L1) Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (Automated)	792
18.9.37.2 (L1) Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (Automated)	795
18.9.38 Removable Storage Access	798
18.9.39 Scripts	798
18.9.40 Security Account Manager.....	798
18.9.41 Server Manager	798
18.9.42 Service Control Manager Settings.....	798
18.9.43 Shutdown	799
18.9.44 Shutdown Options	799
18.9.45 Storage Health	799
18.9.46 Storage Sense	799
18.9.47 System Restore	799
18.9.48 Troubleshooting and Diagnostics	800
18.9.48.1.1 (L2) Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled' (Automated)	801
18.9.49 Trusted Platform Module Services.....	804
18.9.50 User Profiles	804
18.9.50.1 (L2) Ensure 'Turn off the advertising ID' is set to 'Enabled' (Automated)	805
18.9.51 Windows File Protection	809
18.9.52 Windows HotStart	809
18.9.53 Windows Time Service	809
18.9.53.1.1.1 (L2) Ensure 'Enable Windows NTP Client' is set to 'Enabled' (Automated).....	810
18.9.53.1.1.2 (L2) Ensure 'Enable Windows NTP Server' is set to 'Disabled' (Automated).....	812
18.10 Windows Components	814
18.10.1 ActiveX Installer Service	814
18.10.2 Add features to Windows 10 (formerly Windows Anytime Upgrade)	814
18.10.3 App Package Deployment	814
18.10.3.1 (L2) Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled' (Automated)	815
18.10.4 App Privacy.....	817
18.10.4.1 (L1) Ensure 'Let Windows apps activate with voice while the system is locked' is set to 'Disabled' (Automated)	818
18.10.5 App runtime	820
18.10.5.1 (L1) Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled' (Automated).....	821
18.10.5.2 (L2) Ensure 'Block launching Universal Windows apps with Windows Runtime API access from hosted content.' is set to 'Enabled' (Automated)	824
18.10.6 Application Compatibility	826
18.10.7 AutoPlay Policies	826
18.10.7.1 (L1) Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled' (Automated)	827
18.10.7.2 (L1) Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands' (Automated)	830
18.10.7.3 (L1) Ensure 'Turn off Autoplay' is set to 'Enabled: All drives' (Automated)	833
18.10.8 Biometrics.....	836
18.10.9 BitLocker Drive Encryption	837
18.10.9.1.1 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Enabled' (Automated)	838

18.10.9.1.2 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Allow data recovery agent' is set to 'Enabled: True' (Automated)	842
18.10.9.1.3 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Password' is set to 'Enabled: Allow 48-digit recovery password' (Automated)	845
18.10.9.1.4 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Key' is set to 'Enabled: Allow 256-bit recovery key' (Automated)	848
18.10.9.1.5 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)	851
18.10.9.1.6 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Save BitLocker recovery information to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)	854
18.10.9.1.7 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Configure storage of BitLocker recovery information to AD DS' is set to 'Enabled: Backup recovery passwords and key packages' (Automated)	857
18.10.9.1.8 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)	860
18.10.9.2.1 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Enabled' (Automated)	865
18.10.9.2.2 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Allow data recovery agent' is set to 'Enabled: False' (Automated)	870
18.10.9.2.3 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Password' is set to 'Enabled: Require 48-digit recovery password' (Automated)	874
18.10.9.2.4 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Key' is set to 'Enabled: Do not allow 256-bit recovery key' (Automated)	877
18.10.9.2.5 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)	880
18.10.9.2.6 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Save BitLocker recovery information to AD DS for operating system drives' is set to 'Enabled: True' (Automated)	884
18.10.9.2.7 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Configure storage of BitLocker recovery information to AD DS:' is set to 'Enabled: Store recovery passwords and key packages' (Automated)	888
18.10.9.2.8 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' is set to 'Enabled: True' (Automated)	892
18.10.9.2.9 (BL) Ensure 'Require additional authentication at startup' is set to 'Enabled' (Automated)	896
18.10.9.2.10 (BL) Ensure 'Require additional authentication at startup: Allow BitLocker without a compatible TPM' is set to 'Enabled: False' (Automated)	899
18.10.9.3.1 (BL) Ensure 'Deny write access to removable drives not protected by BitLocker' is set to 'Enabled' (Automated)	904
18.10.9.3.2 (BL) Ensure 'Deny write access to removable drives not protected by BitLocker: Do not allow write access to devices configured in another organization' is set to 'Enabled: False' (Automated)	907
18.10.10 Camera	910
18.10.10.1 (L2) Ensure 'Allow Use of Camera' is set to 'Disabled' (Automated)	911
18.10.11 Chat	913
18.10.12 Cloud Content	913
18.10.12.1 (L1) Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled' (Automated)	914
18.10.13 Connect	917
18.10.13.1 (L1) Ensure 'Require pin for pairing' is set to 'Enabled' (Automated)	918
18.10.14 Credential User Interface	920
18.10.14.1 (L1) Ensure 'Do not display the password reveal button' is set to 'Enabled' (Automated)	921
18.10.14.2 (L1) Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled' (Automated)	924
18.10.14.3 (L1) Ensure 'Prevent the use of security questions for local accounts' is set to 'Enabled' (Automated)	927
18.10.15 Data Collection and Preview Builds	929

18.10.15.1 (L1) Ensure 'Allow Diagnostic Data' is set to 'Enabled: Diagnostic data off (not recommended)' or 'Enabled: Send required diagnostic data' (Automated)	930
18.10.15.2 (L2) Ensure 'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' is set to 'Enabled: Disable Authenticated Proxy usage' (Automated)	933
18.10.15.3 (L1) Ensure 'Do not show feedback notifications' is set to 'Enabled' (Automated)	935
18.10.15.4 (L1) Ensure 'Toggle user control over Insider builds' is set to 'Disabled' (Automated)	937
18.10.16 Delivery Optimization	940
18.10.17 Desktop App Installer	941
18.10.18 Desktop Gadgets.....	941
18.10.19 Desktop Window Manager	941
18.10.20 Device and Driver Compatibility	941
18.10.21 Device Registration (formerly Workplace Join)	941
18.10.22 Digital Locker.....	942
18.10.23 Edge UI	942
18.10.24 EMET	942
18.10.25 Event Forwarding	943
18.10.26 Event Log Service	943
18.10.26.1.1 (L1) Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated).....	944
18.10.26.1.2 (L1) Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	946
18.10.26.2.1 (L1) Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated).....	950
18.10.26.2.2 (L1) Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 196,608 or greater' (Automated)	952
18.10.26.3.1 (L1) Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated).....	956
18.10.26.3.2 (L1) Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	958
18.10.26.4.1 (L1) Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated).....	961
18.10.26.4.2 (L1) Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	963
18.10.27 Event Logging	966
18.10.28 Event Viewer	966
18.10.29 File Explorer (formerly Windows Explorer)	966
18.10.29.2 (L1) Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled' (Automated)	967
18.10.29.3 (L1) Ensure 'Turn off heap termination on corruption' is set to 'Disabled' (Automated)	971
18.10.29.4 (L1) Ensure 'Turn off shell protocol protected mode' is set to 'Disabled' (Automated)	974
18.10.30 File History.....	977
18.10.31 Find My Device	977
18.10.32 Handwriting.....	977
18.10.33 HomeGroup.....	977
18.10.33.1 (L1) Ensure 'Prevent the computer from joining a homegroup' is set to 'Enabled' (Automated)	978
18.10.34 Human Presence	981
18.10.35 Internet Explorer.....	981
18.10.36 Internet Information Services	981
18.10.37 Location and Sensors.....	981
18.10.37.1 (L2) Ensure 'Turn off location' is set to 'Enabled' (Automated)	982
18.10.38 Maintenance Scheduler	985
18.10.39 Maps	985
18.10.40 MDM.....	985
18.10.41 Messaging	985

18.10.41.1 (L2) Ensure 'Allow Message Service Cloud Sync' is set to 'Disabled' (Automated).....	986
18.10.42 Microsoft account	989
18.10.42.1 (L1) Ensure 'Block all consumer Microsoft account user authentication' is set to 'Enabled' (Automated)	990
18.10.43 Microsoft Defender Antivirus (formerly Windows Defender and Windows Defender Antivirus).....	993
18.10.43.3.1 (L1) Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)	994
18.10.43.3.2 (L2) Ensure 'Join Microsoft MAPS' is set to 'Disabled' (Automated).....	997
18.10.43.4.1.1 (L1) Ensure 'Configure Attack Surface Reduction rules' is set to 'Enabled' (Manual)	1001
18.10.43.4.1.2 (L1) Ensure 'Configure Attack Surface Reduction rules: Set the state for each ASR rule' is configured (Automated)	1003
18.10.43.4.3.1 (L1) Ensure 'Prevent users and apps from accessing dangerous websites' is set to 'Enabled: Block' (Automated)	1008
18.10.43.5.1 (L2) Ensure 'Enable file hash computation feature' is set to 'Enabled' (Automated)	1013
18.10.43.8.1 (L1) Ensure 'Scan all downloaded files and attachments' is set to 'Enabled' (Automated) ..	1016
18.10.43.8.2 (L1) Ensure 'Turn off real-time protection' is set to 'Disabled' (Automated)	1019
18.10.43.8.3 (L1) Ensure 'Turn on behavior monitoring' is set to 'Enabled' (Automated)	1022
18.10.43.10.1 (L2) Ensure 'Configure Watson events' is set to 'Disabled' (Automated)	1025
18.10.43.11.1 (L1) Ensure 'Scan removable drives' is set to 'Enabled' (Automated)	1028
18.10.43.11.2 (L1) Ensure 'Turn on e-mail scanning' is set to 'Enabled' (Automated)	1030
18.10.43.14 (L1) Ensure 'Configure detection for potentially unwanted applications' is set to 'Enabled: Block' (Automated)	1033
18.10.43.15 (L1) Ensure 'Turn off Microsoft Defender AntiVirus' is set to 'Disabled' (Automated)	1036
18.10.44 Microsoft Defender Application Guard (formerly Windows Defender Application Guard).....	1038
18.10.45 Microsoft Defender Exploit Guard (formerly Windows Defender Exploit Guard) ...	1038
18.10.46 Microsoft Edge	1038
18.10.47 Microsoft FIDO Authentication	1038
18.10.48 Microsoft Secondary Authentication Factor	1039
18.10.49 Microsoft User Experience Virtualization	1040
18.10.50 NetMeeting	1040
18.10.51 News and interests	1040
18.10.52 OneDrive (formerly SkyDrive)	1040
18.10.52.1 (L1) Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled' (Automated)	1041
18.10.53 Online Assistance	1044
18.10.54 OOBE.....	1044
18.10.55 Portable Operating System	1044
18.10.56 Presentation Settings	1044
18.10.57 Push To Install.....	1044
18.10.57.1 (L2) Ensure 'Turn off Push To Install service' is set to 'Enabled' (Automated)	1045
18.10.58 Remote Desktop Services (formerly Terminal Services)	1047
18.10.58.2.2 (L1) Ensure 'Do not allow passwords to be saved' is set to 'Enabled' (Automated)	1048
18.10.58.3.2.1 (L2) Ensure 'Allow users to connect remotely by using Remote Desktop Services' is set to 'Disabled' (Automated)	1052
18.10.58.3.3.1 (L2) Ensure 'Do not allow COM port redirection' is set to 'Enabled' (Automated)	1056
18.10.58.3.3.2 (L1) Ensure 'Do not allow drive redirection' is set to 'Enabled' (Automated)	1058
18.10.58.3.3.3 (L2) Ensure 'Do not allow LPT port redirection' is set to 'Enabled' (Automated)	1060
18.10.58.3.3.4 (L2) Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled' (Automated)	1062
18.10.58.3.9.1 (L1) Ensure 'Always prompt for password upon connection' is set to 'Enabled' (Automated)	1067
18.10.58.3.9.2 (L1) Ensure 'Require secure RPC communication' is set to 'Enabled' (Automated)	1069

18.10.58.3.9.3 (L1) Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL' (Automated)	1071
18.10.58.3.9.4 (L1) Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled' (Automated)	1074
18.10.58.3.9.5 (L1) Ensure 'Set client connection encryption level' is set to 'Enabled: High Level' (Automated)	1077
18.10.58.3.10.1 (L2) Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 15 minutes or less, but not Never (0)' (Automated)	1081
18.10.58.3.10.2 (L2) Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 1 minute' (Automated)	1083
18.10.58.3.11.1 (L1) Ensure 'Do not delete temp folders upon exit' is set to 'Disabled' (Automated)	1086
18.10.59 RSS Feeds.....	1088
18.10.59.1 (L1) Ensure 'Prevent downloading of enclosures' is set to 'Enabled' (Automated)	1089
18.10.60 Search	1093
18.10.60.2 (L2) Ensure 'Allow Cloud Search' is set to 'Enabled: Disable Cloud Search' (Automated)	1094
18.10.60.3 (L1) Ensure 'Allow Cortana' is set to 'Disabled' (Automated)	1097
18.10.60.4 (L1) Ensure 'Allow Cortana above lock screen' is set to 'Blocked' (Automated)	1100
18.10.60.5 (L1) Ensure 'Allow indexing of encrypted files' is set to 'Disabled' (Automated)	1102
18.10.60.6 (L1) Ensure 'Allow search and Cortana to use location' is set to 'Disabled' (Automated)	1105
18.10.61 Security Center.....	1108
18.10.62 Shutdown Options	1108
18.10.63 Smart Card.....	1108
18.10.64 Software Protection Platform.....	1108
18.10.64.1 (L2) Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled' (Automated)	1109
18.10.65 Sound Recorder	1111
18.10.66 Speech.....	1111
18.10.67 Store	1111
18.10.67.1 (L2) Ensure 'Disable all apps from Microsoft Store' is set to 'Disabled' (Automated)	1112
18.10.67.2 (L1) Ensure 'Only display the private store within the Microsoft Store' is set to 'Enabled' (Automated)	1115
18.10.67.3 (L1) Ensure 'Turn off Automatic Download and Install of updates' is set to 'Disabled' (Automated)	1118
18.10.67.4 (L1) Ensure 'Turn off the offer to update to the latest version of Windows' is set to 'Enabled' (Automated)	1121
18.10.67.5 (L2) Ensure 'Turn off the Store application' is set to 'Enabled' (Automated)	1123
18.10.68 Sync your settings	1125
18.10.69 Tablet PC.....	1125
18.10.70 Task Scheduler.....	1125
18.10.71 Tenant Restrictions.....	1125
18.10.72 Text Input	1125
18.10.73 Widgets	1126
18.10.74 Windows Calendar	1126
18.10.75 Windows Color System	1126
18.10.76 Windows Customer Experience Improvement Program.....	1126
18.10.77 Windows Defender SmartScreen.....	1126
18.10.77.1.1 (L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled: Warn and prevent bypass' (Automated)	1128
18.10.77.2.1 (L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled' (Automated)	1132
18.10.77.2.2 (L1) Ensure 'Prevent bypassing Windows Defender SmartScreen prompts for sites' is set to 'Enabled' (Automated)	1135
18.10.78 Windows Error Reporting.....	1138
18.10.79 Windows Game Recording and Broadcasting	1138
18.10.79.1 (L1) Ensure 'Enables or disables Windows Game Recording and Broadcasting' is set to 'Disabled' (Automated)	1139

18.10.80 Windows Hello for Business (formerly Microsoft Passport for Work)	1142
18.10.81 Windows Ink Workspace	1142
18.10.81.1 (L2) Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled' (Automated)	1143
18.10.81.2 (L1) Ensure 'Allow Windows Ink Workspace' is set to 'Enabled: On, but disallow access above lock' OR 'Disabled' but not 'Enabled: On' (Automated)	1146
18.10.82 Windows Installer	1149
18.10.82.1 (L1) Ensure 'Allow user control over installs' is set to 'Disabled' (Automated)	1150
18.10.82.2 (L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)	1152
18.10.83 Windows Logon Options	1156
18.10.83.1 (L1) Ensure 'Sign-in and lock last interactive user automatically after a restart' is set to 'Disabled' (Automated)	1157
18.10.84 Windows Media Digital Rights Management	1160
18.10.85 Windows Media Player	1160
18.10.86 Windows Messenger	1160
18.10.87 Windows Mobility Center	1160
18.10.88 Windows PowerShell	1160
18.10.88.1 (L1) Ensure 'Turn on PowerShell Script Block Logging' is set to 'Enabled' (Automated)	1161
18.10.88.2 (L1) Ensure 'Turn on PowerShell Transcription' is set to 'Enabled' (Automated)	1164
18.10.89 Windows Reliability Analysis	1166
18.10.90 Windows Remote Management (WinRM)	1166
18.10.90.1.1 (L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)	1167
18.10.90.1.2 (L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)	1170
18.10.90.1.3 (L1) Ensure 'Disallow Digest authentication' is set to 'Enabled' (Automated)	1173
18.10.90.2.1 (L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)	1177
18.10.90.2.2 (L2) Ensure 'Allow remote server management through WinRM' is set to 'Disabled' (Automated)	1180
18.10.90.2.3 (L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)	1184
18.10.90.2.4 (L1) Ensure 'Disallow WinRM from storing RunAs credentials' is set to 'Enabled' (Automated)	1187
18.10.91 Windows Remote Shell	1190
18.10.91.1 (L2) Ensure 'Allow Remote Shell Access' is set to 'Disabled' (Automated)	1191
18.10.92 Windows Sandbox	1194
18.10.93 Windows Security (formerly Windows Defender Security Center)	1194
18.10.93.2.1 (L1) Ensure 'Prevent users from modifying settings' is set to 'Enabled' (Automated)	1195
18.10.94 Windows Update	1198
18.10.94.2.1 (L1) Ensure 'Configure Automatic Updates' is set to 'Enabled' (Automated)	1199
18.10.94.2.2 (L1) Ensure 'Configure Automatic Updates: Scheduled install day' is set to '0 - Every day' (Automated)	1203
18.10.94.2.3 (L1) Ensure 'Remove access to "Pause updates" feature' is set to 'Enabled' (Automated)	1206
18.10.94.3.1 (L1) Ensure 'Manage preview builds' is set to 'Enabled: Disable preview builds' (Automated)	1210
18.10.94.3.2 (L1) Ensure 'Select when Quality Updates are received' is set to 'Enabled: 0 days' (Automated)	1213
19 Administrative Templates (User)	1216
19.1 Control Panel	1216
19.2 Desktop	1216
19.3 Network	1216
19.4 Shared Folders	1217
19.5 Start Menu and Taskbar	1217
19.5.1 Notifications	1217
19.5.1.1 (L1) Ensure 'Turn off toast notifications on the lock screen' is set to 'Blocked' (Automated)	1218
19.6 System	1220

19.6.1 Ctrl+Alt+Del Options	1220
19.6.2 Display.....	1220
19.6.3 Driver Installation	1220
19.6.4 Folder Redirection.....	1220
19.6.5 Group Policy	1221
19.6.6 Internet Communication Management.....	1221
19.6.6.1.1 (L2) Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled' (Automated)	1222
19.7 Windows Components	1225
19.7.1 Add features to Windows 8 / 8.1 / 10 (formerly Windows Anytime Upgrade)	1225
19.7.2 App runtime	1225
19.7.3 Application Compatibility	1225
19.7.4 Attachment Manager.....	1225
19.7.4.1 (L1) Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled' (Automated)	1226
19.7.4.2 (L1) Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled' (Automated)	1228
19.7.5 AutoPlay Policies	1231
19.7.6 Calculator	1231
19.7.7 Cloud Content.....	1231
19.7.8 Credential User Interface.....	1232
19.7.9 Data Collection and Preview Builds	1232
19.7.10 Desktop Gadgets.....	1232
19.7.11 Desktop Window Manager	1232
19.7.12 Digital Locker.....	1232
19.7.13 Edge UI	1233
19.7.14 File Explorer (formerly Windows Explorer)	1233
19.7.15 File Revocation	1233
19.7.16 IME	1233
19.7.17 Instant Search.....	1233
19.7.18 Internet Explorer.....	1234
19.7.19 Location and Sensors.....	1234
19.7.20 Microsoft Edge	1234
19.7.21 Microsoft Management Console.....	1234
19.7.22 Microsoft User Experience Virtualization	1234
19.7.23 NetMeeting	1235
19.7.24 Network Sharing.....	1235
19.7.24.1 (L1) Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled' (Automated)	1236
19.7.25 OOBE.....	1238
19.7.26 Presentation Settings	1238
19.7.27 Remote Desktop Services (formerly Terminal Services)	1238
19.7.28 RSS Feeds.....	1238
19.7.29 Search	1238
19.7.30 Sound Recorder	1239
19.7.31 Store	1239
19.7.32 Tablet PC.....	1239
19.7.33 Task Scheduler.....	1239
19.7.34 Windows Calendar	1239
19.7.35 Windows Color System	1240
19.7.36 Windows Defender SmartScreen.....	1240
19.7.37 Windows Error Reporting.....	1240
19.7.38 Windows Hello for Business (formerly Microsoft Passport for Work)	1240
19.7.39 Windows Installer.....	1240
19.7.39.1 (L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)	1241

19.7.40 Windows Logon Options	1244
19.7.41 Windows Media Player	1244
<i>Appendix: Summary Table</i>	<i>1245</i>
<i>Appendix: Change History</i>	<i>1291</i>

Overview

All CIS Benchmarks focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system for vulnerabilities and quickly updating with the latest security patches
- Monitoring applications and libraries for vulnerabilities and quickly updating with the latest security patches

In the end, the CIS Benchmarks are designed as a key **component** of a comprehensive cybersecurity program.

This document provides prescriptive guidance for establishing a secure configuration posture for **Microsoft Intune for Windows 11 Benchmark**. This guide was tested against **Microsoft Windows 11 Release 22H2 Enterprise edition**.

Please note that Intune is continually updating to support settings that are backed by group policy. This benchmark is based off settings that were available natively within Intune at the time of publication.

To obtain the latest version of this guide, please visit <https://www.cisecurity.org/cis-benchmarks/>. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

The Windows CIS Benchmarks are written for MDM-joined systems using Intune (Microsoft Endpoint Manager) Configuration Profile and not standalone/workgroup systems. Adjustments/tailoring to some recommendations will be needed to maintain functionality if attempting to implement CIS hardening on standalone systems.

Consensus Guidance

This CIS Benchmark was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<i><italic font in brackets></i>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 (L1) - Corporate/Enterprise Environment (general use)**

Items in this profile intend to:

- be the starting baseline for most organizations;
- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 1 (L1) + BitLocker (BL)**

This profile extends the "Level 1 (L1)" profile and includes BitLocker-related recommendations.

- **Level 1 (L1) + Next Generation Windows Security (NG)**

This profile extends the "Level 1 (L1)" profile and includes Next Generation Windows Security-related recommendations.

- **Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)**

This profile extends the "Level 1 (L1)" profile and includes BitLocker and Next Generation Windows Security-related recommendations.

- **Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)**

This profile extends the "Level 1 (L1)" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is more critical than manageability and usability;
- may negatively inhibit the utility or performance of the technology; and
- limit the ability of remote management/access.

Note: Implementation of Level 2 requires that **both** Level 1 and Level 2 settings are applied.

- **Level 2 (L2) + BitLocker (BL)**

This profile extends the "Level 2 (L2)" profile and includes BitLocker-related recommendations.

- **Level 2 (L2) + Next Generation Windows Security (NG)**

This profile extends the "Level 2 (L2)" profile and includes Next Generation Windows Security-related recommendations.

- **Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)**

This profile extends the "Level 2 (L2)" profile and includes BitLocker and Next Generation Windows Security-related recommendations.

- **BitLocker (BL) - optional add-on for when BitLocker is deployed**

This profile contains BitLocker-related recommendations, if your organization chooses to use it. It is intended be an optional "add-on" to the Level 1 (L1) or Level 2 (L2) profiles.

- **Next Generation Windows Security (NG) - optional add-on for use in the newest hardware and configuration environments**

This profile contains advanced Windows security features that have specific configuration dependencies, and may not be compatible with all systems. It therefore requires special attention to detail and testing before implementation. If your environment supports these features, they are highly recommended as they have tangible security benefits. This profile is intended to be an optional "add-on" to the Level 1 (L1) or Level 2 (L2) profiles.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

The Center for Internet Security extends special recognition and thanks to Rick Munck from Microsoft, as well as Mike Harris from General Dynamics Information Technology for their collaboration developing the configuration recommendations contained in this document.

Editor

Jennifer Jarose

Matthew Woods

Contributor

Phil Chatham

Haemish Edgerton

Hardeep Mehrotara

Phil White

Kevin Zhang

Recommendations

1 Account Policies

This section contains recommendations for account policies.

1.1 Password Policy

This section contains recommendations for password policy.

1.1.1 (L1) Ensure 'Enforce password history' is set to '24 or more passwords' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines the number of renewed, unique passwords that have to be associated with a user account before you can reuse an old password. The value for this policy setting must be between 0 and 24 passwords. The default value for Windows Vista is 0 passwords, but the default setting in a domain is 24 passwords. To maintain the effectiveness of this policy setting, use the Minimum password age setting to prevent users from repeatedly changing their password.

Note: All recommendations in Section 1.1 (Password Policy) are only applied to Local and Microsoft accounts and not Domain accounts. For more information, please see the references section below.

Note #2: As of the publication of this benchmark, Microsoft currently has a maximum limit of 24 saved passwords. For more information, please visit [Enforce password history \(Windows 10\) - Windows security | Microsoft Docs](#)

The recommended state for this setting is: 24 or more passwords.

Rationale:

The longer a user uses the same password, the greater the chance that an attacker can determine the password through brute force attacks. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced.

If you specify a low number for this policy setting, users will be able to use the same small number of passwords repeatedly. If you do not also configure the Minimum password age setting, users might repeatedly change their passwords until they can reuse their original password.

Impact:

The major impact of this configuration is that users must create a new password every time they are required to change their old one. If users are required to change their passwords to new unique values, there is an increased risk of users who write their passwords somewhere so that they do not forget them. Another risk is that users may create passwords that change incrementally (for example, password01, password02, and so on) to facilitate memorization but make them easier to guess. Also, an excessively low value for the Minimum password age setting will likely increase administrative overhead, because users who forget their passwords might ask the help desk to reset them frequently.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:DevicePasswordHistory_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 24 or more passwords.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
Device\DeviceLock:DevicePasswordHistory
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Note #2: This policy can also be verified with the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:DevicePasswordHistory
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Required* and 24 or more passwords:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/Password
Setting Name:	Password
Configuration:	Required

AND

Path:	Device restrictions/Password
Setting Name:	Prevent reuse of previous passwords
Configuration:	24

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

./Device/Vendor/MSFT/Policy/Config/DeviceLock/DevicePasswordHistory

Note #3: This setting can also be created via the *Settings Catalog* via the following path:

Device Lock\Device Password Enabled\Device Password History

Default Value:

24 passwords remembered on domain members. 0 passwords remembered on stand-alone workstations.

References:

1. <https://docs.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-devicepasswordhistory>
2. <https://docs.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-mindevicepasswordcomplexcharacters>
3. [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287\(v=ws.11\)#password-length-and-complexity-supported-by-account-types](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287(v=ws.11)#password-length-and-complexity-supported-by-account-types)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

1.1.2 (L1) Ensure 'Maximum password age' is set to '365 or fewer days, but not 0' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting defines how long a user can use their password before it expires.

Values for this policy setting range from 0 to 999 days. If you set the value to 0, the password will never expire.

Because attackers can crack passwords, the more frequently you change the password the less opportunity an attacker has to use a cracked password. However, the lower this value is set, the higher the potential for an increase in calls to help desk support due to users having to change their password or forgetting which password is current.

Note: All recommendations in Section 1.1 (Password Policy) are only applied to Local and Microsoft accounts and not Domain accounts. For more information, please see the references section below.

The recommended state for this setting is `365 or fewer days, but not 0`.

Rationale:

The longer a password exists the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user, or by the user sharing the password. Configuring the Maximum password age setting to 0 so that users are never required to change their passwords is a major security risk because that allows a compromised password to be used by the malicious user for as long as the valid user has authorized access.

Impact:

If the Maximum password age setting is too low, users are required to change their passwords very often. Such a configuration can reduce security in the organization, because users might write their passwords in an insecure location or lose them. If the value for this policy setting is too high, the level of security within an organization is reduced because it allows potential attackers more time in which to discover user passwords or to use compromised accounts.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:DevicePasswordExpiration_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 365 or fewer days, but not 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\  
Device\DeviceLock:DevicePasswordExpiration
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Note #2: This policy can also be verified with the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:DevicePasswordExpiration
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Required* and 365 or fewer days, but not 0:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/Password
Setting Name:	Password
Configuration:	Required

AND

Path:	Device restrictions/Password
Setting Name:	Password expiration (days)
Configuration:	365

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

./Device/Vendor/MSFT/Policy/Config/DeviceLock/DevicePasswordExpiration
--

Note #3: This setting can also be created via the *Settings Catalog* via the following path:

Device Lock\Device Password Enabled\Device Password Expiration
--

Default Value:

42 days.

References:

1. <https://docs.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-enforcelockscreenandlogonimage>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-policies>
3. [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287\(v=ws.11\)#password-length-and-complexity-supported-by-account-types](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287(v=ws.11)#password-length-and-complexity-supported-by-account-types)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	16.10 Ensure All Accounts Have An Expiration Date Ensure that all accounts have an expiration date that is monitored and enforced.			

1.1.3 (L1) Ensure 'Minimum password age' is set to '1 or more day(s)' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines the number of days that you must use a password before you can change it. The range of values for this policy setting is between 1 and 999 days. (You may also set the value to 0 to allow immediate password changes.) The default value for this setting is 0 days.

Note: All recommendations in Section 1.1 (Password Policy) are only applied to Local and Microsoft accounts and not Domain accounts. For more information, please see the references section below.

The recommended state for this setting is: `1 or more day(s)`.

Rationale:

Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise. Unfortunately, passwords are compromised and if an attacker is targeting a specific individual's user account, with foreknowledge of data about that user, reuse of old passwords can cause a security breach. To address password reuse a combination of security settings is required. Using this policy setting with the Enforce password history setting prevents the easy reuse of old passwords. For example, if you configure the Enforce password history setting to ensure that users cannot reuse any of their last 12 passwords, they could change their password 13 times in a few minutes and reuse the password they started with, unless you also configure the Minimum password age setting to a number that is greater than 0. You must configure this policy setting to a number that is greater than 0 for the Enforce password history setting to be effective.

Impact:

If an administrator sets a password for a user but wants that user to change the password when the user first logs on, the administrator must select the User must change password at next logon check box, or the user will not be able to change the password until the next day.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinimumPasswordAge_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1 or more day(s).

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\  
Device\DeviceLock:MinimumPasswordAge
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Note #2: This policy can also be verified with the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinimumPasswordAge
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 1 or more day(s):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/DeviceLock/MinimumPasswordAge
Data type:	Integer
Value:	1 or more day(s)

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

./Device/Vendor/MSFT/Policy/Config/DeviceLock/MinimumPasswordAge
--

Note #3: This setting can also be created via the *Settings Catalog* via the following path:

Device Lock\Min Device Password Length\Minimum Password Age

Default Value:

1 day on domain members. 0 days on stand-alone workstations.

References:

1. <https://docs.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-enforcelockscreenandlogonimage>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-policies>
3. [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287\(v=ws.11\)#password-length-and-complexity-supported-by-account-types](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287(v=ws.11)#password-length-and-complexity-supported-by-account-types)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	16.10 Ensure All Accounts Have An Expiration Date Ensure that all accounts have an expiration date that is monitored and enforced.			

1.1.4 (L1) Ensure 'Minimum password length' is set to '14 or more characters' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines the least number of characters that make up a password for a user account. There are many different theories about how to determine the best password length for an organization, but perhaps "passphrase" is a better term than "password." In Microsoft Windows 2000 and newer, passphrases can be quite long and can include spaces. Therefore, a phrase such as "I want to drink a \$5 milkshake" is a valid passphrase; it is a considerably stronger password than an 8 or 10 character string of random numbers and letters, and yet is easier to remember. Users must be educated about the proper selection and maintenance of passwords, especially with regard to password length. In enterprise environments, the ideal value for the Minimum password length setting is 14 characters, however you should adjust this value to meet your organization's business requirements.

Note: All recommendations in Section 1.1 (Password Policy) are only applied to Local and Microsoft accounts and not Domain accounts. For more information, please see the references section below.

The recommended state for this setting is: `14 or more characters`.

Rationale:

Types of password attacks include dictionary attacks (which attempt to use common words and phrases) and brute force attacks (which try every possible combination of characters). Also, attackers sometimes try to obtain the account database so they can use tools to discover the accounts and passwords.

Impact:

Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave the information in an insecure location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase the volume of help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about passphrases, which are often easier to remember and due to the larger number of character combinations, much harder to discover.

Warning: If Windows Hello for Business is used, an exception to this recommendation might be needed as a PIN length of 14 could be considered unrealistic.

Warning: [Windows Autopilot - Policy Conflicts](#): The out-of-box experience (OOBE) or user desktop auto logon can fail when a device reboots during the device Enrollment Status Page (ESP). This failure can occur when certain DeviceLock policies are applied to a device. An exception to this recommendation might be needed is Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinDevicePasswordLength_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 14 or more characters.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\  
Device\DeviceLock:MinDevicePasswordLength
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Note #2: This policy can also be verified with the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinDevicePasswordLength
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Required* and 14 or more characters:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/Password
Setting Name:	Password
Configuration:	Required

AND

Path:	Device restrictions/Password
Setting Name:	Minimum password length
Configuration:	14

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

./Device/Vendor/MSFT/Policy/Config/DeviceLock/MinDevicePasswordLength

Note #3: This setting can also be created via the *Settings Catalog* via the following path:

Device Lock\Device Password Enabled\Min Device Password Length
--

Default Value:

7 characters on domain members. 0 characters on stand-alone servers.

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock#devicelock-policies>
2. [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287\(v=ws.11\)#password-length-and-complexity-supported-by-account-types](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn282287(v=ws.11)#password-length-and-complexity-supported-by-account-types)
3. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

1.1.5 (L1) Ensure 'Password must meet complexity requirements' is set to 'Numbers and lowercase' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting checks all new passwords to ensure that they meet basic requirements for strong passwords.

When this policy is enabled, passwords must meet the following minimum requirements:

- Not contain the user's account name or parts of the user's full name that exceed two consecutive characters
- Be at least eight characters in length
- Contain characters from following categories:
- English lowercase characters (a through z)
- Base 10 digits (0 through 9)

Each additional character in a password increases its complexity exponentially. For instance, a seven-character, all lower-case alphabetic password would have 26⁷ (approximately 8 x 10⁹ or 8 billion) possible combinations. At 1,000,000 attempts per second (a capability of many password-cracking utilities), it would only take 133 minutes to crack. A seven-character alphabetic password with case sensitivity has 52⁷ combinations. A seven-character case-sensitive alphanumeric password without punctuation has 62⁷ combinations. Although this might seem to be a large number, at 1,000,000 attempts per second it would take only 59 hours to try all possible passwords. Remember, these times will significantly increase for passwords that use ALT characters and other special keyboard characters such as "!" or "@". Proper use of the password settings can help make it difficult to mount a brute force attack.

Note: The enforcement of policies for Microsoft accounts happens on the server, and the server requires a password length of 8 and a complexity of 2. **A complexity value of 3 or 4 is unsupported.**

The recommended state for this setting is: `Numbers and lowercase`.

Rationale:

Passwords that contain only alphanumeric characters are extremely easy to discover with several publicly available tools.

Impact:

If the default password complexity configuration is retained, additional help desk calls for locked-out accounts could occur because users might not be accustomed to passwords that contain non-alphabetic characters. However, all users should be able to comply with the complexity requirement with minimal difficulty.

If your organization has more stringent security requirements, you can create a custom version of the Passfilt.dll file that allows the use of arbitrarily complex password strength rules. For example, a custom password filter might require the use of non-upper row characters. (Upper row characters are those that require you to hold down the SHIFT key and press any of the digits between 1 and 0.) A custom password filter might also perform a dictionary check to verify that the proposed password does not contain common dictionary words or fragments.

Also, the use of ALT key character combinations can greatly enhance the complexity of a password. However, such stringent password requirements can result in unhappy users and an extremely busy help desk. Alternatively, your organization could consider a requirement for all administrator passwords to use ALT characters in the 0128 - 0159 range. (ALT characters outside of this range can represent standard alphanumeric characters that would not add additional complexity to the password.)

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinDevicePasswordComplexCharacters_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
DeviceLock:MinDevicePasswordComplexCharacters
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Note #2: This policy can also be verified with the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:MinDevicePasswordComplexCharacters
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Numbers and lowercase`:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/Password
Setting Name:	Password
Configuration:	Required

AND

Path:	Device restrictions/Password
Setting Name:	Password complexity
Configuration:	Numbers and lowercase letters are required

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via the *Settings Catalog* via the following path:

Device Lock\Device Password Enabled\Alphanumeric Device Password Required

Default Value:

Enabled on domain members. Disabled on stand-alone workstations.

References:

1. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock?WT.mc_id=Portal-fx#alphanumericdevicepasswordrequired
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-devicelock?WT.mc_id=Portal-fx#mindevicepasswordcomplexcharacters

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 <u>Use Unique Passwords</u> Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	4.4 <u>Use Unique Passwords</u> Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			
v7	16.2 <u>Configure Centralized Point of Authentication</u> Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

2 Local Policies

This section contains recommendations for local policies.

2.1 Audit Policy

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.2 User Rights Assignment

This section contains recommendations for user rights assignments.

2.2.1 (L1) Ensure 'Access Credential Manager as a trusted caller' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This security setting is used by Credential Manager during Backup and Restore. No accounts should have this user right, as it is only assigned to Winlogon. Users' saved credentials might be compromised if this user right is assigned to other entities.

The recommended state for this setting is: No One.

Rationale:

If an account is given this right the user of the account may create an application that calls into Credential Manager and is returned the credentials for another user.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:AccessCredentialManagerAsTrustedCaller_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No one.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\UserRights:AccessCredentialManagerAsTrustedCaller
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Access Credential Manager as a trusted caller
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Access Credential Manager as trusted caller
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/AccessCredentialManagerAsTrustedCaller
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`□`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	4.8 <u>Log and Alert on Changes to Administrative Group Membership</u> Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●

2.2.2 (L1) Ensure 'Access this computer from the network' is set to 'Administrators, Remote Desktop Users' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows other users on the network to connect to the computer and is required by various network protocols that include Server Message Block (SMB)-based protocols, NetBIOS, Common Internet File System (CIFS), and Component Object Model Plus (COM+).

The recommended state for this setting is: `Administrators, Remote Desktop Users`.

Rationale:

Users who can connect from their computer to the network can access resources on target computers for which they have permission. For example, the **Access this computer from the network** user right is required for users to connect to shared printers and folders. If this user right is assigned to the `Everyone` group, then anyone will be able to read the files in those shared folders. However, this situation is unlikely for new installations of Windows Server 2003 with Service Pack 1 (SP1), because the default share and NTFS permissions in Windows Server 2003 do not include the `Everyone` group. This vulnerability may have a higher level of risk for computers that you upgrade from Windows NT 4.0 or Windows 2000, because the default permissions for these operating systems are not as restrictive as the default permissions in Windows Server 2003.

Impact:

If you remove the **Access this computer from the network** user right on Domain Controllers for all users, no one will be able to log on to the domain or use network resources. If you remove this user right on Member Servers, users will not be able to connect to those servers through the network. Successful negotiation of IPsec connections requires that the initiating machine has this right, therefore if using IPsec, it is recommended that it be assigned to the `Authenticated Users` group. If you have installed optional components such as ASP.NET or Internet Information Services (IIS), you may need to assign this user right to additional accounts that are required by those components. It is important to verify that authorized users are assigned this user right for the computers they need to access the network.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:AccessFromNetwork_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators, Remote Desktop Users.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\UserRights:AccessFromNetwork
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators, Remote Desktop Users

```
Security Settings\Local Policies\User Rights Assignment\Access this computer from the network
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators, Remote Desktop Users:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Allow Access From Network
Configuration:	Allow and sub-option: Administrators, Remote Desktop Users

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/AccessFromNetwork
Data type:	String
Value:	Administrators, Remote Desktop Users

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, Backup Operators, Everyone, Users.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.2.3 (L1) Ensure 'Act as part of the operating system' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows a process to assume the identity of any user and thus gain access to the resources that the user is authorized to access.

The recommended state for this setting is: `No One`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

The **Act as part of the operating system** user right is extremely powerful. Anyone with this user right can take complete control of the computer and erase evidence of their activities.

Impact:

There should be little or no impact because the **Act as part of the operating system** user right is rarely needed by any accounts other than the `Local System` account, which implicitly has this right.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ActAsPartOfTheOperatingSystem_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No one.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\UserRights:ActAsPartOfTheOperatingSystem
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Act as part of the operating system
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Act As Part Of The OS
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ActAsPartOfTheOperatingSystem
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `֠` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`□`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.4 (L1) Ensure 'Allow log on locally' is set to 'Administrators, Users' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users can interactively log on to computers in your environment. Logons that are initiated by pressing the CTRL+ALT+DEL key sequence on the client computer keyboard require this user right. Users who attempt to log on through Terminal Services / Remote Desktop Services or IIS also require this user right.

The recommended state for this setting is: `Administrators, Users`.

Note: The `Guest` account is also assigned this user right by default. Although this account is disabled by default, it's recommended that you configure this setting through Group Policy. However, this user right should generally be restricted to the `Administrators` and `Users` groups. Assign this user right to the `Backup Operators` group if your organization requires that they have this capability.

Rationale:

Any account with the **Allow log on locally** user right can log on at the console of the computer. If you do not restrict this user right to legitimate users who need to be able to log on to the console of the computer, unauthorized users could download and run malicious software to elevate their privileges.

Impact:

If you remove these default groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected by any changes that you make to the **Allow log on locally** user right.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:AllowLocalLogOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators, Users.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\UserRights:AllowLocalLogOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators, Users

```
Security Settings\Local Policies\User Rights Assignment\Allow log on locally
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Administrators, Users*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Allow local log on
Configuration:	Allow and sub-option: Administrators, Users

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/AllowLocalLogOn
Data type:	String
Value:	Administrators, Users

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, Backup Operators, Guest, Users.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.5 (L1) Ensure 'Back up files and directories' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to circumvent file and directory permissions to back up the system. This user right is enabled only when an application (such as NTBACKUP) attempts to access a file or directory through the NTFS file system backup application programming interface (API). Otherwise, the assigned file and directory permissions apply.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

Users who are able to back up data from a computer could take the backup media to a non-domain computer on which they have administrative privileges and restore the data. They could take ownership of the files and view any unencrypted data that is contained within the backup set.

Impact:

Changes in the membership of the groups that have the **Back up files and directories** user right could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that authorized backup administrators are still able to perform backup operations.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:BackupFilesAndDirectories_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
UserRights:BackupFilesAndDirectories
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Back up files and  
directories
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Administrators*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Backup files and directories
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/BackupFilesAndDirectories
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, Backup Operators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.6 (L1) Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users and groups can change the time and date on the internal clock of the computers in your environment. Users who are assigned this user right can affect the appearance of event logs. When a computer's time setting is changed, logged events reflect the new time, not the actual time that the events occurred.

The recommended state for this setting is: `Administrators, LOCAL SERVICE`.

Note: Discrepancies between the time on the local computer and on the Domain Controllers in your environment may cause problems for the Kerberos authentication protocol, which could make it impossible for users to log on to the domain or obtain authorization to access domain resources after they are logged on. Also, problems will occur when Group Policy is applied to client computers if the system time is not synchronized with the Domain Controllers.

Rationale:

Users who can change the time on a computer could cause several problems. For example, time stamps on event log entries could be made inaccurate, time stamps on files and folders that are created or modified could be incorrect, and computers that belong to a domain may not be able to authenticate themselves or users who try to log on to the domain from them. Also, because the Kerberos authentication protocol requires that the requestor and authenticator have their clocks synchronized within an administrator-defined skew period, an attacker who changes a computer's time may cause that computer to be unable to obtain or grant Kerberos tickets.

The risk from these types of events is mitigated on most Domain Controllers, Member Servers, and end-user computers because the Windows Time service automatically synchronizes time with Domain Controllers in the following ways:

- All client desktop computers and Member Servers use the authenticating Domain Controller as their inbound time partner.
- All Domain Controllers in a domain nominate the Primary Domain Controller (PDC) Emulator operations master as their inbound time partner.
- All PDC Emulator operations masters follow the hierarchy of domains in the selection of their inbound time partner.
- The PDC Emulator operations master at the root of the domain is authoritative for the organization. Therefore, it is recommended that you configure this computer to synchronize with a reliable external time server.

This vulnerability becomes much more serious if an attacker is able to change the system time and then stop the Windows Time service or reconfigure it to synchronize with a time server that is not accurate.

Impact:

There should be no impact, because time synchronization for most organizations should be fully automated for all computers that belong to the domain. Computers that do not belong to the domain should be configured to synchronize with an external source.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:ChangeSystemTime_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators, LOCAL SERVICE.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
UserRights:ChangeSystemTime
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators, LOCAL SERVICE

```
Security Settings\Local Policies\User Rights Assignment\Change the system  
time
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Administrators, LOCAL SERVICE`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Change the system time
Configuration:	Allow and sub-option: Administrators, LOCAL SERVICE

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ChangeSystemTime
Data type:	String
Value:	Administrators, LOCAL SERVICE

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, LOCAL SERVICE.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.7 (L1) Ensure 'Create a pagefile' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to change the size of the pagefile. By making the pagefile extremely large or extremely small, an attacker could easily affect the performance of a compromised computer.

The recommended state for this setting is: `Administrators`.

Rationale:

Users who can change the page file size could make it extremely small or move the file to a highly fragmented storage volume, which could cause reduced computer performance.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:CreatePageFile_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:CreatePageFile
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Create a pagefile
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Create pagefile
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/CreatePageFile
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.8 (L1) Ensure 'Create a token object' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows a process to create an access token, which may provide elevated rights to access sensitive data.

The recommended state for this setting is: `No One`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

A user account that is given this user right has complete control over the system and can lead to the system being compromised. It is highly recommended that you do not assign any user accounts this right.

The operating system examines a user's access token to determine the level of the user's privileges. Access tokens are built when users log on to the local computer or connect to a remote computer over a network. When you revoke a privilege, the change is immediately recorded, but the change is not reflected in the user's access token until the next time the user logs on or connects. Users with the ability to create or modify tokens can change the level of access for any currently logged on account. They could escalate their own privileges or create a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:CreateToken_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No one.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:CreateToken
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Create a token object
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Create tokens
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/CreateToken
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.9 (L1) Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can create global objects that are available to all sessions. Users can still create objects that are specific to their own session if they do not have this user right.

Users who can create global objects could affect processes that run under other users' sessions. This capability could lead to a variety of problems, such as application failure or data corruption.

The recommended state for this setting is: Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE.

Rationale:

Users who can create global objects could affect Windows services and processes that run under other user or system accounts. This capability could lead to a variety of problems, such as application failure, data corruption and elevation of privilege.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:CreateGlobalObjects_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:CreateGlobalObjects
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

```
Security Settings\Local Policies\User Rights Assignment\Create global objects
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Create global objects
Configuration:	Allow and sub-option: Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/CreateGlobalObjects
Data type:	String
Value:	Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.10 (L1) Ensure 'Create permanent shared objects' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This user right is useful to kernel-mode components that extend the object namespace. However, components that run in kernel mode have this user right inherently. Therefore, it is typically not necessary to specifically assign this user right.

The recommended state for this setting is: `No One`.

Rationale:

Users who have the **Create permanent shared objects** user right could create new shared objects and expose sensitive data to the network.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:CreatePermanentSharedObjects_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No one.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:CreatePermanentSharedObjects
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Create permanent shared objects
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Create permanent shared objects
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/CreatePermanentSharedObjects
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `֠` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`□`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3:** The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.11 (L1) Configure 'Create symbolic links' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users can create symbolic links. In Windows Vista, existing NTFS file system objects, such as files and folders, can be accessed by referring to a new kind of file system object called a symbolic link. A symbolic link is a pointer (much like a shortcut or .lnk file) to another file system object, which can be a file, folder, shortcut or another symbolic link. The difference between a shortcut and a symbolic link is that a shortcut only works from within the Windows shell. To other programs and applications, shortcuts are just another file, whereas with symbolic links, the concept of a shortcut is implemented as a feature of the NTFS file system.

Symbolic links can potentially expose security vulnerabilities in applications that are not designed to use them. For this reason, the privilege for creating symbolic links should only be assigned to trusted users. By default, only `Administrators` can create symbolic links.

The recommended state for this setting is: `Administrators` and (when the *Hyper-V* feature is installed) `NT VIRTUAL MACHINE\Virtual Machines`.

Rationale:

Users who have the **Create symbolic links** user right could inadvertently or maliciously expose your system to symbolic link attacks. Symbolic link attacks can be used to change the permissions on a file, to corrupt data, to destroy data, or as a Denial of Service attack.

Impact:

In most cases there will be no impact because this is the default configuration. However, on Windows Workstations with the Hyper-V feature installed, this user right should also be granted to the special group `NT VIRTUAL MACHINE\Virtual Machines` - otherwise you will not be able to create new virtual machines.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:CreateSymbolicLinks_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:CreateSymbolicLinks
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Create symbolic links
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Create symbolic links
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/CreateSymbolicLinks
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.12 (L1) Ensure 'Debug programs' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which user accounts will have the right to attach a debugger to any process or to the kernel, which provides complete access to sensitive and critical operating system components. Developers who are debugging their own applications do not need to be assigned this user right; however, developers who are debugging new system components will need it.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

The **Debug programs** user right can be exploited to capture sensitive computer information from system memory, or to access and modify kernel or application structures. Some attack tools exploit this user right to extract hashed passwords and other private security information, or to insert rootkit code. By default, the **Debug programs** user right is assigned only to administrators, which helps to mitigate the risk from this vulnerability.

Impact:

If you revoke this user right, no one will be able to debug programs. However, typical circumstances rarely require this capability on production computers. If a problem arises that requires an application to be debugged on a production server, you can move the server to a different OU temporarily and assign the **Debug programs** user right to a separate Group Policy for that OU.

The service account that is used for the cluster service needs the **Debug programs** user right; if it does not have it, Windows Clustering will fail.

Tools that are used to manage processes will be unable to affect processes that are not owned by the person who runs the tools. For example, the Windows Server 2003 Resource Kit tool `Kill.exe` requires this user right for administrators to terminate processes that they did not start.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:DebugPrograms_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:DebugPrograms
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Debug programs
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Debug programs
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/DebugPrograms
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	18.2 <u>Ensure Explicit Error Checking is Performed for All In-house Developed Software</u> For in-house developed software, ensure that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats.		●	●

2.2.13 (L1) Ensure 'Deny access to this computer from the network' to include 'Guests, Local account' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prohibits users from connecting to a computer from across the network, which would allow users to access and potentially modify data remotely. In high security environments, there should be no need for remote users to access data on a computer. Instead, file sharing should be accomplished through the use of network servers. This user right supersedes the **Access this computer from the network** user right if an account is subject to both policies.

The recommended state for this setting is to include: `Guests, Local account`.

Caution: Configuring a standalone (non-domain-joined) workstation as described above may result in an inability to remotely administer the workstation.

Note: The security identifier `Local account` is not available in Windows 7 and Windows 8.0 unless [MSKB 2871997](#) has been installed.

Rationale:

Users who can log on to the computer over the network can enumerate lists of account names, group names, and shared resources. Users with permission to access shared folders and files can connect over the network and possibly view or modify data.

Impact:

If you configure the **Deny access to this computer from the network** user right for other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should verify that delegated tasks will not be negatively affected.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:  
:DenyAccessFromNetwork_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Guests, Local account.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:DenyAccessFromNetwork
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to include Guests, Local account

```
Security Settings\Local Policies\User Rights Assignment\Deny access to this  
computer from the network
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Guests, Local account*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Deny Access From Network
Configuration:	Allow and sub-option: Guests, Local account

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/DenyAccessFromNetwork
Data type:	String
Value:	Guests, Local account

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Guest.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.14 (L1) Ensure 'Deny log on as a service' to include 'Guests' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This security setting determines which service accounts are prevented from registering a process as a service. This user right supersedes the **Log on as a service** user right if an account is subject to both policies.

The recommended state for this setting is to include: `Guests`.

Note: This security setting does not apply to the `System`, `Local Service`, or `Network Service` accounts.

Rationale:

Accounts that can log on as a service could be used to configure and start new unauthorized services, such as a keylogger or other malicious software. The benefit of the specified countermeasure is somewhat reduced by the fact that only users with administrative privileges can install and configure services, and an attacker who has already attained that level of access could configure the service to run with the `System` account.

Impact:

If you assign the **Deny log on as a service** user right to specific accounts, services may not be able to start and a DoS condition could result.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:DenyLogOnAsService_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `Guests`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:DenyLogOnAsService
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to `Guests`

```
Security Settings\Local Policies\User Rights Assignment\DenyLogOnAsService
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Guests`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Deny log on as a service
Configuration:	Allow and sub-option: Guests

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/DenyLogOnAsService
Data type:	String
Value:	Guests

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`␣`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

References:

1. <https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/deny-log-on-as-a-service>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.15 (L1) Ensure 'Deny log on locally' to include 'Guests' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This security setting determines which users are prevented from logging on at the computer. This policy setting supersedes the **Allow log on locally** policy setting if an account is subject to both policies.

The recommended state for this setting is to include: `Guests`.

Important: If you apply this security policy to the `Everyone` group, no one will be able to log on locally.

Rationale:

Any account with the ability to log on locally could be used to log on at the console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the **Deny log on locally** user right to additional accounts, you could limit the abilities of users who are assigned to specific roles in your environment. However, this user right should explicitly be assigned to the `ASPNET` account on computers that run IIS 6.0. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:  
:DenyLocalLogOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `Guests`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:DenyLocalLogOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to include `Guests`

```
Security Settings\Local Policies\User Rights Assignment\Deny log on locally
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Guests`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/DenyLocalLogOn
Data type:	String
Value:	Allow and sub-option: Guests

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `֠` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`⓼`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #2: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Guest.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			

2.2.16 (L1) Ensure 'Deny log on through Remote Desktop Services' to include 'Guests, Local account' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can log on as Remote Desktop clients. After the baseline workstation is joined to a domain environment, there is no need to use local accounts to access the workstation from the network. Domain accounts can access the workstation for administration and end-user processing. This user right supersedes the **Allow log on through Remote Desktop Services** user right if an account is subject to both policies.

The recommended state for this setting is to include: `Guests, Local account`.

Caution: Configuring a standalone (non-domain-joined) workstation as described above may result in an inability to remotely administer the workstation.

Note: The security identifier `Local account` is not available in Windows 7 and Windows 8.0 unless [MSKB 2871997](#) has been installed.

Note #2: In all versions of Windows prior to Windows 7, **Remote Desktop Services** was known as **Terminal Services**, so you should substitute the older term if comparing against an older OS.

Rationale:

Any account with the right to log on through Remote Desktop Services could be used to log on to the remote console of the computer. If this user right is not restricted to legitimate users who need to log on to the console of the computer, unauthorized users might download and run malicious software that elevates their privileges.

Impact:

If you assign the **Deny log on through Remote Desktop Services** user right to other groups, you could limit the abilities of users who are assigned to specific administrative roles in your environment. Accounts that have this user right will be unable to connect to the computer through either Remote Desktop Services or Remote Assistance. You should confirm that delegated tasks will not be negatively impacted.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:DenyRemoteDesktopServicesLogOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Guests, Local account.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:DenyRemoteDesktopServicesLogOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to include Guests, Local account

```
Security Settings\Local Policies\User Rights Assignment\Deny log on through Remote Desktop Services
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Guests, Local account`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Deny log on through Remote Desktop Services
Configuration:	Allow and sub-option: <code>Guests, Local account</code>

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/DenyRemoteDesktopServicesLogOn
Data type:	String
Value:	<code>Guests, Local account</code>

Important: When there is more than one value that needs to be entered (ex: `Guests, Administrator`), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`□`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.17 (L1) Ensure 'Enable computer and user accounts to be trusted for delegation' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to change the Trusted for Delegation setting on a computer object in Active Directory. Abuse of this privilege could allow unauthorized users to impersonate other users on the network.

The recommended state for this setting is: `No One`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

Misuse of the **Enable computer and user accounts to be trusted for delegation** user right could allow unauthorized users to impersonate other users on the network. An attacker could exploit this privilege to gain access to network resources and make it difficult to determine what has happened after a security incident.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:EnableDelegation_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No one.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:EnableDelegation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Enable computer and user accounts to be trusted for delegation
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Enable delegation
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/EnableDelegation
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.18 (L1) Ensure 'Force shutdown from a remote system' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to shut down Windows Vista-based and newer computers from remote locations on the network. Anyone who has been assigned this user right can cause a denial of service (DoS) condition, which would make the computer unavailable to service user requests. Therefore, it is recommended that only highly trusted administrators be assigned this user right.

The recommended state for this setting is: `Administrators`.

Rationale:

Any user who can shut down a computer could cause a DoS condition to occur. Therefore, this user right should be tightly restricted.

Impact:

If you remove the **Force shutdown from a remote system** user right from the Server Operators group you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should confirm that delegated activities will not be adversely affected.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:RemoteShutdown_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:RemoteShutdown
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Force shutdown from a remote system
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Remote shutdown
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/RemoteShutdown
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

None - this is the default behavior.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.19 (L1) Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users or processes can generate audit records in the Security log.

The recommended state for this setting is: `LOCAL SERVICE, NETWORK SERVICE`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

An attacker could use this capability to create a large number of audited events, which would make it more difficult for a system administrator to locate any illicit activity. Also, if the event log is configured to overwrite events as needed, any evidence of unauthorized activities could be overwritten by a large number of unrelated events.

Impact:

On most computers, this is the default configuration and there will be no negative impact. However, if you have installed *Web Server (IIS)*, you will need to allow the IIS application pool(s) to be granted this user right.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:GenerateSecurityAudits_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to LOCAL SERVICE, NETWORK SERVICE.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:GenerateSecurityAudits
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to LOCAL SERVICE, NETWORK SERVICE

```
Security Settings\Local Policies\User Rights Assignment\Generate security audits
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `LOCAL SERVICE, NETWORK SERVICE`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Generate security audits
Configuration:	Allow and sub-option: <code>LOCAL SERVICE, NETWORK SERVICE</code>

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/GenerateSecurityAudits
Data type:	String
Value:	<code>LOCAL SERVICE, NETWORK SERVICE</code>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

LOCAL SERVICE, NETWORK SERVICE.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	6.2 <u>Activate audit logging</u> Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

2.2.20 (L1) Ensure 'Impersonate a client after authentication' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The policy setting allows programs that run on behalf of a user to impersonate that user (or another specified account) so that they can act on behalf of the user. If this user right is required for this kind of impersonation, an unauthorized user will not be able to convince a client to connect—for example, by remote procedure call (RPC) or named pipes—to a service that they have created to impersonate that client, which could elevate the unauthorized user's permissions to administrative or system levels.

Services that are started by the Service Control Manager have the built-in Service group added by default to their access tokens. COM servers that are started by the COM infrastructure and configured to run under a specific account also have the Service group added to their access tokens. As a result, these processes are assigned this user right when they are started.

Also, a user can impersonate an access token if any of the following conditions exist:

- The access token that is being impersonated is for this user.
- The user, in this logon session, logged on to the network with explicit credentials to create the access token.
- The requested level is less than Impersonate, such as Anonymous or Identify.

An attacker with the **Impersonate a client after authentication** user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

The recommended state for this setting is: `Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

An attacker with the **Impersonate a client after authentication** user right could create a service, trick a client to make them connect to the service, and then impersonate that client to elevate the attacker's level of access to that of the client.

Impact:

In most cases this configuration will have no impact. If you have installed *Web Server (IIS)*, you will need to also assign the user right to `IIS_IUSRS`.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ImpersonateClient_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:ImpersonateClient
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to `Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE`

```
Security Settings\Local Policies\User Rights Assignment\Impersonate a client after authentication
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Impersonate a client
Configuration:	Allow and sub-option: Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ImpersonateClient
Data type:	String
Value:	Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.21 (L1) Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can increase the base priority class of a process. (It is not a privileged operation to increase relative priority within a priority class.) This user right is not required by administrative tools that are supplied with the operating system but might be required by software development tools.

The recommended state for this setting is: `Administrators, Window Manager\Window Manager Group`.

Rationale:

A user who is assigned this user right could increase the scheduling priority of a process to Real-Time, which would leave little processing time for all other processes and could lead to a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:IncreaseSchedulingPriority_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators, Window Manager\Window Manager Group.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:IncreaseSchedulingPriority
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators, Window Manager\Window Manager Group

```
Security Settings\Local Policies\User Rights Assignment\Increase scheduling  
priority
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Administrators, Window Manager\Window Manager Group`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Increase scheduling priority
Configuration:	Allow and sub-option: Administrators, Window Manager\Window Manager Group

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/IncreaseSchedulingPriority
Data type:	String
Value:	Administrators, Window Manager\Window Manager Group

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

On Windows 10 R1607 or older: Administrators.

On Windows 10 R1703 or newer: Administrators, Window Manager\Window Manager Group.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.22 (L1) Ensure 'Load and unload device drivers' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to dynamically load a new device driver on a system. An attacker could potentially use this capability to install malicious code that appears to be a device driver. This user right is required for users to add local printers or printer drivers in Windows Vista.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

Device drivers run as highly privileged code. A user who has the **Load and unload device drivers** user right could unintentionally install malicious code that masquerades as a device driver. Administrators should exercise greater care and install only drivers with verified digital signatures.

Impact:

If you remove the **Load and unload device drivers** user right from the `Print Operators` group or other accounts you could limit the abilities of users who are assigned to specific administrative roles in your environment. You should ensure that delegated tasks will not be negatively affected.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:  
:LoadUnloadDeviceDrivers_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:LoadUnloadDeviceDrivers
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Load and unload  
device drivers
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Load and unload device drivers
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/LoadUnloadDeviceDrivers
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.23 (L1) Ensure 'Lock pages in memory' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows a process to keep data in physical memory, which prevents the system from paging the data to virtual memory on disk. If this user right is assigned, significant degradation of system performance can occur.

The recommended state for this setting is: `No One`.

Rationale:

Users with the **Lock pages in memory** user right could assign physical memory to several processes, which could leave little or no RAM for other processes and result in a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:LockMemory_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No One.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:LockMemory
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Lock pages in memory
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Lock pages in memory
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/LockMemory
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.24 (L1) Ensure 'Manage auditing and security log' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users can change the auditing options for files and directories and clear the Security log.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

The ability to manage the Security event log is a powerful user right and it should be closely guarded. Anyone with this user right can clear the Security log to erase important evidence of unauthorized activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ManageAuditingAndSecurityLog_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:ManageAuditingAndSecurityLog
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Manage auditing and security log
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Manage auditing and security log
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ManageAuditingAndSecurityLog
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of ֠ will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.25 (L1) Ensure 'Modify an object label' is set to 'No One' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This privilege determines which user accounts can modify the integrity label of objects, such as files, registry keys, or processes owned by other users. Processes running under a user account can modify the label of an object owned by that user to a lower level without this privilege.

The recommended state for this setting is: `No One`.

Rationale:

By modifying the integrity label of an object owned by another user a malicious user may cause them to execute code at a higher level of privilege than intended.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ModifyObjectLabel_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to No One.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:ModifyObjectLabel
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to No one

```
Security Settings\Local Policies\User Rights Assignment\Modify an object label
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `No one`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Modify an object label
Configuration:	Allow and leave sub-option blank

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ModifyObjectLabel
Data type:	String
Value:	<Data></Data>

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of `` will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (`□`). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

No one.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.26 (L1) Ensure 'Modify firmware environment values' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to configure the system-wide environment variables that affect hardware configuration. This information is typically stored in the Last Known Good Configuration. Modification of these values and could lead to a hardware failure that would result in a denial of service condition.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

Anyone who is assigned the **Modify firmware environment values** user right could configure the settings of a hardware component to cause it to fail, which could lead to data corruption or a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ModifyFirmwareEnvironment_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:ModifyFirmwareEnvironment
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Modify firmware environment values
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Modify firmware environment values
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ModifyFirmwareEnvironment
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.27 (L1) Ensure 'Perform volume maintenance tasks' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to manage the system's volume or disk configuration, which could allow a user to delete a volume and cause data loss as well as a denial-of-service condition.

The recommended state for this setting is: `Administrators`.

Rationale:

A user who is assigned the **Perform volume maintenance tasks** user right could delete a volume, which could result in the loss of data or a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:ManageVolume_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\UserRights:ManageVolume
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Perform volume maintenance tasks
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Preform volume maintenance tasks
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ManageVolume
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.28 (L1) Ensure 'Profile single process' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users can use tools to monitor the performance of non-system processes. Typically, you do not need to configure this user right to use the Microsoft Management Console (MMC) Performance snap-in. However, you do need this user right if System Monitor is configured to collect data using Windows Management Instrumentation (WMI). Restricting the **Profile single process** user right prevents intruders from gaining additional information that could be used to mount an attack on the system.

The recommended state for this setting is: `Administrators`.

Rationale:

The **Profile single process** user right presents a moderate vulnerability. An attacker with this user right could monitor a computer's performance to help identify critical processes that they might wish to attack directly. The attacker may also be able to determine what processes run on the computer so that they could identify countermeasures that they may need to avoid, such as antivirus software, an intrusion-detection system, or which other users are logged on to a computer.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights  
:ProfileSingleProcess_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
device\UserRights:ProfileSingleProcess
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Profile single  
process
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Profile single process
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/ProfileSingleProcess
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of ֠ will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.29 (L1) Ensure 'Restore files and directories' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which users can bypass file, directory, registry, and other persistent object permissions when restoring backed up files and directories on computers that run Windows Vista (or newer) in your environment. This user right also determines which users can set valid security principals as object owners; it is similar to the **Back up files and directories** user right.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

An attacker with the **Restore files and directories** user right could restore sensitive data to a computer and overwrite data that is more recent, which could lead to loss of important data, data corruption, or a denial of service. Attackers could overwrite executable files that are used by legitimate administrators or system services with versions that include malicious software to grant themselves elevated privileges, compromise data, or install backdoors for continued access to the computer.

Note: Even if the following countermeasure is configured, an attacker could still restore data to a computer in a domain that is controlled by the attacker. Therefore, it is critical that organizations carefully protect the media that is used to back up data.

Impact:

If you remove the **Restore files and directories** user right from the `Backup Operators` group and other accounts you could make it impossible for users who have been delegated specific tasks to perform those tasks. You should verify that this change won't negatively affect the ability of your organization's personnel to do their jobs.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:RestoreFilesAndDirectories_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\UserRights:RestoreFilesAndDirectories
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Restore files and directories
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Administrators:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Restore files and directories
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/RestoreFilesAndDirectories
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of ֠ will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators, Backup Operators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.2.30 (L1) Ensure 'Take ownership of files or other objects' is set to 'Administrators' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows users to take ownership of files, folders, registry keys, processes, or threads. This user right bypasses any permissions that are in place to protect objects to give ownership to the specified user.

The recommended state for this setting is: `Administrators`.

Note: This user right is considered a "sensitive privilege" for the purposes of auditing.

Rationale:

Any users with the **Take ownership of files or other objects** user right can take control of any object, regardless of the permissions on that object, and then make any changes they wish to that object. Such changes could result in exposure of data, corruption of data, or a DoS condition.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\UserRights:TakeOwnership_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to Administrators.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\UserRights:TakeOwnership
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following **Local Security Policy** location and confirm it is set to Administrators

```
Security Settings\Local Policies\User Rights Assignment\Take ownership of files or other objects
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Administrators*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/User Rights
Setting Name:	Take ownership of files or objects
Configuration:	Allow and sub-option: Administrators

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/UserRights/TakeOwnership
Data type:	String
Value:	Administrators

Important: When there is more than one value that needs to be entered (ex: Guests, Administrator), the XML value of  will need to be converted to its Unicode character representation to separate the values in the *Value* field of the *Custom Device Configuration Policy*. This value should convert to a square with a question mark in it (). Please note that when copied from the converter to Intune a square will appear, but the value will still work. Also note that this value cannot be copied from sources like Microsoft Word. We recommend that the value be copied and used directly from the converter. A sample converter can be found at [Online XML entity decoder | Coder's Toolbox](#).

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note #3: The following link is an alternative way to set the "User Rights Assignment" section. [Policy CSP - UserRights - Windows Client Management | Microsoft Docs](#)

Default Value:

Administrators.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.3 Security Options

This section contains recommendations for security options.

2.3.1 Accounts

This section contains recommendations related to default accounts.

2.3.1.1 (L1) Ensure 'Accounts: Block Microsoft accounts' is set to 'Blocked' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents users from adding new Microsoft accounts on this computer.

The recommended state for this setting is: `Blocked`.

The value of `Enabled` (users can't add Microsoft accounts) **or** `Users can't add or log on with Microsoft accounts` is considered compliant for this recommendation when using a Custom Profile.

Rationale:

Organizations that want to effectively implement identity management policies and maintain firm control of what accounts are used to log onto their computers will probably want to block Microsoft accounts. Organizations may also need to block Microsoft accounts in order to meet the requirements of compliance standards that apply to their information systems.

Impact:

Users will not be able to log onto the computer with their Microsoft account.

Audit:

Navigate to the following registry location and confirm it is set to 1 or 3. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:Accounts_BlockMicrosoftAccounts_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following **Local Security Policy** location and confirm it is set to `Blocked`

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Block Microsoft accounts
```

OR

Navigate to the following registry location and confirm it is set to 1 or 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:NoConnectedUser
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Blocked`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Accounts
Setting Name:	Add new Microsoft accounts
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Accounts_BlockMicrosoftAccounts
Data type:	Integer
Value:	1 or 3

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Users are able to use Microsoft accounts with Windows.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.			
v7	16.2 <u>Configure Centralized Point of Authentication</u> Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

2.3.1.2 (L1) Ensure 'Accounts: Guest account status' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the Guest account is enabled or disabled. The Guest account allows unauthenticated network users to gain access to the system.

The recommended state for this setting is: `Disabled`.

Rationale:

The default Guest account allows unauthenticated network users to log on as Guest with no password. These unauthorized users could access any resources that are accessible to the Guest account over the network. This capability means that any network shares with permissions that allow access to the Guest account, the Guests group, or the Everyone group will be accessible over the network, which could lead to the exposure or corruption of data.

Impact:

All network users will need to authenticate before they can access shared resources. If you disable the Guest account and the Network Access: Sharing and Security Model option is set to Guest Only, network logons, such as those performed by the Microsoft Network Server (SMB Service), will fail. This policy setting should have little impact on most organizations because it is the default setting in Microsoft Windows 2000, Windows XP, and Windows Server™ 2003.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:Accounts_EnableGuestAccountStatus_ProviderSet
```

Navigate to the following **Local Security Policy** location and confirm it is set to Disabled.

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Guest account status
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Accounts
Setting Name:	Guest account
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Accounts_EnableGuestAccountStatus
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.7 Manage Default Accounts on Enterprise Assets and Software</u> Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.			
v7	<u>16.8 Disable Any Unassociated Accounts</u> Disable any account that cannot be associated with a business process or business owner.			

2.3.1.3 (L1) Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether local accounts that are not password protected can be used to log on from locations other than the physical computer console. If you enable this policy setting, local accounts that have blank passwords will not be able to log on to the network from remote client computers. Such accounts will only be able to log on at the keyboard of the computer.

The recommended state for this setting is: `Enabled`.

Rationale:

Blank passwords are a serious threat to computer security and should be forbidden through both organizational policy and suitable technical measures. In fact, the default settings for Active Directory domains require complex passwords of at least seven characters. However, if users with the ability to create new accounts bypass your domain-based password policies, they could create accounts with blank passwords. For example, a user could build a stand-alone computer, create one or more accounts with blank passwords, and then join the computer to the domain. The local accounts with blank passwords would still function. Anyone who knows the name of one of these unprotected accounts could then use it to log on.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:Accounts_LimitLocalAccountUseOfBlankPasswordsToConsoleLogonOnly_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following **Local Security Policy** location and confirm it is set to Enabled.

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Limit local account use of blank passwords to console logon only
```

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:LimitBlankPasswordUse
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Accounts
Setting Name:	Remote log on without password
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Accounts_LimitLocalAccountUseOfBlankPasswordsToConsoleLogonOnly
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 <u>Use Unique Passwords</u> Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	4.4 <u>Use Unique Passwords</u> Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			

2.3.1.4 (L1) Configure 'Accounts: Rename administrator account' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The built-in local administrator account is a well-known account name that attackers will target. It is recommended to choose another name for this account, and to avoid names that denote administrative or elevated access accounts. Be sure to also change the default description for the local administrator (through the Computer Management console).

Rationale:

The Administrator account exists on all computers that run the Windows 2000 or newer operating systems. If you rename this account, it is slightly more difficult for unauthorized persons to guess this privileged user name and password combination.

The built-in Administrator account cannot be locked out, regardless of how many times an attacker might use a bad password. This capability makes the Administrator account a popular target for brute force attacks that attempt to guess passwords. The value of this countermeasure is lessened because this account has a well-known SID, and there are third-party tools that allow authentication by using the SID rather than the account name. Therefore, even if you rename the Administrator account, an attacker could launch a brute force attack by using the SID to log on.

Impact:

You will have to inform users who are authorized to use this account of the new account name. (The guidance for this setting assumes that the Administrator account was not disabled, which was recommended earlier in this chapter.)

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:Accounts_RenameAdministratorAccount_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following **Local Security Policy** location and confirm it is set to CISADMIN.

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename administrator account
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to CISADMIN or another admin account name:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Accounts
Setting Name:	Rename admin account
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Accounts_RenameAdministratorAccount
Data type:	String
Value:	CISADMIN <or choose admin account name>

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Administrator.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.7 Manage Default Accounts on Enterprise Assets and Software</u> Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.			

2.3.1.5 (L1) Configure 'Accounts: Rename guest account' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The built-in local guest account is another well-known name to attackers. It is recommended to rename this account to something that does not indicate its purpose. Even if you disable this account, which is recommended, ensure that you rename it for added security.

Rationale:

The Guest account exists on all computers that run the Windows 2000 or newer operating systems. If you rename this account, it is slightly more difficult for unauthorized persons to guess this privileged user name and password combination.

Impact:

There should be little impact, because the Guest account is disabled by default.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:Accounts_RenameGuestAccount_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following **Local Security Policy** location and confirm it is set to CISGUEST.

```
Computer Configuration\Policies\Windows Settings\Security Settings\Local Policies\Security Options\Accounts: Rename guest account
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `CISGUEST` or another account name:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Accounts
Setting Name:	Rename guest account
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Accounts_RenameGuestAccount
Data type:	String
Value:	CISGUEST <or choose admin account name>

- Select *OK*

Default Value:

Guest.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.7 Manage Default Accounts on Enterprise Assets and Software</u> Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.			

2.3.2 Audit

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.3 DCOM

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.4 Devices

This section contains recommendations related to managing devices.

2.3.4.1 (L2) Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

For a computer to print to a shared printer, the driver for that shared printer must be installed on the local computer. This security setting determines who is allowed to install a printer driver as part of connecting to a shared printer.

The recommended state for this setting is: `Enabled`.

Note: This setting does not affect the ability to add a local printer. This setting does not affect Administrators.

Rationale:

It may be appropriate in some organizations to allow users to install printer drivers on their own workstations. However, in a high security environment, you should allow only Administrators, not users, to do this, because printer driver installation may unintentionally cause the computer to become less stable. A malicious user could install inappropriate printer drivers in a deliberate attempt to damage the computer, or a user might accidentally install malicious software that masquerades as a printer driver. It is feasible for an attacker to disguise a Trojan horse program as a printer driver. The program may appear to users as if they must use it to print, but such a program could unleash malicious code on your computer network.

Impact:

Only Administrators will be able to install a printer driver as part of connecting to a shared printer. The ability to add a local printer will not be affected.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:DisableDownloadingOfPrintDriversOverHTTP_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Connectivity:DisableDownloadingOfPrintDriversOverHTTP
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Print\Providers\LanMan Print Services\Servers:AddPrinterDrivers
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Devices
Setting Name:	Install printer drivers for shared printers
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/Devices_PreventUsersFromInstallingPrinterDriversWhenConnectingToSharedPrinters
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (Any user can install a printer driver as part of connecting to a shared printer.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 <u>Define and Maintain Role-Based Access Control</u> Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2.3.5 Domain controller

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.6 Domain member

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.7 Interactive logon

This section contains recommendations related to interactive logons.

2.3.7.1 (L1) Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users must press CTRL+ALT+DEL before they log on.

The recommended state for this setting is: `Disabled`.

Rationale:

Microsoft developed this feature to make it easier for users with certain types of physical impairments to log on to computers that run Windows. If users are not required to press CTRL+ALT+DEL, they are susceptible to attacks that attempt to intercept their passwords. If CTRL+ALT+DEL is required before logon, user passwords are communicated by means of a trusted path.

An attacker could install a Trojan horse program that looks like the standard Windows logon dialog box and capture the user's password. The attacker would then be able to log on to the compromised account with whatever level of privilege that user has.

Impact:

Users must press CTRL+ALT+DEL before they log on to Windows unless they use a smart card for Windows logon. A smart card is a tamper-proof device that stores security information.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_DoNotRequireCTRLALTDEL_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_DoNotRequireCTRLALTDEL
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Interactive Logon
Setting Name:	Require CTRL + ALT + DEL to log on
Configuration:	Enable

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_DoNotRequireCTRLALTD
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

On Windows 7 or older: Disabled.

On Windows 8.0 or newer: Enabled.

2.3.7.2 (L1) Ensure 'Interactive logon: Don't display last signed-in' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the account name of the last user to log on to the client computers in your organization will be displayed in each computer's respective Windows logon screen. Enable this policy setting to prevent intruders from collecting account names visually from the screens of desktop or laptop computers in your organization.

The recommended state for this setting is: `Enabled`.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the server through Remote Desktop Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

The name of the last user to successfully log on will not be displayed in the Windows logon screen.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_DoNotDisplayLastSignedIn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_DoNotDisplayLastSignedIn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DontDisplayLastUserName
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Endpoint protection/Local device security options/Interactive Logon  
Setting Name:  Hide last signed-in user  
Configuration: Enable
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:          <Enter name>  
Description:   <Enter Description>  
OMA-URI:  
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_DoNotDisplayLastSignedIn  
Data type:    Integer  
Value:       1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (The name of the last user to log on is displayed in the Windows logon screen.)

2.3.7.3 (L1) Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Windows notices inactivity of a logon session, and if the amount of inactive time exceeds the inactivity limit, then the screen saver will run, locking the session.

The recommended state for this setting is: `900 or fewer second(s), but not 0`.

Note: A value of `0` does not conform to the benchmark as it disables the machine inactivity limit.

Rationale:

If a user forgets to lock their computer when they walk away it's possible that a passerby will hijack it.

Impact:

The screen saver will automatically activate when the computer has been unattended for the amount of time specified. The impact should be minimal since the screen saver is enabled by default.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_MachineInactivityLimit_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 900 or fewer seconds, but not 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_MachineInactivityLimit
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 900 or fewer seconds, but not 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:InactivityTimeoutSecs
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 900 or fewer second(s), but not 0:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Interactive Logon
Setting Name:	Minutes of lock screen inactivity until screen saver activates
Configuration:	15

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_MachineInactivityLimit
Data type:	Integer
Value:	900 or fewer, but not 0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

0 seconds. (There is no inactivity limit.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.3 Configure Automatic Session Locking on Enterprise Assets</u> Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.			
v7	<u>16.11 Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

2.3.7.4 (L1) Configure 'Interactive logon: Message text for users attempting to log on' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies a text message that displays to users when they log on. Set the following group policy to a value that is consistent with the security and operational requirements of your organization.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process. This text is often used for legal reasons—for example, to warn users about the ramifications of misusing company information or to warn them that their actions may be audited.

Note: Any warning that you display should first be approved by your organization's legal and human resources representatives.

Impact:

Users will have to acknowledge a dialog box containing the configured text before they can log on to the computer.

Warning: [Windows Autopilot - Policy Conflicts](#): Windows Autopilot pre-provisioning doesn't work when this GPO policy settings is enabled. An exception to this recommendation will be needed if Windows AutoPilot is used.

Note: Windows Vista and Windows XP Professional support logon banners that can exceed 512 characters in length and that can also contain carriage-return line-feed sequences. However, Windows 2000-based clients cannot interpret and display these messages. You must use a Windows 2000-based computer to create a logon message policy that applies to Windows 2000-based computers.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_MessageTextForUsersAttemptingToLogOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set as prescribed.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_MessageTextForUsersAttemptingToLogOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set as prescribed.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:LegalNoticeText
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* as prescribed:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Endpoint protection/Local device security options/Interactive Logon
Setting Name:  Login message text
Configuration: <enter text>
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_MessageTextForUsersAttemptingToLogOn
Data type:    String
Value:        <Enter text>
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

No message.

2.3.7.5 (L1) Configure 'Interactive logon: Message title for users attempting to log on' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies the text displayed in the title bar of the window that users see when they log on to the system. Configure this setting in a manner that is consistent with the security and operational requirements of your organization.

Rationale:

Displaying a warning message before logon may help prevent an attack by warning the attacker about the consequences of their misconduct before it happens. It may also help to reinforce corporate policy by notifying employees of the appropriate policy during the logon process.

Impact:

Users will have to acknowledge a dialog box with the configured title before they can log on to the computer.

Warning: [Windows Autopilot - Policy Conflicts](#): Windows Autopilot pre-provisioning doesn't work when this GPO policy settings is enabled. An exception to this recommendation will be needed if Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_MessageTitleForUsersAttemptingToLogOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set as prescribed.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_MessageTitleForUsersAttemptingToLogOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set as prescribed.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:LegalNoticeCaption
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to as prescribed:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:                Endpoint protection/Local device security options/Interactive Logon
Setting Name:        Login message title
Configuration:        <enter text>
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:                <Enter name>
Description:          <Enter Description>
OMA-URI:              ./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_MessageTitleForUsersAttemptingToLogOn
Data type:            String
Value:                <Enter text>
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

No message.

2.3.7.6 (L1) Ensure 'Interactive logon: Smart card removal behavior' is set to 'Lock Workstation' or higher (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines what happens when the smart card for a logged-on user is removed from the smart card reader.

The recommended state for this setting is: `Lock Workstation`. Configuring this setting to `Force Logoff` **OR** `Disconnect if a Remote Desktop Services session` also conforms to the benchmark.

Rationale:

Users sometimes forget to lock their workstations when they are away from them, allowing the possibility for malicious users to access their computers. If smart cards are used for authentication, the computer should automatically lock itself when the card is removed to ensure that only the user with the smart card is accessing resources using those credentials.

Impact:

If you select `Lock Workstation`, the workstation is locked when the smart card is removed, allowing users to leave the area, take their smart card with them, and still maintain a protected session.

If you select `Force Logoff`, users are automatically logged off when their smart card is removed.

If you select `Disconnect if a Remote Desktop Services session`, removal of the smart card disconnects the session without logging the users off. This allows the user to insert the smart card and resume the session later, or at another smart card reader-equipped computer, without having to log on again. If the session is local, this policy will function identically to `Lock Workstation`.

Enforcing this setting on computers used by people who must log onto multiple computers in order to perform their duties could be frustrating and lower productivity. For example, if network administrators are limited to a single account but need to log into several computers simultaneously in order to effectively manage the network enforcing this setting will limit them to logging onto one computer at a time. For these reasons it is recommended that this setting only be enforced on workstations used for purposes commonly associated with typical users such as document creation and email.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:InteractiveLogon_SmartCardRemovalBehavior_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1, 2, or 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:InteractiveLogon_SmartCardRemovalBehavior
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Lock Workstation or higher`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Interactive Logon
Setting Name: Smart card removal behavior
Configuration: Lock Workstation or Higher
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/InteractiveLogon_SmartCardRemovalBehavior
Data type: String
Value: 1, 2, or 3

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

No action.

References:

1. <https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/interactive-logon-smart-card-removal-behavior>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 <u>Configure Automatic Session Locking on Enterprise Assets</u> Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.			
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

2.3.8 Microsoft network client

This section contains recommendations related to configuring the Microsoft network client.

2.3.8.1 (L1) Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether packet signing is required by the SMB client component.

Note: When Windows Vista-based computers have this policy setting enabled and they connect to file or print shares on remote servers, it is important that the setting is synchronized with its companion setting, **Microsoft network server: Digitally sign communications (always)**, on those servers. For more information about these settings, see the "Microsoft network client and server: Digitally sign communications (four related settings)" section in Chapter 5 of the Threats and Countermeasures guide.

The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Microsoft network client will not communicate with a Microsoft network server unless that server agrees to perform SMB packet signing.

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server.

Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a Domain Controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks.

When SMB signing policies are enabled on Domain Controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledge Base article 950876 for more details: [Group Policy settings are not applied on member computers that are running Windows Server 2008 or Windows Vista SP1 when certain SMB signing policies are enabled](#).

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters:RequireSecuritySignature
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Microsoft Network Client
Setting Name:	Digitally sign communications (always)
Configuration:	Enable

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/MicrosoftNetworkClient_DigitallySignCommunicationsAlways
Data type:	Integer
Value:	1

Default Value:

Disabled. (SMB packet signing is negotiated between the client and server.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.3.8.2 (L1) Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the SMB client will attempt to negotiate SMB packet signing.

Note: Enabling this policy setting on SMB clients on your network makes them fully effective for packet signing with all clients and servers in your environment.

The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

None - this is the default behavior.

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server.

Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a Domain Controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks.

When SMB signing policies are enabled on Domain Controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledge Base article 950876 for more details: [Group Policy settings are not applied on member computers that are running Windows Server 2008 or Windows Vista SP1 when certain SMB signing policies are enabled](#).

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanWorkstation\Parameters:EnableSecuritySignature
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/MicrosoftNetworkClient_DigitallySignCommunicationsIfServerAgrees
Data type:    Integer
Value:        0
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2 This recommendation cannot be set via the *Endpoint protection* profile using *Local device security options/Microsoft Network Client* settings due to the only available option of *Blocked*.

Default Value:

Enabled. (The Microsoft network client will ask the server to perform SMB packet signing upon session setup. If packet signing has been enabled on the server, packet signing will be negotiated.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.3.8.3 (L1) Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the SMB redirector will send plaintext passwords during authentication to third-party SMB servers that do not support password encryption.

It is recommended that you disable this policy setting unless there is a strong business case to enable it. If this policy setting is enabled, unencrypted passwords will be allowed across the network.

The recommended state for this setting is: `Disabled`.

Rationale:

If you enable this policy setting, the server can transmit passwords in plaintext across the network to other computers that offer SMB services, which is a significant security risk. These other computers may not use any of the SMB security mechanisms that are included with Windows Server 2003.

Impact:

None - this is the default behavior.

Some very old applications and operating systems such as MS-DOS, Windows for Workgroups 3.11, and Windows 95a may not be able to communicate with the servers in your organization by means of the SMB protocol.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:MicrosoftNetworkClient_SendUnencryptedPasswordToThirdPartySMBServers_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:MicrosoftNetworkClient_SendUnencryptedPasswordToThirdPartySMBServers
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Endpoint protection/Local device security options/Microsoft
Network Client
Setting Name:   Send unencrypted password to third-party SMB servers
Configuration:  Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/MicrosoftNetw
orkClient_SendUnencryptedPasswordToThirdPartySMBServers
Data type:     Integer
Value:         0
```

Default Value:

Disabled. (Plaintext passwords will not be sent during authentication to third-party SMB servers that do not support password encryption.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

2.3.9 Microsoft network server

This section contains recommendations related to configuring the Microsoft network server.

2.3.9.1 (L1) Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether packet signing is required by the SMB server component. Enable this policy setting in a mixed environment to prevent downstream clients from using the workstation as a network server.

The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Microsoft network server will not communicate with a Microsoft network client unless that client agrees to perform SMB packet signing.

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server.

Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a Domain Controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks.

When SMB signing policies are enabled on Domain Controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledge Base article 950876 for more details: [Group Policy settings are not applied on member computers that are running Windows Server 2008 or Windows Vista SP1 when certain SMB signing policies are enabled](#).

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:MicrosoftNetworkServer_DigitallySignCommunicationsAlways_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:MicrosoftNetworkServer_DigitallySignCommunicationsAlways
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Microsoft Network Server
Setting Name:	Digitally sign communications (always)
Configuration:	Enable

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/MicrosoftNetworkServer_DigitallySignCommunicationsAlways
Data type:	Integer
Value:	1

Default Value:

Disabled. (SMB packet signing is negotiated between the client and server.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.3.9.2 (L1) Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the SMB server will negotiate SMB packet signing with clients that request it. If no signing request comes from the client, a connection will be allowed without a signature if the **Microsoft network server: Digitally sign communications (always)** setting is not enabled.

Note: Enable this policy setting on SMB clients on your network to make them fully effective for packet signing with all clients and servers in your environment.

The recommended state for this setting is: `Enabled`.

Rationale:

Session hijacking uses tools that allow attackers who have access to the same network as the client or server to interrupt, end, or steal a session in progress. Attackers can potentially intercept and modify unsigned SMB packets and then modify the traffic and forward it so that the server might perform undesirable actions. Alternatively, the attacker could pose as the server or client after legitimate authentication and gain unauthorized access to data.

SMB is the resource sharing protocol that is supported by many Windows operating systems. It is the basis of NetBIOS and many other protocols. SMB signatures authenticate both users and the servers that host the data. If either side fails the authentication process, data transmission will not take place.

Impact:

The Microsoft network server will negotiate SMB packet signing as requested by the client. That is, if packet signing has been enabled on the client, packet signing will be negotiated.

The Windows 2000 Server, Windows 2000 Professional, Windows Server 2003, Windows XP Professional and Windows Vista implementations of the SMB file and print sharing protocol support mutual authentication, which prevents session hijacking attacks and supports message authentication to prevent man-in-the-middle attacks. SMB signing provides this authentication by placing a digital signature into each SMB, which is then verified by both the client and the server.

Implementation of SMB signing may negatively affect performance, because each packet needs to be signed and verified. If these settings are enabled on a server that is performing multiple roles, such as a small business server that is serving as a Domain Controller, file server, print server, and application server performance may be substantially slowed. Additionally, if you configure computers to ignore all unsigned SMB communications, older applications and operating systems will not be able to connect. However, if you completely disable all SMB signing, computers will be vulnerable to session hijacking attacks.

When SMB signing policies are enabled on Domain Controllers running Windows Server 2003 and member computers running Windows Vista SP1 or Windows Server 2008 group policy processing will fail. A hotfix is available from Microsoft that resolves this issue; see Microsoft Knowledge Base article 950876 for more details: [Group Policy settings are not applied on member computers that are running Windows Server 2008 or Windows Vista SP1 when certain SMB signing policies are enabled.](#)

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:MicrosoftNetworkServer_DigitallySignCommunicationsIfClientAgrees_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:MicrosoftNetworkServer_DigitallySignCommunicationsIfClientAgrees
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters:EnableSecuritySignature
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Microsoft Network Server
Setting Name:	Digitally sign communications (if server agrees)
Configuration:	Enable

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/MicrosoftNetworkServer_DigitallySignCommunications
	IfClientAgrees
Data type:	Integer
Value:	1

Default Value:

Disabled. (The SMB client will never negotiate SMB packet signing.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			

2.3.10 Network access

This section contains recommendations related to network access.

2.3.10.1 (L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the ability of anonymous users to enumerate the accounts in the Security Accounts Manager (SAM). If you enable this policy setting, users with anonymous connections will not be able to enumerate domain account user names on the systems in your environment. This policy setting also allows additional restrictions on anonymous connections.

The recommended state for this setting is: `Enabled`.

Note: This policy has no effect on Domain Controllers.

Rationale:

An unauthorized user could anonymously list account names and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information.)

Impact:

None - this is the default behavior. It will be impossible to establish trusts with Windows NT 4.0-based domains. Also, client computers that run older versions of the Windows operating system such as Windows NT 3.51 and Windows 95 will experience problems when they try to use resources on the server.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkAccess_DoNotAllowAnonymousEnumerationOfSAMAccounts_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkAccess_DoNotAllowAnonymousEnumerationOfSAMAccounts
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:      Endpoint protection/Local device security options/Network
access and security
Setting Name: Anonymous enumeration of SAM accounts
Configuration: Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:      <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkAccess
_DoNotAllowAnonymousEnumerationOfSAMAccounts
Data type: Integer
Value:      1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled. (Do not allow anonymous enumeration of SAM accounts. This option replaces Everyone with Authenticated Users in the security permissions for resources.)

2.3.10.2 (L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the ability of anonymous users to enumerate SAM accounts as well as shares. If you enable this policy setting, anonymous users will not be able to enumerate domain account user names and network share names on the systems in your environment.

The recommended state for this setting is: `Enabled`.

Note: This policy has no effect on Domain Controllers.

Rationale:

An unauthorized user could anonymously list account names and shared resources and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information.)

Impact:

It will be impossible to establish trusts with Windows NT 4.0-based domains. Also, client computers that run older versions of the Windows operating system such as Windows NT 3.51 and Windows 95 will experience problems when they try to use resources on the server. Users who access file and print servers anonymously will be unable to list the shared network resources on those servers; the users will have to authenticate before they can view the lists of shared folders and printers. However, even with this policy setting enabled, anonymous users will have access to resources with permissions that explicitly include the built-in group, `ANONYMOUS LOGON`.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkAccess_DoNotAllowAnonymousEnumerationOfSAMAccountsAndShares_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkAccess_DoNotAllowAnonymousEnumerationOfSAMAccountsAndShares
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: Anonymous enumeration of SAM accounts and shares
Configuration: Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkAccess
_DoNotAllowAnonymousEnumerationOfSAMAccountsAndShares
Data type: Integer
Value: 1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (Allow anonymous enumeration of SAM accounts and shares. No additional permissions can be assigned by the administrator for anonymous connections to the computer. Anonymous connections will rely on default permissions.)

2.3.10.3 (L1) Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

When enabled, this policy setting restricts anonymous access to only those shares and pipes that are named in the `Network access: Named pipes that can be accessed anonymously` and `Network access: Shares that can be accessed anonymously` settings. This policy setting controls null session access to shares on your computers by adding `RestrictNullSessAccess` with the value 1 in the

`HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanManServer\Parameters`

registry key. This registry value toggles null session shares on or off to control whether the server service restricts unauthenticated clients' access to named resources.

The recommended state for this setting is: `Enabled`.

Rationale:

Null sessions are a weakness that can be exploited through shares (including the default shares) on computers in your environment.

Impact:

None - this is the default behavior. If you choose to enable this setting and are supporting Windows NT 4.0 domains, you should check if any of the named pipes are required to maintain trust relationships between the domains, and then add the pipe to the **Network access: Named pipes that can be accessed anonymously** list:

- COMNAP: SNA session access
- COMNODE: SNA session access
- SQL\QUERY: SQL instance access
- SPOOLSS: Spooler service
- LLSRPC: License Logging service
- NETLOGON: Net Logon service
- LSARPC: LSA access
- SAMR: Remote access to SAM objects
- BROWSER: Computer Browser service

Previous to the release of Windows Server 2003 with Service Pack 1 (SP1) these named pipes were allowed anonymous access by default, but with the increased hardening in Windows Server 2003 with SP1 these pipes must be explicitly added if needed.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkAccess_RestrictAnonymousAccessToNamedPipesAndShares_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkAccess_RestrictAnonymousAccessToNamedPipesAndShares
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: Anonymous access to Named Pipes and Shares
Configuration: Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkAccess
_RestrictAnonymousAccessToNamedPipesAndShares
Data type: Integer
Value: 1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled. (Anonymous access is restricted to shares and pipes listed in the `Network access`: Named pipes that can be accessed anonymously and `Network access`: Shares that can be accessed anonymously **settings**.)

2.3.10.4 (L1) Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to restrict remote RPC connections to SAM.

The recommended state for this setting is: `Administrators: Remote Access: Allow`.

Note: A Windows 10 R1607, Server 2016 or newer OS is required to access and set this value in Group Policy.

Rationale:

To ensure that an unauthorized user cannot anonymously list local account names or groups and use the information to attempt to guess passwords or perform social engineering attacks. (Social engineering attacks try to deceive users in some way to obtain passwords or some form of security information.)

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkAccess_RestrictClientsAllowedToMakeRemoteCallsToSAMProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to

O:BAG:BAD:(A;;RC;;;BA).

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkAccess_RestrictClientsAllowedToMakeRemoteCallsToSAM
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to

O:BAG:BAD:(A;;RC;;;BA).

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:RestrictRemoteSAM
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Allow: O:BAG:BAD:(A;;RC;;;BA):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: Restrict remote RPC connections to SAM
Configuration: Allow: O:BAG:BAD:(A;;RC;;;BA)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkAccess
_RestrictClientsAllowedToMakeRemoteCallsToSAM
Data type: String
Value: O:BAG:BAD:(A;;RC;;;BA)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Administrators: Remote Access: Allow.

2.3.11 Network security

This section contains recommendations related to network security.

2.3.11.1 (L1) Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether Local System services that use Negotiate when reverting to NTLM authentication can use the computer identity. This policy is supported on at least Windows 7 or Windows Server 2008 R2.

The recommended state for this setting is: *Enabled*.

Rationale:

When connecting to computers running versions of Windows earlier than Windows Vista or Windows Server 2008 (non-R2), services running as Local System and using SPNEGO (Negotiate) that revert to NTLM use the computer identity. In Windows 7, if you are connecting to a computer running Windows Server 2008 or Windows Vista, then a system service uses either the computer identity or a NULL session. When connecting with a NULL session, a system-generated session key is created, which provides no protection but allows applications to sign and encrypt data without errors. When connecting with the computer identity, both signing and encryption is supported in order to provide data protection.

Impact:

Services running as Local System that use Negotiate when reverting to NTLM authentication will use the computer identity. This might cause some authentication requests between Windows operating systems to fail and log an error.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkSecurity_AllowLocalSystemToUseComputerIdentityForNTLM_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkSecurity_AllowLocalSystemToUseComputerIdentityForNTLM
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:UseMachineId
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkSecurity_AllowLocalSystemToUseComputerIdentityForNTLM
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Services running as Local System that use Negotiate when reverting to NTLM authentication will authenticate anonymously.)

2.3.11.2 (L1) Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines if online identities are able to authenticate to this computer.

The Public Key Cryptography Based User-to-User (PKU2U) protocol introduced in Windows 7 and Windows Server 2008 R2 is implemented as a security support provider (SSP). The SSP enables peer-to-peer authentication, particularly through the Windows 7 media and file sharing feature called HomeGroup, which permits sharing between computers that are not members of a domain.

With PKU2U, a new extension was introduced to the Negotiate authentication package, `Spnego.dll`. In previous versions of Windows, Negotiate decided whether to use Kerberos or NTLM for authentication. The extension SSP for Negotiate, `Negoexts.dll`, which is treated as an authentication protocol by Windows, supports Microsoft SSPs including PKU2U.

When computers are configured to accept authentication requests by using online IDs, `Negoexts.dll` calls the PKU2U SSP on the computer that is used to log on. The PKU2U SSP obtains a local certificate and exchanges the policy between the peer computers. When validated on the peer computer, the certificate within the metadata is sent to the logon peer for validation and associates the user's certificate to a security token and the logon process completes.

The recommended state for this setting is: `Disabled`.

Rationale:

The PKU2U protocol is a peer-to-peer authentication protocol - authentication should be managed centrally in most managed networks.

Impact:

None - this is the default configuration for domain-joined computers.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkSecurity_AllowPKU2UAuthenticationRequests_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkSecurity_AllowPKU2UAuthenticationRequests
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa\pku2u:AllowOnlineID
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: PKU2U authentication requests
Configuration: Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkSecurity_AllowPKU2UAuthenticationRequests
Data type: Integer
Value: 0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (Online identities will not to be allowed to authenticate to a domain-joined machine.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

2.3.11.3 (L1) Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the LAN Manager (LM) hash value for the new password is stored when the password is changed. The LM hash is relatively weak and prone to attack compared to the cryptographically stronger Microsoft Windows NT hash. Since LM hashes are stored on the local computer in the security database, passwords can then be easily compromised if the database is attacked.

Note: Older operating systems and some third-party applications may fail when this policy setting is enabled. Also, note that the password will need to be changed on all accounts after you enable this setting to gain the proper benefit.

The recommended state for this setting is: `Enabled`.

Rationale:

The SAM file can be targeted by attackers who seek access to username and password hashes. Such attacks use special tools to crack passwords, which can then be used to impersonate users and gain access to resources on your network. These types of attacks will not be prevented if you enable this policy setting, but it will be much more difficult for these types of attacks to succeed.

Impact:

None - this is the default behavior. Earlier operating systems such as Windows 95, Windows 98, and Windows ME as well as some third-party applications will fail.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkSecurity_DoNotStoreLANManagerHashValueOnNextPasswordChange_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkSecurity_DoNotStoreLANManagerHashValueOnNextPasswordChange
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:NoLMHash
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: LAN Manager hash value stored on password change
Configuration: Block
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkSecurity_DoNotStoreLANManagerHashValueOnNextPasswordChange
Data type: Integer
Value: 1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled. (LAN Manager hash values are not stored when passwords are changed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

2.3.11.4 (L1) Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

LAN Manager (LM) was a family of early Microsoft client/server software (predating Windows NT) that allowed users to link personal computers together on a single network. LM network capabilities included transparent file and print sharing, user security features, and network administration tools. In Active Directory domains, the Kerberos protocol is the default authentication protocol. However, if the Kerberos protocol is not negotiated for some reason, Active Directory will use LM, NTLM, or NTLMv2. LAN Manager authentication includes the LM, NTLM, and NTLM version 2 (NTLMv2) variants, and is the protocol that is used to authenticate all Windows clients when they perform the following operations:

- Join a domain
- Authenticate between Active Directory forests
- Authenticate to down-level domains
- Authenticate to computers that do not run Windows 2000, Windows Server 2003, or Windows XP
- Authenticate to computers that are not in the domain

The Network security: LAN Manager authentication level setting determines which challenge/response authentication protocol is used for network logons. This choice affects the level of authentication protocol used by clients, the level of session security negotiated, and the level of authentication accepted by servers.

The recommended state for this setting is: `Send NTLMv2 response only. Refuse LM & NTLM.`

Rationale:

Windows 2000 and Windows XP clients were configured by default to send LM and NTLM authentication responses (Windows 95-based and Windows 98-based clients only send LM). The default settings in OSes predating Windows Vista / Windows Server 2008 (non-R2) allowed all clients to authenticate with servers and use their resources. However, this meant that LM responses - the weakest form of authentication response - were sent over the network, and it was potentially possible for attackers to sniff that traffic to more easily reproduce the user's password.

The Windows 95, Windows 98, and Windows NT operating systems cannot use the Kerberos version 5 protocol for authentication. For this reason, in a Windows Server 2003 domain, these computers authenticate by default with both the LM and NTLM protocols for network authentication. You can enforce a more secure authentication protocol for Windows 95, Windows 98, and Windows NT by using NTLMv2. For the logon process, NTLMv2 uses a secure channel to protect the authentication process. Even if you use NTLMv2 for older clients and servers, Windows-based clients and servers that are members of the domain will use the Kerberos authentication protocol to authenticate with Windows Server 2003 or newer Domain Controllers. For these reasons, it is strongly preferred to restrict the use of LM & NTLM (non-v2) as much as possible.

Impact:

Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it; Domain Controllers refuse LM and NTLM (accept only NTLMv2 authentication). Clients that do not support NTLMv2 authentication will not be able to authenticate in the domain and access domain resources by using LM and NTLM.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkSecurity_LANManagerAuthenticationLevel_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 5.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkSecurity_LANManagerAuthenticationLevel
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 5.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa:LmCompatibilityLevel
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to NTLMv2 and 128-bit encryption:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Local device security options/Network
access and security
Setting Name: LAN Manager Authentication Level
Configuration: NTLMv2 and 128-bit encryption
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name: <Enter name>
Description: <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkSecurity_LANManagerAuthenticationLevel
Data type: Integer
Value: 5
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Send NTLMv2 response only. (Clients use NTLMv2 authentication only and use NTLMv2 session security if the server supports it; Domain Controllers accept LM, NTLM & NTLMv2 authentication.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

2.3.11.5 (L1) Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines which behaviors are allowed by clients for applications using the NTLM Security Support Provider (SSP). The SSP Interface (SSPI) is used by applications that need authentication services. The setting does not modify how the authentication sequence works but instead require certain behaviors in applications that use the SSPI.

The recommended state for this setting is: `Require NTLMv2 session security, Require 128-bit encryption`.

Note: These values are dependent on the *Network security: LAN Manager Authentication Level* (Rule 2.3.11.7) security setting value.

Rationale:

You can enable both options for this policy setting to help protect network traffic that uses the NTLM Security Support Provider (NTLM SSP) from being exposed or tampered with by an attacker who has gained access to the same network. In other words, these options help protect against man-in-the-middle attacks.

Impact:

NTLM connections will fail if NTLMv2 protocol and strong encryption (128-bit) are not **both** negotiated. Client applications that are enforcing these settings will be unable to communicate with older servers that do not support them. This setting could impact Windows Clustering when applied to servers running Windows Server 2003, see Microsoft Knowledge Base article 890761: [You receive an "Error 0x8007042b" error message when you add or join a node to a cluster if you use NTLM version 2 in Windows Server 2003](#) for more information on possible issues and how to resolve them.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions:NetworkSecurity_MinimumSessionSecurityForNTLMSSPBasedClients_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 537395200.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions:NetworkSecurity_MinimumSessionSecurityForNTLMSSPBasedClients
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to NTLMv2 and 128-bit encryption:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/Network access and security
Setting Name:	Minimum Session Security For NTLM SSP Based Clients
Configuration:	NTLMv2 and 128-bit encryption

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/NetworkSecurity_MinimumSessionSecurityForNTLMSSPBasedClients
Data type:	Integer
Value:	537395200

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Require 128-bit encryption. (NTLM connections will fail if strong encryption (128-bit) is not negotiated.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	12.5 <u>Configure Monitoring Systems to Record Network Packets</u> Configure monitoring systems to record network packets passing through the boundary at each of the organization's network boundaries.			

2.3.12 Recovery console

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.13 Shutdown

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.14 System cryptography

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.15 System objects

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.16 System settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

2.3.17 User Account Control

This section contains recommendations related to User Account Control.

2.3.17.1 (L1) Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the behavior of Admin Approval Mode for the built-in Administrator account.

The recommended state for this setting is: `Enabled`.

Rationale:

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. An attack vector for these programs was to discover the password of the account named "Administrator" because that user account was created for all installations of Windows. To address this risk, in Windows Vista and newer, the built-in Administrator account is now disabled by default. In a default installation of a new computer, accounts with administrative control over the computer are initially set up in one of two ways:

- If the computer is not joined to a domain, the first user account you create has the equivalent permissions as a local administrator.
- If the computer is joined to a domain, no local administrator accounts are created. The Enterprise or Domain Administrator must log on to the computer and create one if a local administrator account is warranted.

Once Windows is installed, the built-in Administrator account may be manually enabled, but we strongly recommend that this account remain disabled.

Impact:

The built-in Administrator account uses Admin Approval Mode. Users that log on using the local Administrator account will be prompted for consent whenever a program requests an elevation in privilege, just like any other user would.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_UseAdminApprovalMode_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_UseAdminApprovalMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/User account control
Setting Name:	Run all admins in Admin Approval Mode
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	OMA-URI: ./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_UseAdminApprovalMode
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (The built-in Administrator account runs all applications with full administrative privilege.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			

2.3.17.2 (L1) Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop' or higher (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the behavior of the elevation prompt for administrators.

The recommended state for this setting is: Prompt for consent on the secure desktop. Configuring this setting to Prompt for credentials on the secure desktop also conforms to the benchmark.

Rationale:

One of the risks that the UAC feature introduced with Windows Vista is trying to mitigate is that of malicious software running under elevated credentials without the user or administrator being aware of its activity. This setting raises awareness to the administrator of elevated privilege operations and permits the administrator to prevent a malicious program from elevating its privilege when the program attempts to do so.

Impact:

When an operation (including execution of a Windows binary) requires elevation of privilege, the user is prompted on the secure desktop to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege.

Warning: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process. An exception to this recommendation may be needed if Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_BehaviorOfTheElevationPromptForAdministrators_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1 or 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_BehaviorOfTheElevationPromptForAdministrators
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Prompt for consent on the secure desktop` or 'higher':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/User account control
Setting Name:	Elevation prompt for admins
Configuration:	Prompt for consent on the secure desktop or higher

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_BehaviorOfTheElevationPromptForAdministrators
Data type:	Integer
Value:	1 or 2

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Prompt for consent for non-Windows binaries. (When an operation for a non-Microsoft application requires elevation of privilege, the user is prompted on the secure desktop to select either Permit or Deny. If the user selects Permit, the operation continues with the user's highest available privilege.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-localpoliciessecurityoptions>
2. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-localpoliciessecurityoptions#useraccountcontrol_behavioroftheelevationpromptforadministrators
3. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			
v7	0.0 <u>Explicitly Not Mapped</u> Explicitly Not Mapped			

2.3.17.3 (L1) Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the behavior of the elevation prompt for standard users.

The recommended state for this setting is: `Automatically deny elevation requests`.

Rationale:

One of the risks that the User Account Control feature introduced with Windows Vista is trying to mitigate is that of malicious programs running under elevated credentials without the user or administrator being aware of their activity. This setting raises awareness to the user that a program requires the use of elevated privilege operations and requires that the user be able to supply administrative credentials in order for the program to run.

Impact:

When an operation requires elevation of privilege, a configurable access denied error message is displayed. An enterprise that is running desktops as standard user may choose this setting to reduce help desk calls.

Note: With this setting configured as recommended, the default error message displayed when a user attempts to perform an operation or run a program requiring privilege elevation (without Administrator rights) is "*This program will not run. This program is blocked by group policy. For more information, contact your system administrator.*" Some users who are not used to seeing this message may believe that the operation or program they attempted to run is specifically blocked by group policy, as that is what the message seems to imply. This message may therefore result in user questions as to why that specific operation/program is blocked, when in fact, the problem is that they need to perform the operation or run the program with an Administrative account (or "Run as Administrator" if it *is* already an Administrator account), and they are not doing that.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_BehaviorOfTheElevationPromptForStandardUsers_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_BehaviorOfTheElevationPromptForStandardUsers
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Automatically deny elevation requests:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/User account control
Setting Name:	Elevation prompt for standard users
Configuration:	Automatically deny elevation requests

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_BehaviorOfTheElevationPromptForStandardUsers
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Prompt for credentials. (When an operation requires elevation of privilege, the user is prompted to enter an administrative user name and password. If the user enters valid credentials, the operation continues with the applicable privilege.)

2.3.17.4 (L1) Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the behavior of application installation detection for the computer.

The recommended state for this setting is: `Enabled`.

Rationale:

Some malicious software will attempt to install itself after being given permission to run. For example, malicious software with a trusted application shell. The user may have given permission for the program to run because the program is trusted, but if they are then prompted for installation of an unknown component this provides another way of trapping the software before it can do damage

Impact:

When an application installation package is detected that requires elevation of privilege, the user is prompted to enter an administrative user name and password. If the user enters valid credentials, the operation continues with the applicable privilege.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_DetectApplicationInstallationsAndPromptForElevation_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_DetectApplicationInstallationsAndPromptForElevation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/User account control
Setting Name:	Elevated prompt for app installations
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_DetectApplicationInstallationsAndPromptForElevation
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Disabled. (Default for enterprise. Application installation packages are not detected and prompted for elevation.)

2.3.17.5 (L1) Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether applications that request to run with a User Interface Accessibility (UIAccess) integrity level must reside in a secure location in the file system. Secure locations are limited to the following:

- ...\\Program Files\\, including subfolders
- ...\\Windows\\System32\\
- ...\\Program Files (x86)\\, including subfolders (for 64-bit versions of Windows)

Note: Windows enforces a public key infrastructure (PKI) signature check on any interactive application that requests to run with a UIAccess integrity level regardless of the state of this security setting.

The recommended state for this setting is: *Enabled*.

Rationale:

UIAccess Integrity allows an application to bypass User Interface Privilege Isolation (UIPI) restrictions when an application is elevated in privilege from a standard user to an administrator. This is required to support accessibility features such as screen readers that are transmitting user interfaces to alternative forms. A process that is started with UIAccess rights has the following abilities:

- To set the foreground window.
- To drive any application window using SendInput function.
- To use read input for all integrity levels using low-level hooks, raw input, GetKeyState, GetAsyncKeyState, and GetKeyboardInput.
- To set journal hooks.
- To uses AttachThreadInput to attach a thread to a higher integrity input queue.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_OnlyElevateUIAccessApplicationsThatAreInstalledInSecureLocations_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_OnlyElevateUIAccessApplicationsThatAreInstalledInSecureLocations
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:EnableSecureUIAPaths
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_OnlyElevateUIAccessApplications
               ThatAreInstalledInSecureLocations
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2 This recommendation can also be set using the *Endpoint protection* profile using *Local device security options/User account control* settings.

Default Value:

Enabled. (If an application resides in a secure location in the file system, it runs only with UIAccess integrity.)

2.3.17.6 (L1) Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the behavior of all User Account Control (UAC) policy settings for the computer. If you change this policy setting, you must restart your computer.

The recommended state for this setting is: `Enabled`.

Note: If this policy setting is disabled, the Security Center notifies you that the overall security of the operating system has been reduced.

Rationale:

This is the setting that turns on or off UAC. If this setting is disabled, UAC will not be used and any security benefits and risk mitigations that are dependent on UAC will not be present on the system.

Impact:

None - this is the default behavior. Users and administrators will need to learn to work with UAC prompts and adjust their work habits to use least privilege operations.

Warning: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process. An exception to this recommendation may be needed if Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_RunAllAdministratorsInAdminApprovalModeProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_RunAllAdministratorsInAdminApprovalMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Local device security options/User account control
Setting Name:	Run all admins in Admin Approval Mode
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_RunAllAdministratorsInAdminApprovalMode
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled. (Admin Approval Mode is enabled. This policy must be enabled and related UAC policy settings must also be set appropriately to allow the built-in Administrator account and all other users who are members of the Administrators group to run in Admin Approval Mode.)

References:

1. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>

2.3.17.7 (L1) Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether the elevation request prompt is displayed on the interactive user's desktop or the secure desktop.

The recommended state for this setting is: `Enabled`.

Rationale:

Standard elevation prompt dialog boxes can be spoofed, which may cause users to disclose their passwords to malicious software. The secure desktop presents a very distinct appearance when prompting for elevation, where the user desktop dims, and the elevation prompt UI is more prominent. This increases the likelihood that users who become accustomed to the secure desktop will recognize a spoofed elevation prompt dialog box and not fall for the trick.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_SwitchToTheSecureDesktopWhenPromptingForElevation_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_SwitchToTheSecureDesktopWhenPromptingForElevation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:PromptOnSecureDesktop
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountCo
ntrol_SwitchToTheSecureDesktopWhenProm
ptingForElevation
Data type:     Integer
Value:         1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2 This recommendation can also be set using the *Endpoint protection* profile using *Local device security options/User account control* settings.

Default Value:

Enabled. (All elevation requests go to the secure desktop regardless of prompt behavior policy settings for administrators and standard users.)

2.3.17.8 (L1) Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether application write failures are redirected to defined registry and file system locations. This policy setting mitigates applications that run as administrator and write run-time application data to:

- %ProgramFiles%
- %windir%
- %windir%\System32
- HKEY_LOCAL_MACHINE\SOFTWARE

The recommended state for this setting is: Enabled.

Rationale:

This setting reduces vulnerabilities by ensuring that legacy applications only write data to permitted locations.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LocalPoliciesSecurityOptions\UserAccountControl_VirtualizeFileAndRegistryWriteFailuresToPerUserLocations_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\LocalPoliciesSecurityOptions\UserAccountControl_VirtualizeFileAndRegistryWriteFailuresToPerUserLocations
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Endpoint protection/Local device security options/User account control
Setting Name:  Virtualize file and registry write failures to per-user locations
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:        ./Device/Vendor/MSFT/Policy/Config/LocalPoliciesSecurityOptions/UserAccountControl_VirtualizeFileAndRegistryWriteFailuresToPerUserLocations
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Default Value:

Enabled. (Application write failures are redirected at run time to defined user locations for both the file system and registry.)

3 Event Log

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

4 Restricted Groups

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

5 System Services

This section contains recommendations for system services.

5.1 (L1) Ensure 'Xbox Accessory Management Service (XboxGipSvc)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This service manages connected Xbox Accessories.

The recommended state for this setting is: `Disabled`.

Rationale:

Xbox Live is a gaming service and has no place in an enterprise managed environment (perhaps unless it is a gaming company).

Impact:

Connected Xbox accessories may not function.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\SystemServices:ConfigureXboxAccessoryManagementServiceStartupMode_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 4.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\SystemServices:ConfigureXboxAccessoryManagementServiceStartupMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Xbox services
Setting Name:	Xbox Accessory Management Service
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 10 R1703: Manual

Windows 10 R1709 and newer: Manual (Trigger Start)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

5.2 (L1) Ensure 'Xbox Live Auth Manager (XblAuthManager)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Provides authentication and authorization services for interacting with Xbox Live.

The recommended state for this setting is: `Disabled`.

Rationale:

Xbox Live is a gaming service and has no place in an enterprise managed environment (perhaps unless it is a gaming company).

Impact:

Connections to Xbox Live may fail and applications that interact with that service may also fail.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\SystemServices:ConfigureXboxLiveAuthManagerServiceStartupMode_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 4.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\SystemServices:ConfigureXboxLiveAuthManagerServiceStartupMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Xbox services
Setting Name:	Xbox Live Auth Manager Service
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Manual

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

5.3 (L1) Ensure 'Xbox Live Game Save (XblGameSave)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This service syncs save data for Xbox Live save enabled games.

The recommended state for this setting is: `Disabled`.

Rationale:

Xbox Live is a gaming service and has no place in an enterprise managed environment (perhaps unless it is a gaming company).

Impact:

Game save data will not upload to or download from Xbox Live.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\SystemServices:ConfigureXboxLiveGameSaveServiceStartupMode_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 4.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\SystemServices:ConfigureXboxLiveGameSaveServiceStartupMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Xbox services
Setting Name:	Xbox Live Game Save Service
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 10 R1507 and R1511: Manual

Windows 10 R1607 and newer: Manual (Trigger Start)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

5.4 (L1) Ensure 'Xbox Live Networking Service (XboxNetApiSvc)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This service supports the Windows.Networking.XboxLive application programming interface.

The recommended state for this setting is: `Disabled`.

Rationale:

Xbox Live is a gaming service and has no place in an enterprise managed environment (perhaps unless it is a gaming company).

Impact:

Connections to Xbox Live may fail and applications that interact with that service may also fail.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\SystemServices:ConfigureXboxLiveNetworkingServiceStartupMode_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `4`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\device\SystemServices:ConfigureXboxLiveNetworkingServiceStartupMode
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Xbox services
Setting Name:	Xbox Live Netowrking Service
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Manual

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

6 Registry

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

7 File System

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

8 Wired Network (IEEE 802.3) Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

9 Windows Firewall with Advanced Security

This section contains recommendations for configuring the Windows Firewall.

9.1 Domain Profile

This section contains recommendations for the Domain Profile of the Windows Firewall.

9.1.1 (L1) Ensure 'Windows Firewall: Domain: Firewall state' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

The recommended state for this setting is: `Enabled`.

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\DomainProfile:EnableFirewall
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Endpoint protection/Microsoft Defender Firewall/Domain  
(workplace) network  
Setting Name:  Microsoft Defender Firewall  
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

On (recommended). (The Windows Firewall with Advanced Security will be active in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.5 Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	<u>9.4 Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			

9.1.2 (L1) Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

The recommended state for this setting is: `Block`.

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\DomainProfile:DefaultInboundAction
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Block**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Endpoint protection/Microsoft Defender Firewall/Domain (workplace) network
Setting Name: Default action for inbound connections
Configuration: Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Block (default). (The Windows Firewall with Advanced Security will block all inbound connections that do not match an inbound firewall rule in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.1.3 (L1) Ensure 'Windows Firewall: Domain: Outbound connections' is set to 'Allow' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule.

The recommended state for this setting is: `Allow`.

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\DomainProfile:DefaultOutboundAction
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Allow`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Endpoint protection/Microsoft Defender Firewall/Domain (workplace) network
Setting Name: Default action for outbound connections
Configuration: Allow

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Allow (default). (The Windows Firewall with Advanced Security will allow all outbound connections in this profile unless there is a firewall rule explicitly blocking it.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.1.4 (L1) Ensure 'Windows Firewall: Domain: Settings: Display a notification' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

The recommended state for this setting is: `Block`.

Rationale:

Firewall notifications can be complex and may confuse the end users, who would not be able to address the alert.

Impact:

Windows Firewall will not display a notification when a program is blocked from receiving inbound connections.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\DomainProfile:DisableNotifications
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Endpoint protection/Microsoft Defender Firewall/Domain (workplace) network Setting Name: Inbound notifications Configuration: Block
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Yes. (Windows Firewall with Advanced Security will display a notification when a program is blocked from receiving inbound connections.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.2 Private Profile

This section contains recommendations for the Private Profile of the Windows Firewall.

9.2.1 (L1) Ensure 'Windows Firewall: Private: Firewall state' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

The recommended state for this setting is: `Enabled`.

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:EnableFirewall
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Endpoint protection/Microsoft Defender Firewall/Private
(discoverable) network
Setting Name: Microsoft Defender Firewall
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

On (recommended). (The Windows Firewall with Advanced Security will be active in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			

9.2.2 (L1) Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

The recommended state for this setting is: `Block`.

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\PublicProfile:DefaultInboundAction
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Private (discoverable) network
Setting Name:	Default action for inbound connections
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Block (default). (The Windows Firewall with Advanced Security will block all inbound connections that do not match an inbound firewall rule in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.2.3 (L1) Ensure 'Windows Firewall: Private: Outbound connections' is set to 'Allow' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule.

The recommended state for this setting is: `Allow`.

Note: If you set Outbound connections to Block and then deploy the firewall policy by using a GPO, computers that receive the GPO settings cannot receive subsequent Group Policy updates unless you create and deploy an outbound rule that enables Group Policy to work. Predefined rules for Core Networking include outbound rules that enable Group Policy to work. Ensure that these outbound rules are active, and thoroughly test firewall profiles before deploying.

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\PublicProfile:DefaultOutboundAction
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Allow`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Private (discoverable) network
Setting Name:	Default action for outbound connections
Configuration:	Allow

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Allow (default). (The Windows Firewall with Advanced Security will allow all outbound connections in this profile unless there is a firewall rule explicitly blocking it.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.2.4 (L1) Ensure 'Windows Firewall: Private: Settings: Display a notification' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

The recommended state for this setting is: `Block`.

Rationale:

Firewall notifications can be complex and may confuse the end users, who would not be able to address the alert.

Impact:

Windows Firewall will not display a notification when a program is blocked from receiving inbound connections.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\PublicProfile:DisableNotifications
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Private (discoverable) network
Setting Name:	Inbound notifications
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Yes. (Windows Firewall with Advanced Security will display a notification when a program is blocked from receiving inbound connections.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.3 Public Profile

This section contains recommendations for the Public Profile of the Windows Firewall.

9.3.1 (L1) Ensure 'Windows Firewall: Public: Firewall state' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select On (recommended) to have Windows Firewall with Advanced Security use the settings for this profile to filter network traffic. If you select Off, Windows Firewall with Advanced Security will not use any of the firewall rules or connection security rules for this profile.

The recommended state for this setting is: *Enabled*.

Rationale:

If the firewall is turned off all traffic will be able to access the system and an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:EnableFirewall
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Public (non-discoverable) network
Setting Name:	Microsoft Defender Firewall
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

On (recommended). (The Windows Firewall with Advanced Security will be active in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.5 Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	<u>9.4 Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			

9.3.2 (L1) Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for inbound connections that do not match an inbound firewall rule.

The recommended state for this setting is: `Block`.

Rationale:

If the firewall allows all traffic to access the system then an attacker may be more easily able to remotely exploit a weakness in a network service.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:DefaultInboundAction
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Public (non-discoverable) network
Setting Name:	Default action for inbound connections
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Block (default). (The Windows Firewall with Advanced Security will block all inbound connections that do not match an inbound firewall rule in this profile.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.3.3 (L1) Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Allow' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines the behavior for outbound connections that do not match an outbound firewall rule.

The recommended state for this setting is: `Allow`.

Note: If you set Outbound connections to Block and then deploy the firewall policy by using a GPO, computers that receive the GPO settings cannot receive subsequent Group Policy updates unless you create and deploy an outbound rule that enables Group Policy to work. Predefined rules for Core Networking include outbound rules that enable Group Policy to work. Ensure that these outbound rules are active, and thoroughly test firewall profiles before deploying.

Rationale:

Some people believe that it is prudent to block all outbound connections except those specifically approved by the user or administrator. Microsoft disagrees with this opinion, blocking outbound connections by default will force users to deal with a large number of dialog boxes prompting them to authorize or block applications such as their web browser or instant messaging software. Additionally, blocking outbound traffic has little value because if an attacker has compromised the system they can reconfigure the firewall anyway.

Impact:

None - this is the default behavior.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:DefaultOutboundAction
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Allow`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Public (non-discoverable) network
Setting Name:	Default action for outbound connections
Configuration:	Allow

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Allow (default). (The Windows Firewall with Advanced Security will allow all outbound connections in this profile unless there is a firewall rule explicitly blocking it.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.3.4 (L1) Ensure 'Windows Firewall: Public: Settings: Display a notification' is set to 'Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Select this option to have Windows Firewall with Advanced Security display notifications to the user when a program is blocked from receiving inbound connections.

The recommended state for this setting is: `Block`.

Rationale:

Some organizations may prefer to avoid alarming users when firewall rules block certain types of network activity. However, notifications can be helpful when troubleshooting network issues involving the firewall.

Impact:

Windows Firewall will not display a notification when a program is blocked from receiving inbound connections.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:DisableNotifications
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Public (non-discoverable) network
Setting Name:	Inbound notifications
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Yes. (Windows Firewall with Advanced Security will display a notification when a program is blocked from receiving inbound connections.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

9.3.5 (L1) Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting controls whether local administrators are allowed to create connection security rules that apply together with connection security rules configured by Group Policy.

The recommended state for this setting is: `No`.

Rationale:

Users with administrative privileges might create firewall rules that expose the system to remote attack.

Impact:

Administrators can still create local connection security rules, but the rules will not be applied.

Audit:

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `1`.

```
HKEY_LOCAL_MACHINE\SYSTEM\ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\Mdm\StandardProfile:AllowLocalIpsecPolicyMerge
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Firewall/Public (non-discoverable) network
Setting Name:	Microsoft Defender Firewall rules from the local store
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Yes (default). (Local connection security rules created by administrators will be applied.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/firewall-csp#mdmstoredomainprofileallowlocalipsecpolicymerge>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.5 <u>Implement and Manage a Firewall on End-User Devices</u> Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	9.4 <u>Apply Host-based Firewalls or Port Filtering</u> Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.			
v7	11.2 <u>Document Traffic Configuration Rules</u> All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.			

10 Network List Manager Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

11 Wireless Network (IEEE 802.11) Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

12 Public Key Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

13 Software Restriction Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

14 Network Access Protection NAP Client Configuration

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

15 Application Control Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

16 IP Security Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

17 Advanced Audit Policy Configuration

This section contains recommendations for configuring the Windows audit facilities.

17.1 Account Logon

This section contains recommendations for configuring the Account Logon audit policy.

17.1.1 (L1) Ensure 'Audit Credential Validation' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports the results of validation tests on credentials submitted for a user account logon request. These events occur on the computer that is authoritative for the credentials. For domain accounts, the Domain Controller is authoritative, whereas for local accounts, the local computer is authoritative. In domain environments, most of the Account Logon events occur in the Security log of the Domain Controllers that are authoritative for the domain accounts. However, these events can occur on other computers in the organization when local accounts are used to log on. Events for this subcategory include:

- 4774: An account was mapped for logon.
- 4775: An account could not be mapped for logon.
- 4776: The Domain Controller attempted to validate the credentials for an account.
- 4777: The Domain Controller failed to validate the credentials for an account.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogon_AuditCredentialValidation_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogon_AuditCredentialValidation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogon_AuditCredentialValidati
on
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Audit Credential Validation
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.2 Account Management

This section contains recommendations for configuring the Account Management audit policy.

17.2.1 (L1) Ensure 'Audit Application Group Management' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to audit events generated by changes to application groups such as the following:

- Application group is created, changed, or deleted.
- Member is added or removed from an application group.

Application groups are utilized by Windows Authorization Manager, which is a flexible framework created by Microsoft for integrating role-based access control (RBAC) into applications. More information on Windows Authorization Manager is available at [MSDN - Windows Authorization Manager](#).

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing events in this category may be useful when investigating an incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountManagement_AuditApplicationGroupManagement_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountManagement_AuditApplicationGroupManagement
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountManagement_AuditApplicationGroupManagement
Data type:    Integer
Value:       3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Management Audit Application Group Management
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.2.2 (L1) Ensure 'Audit Security Group Management' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports each event of security group management, such as when a security group is created, changed, or deleted or when a member is added to or removed from a security group. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of security group accounts. Events for this subcategory include:

- 4727: A security-enabled global group was created.
- 4728: A member was added to a security-enabled global group.
- 4729: A member was removed from a security-enabled global group.
- 4730: A security-enabled global group was deleted.
- 4731: A security-enabled local group was created.
- 4732: A member was added to a security-enabled local group.
- 4733: A member was removed from a security-enabled local group.
- 4734: A security-enabled local group was deleted.
- 4735: A security-enabled local group was changed.
- 4737: A security-enabled global group was changed.
- 4754: A security-enabled universal group was created.
- 4755: A security-enabled universal group was changed.
- 4756: A member was added to a security-enabled universal group.
- 4757: A member was removed from a security-enabled universal group.
- 4758: A security-enabled universal group was deleted.
- 4764: A group's type was changed.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountManagement_AuditSecurityGroupManagement_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountManagement_AuditSecurityGroupManagement
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountManagement_AuditSecurityGroup
Management
Data type:     Integer
Value:         1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Audit Security Group Management
Configuration:  Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.6 <u>Maintain an Inventory of Accounts</u> Maintain an inventory of all accounts organized by authentication system.			

17.2.3 (L1) Ensure 'Audit User Account Management' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports each event of user account management, such as when a user account is created, changed, or deleted; a user account is renamed, disabled, or enabled; or a password is set or changed. If you enable this Audit policy setting, administrators can track events to detect malicious, accidental, and authorized creation of user accounts. Events for this subcategory include:

- 4720: A user account was created.
- 4722: A user account was enabled.
- 4723: An attempt was made to change an account's password.
- 4724: An attempt was made to reset an account's password.
- 4725: A user account was disabled.
- 4726: A user account was deleted.
- 4738: A user account was changed.
- 4740: A user account was locked out.
- 4765: SID History was added to an account.
- 4766: An attempt to add SID History to an account failed.
- 4767: A user account was unlocked.
- 4780: The ACL was set on accounts which are members of administrators groups.
- 4781: The name of an account was changed:
- 4794: An attempt was made to set the Directory Services Restore Mode.
- 5376: Credential Manager credentials were backed up.
- 5377: Credential Manager credentials were restored from a backup.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountManagement_AuditUserAccountManagement_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountManagement_AuditUserAccountManagement
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountManagement_AuditUserAccountMa
nagement
Data type:     Integer
Value:         3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Audit User Account Management
Configuration:  Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.3 Detailed Tracking

This section contains recommendations for configuring the Detailed Tracking audit policy.

17.3.1 (L1) Ensure 'Audit PNP Activity' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to audit when plug and play detects an external device.

The recommended state for this setting is to include: `Success`.

Note: A Windows 10, Server 2016 or newer OS is required to access and set this value in Group Policy.

Rationale:

Enabling this setting will allow a user to audit events when a device is plugged into a system. This can help alert IT staff if unapproved devices are plugged in.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:DetailedTracking_AuditPNPActivity_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:DetailedTracking_AuditPNPActivity
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/DetailedTracking_AuditPNPActivity
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Detailed Tracking Audit PNP Activity
Configuration: Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.3.2 (L1) Ensure 'Audit Process Creation' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports the creation of a process and the name of the program or user that created it. Events for this subcategory include:

- 4688: A new process has been created.
- 4696: A primary token was assigned to process.

Refer to Microsoft Knowledge Base article 947226: [Description of security events in Windows Vista and in Windows Server 2008](#) for the most recent information about this setting.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:DetailedTracking_AuditProcessCreation_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:DetailedTracking_AuditProcessCreation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/DetailedTracking_AuditProcessCreatio
n
Data type:    Integer
Value:       1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Detailed Tracking Audit Process Creation
Configuration:  Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*. 17.3.2 (L1) Ensure 'Audit Process Creation' is set to include 'Success'

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.4 DS Access

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

17.5 Logon/Logoff

This section contains recommendations for configuring the Logon/Logoff audit policy.

17.5.1 (L1) Ensure 'Audit Account Lockout' is set to include 'Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports when a user's account is locked out as a result of too many failed logon attempts. Events for this subcategory include:

- 4625: An account failed to log on.

The recommended state for this setting is to include: `Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditAccountLockout_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditAccountLockout
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditAccountLockout
Data type:    Integer
Value:        2
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Logoff Audit Account Lockout
Configuration:  Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.6 <u>Maintain an Inventory of Accounts</u> Maintain an inventory of all accounts organized by authentication system.			

17.5.2 (L1) Ensure 'Audit Group Membership' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy allows you to audit the group membership information in the user's logon token. Events in this subcategory are generated on the computer on which a logon session is created. For an interactive logon, the security audit event is generated on the computer that the user logged on to. For a network logon, such as accessing a shared folder on the network, the security audit event is generated on the computer hosting the resource.

The recommended state for this setting is to include: `Success`.

Note: A Windows 10, Server 2016 or newer OS is required to access and set this value in Group Policy.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditGroupMembership_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditGroupMembership
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditGroupMembers
hip
Data type:     Integer
Value:         1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Logoff Audit Group Membership
Configuration:  Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.8 <u>Log and Alert on Changes to Administrative Group Membership</u> Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●
v7	16.6 <u>Maintain an Inventory of Accounts</u> Maintain an inventory of all accounts organized by authentication system.		●	●

17.5.3 (L1) Ensure 'Audit Logoff' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports when a user logs off from the system. These events occur on the accessed computer. For interactive logons, the generation of these events occurs on the computer that is logged on to. If a network logon takes place to access a share, these events generate on the computer that hosts the accessed resource. If you configure this setting to No auditing, it is difficult or impossible to determine which user has accessed or attempted to access organization computers. Events for this subcategory include:

- 4634: An account was logged off.
- 4647: User initiated logoff.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditLogoff_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditLogoff
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditLogoff
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Logoff Audit Logoff
Configuration: Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.13 <u>Alert on Account Login Behavior Deviation</u> Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

17.5.4 (L1) Ensure 'Audit Logon' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports when a user attempts to log on to the system. These events occur on the accessed computer. For interactive logons, the generation of these events occurs on the computer that is logged on to. If a network logon takes place to access a share, these events generate on the computer that hosts the accessed resource. If you configure this setting to No auditing, it is difficult or impossible to determine which user has accessed or attempted to access organization computers. Events for this subcategory include:

- 4624: An account was successfully logged on.
- 4625: An account failed to log on.
- 4648: A logon was attempted using explicit credentials.
- 4675: SIDs were filtered.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditLogon_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditLogon
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditLogon
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Logoff Audit Logon
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.13 <u>Alert on Account Login Behavior Deviation</u> Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

17.5.5 (L1) Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports other logon/logoff-related events, such as Remote Desktop Services session disconnects and reconnects, using RunAs to run processes under a different account, and locking and unlocking a workstation. Events for this subcategory include:

- 4649: A replay attack was detected.
- 4778: A session was reconnected to a Window Station.
- 4779: A session was disconnected from a Window Station.
- 4800: The workstation was locked.
- 4801: The workstation was unlocked.
- 4802: The screen saver was invoked.
- 4803: The screen saver was dismissed.
- 5378: The requested credentials delegation was disallowed by policy.
- 5632: A request was made to authenticate to a wireless network.
- 5633: A request was made to authenticate to a wired network.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditOtherLogonLogoffEvents_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditOtherLogonLogoffEvents
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditOtherLogonLogoffEvents
Data type:     Integer
Value:         3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Account Logon Audit Other Account Logon Events
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.13 <u>Alert on Account Login Behavior Deviation</u> Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

17.5.6 (L1) Ensure 'Audit Special Logon' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports when a special logon is used. A special logon is a logon that has administrator-equivalent privileges and can be used to elevate a process to a higher level. Events for this subcategory include:

- 4964 : Special groups have been assigned to a new logon.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:AccountLogonLogoff_AuditSpecialLogon_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:AccountLogonLogoff_AuditSpecialLogon
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Success*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/AccountLogonLogoff_AuditSpecialLogon
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Audit Special Logon
Configuration:  Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	16.13 <u>Alert on Account Login Behavior Deviation</u> Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			

17.6 Object Access

This section contains recommendations for configuring the Object Access audit policy.

17.6.1 (L1) Ensure 'Audit Detailed File Share' is set to include 'Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory allows you to audit attempts to access files and folders on a shared folder. Events for this subcategory include:

- 5145: network share object was checked to see whether client can be granted desired access.

The recommended state for this setting is to include: `Failure`

Rationale:

Auditing the Failures will log which unauthorized users attempted (and failed) to get access to a file or folder on a network share on this computer, which could possibly be an indication of malicious intent.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:ObjectAccess_AuditDetailedFileShare_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:ObjectAccess_AuditDetailedFileShare
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/ObjectAccess_AuditDetailedFileShare
Data type:    Integer
Value:        2
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Object Access Audit Detailed File Share
Configuration: Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

17.6.2 (L1) Ensure 'Audit File Share' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to audit attempts to access a shared folder.

The recommended state for this setting is: `Success and Failure`.

Note: There are no system access control lists (SACLs) for shared folders. If this policy setting is enabled, access to all shared folders on the system is audited.

Rationale:

In an enterprise managed environment, workstations should have limited file sharing activity, as file servers would normally handle the overall burden of file sharing activities. Any unusual file sharing activity on workstations may therefore be useful in an investigation of potentially malicious activity.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:ObjectAccess_AuditFileShare_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:ObjectAccess_AuditFileShare
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/ObjectAccess_AuditFileShare
Data type:     Integer
Value:         3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Audit File Share Access
Configuration:  Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

17.6.3 (L1) Ensure 'Audit Other Object Access Events' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to audit events generated by the management of task scheduler jobs or COM+ objects.

For scheduler jobs, the following are audited:

- Job created.
- Job deleted.
- Job enabled.
- Job disabled.
- Job updated.

For COM+ objects, the following are audited:

- Catalog object added.
- Catalog object updated.
- Catalog object deleted.

The recommended state for this setting is: `Success and Failure`.

Rationale:

The unexpected creation of scheduled tasks and COM+ objects could potentially be an indication of malicious activity. Since these types of actions are generally low volume, it may be useful to capture them in the audit logs for use during an investigation.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:ObjectAccess_AuditOtherObjectAccessEvents_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:ObjectAccess_AuditOtherObjectAccessEvents
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/ObjectAccess_AuditOtherObjectAccessE
vents
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Object Access Audit Other Object Access Events
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.6.4 (L1) Ensure 'Audit Removable Storage' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to audit user attempts to access file system objects on a removable storage device. A security audit event is generated only for all objects for all types of access requested. If you configure this policy setting, an audit event is generated each time an account accesses a file system object on a removable storage. Success audits record successful attempts and Failure audits record unsuccessful attempts. If you do not configure this policy setting, no audit event is generated when an account accesses a file system object on a removable storage.

The recommended state for this setting is: `Success and Failure`.

Note: A Windows 8.0, Server 2012 (non-R2) or newer OS is required to access and set this value in Group Policy.

Rationale:

Auditing removable storage may be useful when investigating an incident. For example, if an individual is suspected of copying sensitive information onto a USB drive.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:ObjectAccess_AuditRemovableStorage_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:ObjectAccess_AuditRemovableStorage
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/ObjectAccess_AuditRemovableStorage
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Object Access Audit Removable Storage
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.7 Policy Change

This section contains recommendations for configuring the Policy Change audit policy.

17.7.1 (L1) Ensure 'Audit Audit Policy Change' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports changes in audit policy including SACL changes. Events for this subcategory include:

- 4715: The audit policy (SACL) on an object was changed.
- 4719: System audit policy was changed.
- 4902: The Per-user audit policy table was created.
- 4904: An attempt was made to register a security event source.
- 4905: An attempt was made to unregister a security event source.
- 4906: The CrashOnAuditFail value has changed.
- 4907: Auditing settings on object were changed.
- 4908: Special Groups Logon table modified.
- 4912: Per User Audit Policy was changed.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PolicyChange_AuditPolicyChange_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PolicyChange_AuditPolicyChange
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Success**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PolicyChange_AuditPolicyChange
Data type:    Integer
Value:       1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	5.5 <u>Implement Automated Configuration Monitoring Systems</u> Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.7.2 (L1) Ensure 'Audit Authentication Policy Change' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports changes in authentication policy. Events for this subcategory include:

- 4706: A new trust was created to a domain.
- 4707: A trust to a domain was removed.
- 4713: Kerberos policy was changed.
- 4716: Trusted domain information was modified.
- 4717: System security access was granted to an account.
- 4718: System security access was removed from an account.
- 4739: Domain Policy was changed.
- 4864: A namespace collision was detected.
- 4865: A trusted forest information entry was added.
- 4866: A trusted forest information entry was removed.
- 4867: A trusted forest information entry was modified.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PolicyChange_AuditAuthenticationPolicyChange_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PolicyChange_AuditAuthenticationPolicyChange
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Success*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PolicyChange_AuditAuthenticationPolicyChange
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Audit Authentication Policy Change
Configuration:  Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>8.5 Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	<u>5.5 Implement Automated Configuration Monitoring Systems</u> Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.			
v7	<u>6.3 Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.7.3 (L1) Ensure 'Audit Authorization Policy Change' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports changes in authorization policy. Events for this subcategory include:

- 4704: A user right was assigned.
- 4705: A user right was removed.
- 4706: A new trust was created to a domain.
- 4707: A trust to a domain was removed.
- 4714: Encrypted data recovery policy was changed.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PolicyChange_AuditAuthorizationPolicyChange_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PolicyChange_AuditAuthorizationPolicyChange
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Success*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PolicyChange_AuditAuthorizationPolicyChange
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:  Audit Authorization Policy Change
Configuration: Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	5.5 <u>Implement Automated Configuration Monitoring Systems</u> Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.7.4 (L1) Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory determines whether the operating system generates audit events when changes are made to policy rules for the Microsoft Protection Service (MPSSVC.exe). Events for this subcategory include:

- 4944: The following policy was active when the Windows Firewall started.
- 4945: A rule was listed when the Windows Firewall started.
- 4946: A change has been made to Windows Firewall exception list. A rule was added.
- 4947: A change has been made to Windows Firewall exception list. A rule was modified.
- 4948: A change has been made to Windows Firewall exception list. A rule was deleted.
- 4949: Windows Firewall settings were restored to the default values.
- 4950: A Windows Firewall setting has changed.
- 4951: A rule has been ignored because its major version number was not recognized by Windows Firewall.
- 4952: Parts of a rule have been ignored because its minor version number was not recognized by Windows Firewall. The other parts of the rule will be enforced.
- 4953: A rule has been ignored by Windows Firewall because it could not parse the rule.
- 4954: Windows Firewall Group Policy settings have changed. The new settings have been applied.
- 4956: Windows Firewall has changed the active profile.
- 4957: Windows Firewall did not apply the following rule.
- 4958: Windows Firewall did not apply the following rule because the rule referred to items not configured on this computer.

The recommended state for this setting is : `Success and Failure`

Rationale:

Changes to firewall rules are important for understanding the security state of the computer and how well it is protected against network attacks.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PolicyChange_AuditMPSSVCRuleLevelPolicyChange_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PolicyChange_AuditMPSSVCRuleLevelPolicyChange
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PolicyChange_AuditMPSSVCRuleLevelPolicyChange
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	5.5 <u>Implement Automated Configuration Monitoring Systems</u> Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.7.5 (L1) Ensure 'Audit Other Policy Change Events' is set to include 'Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory contains events about EFS Data Recovery Agent policy changes, changes in Windows Filtering Platform filter, status on Security policy settings updates for local Group Policy settings, Central Access Policy changes, and detailed troubleshooting events for Cryptographic Next Generation (CNG) operations.

- 5063: A cryptographic provider operation was attempted.
- 5064: A cryptographic context operation was attempted.
- 5065: A cryptographic context modification was attempted.
- 5066: A cryptographic function operation was attempted.
- 5067: A cryptographic function modification was attempted.
- 5068: A cryptographic function provider operation was attempted.
- 5069: A cryptographic function property operation was attempted.
- 5070: A cryptographic function property modification was attempted.
- 6145: One or more errors occurred while processing security policy in the group policy objects.

The recommended state for this setting is to include: `Failure`.

Rationale:

This setting can help detect errors in applied Security settings which came from Group Policy, and failure events related to Cryptographic Next Generation (CNG) functions.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PolicyChange_AuditOtherPolicyChangeEvents_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PolicyChange_AuditOtherPolicyChangeEvents
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PolicyChange_AuditOtherPolicyChangeE
vents
Data type:    Integer
Value:        2
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Policy Change Audit Other Policy Change Events
Configuration: Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	5.5 <u>Implement Automated Configuration Monitoring Systems</u> Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.8 Privilege Use

This section contains recommendations for configuring the Privilege Use audit policy.

17.8.1 (L1) Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports when a user account or service uses a sensitive privilege. A sensitive privilege includes the following user rights:

- Act as part of the operating system
- Back up files and directories
- Create a token object
- Debug programs
- Enable computer and user accounts to be trusted for delegation
- Generate security audits
- Impersonate a client after authentication
- Load and unload device drivers
- Manage auditing and security log
- Modify firmware environment values
- Replace a process-level token
- Restore files and directories
- Take ownership of files or other objects

Auditing this subcategory will create a high volume of events. Events for this subcategory include:

- 4672: Special privileges assigned to new logon.
- 4673: A privileged service was called.
- 4674: An operation was attempted on a privileged object.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:PrivilegeUse_AuditSensitivePrivilegeUse_ProviderSet
```

****To confirm that the policy was properly applied to the system, check one of the following locations:**** Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:PrivilegeUse_AuditSensitivePrivilegeUse
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name> ex: 17.9.1 (L1) Ensure 'Audit IPsec Driver' is set
to 'Success and Failure'
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/PrivilegeUse_AuditSensitivePrivilege
Use
Data type:     Integer
Value:         3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   Privilege Use Audit Sensitive Privilege Use
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.9 System

This section contains recommendations for configuring the System audit policy.

17.9.1 (L1) Ensure 'Audit IPsec Driver' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports on the activities of the Internet Protocol security (IPsec) driver. Events for this subcategory include:

- 4960: IPsec dropped an inbound packet that failed an integrity check. If this problem persists, it could indicate a network issue or that packets are being modified in transit to this computer. Verify that the packets sent from the remote computer are the same as those received by this computer. This error might also indicate interoperability problems with other IPsec implementations.
- 4961: IPsec dropped an inbound packet that failed a replay check. If this problem persists, it could indicate a replay attack against this computer.
- 4962: IPsec dropped an inbound packet that failed a replay check. The inbound packet had too low a sequence number to ensure it was not a replay.
- 4963: IPsec dropped an inbound clear text packet that should have been secured. This is usually due to the remote computer changing its IPsec policy without informing this computer. This could also be a spoofing attack attempt.
- 4965: IPsec received a packet from a remote computer with an incorrect Security Parameter Index (SPI). This is usually caused by malfunctioning hardware that is corrupting packets. If these errors persist, verify that the packets sent from the remote computer are the same as those received by this computer. This error may also indicate interoperability problems with other IPsec implementations. In that case, if connectivity is not impeded, then these events can be ignored.
- 5478: IPsec Services has started successfully.
- 5479: IPsec Services has been shut down successfully. The shutdown of IPsec Services can put the computer at greater risk of network attack or expose the computer to potential security risks.
- 5480: IPsec Services failed to get the complete list of network interfaces on the computer. This poses a potential security risk because some of the network interfaces may not get the protection provided by the applied IPsec filters. Use the IP Security Monitor snap-in to diagnose the problem.
- 5483: IPsec Services failed to initialize RPC server. IPsec Services could not be started.

- 5484: IPsec Services has experienced a critical failure and has been shut down. The shutdown of IPsec Services can put the computer at greater risk of network attack or expose the computer to potential security risks.
- 5485: IPsec Services failed to process some IPsec filters on a plug-and-play event for network interfaces. This poses a potential security risk because some of the network interfaces may not get the protection provided by the applied IPsec filters. Use the IP Security Monitor snap-in to diagnose the problem.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit\System_AuditIPsecDriver_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit\System_AuditIPsecDriver
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Audit/System_AuditIPsecDriver
Data type:	Integer
Value:	3

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

Path:	Auditing
Setting Name:	System Audit I Psec Driver
Configuration:	Success+ Failure

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.9.2 (L1) Ensure 'Audit Other System Events' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports on other system events. Events for this subcategory include:

- 5024 : The Windows Firewall Service has started successfully.
- 5025 : The Windows Firewall Service has been stopped.
- 5027 : The Windows Firewall Service was unable to retrieve the security policy from the local storage. The service will continue enforcing the current policy.
- 5028 : The Windows Firewall Service was unable to parse the new security policy. The service will continue with currently enforced policy.
- 5029: The Windows Firewall Service failed to initialize the driver. The service will continue to enforce the current policy.
- 5030: The Windows Firewall Service failed to start.
- 5032: Windows Firewall was unable to notify the user that it blocked an application from accepting incoming connections on the network.
- 5033 : The Windows Firewall Driver has started successfully.
- 5034 : The Windows Firewall Driver has been stopped.
- 5035 : The Windows Firewall Driver failed to start.
- 5037 : The Windows Firewall Driver detected critical runtime error. Terminating.
- 5058: Key file operation.
- 5059: Key migration operation.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Capturing these audit events may be useful for identifying when the Windows Firewall is not performing as expected.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit\System_AuditOtherSystemEvents_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit\System_AuditOtherSystemEvents
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Audit/System_AuditOtherSystemEvents
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   System Audit Other System Events
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success and Failure.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.9.3 (L1) Ensure 'Audit Security State Change' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports changes in security state of the system, such as when the security subsystem starts and stops. Events for this subcategory include:

- 4608: Windows is starting up.
- 4609: Windows is shutting down.
- 4616: The system time was changed.
- 4621: Administrator recovered system from CrashOnAuditFail. Users who are not administrators will now be allowed to log on. Some audit-able activity might not have been recorded.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:System_AuditSecuritySystemExtension_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:System_AuditSecuritySystemExtension
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/System_AuditSecurityStateChange
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   System Audit Security State Change
Configuration: Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.9.4 (L1) Ensure 'Audit Security System Extension' is set to include 'Success' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports the loading of extension code such as authentication packages by the security subsystem. Events for this subcategory include:

- 4610: An authentication package has been loaded by the Local Security Authority.
- 4611: A trusted logon process has been registered with the Local Security Authority.
- 4614: A notification package has been loaded by the Security Account Manager.
- 4622: A security package has been loaded by the Local Security Authority.
- 4697: A service was installed in the system.

The recommended state for this setting is to include: `Success`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit:System_AuditSecuritySystemExtension_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit:System_AuditSecuritySystemExtension
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to include *Success*.

- *Open* an elevated command prompt (as Administrator)
- *Run* AuditPol.exe /get /category:*
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to include `Success`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/System_AuditSecuritySystemExtension
Data type:    Integer
Value:        1
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:  Audit Security System Extension
Configuration: Success
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No Auditing.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

17.9.5 (L1) Ensure 'Audit System Integrity' is set to 'Success and Failure' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This subcategory reports on violations of integrity of the security subsystem. Events for this subcategory include:

- 4612 : Internal resources allocated for the queuing of audit messages have been exhausted, leading to the loss of some audits.
- 4615 : Invalid use of LPC port.
- 4618 : A monitored security event pattern has occurred.
- 4816 : RPC detected an integrity violation while decrypting an incoming message.
- 5038 : Code integrity determined that the image hash of a file is not valid. The file could be corrupt due to unauthorized modification or the invalid hash could indicate a potential disk device error.
- 5056: A cryptographic self test was performed.
- 5057: A cryptographic primitive operation failed.
- 5060: Verification operation failed.
- 5061: Cryptographic operation.
- 5062: A kernel-mode cryptographic self test was performed.

The recommended state for this setting is: `Success and Failure`.

Rationale:

Auditing these events may be useful when investigating a security incident.

Impact:

If no audit settings are configured, or if audit settings are too lax on the computers in your organization, security incidents might not be detected or not enough evidence will be available for network forensic analysis after security incidents occur. However, if audit settings are too severe, critically important entries in the Security log may be obscured by all of the meaningless entries and computer performance and the available amount of data storage may be seriously affected. Companies that operate in certain regulated industries may have legal obligations to log certain events or activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Audit\System_AuditSystemIntegrity_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\Audit\System_AuditSystemIntegrity
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Confirm that the audit setting is set to `Success` and `Failure`.

- *Open* an elevated command prompt (as Administrator)
- *Run* `AuditPol.exe /get /category:*`
- *Find* the corresponding setting and make sure it is set as prescribed

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Success` and `Failure`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/Audit/System_AuditSystemIntegrity
Data type:    Integer
Value:        3
```

- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Settings Picker)
- Click *Create*
- Enter a *Name*
- Click *Add settings*
- Configure the following Setting:

```
Path:          Auditing
Setting Name:   System Audit System Integrity
Configuration: Success+ Failure
```

- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Success and Failure.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 <u>Collect Detailed Audit Logs</u> Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			

18 Administrative Templates (Computer)

This section contains computer-based recommendations from Group Policy Administrative Templates (ADMX).

18.1 Control Panel

This section contains recommendations for Intune Control Panel settings.

18.1.1 Personalization

This section contains recommendations for Intune Control Panel Personalization settings.

18.1.1.1 (L1) Ensure 'Prevent enabling lock screen camera' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Disables the lock screen camera toggle switch in PC Settings and prevents a camera from being invoked on the lock screen.

The recommended state for this setting is: `Enabled`.

Rationale:

Disabling the lock screen camera extends the protection afforded by the lock screen to camera features.

Impact:

If you enable this setting, users will no longer be able to enable or disable lock screen camera access in PC Settings, and the camera cannot be invoked on the lock screen.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:PreventEnablingLockScreenCamera_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
DeviceLock:PreventLockScreenCamera
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Personalization:NoLock  
ScreenCamera
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Enter a *Name*
- Configure the following *setting*

```
Computer Configuration\Control Panel\Personalization\Prevent enabling lock screen camera
```

- Select *Next*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

OR

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Enter a *Name*
- Click *Add*
- Enter the *Details* below

```
Name:          <Enter name> ex: (L1) Ensure 'Prevent enabling lock screen camera' is set to 'Enabled'
Description:   <Enter Description>
OMA-URI:      ./Device/Vendor/MSFT/Policy/Config/DeviceLock/PreventEnablingLockScreenCamera
Data type:    Integer
Value:        1
```


- Select *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can enable invocation of an available camera on the lock screen.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.1.1.2 (L1) Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Disables the lock screen slide show settings in PC Settings and prevents a slide show from playing on the lock screen.

The recommended state for this setting is: `Enabled`.

Rationale:

Disabling the lock screen slide show extends the protection afforded by the lock screen to slide show contents.

Impact:

If you enable this setting, users will no longer be able to modify slide show settings in PC Settings, and no slide show will ever start.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceLock  
:PreventLockScreenSlideShow_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
DeviceLock:PreventLockScreenSlideShow
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Personalization:NoLock  
ScreenSlideshow
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Enter a *Name*
- Configure the following *setting*

```
Computer Configuration\Control Panel\Personalization\Prevent enabling lock screen slide show
```

- Select *Next*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can enable a slide show that will run after they lock the machine.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.1.2 Regional and Language Options

This section contains recommendation settings for Regional and Language Options.

This Group Policy section is provided by the Group Policy template `Globalization.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.1.2.1 Handwriting personalization

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Globalization.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.1.2.2 (L1) Ensure 'Allow users to enable online speech recognition services' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy enables the automatic learning component of input personalization that includes speech, inking, and typing. Automatic learning enables the collection of speech and handwriting patterns, typing history, contacts, and recent calendar information. It is required for the use of Cortana. Some of this collected information may be stored on the user's OneDrive, in the case of inking and typing; some of the information will be uploaded to Microsoft to personalize speech.

The recommended state for this setting is: `Disabled`.

Rationale:

If this setting is Enabled sensitive information could be stored in the cloud or sent to Microsoft.

Impact:

Automatic learning of speech, inking, and typing stops and users cannot change its value via PC Settings.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Privacy:AllowInputPersonalization_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Privacy:AllowInputPersonalization
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Privacy/AllowInputPersonalization
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Automatic learning of speech, inking and typing is enabled, but users may change this value via PC Settings.)

18.1.3 (L2) Ensure 'Allow Online Tips' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting configures the retrieval of online tips and help for the Settings app.

The recommended state for this setting is: *Disabled*.

Rationale:

Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information.

Impact:

Settings will not contact Microsoft content services to retrieve tips and help content.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Settings:AllowOnlineTips_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Settings:AllowOnlineTips
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Settings/AllowOnlineTips
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Settings will contact Microsoft content services to retrieve tips and help content.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.2 Desktop

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Desktop.admx/adml` that is included with the Microsoft Windows 11 Release 22H2 Administrative Templates (or newer).

18.3 LAPS

This section contains recommendations for configuring Microsoft Local Administrator Password Solution (LAPS).

This Group Policy section is provided by the Group Policy template `AdmPwd.admx/adml` that is included with LAPS.

18.3.1 (L1) Ensure LAPS AdmPwd GPO Extension / CSE is installed (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

No impact. When installed and registered properly, `AdmPwd.dll` takes no action unless given appropriate GPO commands during Group Policy refresh. It is not a memory-resident agent or service.

In a disaster recovery scenario where Active Directory is not available, the local Administrator password will not be retrievable and a local password reset using a tool (such as Microsoft's Disaster and Recovery Toolset (DaRT) Recovery Image) may be necessary.

Audit:

The LAPS AdmPwd GPO Extension / CSE can be verified to be installed by the presence of the following registry value:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Winlogon\GPExtensions\{D76B9641-3288-4f75-942D-  
087DE603E3EA}:DllName
```

Remediation:

In order to utilize LAPS, a minor Active Directory Schema update is required, and a Group Policy Client Side Extension (CSE) must be installed on each managed computer. When LAPS is installed, the file `AdmPwd.dll` must be present in the following location and registered in Windows (the LAPS AdmPwd GPO Extension / CSE installation does this for you):

```
C:\Program Files\LAPS\CSE\AdmPwd.dll
```

Default Value:

Not Installed.

References:

1. <https://techcommunity.microsoft.com/t5/itops-talk-blog/step-by-step-guide-how-to-configure-microsoft-local/ba-p/2806185>
2. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.4 <u>Use Unique Passwords</u> Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			
v7	16.2 <u>Configure Centralized Point of Authentication</u> Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

18.3.2 (L1) Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

The recommended state for this setting is: `Enabled`.

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Note #3: Make sure to choose the local Administrator account that is enabled, and not the built-in disabled local Administrator account.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

Planned password expiration longer than password age dictated by "Password Settings" policy is NOT allowed.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft  
Services\AdmPwd:PwdExpirationProtectionEnabled
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\LAPS  
Setting Name: Do not allow password expiration time longer than required by  
policy  
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Password expiration time may be longer than required by the "Password Settings" policy.)

References:

1. <https://techcommunity.microsoft.com/t5/itops-talk-blog/step-by-step-guide-how-to-configure-microsoft-local/ba-p/2806185>
2. <https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/local-administrator-password-solution-laps-implementation-hints/ba-p/258296>
3. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.10 <u>Ensure All Accounts Have An Expiration Date</u> Ensure that all accounts have an expiration date that is monitored and enforced.		●	●

18.3.3 (L1) Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

The recommended state for this setting is: `Enabled`.

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Note #3: Make sure to choose the local Administrator account that is enabled, and not the built-in disabled local Administrator account.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

The local administrator password is managed (provided that the LAPS AdmPwd GPO Extension / CSE is installed on the target computer (see recommendation *Ensure LAPS AdmPwd GPO Extension / CSE is installed*), the Active Directory domain schema and account permissions have been properly configured on the domain).

In a disaster recovery scenario where Active Directory is not available, the local Administrator password will not be retrievable and a local password reset using a tool (such as Microsoft's Disaster and Recovery Toolset (DaRT) Recovery Image) may be necessary.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd:AdmPwdEnabled
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\LAPS
Setting Name: Enable Local Admin Password Management
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Local Administrator password is NOT managed.)

References:

1. <https://techcommunity.microsoft.com/t5/itops-talk-blog/step-by-step-guide-how-to-configure-microsoft-local/ba-p/2806185>
2. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			
v7	16.2 Configure Centralized Point of Authentication Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.			

18.3.4 (L1) Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

The recommended state for this setting is: `Enabled: Large letters + small letters + numbers + special characters.`

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Note #3: Make sure to choose the local Administrator account that is enabled, and not the built-in disabled local Administrator account.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

LAPS-generated passwords will be required to contain large letters + small letters + numbers + special characters.

Audit:

Navigate to the following registry location and confirm it is set to 4.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft  
Services\AdmPwd:PasswordComplexity
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Configure the Password Complexity option to Large letters + small letters + numbers + special characters:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\LAPS  
Setting Name:  Password Settings  
Configuration: Enabled: Configure the Password Complexity option to Large  
letters + small letters + numbers + special characters
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Large letters + small letters + numbers + special characters.

References:

1. <https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/local-administrator-password-solution-laps-implementation-hints/ba-p/258296>
2. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			

18.3.5 (L1) Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

The recommended state for this setting is: `Enabled: 15 or more`.

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Note #3: Make sure to choose the local Administrator account that is enabled, and not the built-in disabled local Administrator account.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

LAPS-generated passwords will be required to have a length of 15 characters (or more, if selected).

Audit:

Navigate to the following registry location and confirm it is set to 15.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft Services\AdmPwd>PasswordLength
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Configure the Password Length option to 15 or more:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\LAPS
Setting Name: Password Settings
Configuration: Enabled: Configure the Password Length option to 15 or more
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

14 characters.

References:

1. <https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/local-administrator-password-solution-laps-implementation-hints/ba-p/258296>
2. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.			

18.3.6 (L1) Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 30 or fewer' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

In May 2015, Microsoft released the Local Administrator Password Solution (LAPS) tool, which is free and supported software that allows an organization to automatically set randomized and unique local Administrator account passwords on domain-attached workstations and Member Servers. The passwords are stored in a confidential attribute of the domain computer account and can be retrieved from Active Directory by approved Sysadmins when needed.

The LAPS tool requires a small Active Directory Schema update in order to implement, as well as installation of a Group Policy Client Side Extension (CSE) on targeted computers. Please see the LAPS documentation for details.

LAPS supports Windows Vista or newer workstation OSes, and Server 2003 or newer server OSes. LAPS does not support standalone computers - they must be joined to a domain.

The recommended state for this setting is: `Enabled: 30 or fewer`.

Note: Organizations that utilize 3rd-party commercial software to manage unique & complex local Administrator passwords on domain members may opt to disregard these LAPS recommendations.

Note #2: LAPS is only designed to manage *local* Administrator passwords, and is therefore not recommended (or supported) for use directly on Domain Controllers, which do not have a traditional local Administrator account. We strongly encourage you to only deploy the LAPS CSE and LAPS GPO settings to member servers and workstations.

Note #3: Make sure to choose the local Administrator account that is enabled, and not the built-in disabled local Administrator account.

Rationale:

Due to the difficulty in managing local Administrator passwords, many organizations choose to use the same password on all workstations and/or Member Servers when deploying them. This creates a serious attack surface security risk because if an attacker manages to compromise one system and learn the password to its local Administrator account, then they can leverage that account to instantly gain access to all other computers that also use that password for their local Administrator account.

Impact:

LAPS-generated passwords will be required to have a maximum age of 30 days (or fewer, if selected).

Audit:

Navigate to the following registry location and confirm it is set to 30.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft  
Services\AdmPwd>PasswordAgeDays
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Configure the Password Length option to 15 or more:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\LAPS  
Setting Name: Password Settings  
Configuration: Enabled: Configure the Password Age (Days) option to 30 or  
fewer
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

30 days.

References:

1. <https://techcommunity.microsoft.com/t5/core-infrastructure-and-security/local-administrator-password-solution-laps-implementation-hints/ba-p/258296>
2. <https://learn.microsoft.com/en-us/mem/intune/protect/windows-laps-overview#frequently-asked-questions>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.			
v7	16.10 Ensure All Accounts Have An Expiration Date Ensure that all accounts have an expiration date that is monitored and enforced.			

18.4 MS Security Guide

This section contains settings for configuring additional settings from the MS Security Guide.

This Group Policy section is provided by the Group Policy template `SecGuide.admx/adml` that is available from Microsoft at [this link](#).

18.4.1 (L1) Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting controls whether local accounts can be used for remote administration via network logon (e.g., NET USE, connecting to C\$, etc.). Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. Enabling this policy significantly reduces that risk.

Enabled: Applies UAC token-filtering to local accounts on network logons. Membership in powerful group such as Administrators is disabled and powerful privileges are removed from the resulting access token. This configures the `LocalAccountTokenFilterPolicy` registry value to 0. This is the default behavior for Windows.

Disabled: Allows local accounts to have full administrative rights when authenticating via network logon, by configuring the `LocalAccountTokenFilterPolicy` registry value to 1.

For more information about local accounts and credential theft, review the "[Mitigating Pass-the-Hash \(PtH\) Attacks and Other Credential Theft Techniques](#)" documents.

For more information about `LocalAccountTokenFilterPolicy`, see Microsoft Knowledge Base article 951016: [Description of User Account Control and remote restrictions in Windows Vista](#).

The recommended state for this setting is: `Enabled`.

Rationale:

Local accounts are at high risk for credential theft when the same account and password is configured on multiple systems. Ensuring this policy is Enabled significantly reduces that risk.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSecurityGuide:ApplyUACRestrictionsToLocalAccountsOnNetworkLogon_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSecurityGuide:ApplyUACRestrictionsToLocalAccountsOnNetworkLogon_LastWrite
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:LocalAccountTokenFilterPolicy
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/MS Security Guide
Setting Name:	Apply UAC restrictions to local accounts on network logons
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (UAC token-filtering is applied to local accounts on network logons. Membership in powerful groups such as Administrators and disabled and powerful privileges are removed from the resulting access token.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.3 <u>Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

18.4.2 (L1) Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting configures the start type for the Server Message Block version 1 (SMBv1) client driver service (MRxSmb10), which is recommended to be disabled.

The recommended state for this setting is: `Enabled: Disable driver (recommended)`.

Note: Do not, *under any circumstances*, configure this overall setting as `Disabled`, as doing so will delete the underlying registry entry altogether, which will cause serious problems.

Rationale:

Since September 2016, Microsoft has strongly encouraged that SMBv1 be disabled and no longer used on modern networks, as it is a 30 year old design that is much more vulnerable to attacks than much newer designs such as SMBv2 and SMBv3.

More information on this can be found at the following links:

[Stop using SMB1 | Storage at Microsoft](#)

[Disable SMB v1 in Managed Environments with Group Policy – "Stay Safe" Cyber Security Blog](#)

[Disabling SMBv1 through Group Policy – Microsoft Security Guidance blog](#)

Impact:

Some legacy OSes (e.g. Windows XP, Server 2003 or older), applications and appliances may no longer be able to communicate with the system once SMBv1 is disabled. We recommend careful testing be performed to determine the impact prior to configuring this as a widespread control, and where possible, remediate any incompatibilities found with the vendor of the incompatible system. Microsoft is also maintaining a thorough (although not comprehensive) list of known SMBv1 incompatibilities at this link: [SMB1 Product Clearinghouse | Storage at Microsoft](#)

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSecurityGuide:ConfigureSMBV1ClientDriver_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Pol_SecGuide_SMB1ClientDriver" value="4" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\GUID}\Default\MSSecurityGuide:ConfigureSMBV1ClientDriver
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 4.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\MrxSmb10:Start
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Disable driver (recommended):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration/MS Security Guide
Setting Name: Configure SMB v1 client driver
Configuration: Enabled; Disable driver (recommended)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 7 and Windows 8.0: Enabled: Manual start.

Windows 8.1 and Windows 10 (up to R1703): Enabled: Automatic start.

Windows 10 R1709 and newer: Enabled: Disable driver.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			
v7	<u>14.3 Disable Workstation to Workstation Communication</u> Disable all workstation to workstation communication to limit an attacker's ability to move laterally and compromise neighboring systems, through technologies such as Private VLANs or microsegmentation.			

18.4.3 (L1) Ensure 'Configure SMB v1 server' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting configures the server-side processing of the Server Message Block version 1 (SMBv1) protocol.

The recommended state for this setting is: `Disabled`.

Rationale:

Since September 2016, Microsoft has strongly encouraged that SMBv1 be disabled and no longer used on modern networks, as it is a 30 year old design that is much more vulnerable to attacks than much newer designs such as SMBv2 and SMBv3.

More information on this can be found at the following links:

[Stop using SMB1 | Storage at Microsoft](#)

[Disable SMB v1 in Managed Environments with Group Policy – "Stay Safe" Cyber Security Blog](#)

[Disabling SMBv1 through Group Policy – Microsoft Security Guidance blog](#)

Impact:

Some legacy OSes (e.g. Windows XP, Server 2003 or older), applications and appliances may no longer be able to communicate with the system once SMBv1 is disabled. We recommend careful testing be performed to determine the impact prior to configuring this as a widespread control, and where possible, remediate any incompatibilities found with the vendor of the incompatible system. Microsoft is also maintaining a thorough (although not comprehensive) list of known SMBv1 incompatibilities at this link: [SMB1 Product Clearinghouse | Storage at Microsoft](#)

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSecurityGuide:ConfigureSMBV1Server_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSecurityGuide:ConfigureSMBV1Server
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters:SMB1
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/MS Security Guide
Setting Name:	Configure SMB v1 server
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 10 R1703 and older: Enabled.

Windows 10 R1709 and newer: Disabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			
v7	<u>14.3 Disable Workstation to Workstation Communication</u> Disable all workstation to workstation communication to limit an attacker's ability to move laterally and compromise neighboring systems, through technologies such as Private VLANs or microsegmentation.			

18.4.4 (L1) Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Windows includes support for Structured Exception Handling Overwrite Protection (SEHOP). We recommend enabling this feature to improve the security profile of the computer.

The recommended state for this setting is: *Enabled*.

Rationale:

This feature is designed to block exploits that use the Structured Exception Handler (SEH) overwrite technique. This protection mechanism is provided at run-time. Therefore, it helps protect applications regardless of whether they have been compiled with the latest improvements, such as the /SAFESEH option.

Impact:

After you enable SEHOP, existing versions of Cygwin, Skype, and Armadillo-protected applications may not work correctly.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSecurityGuide:EnableStructuredExceptionHandlingOverwriteProtection_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSecurityGuide:EnableStructuredExceptionHandlingOverwriteProtection
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SessionManager\kernel:DisableExceptionChainValidation
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/MS Security Guide
Setting Name:	Enable Structured Exception Handling Overwrite Protection (SEHOP)
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled for 32-bit processes.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.4.5 (L1) Ensure 'WDigest Authentication' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

When WDigest authentication is enabled, Lsass.exe retains a copy of the user's plaintext password in memory, where it can be at risk of theft. If this setting is not configured, WDigest authentication is disabled in Windows 8.1 and in Windows Server 2012 R2; it is enabled by default in earlier versions of Windows and Windows Server.

For more information about local accounts and credential theft, review the "[Mitigating Pass-the-Hash \(PtH\) Attacks and Other Credential Theft Techniques](#)" documents.

For more information about `UseLogonCredential`, see Microsoft Knowledge Base article 2871997: [Microsoft Security Advisory Update to improve credentials protection and management May 13, 2014](#).

The recommended state for this setting is: `Disabled`.

Rationale:

Preventing the plaintext storage of credentials in memory may reduce opportunity for credential theft.

Impact:

None - this is also the default configuration for Windows 8.1 and newer.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSecurityGuide:WDigestAuthentication_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSecurityGuide:WDigestAuthentication
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following local group policy location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest:UseLogonCredential
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Enter the *Details* below

Path:	Computer Configuration/MS Security Guide
Setting Name:	WDigest Authentication (disabling may require KB2871997)
Setting:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

On Windows 8.0 and older: Enabled. (Lsass.exe retains a copy of the user's plaintext password in memory, where it is at risk of theft.)

On Windows 8.1 and newer: Disabled. (Lsass.exe does not retain a copy of the user's plaintext password in memory.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

18.5 MSS (Legacy)

This section contains recommendations for the Microsoft Solutions for Security (MSS) settings.

This Group Policy section is provided by the Group Policy template `MSS-legacy.admx/adml` that is available from this TechNet blog post: [The MSS settings – Microsoft Security Guidance blog](#)

18.5.1 (L1) Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting is separate from the Welcome screen feature in Windows XP and Windows Vista; if that feature is disabled, this setting is not disabled. If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks to which the computer is connected. Also, if you enable automatic logon, the password is stored in the registry in plaintext, and the specific registry key that stores this value is remotely readable by the Authenticated Users group.

For additional information, see Microsoft Knowledge Base article 324737: [How to turn on automatic logon in Windows](#).

The recommended state for this setting is: `Disabled`.

Rationale:

If you configure a computer for automatic logon, anyone who can physically gain access to the computer can also gain access to everything that is on the computer, including any network or networks that the computer is connected to. Also, if you enable automatic logon, the password is stored in the registry in plaintext. The specific registry key that stores this setting is remotely readable by the Authenticated Users group. As a result, this entry is appropriate only if the computer is physically secured and if you ensure that untrusted users cannot remotely see the registry.

Impact:

None - this is the default behavior.

Warning: [Windows Autopilot - Policy Conflicts](#): Windows Autopilot pre-provisioning doesn't work when this GPO policy settings is enabled. An exception to this recommendation will be needed if Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Winlogon:AutoAdminLogon
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration/MSS (Legacy)  
Setting Name: MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)  
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled.

References:

1. <https://docs.microsoft.com/en-us/windows/security/threat-protection/security-policy-settings/recovery-console-allow-automatic-administrative-logon>
2. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 <u>Encrypt Sensitive Data at Rest</u> Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.			
v7	16.4 <u>Encrypt or Hash all Authentication Credentials</u> Encrypt or hash with a salt all authentication credentials when stored.			

18.5.2 (L1) Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should follow through the network.

The recommended state for this setting is: `Enabled: Highest protection, source routing is completely disabled.`

Rationale:

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

Impact:

All incoming source routed packets will be dropped.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSLegacy:IPv6SourceRoutingProtectionLevel_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DisableIPSourceRoutingIPv6" value="2" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSLegacy:IPv6SourceRoutingProtectionLevel
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip6\Parameters:DisableIPSourceRouting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Highest protection, source routing is completely disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)
Configuration: Enabled: Highest protection, source routing is completely disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

No additional protection, source routed packets are allowed.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.5.3 (L1) Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

IP source routing is a mechanism that allows the sender to determine the IP route that a datagram should take through the network. It is recommended to configure this setting to Not Defined for enterprise environments and to Highest Protection for high security environments to completely disable source routing.

The recommended state for this setting is: Enabled: Highest protection, source routing is completely disabled.

Rationale:

An attacker could use source routed packets to obscure their identity and location. Source routing allows a computer that sends a packet to specify the route that the packet takes.

Impact:

All incoming source routed packets will be dropped.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSLegacy:IPSourceRoutingProtectionLevel_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DisableIPSourceRouting" value="2" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\MSSLegacy:IPSourceRoutingProtectionLevel
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:DisableIPSourceRouting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Highest protection`, source routing is completely disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)
Configuration: Enabled: Highest protection, source routing is completely disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Medium, source routed packets ignored when IP forwarding is enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.4 (L2) Ensure 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

When you dial a phonebook or VPN entry in Dial-Up Networking, you can use the "Save Password" option so that your Dial-Up Networking password is cached and you will not need to enter it on successive dial attempts. For security, administrators may want to prevent users from caching passwords.

The recommended state for this setting is: `Enabled`.

Rationale:

An attacker who steals a mobile user's computer could automatically connect to the organization's network if the **Save This Password** check box is selected for the dial-up or VPN networking entry used to connect to your organization's network.

Impact:

Users will not be able to automatically store their logon credentials for dial-up and VPN connections.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\RasMan\Parameters:DisableSavePassword
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/MSS (Legacy)
Setting Name:	MSS: (DisableSavePassword) Prevent the dial-up password from being saved
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Saving of dial-up and VPN passwords is allowed.)

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.5 (L1) Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Internet Control Message Protocol (ICMP) redirects cause the IPv4 stack to plumb host routes. These routes override the Open Shortest Path First (OSPF) generated routes.

The recommended state for this setting is: `Disabled`.

Rationale:

This behavior is expected. The problem is that the 10 minute time-out period for the ICMP redirect-plumbed routes temporarily creates a network situation in which traffic will no longer be routed properly for the affected host. Ignoring such ICMP redirects will limit the system's exposure to attacks that will impact its ability to participate on the network.

Impact:

When Routing and Remote Access Service (RRAS) is configured as an autonomous system boundary router (ASBR), it does not correctly import connected interface subnet routes. Instead, this router injects host routes into the OSPF routes. However, the OSPF router cannot be used as an ASBR router, and when connected interface subnet routes are imported into OSPF the result is confusing routing tables with strange routing paths.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSLegacy:
AllowTheComputerToIgnoreNetBIOSNameReleaseRequestsExceptFromWINSServers_Provi
derSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\
MSSLegacy:AllowICMPRedirectsToOverrideGeneratedRoute
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:EnableI
CMPRedirect
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (ICMP redirects can override OSPF-generated routes.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.6 (L2) Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This value controls how often TCP attempts to verify that an idle connection is still intact by sending a keep-alive packet. If the remote computer is still reachable, it acknowledges the keep-alive packet.

The recommended state for this setting is: `Enabled: 300,000 or 5 minutes (recommended)`.

Rationale:

An attacker who is able to connect to network applications could establish numerous connections to cause a DoS condition.

Impact:

Keep-alive packets are not sent by default by Windows. However, some applications may configure the TCP stack flag that requests keep-alive packets. For such configurations, you can lower this value from the default setting of two hours to five minutes to disconnect inactive sessions more quickly.

Audit:

Navigate to the following registry location and confirm it is set to `300000`.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:KeepAliveTime
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 300,000 or 5 minutes (recommended):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/MSS (Legacy)
Setting Name:	MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds
Configuration:	Enabled: 300,000 or 5 minutes (recommended)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

7,200,000 milliseconds or 120 minutes.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.7 (L1) Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

NetBIOS over TCP/IP is a network protocol that among other things provides a way to easily resolve NetBIOS names that are registered on Windows-based systems to the IP addresses that are configured on those systems. This setting determines whether the computer releases its NetBIOS name when it receives a name-release request.

The recommended state for this setting is: `Enabled`.

Rationale:

The NetBT protocol is designed not to use authentication, and is therefore vulnerable to spoofing. Spoofing makes a transmission appear to come from a user other than the user who performed the action. A malicious user could exploit the unauthenticated nature of the protocol to send a name-conflict datagram to a target computer, which would cause the computer to relinquish its name and not respond to queries.

An attacker could send a request over the network and query a computer to release its NetBIOS name. As with any change that could affect applications, it is recommended that you test this change in a non-production environment before you change the production environment.

The result of such an attack could be to cause intermittent connectivity issues on the target computer, or even to prevent the use of Network Neighborhood, domain logons, the NET SEND command, or additional NetBIOS name resolution.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\MSSLegacy:
AllowTheComputerToIgnoreNetBIOSNameReleaseRequestsExceptFromWINSServers_Provi
derSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\
MSSLegacy:AllowTheComputerToIgnoreNetBIOSNameReleaseRequestsExceptFromWINSSer
vers
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\NetBT\Parameters:NoNameR
eleaseOnDemand
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.8 (L1) Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The DLL search order can be configured to search for DLLs that are requested by running processes in one of two ways:

- Search folders specified in the system path first, and then search the current working folder.
- Search current working folder first, and then search the folders specified in the system path.

When enabled, the registry value is set to 1. With a setting of 1, the system first searches the folders that are specified in the system path and then searches the current working folder. When disabled the registry value is set to 0 and the system first searches the current working folder and then searches the folders that are specified in the system path.

Applications will be forced to search for DLLs in the system path first. For applications that require unique versions of these DLLs that are included with the application, this entry could cause performance or stability problems.

The recommended state for this setting is: `Enabled`.

Note: More information on how Safe DLL search mode works is available at this link: [Dynamic-Link Library Search Order - Windows applications | Microsoft Docs](#)

Rationale:

If a user unknowingly executes hostile code that was packaged with additional files that include modified versions of system DLLs, the hostile code could load its own versions of those DLLs and potentially increase the type and degree of damage the code can render.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Session  
Manager:SafeDllSearchMode
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration/MSS (Legacy)  
Setting Name: MSS: (SafeDllSearchMode) Enable Safe DLL search mode  
(recommended)  
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

18.5.9 (L2) Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting is used to enable or disable the Internet Router Discovery Protocol (IRDP), which allows the system to detect and configure default gateway addresses automatically as described in RFC 1256 on a per-interface basis.

The recommended state for this setting is: `Disabled`.

Rationale:

An attacker who has gained control of a computer on the same network segment could configure a computer on the network to impersonate a router. Other computers with IRDP enabled would then attempt to route their traffic through the already compromised computer.

Impact:

Windows will not automatically detect and configure default gateway addresses on the computer.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:PerformRouterDiscovery
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy) Setting Name: MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS) Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enable only if DHCP sends the Perform Router Discovery option.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.10 (L1) Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Windows includes a grace period between when the screen saver is launched and when the console is actually locked automatically when screen saver locking is enabled.

The recommended state for this setting is: `Enabled: 5 or fewer seconds`.

Rationale:

The default grace period that is allowed for user movement before the screen saver lock takes effect is five seconds. If you leave the default grace period configuration, your computer is vulnerable to a potential attack from someone who could approach the console and attempt to log on to the computer before the lock takes effect. An entry to the registry can be made to adjust the length of the grace period.

Impact:

Users will have to enter their passwords to resume their console sessions as soon as the grace period ends after screen saver activation.

Audit:

Navigate to the following registry location and confirm it is set to 5.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows  
NT\CurrentVersion\Winlogon:ScreenSaverGracePeriod
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 5:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy) Setting Name: MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended) Configuration: Enabled: 5
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

5 seconds.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.3 Configure Automatic Session Locking on Enterprise Assets</u> Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.			
v7	<u>16.11 Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.5.11 (L2) Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection.

The recommended state for this setting is: `Enabled: 3`.

Rationale:

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

Audit:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters:TcpMaxDataRetransmissions
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 3:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted
Configuration: Enabled: 3

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

5 times.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.12 (L2) Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting controls the number of times that TCP retransmits an individual data segment (non-connect segment) before the connection is aborted. The retransmission time-out is doubled with each successive retransmission on a connection. It is reset when responses resume. The base time-out value is dynamically determined by the measured round-trip time on the connection.

The recommended state for this setting is: `Enabled: 3`.

Rationale:

A malicious user could exhaust a target computer's resources if it never sent any acknowledgment messages for data that was transmitted by the target computer.

Impact:

TCP starts a retransmission timer when each outbound segment is passed to the IP. If no acknowledgment is received for the data in a given segment before the timer expires, then the segment is retransmitted up to three times.

Audit:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\TCPIP6\Parameters:TcpMax  
DataRetransmissions
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 3:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy)
Setting Name: MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted
Configuration: Enabled: 3

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

5 times.

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.5.13 (L1) Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting can generate a security audit in the Security event log when the log reaches a user-defined threshold.

The recommended state for this setting is: `Enabled: 90% or less`.

Note: If log settings are configured to Overwrite events as needed or Overwrite events older than x days, this event will not be generated.

Rationale:

If the Security log reaches 90 percent of its capacity and the computer has not been configured to overwrite events as needed, more recent events will not be written to the log. If the log reaches its capacity and the computer has been configured to shut down when it can no longer record events to the Security log, the computer will shut down and will no longer be available to provide network services.

Impact:

An audit event will be generated when the Security log reaches the 90% percent full threshold (or whatever lower value may be set) unless the log is configured to overwrite events as needed.

Audit:

Navigate to the following registry location and confirm it is set to 90.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Eventlog\Security:WarningLevel
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: 90`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/MSS (Legacy) Setting Name: MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning Configuration: Enabled: 90
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

0%. (No warning event is generated.)

References:

1. <https://techcommunity.microsoft.com/t5/microsoft-security-baselines/the-mss-settings/ba-p/701055>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.3 <u>Enable Detailed Logging</u> Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.6 Network

This section contains recommendations for network settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.1 Background Intelligent Transfer Service (BITS)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Bits.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.2 BranchCache

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `PeerToPeerCaching.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.6.3 DirectAccess Client Experience Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `nca.admx/adml` that is included with the Microsoft 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.4 DNS Client

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DnsClient.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.4.1 (L1) Ensure 'Turn off multicast name resolution' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

LLMNR is a secondary name resolution protocol. With LLMNR, queries are sent using multicast over a local network link on a single subnet from a client computer to another client computer on the same subnet that also has LLMNR enabled. LLMNR does not require a DNS server or DNS client configuration, and provides name resolution in scenarios in which conventional DNS name resolution is not possible.

The recommended state for this setting is: `Enabled`.

Rationale:

An attacker can listen on a network for these LLMNR (UDP/5355) or NBT-NS (UDP/137) broadcasts and respond to them, tricking the host into thinking that it knows the location of the requested system.

Note: To completely mitigate local name resolution poisoning, in addition to this setting, the properties of each installed NIC should also be set to `Disable NetBIOS over TCP/IP` (on the WINS tab in the NIC properties). Unfortunately, there is no global setting to achieve this that automatically applies to all NICs - it is a per-NIC setting that varies with different NIC hardware installations.

Impact:

In the event DNS is unavailable a system will be unable to request it from other systems on the same subnet.

Audit:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
NT\DNSClient:EnableMulticast
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\DNS Client
Setting Name:	Turn off multicast name resolution
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (LLMNR will be enabled on all available network adapters.)

References:

1. https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-llmnrp/02b1d227-d7a2-4026-9fd6-27ea5651fe85

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.6.5 Fonts

This section contains recommendations related to Fonts.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.6.5.1 (L2) Ensure 'Enable Font Providers' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting determines whether Windows is allowed to download fonts and font catalog data from an online font provider.

The recommended state for this setting is: `Disabled`.

Rationale:

In an enterprise managed environment the IT department should be managing the changes to the system configuration, to ensure all changes are tested and approved.

Impact:

Windows will not connect to an online font provider and will only enumerate locally-installed fonts.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:AllowFontProviders_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\System:AllowFontProviders
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Disabled':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/System/AllowFontProviders
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Fonts that are included in Windows but that are not stored locally will be downloaded on demand from an online font provider.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>16.5 Use Up-to-Date and Trusted Third-Party Software Components</u> Use up-to-date and trusted third-party software components. When possible, choose established and proven frameworks and libraries that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use.			
v7	<u>18.4 Only Use Up-to-date And Trusted Third-Party Components</u> Only use up-to-date and trusted third-party components for the software developed by the organization.			

18.6.6 Hotspot Authentication

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `hotspotauth.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.7 Lanman Server

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `LanmanServer.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.6.8 Lanman Workstation

This section contains recommendations related to Lanman Workstation.

This Group Policy section is provided by the Group Policy template `LanmanWorkstation.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.6.8.1 (L1) Ensure 'Enable insecure guest logons' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines if the SMB client will allow insecure guest logons to an SMB server.

The recommended state for this setting is: `Disabled`.

Rationale:

Insecure guest logons are used by file servers to allow unauthenticated access to shared folders.

Impact:

The SMB client will reject insecure guest logons. This was not originally the default behavior in older versions of Windows, but Microsoft changed the default behavior starting with Windows 10 R1709: [Guest access in SMB2 disabled by default in Windows 10 and Windows Server 2016](#)

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\LanmanWorkstation:EnableInsecureGuestLogons_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\LanmanWorkstation:EnableInsecureGuestLogons
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Endpoint protection/Local device security options/Network access and security Setting Name: Insecure Guest Logons Configuration: Block
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 10 R1703 and older: Enabled. (The SMB client will allow insecure guest logons.)

Windows 10 R1709 and newer: Disabled. (The SMB client will reject insecure guest logons.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.6.9 Link-Layer Topology Discovery

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `LinkLayerTopologyDiscovery.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.9.1 (L2) Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting changes the operational behavior of the Mapper I/O network protocol driver.

LLTDIO allows a computer to discover the topology of a network it's connected to. It also allows a computer to initiate Quality-of-Service requests such as bandwidth estimation and network health analysis.

The recommended state for this setting is: `Disabled`.

Rationale:

To help protect from potentially discovering and connecting to unauthorized devices, this setting should be disabled to prevent responding to network traffic for network topology discovery.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry locations and confirm they are set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowLLTDIOOnDomain
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowLLTDIOOnPublicNet
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:EnableLLTDIO
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:ProhibitLLTDIOOnPrivateNet
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Disabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Link-Layer Topology Discovery
Setting Name:	Turn on Mapper I/O (LLTDIO) driver
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The Mapper I/O (LLTDIO) network protocol driver is turned off.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.6.9.2 (L2) Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting changes the operational behavior of the Responder network protocol driver.

The Responder allows a computer to participate in Link Layer Topology Discovery requests so that it can be discovered and located on the network. It also allows a computer to participate in Quality-of-Service activities such as bandwidth estimation and network health analysis.

The recommended state for this setting is: `Disabled`.

Rationale:

To help protect from potentially discovering and connecting to unauthorized devices, this setting should be disabled to prevent responding to network traffic for network topology discovery.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowRspndrOnDomain
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:AllowRspndrOnPublicNet
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:EnableRspndr
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\LLTD:ProhibitRspndrOnPrivateNet
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Link-Layer Topology Discovery
Setting Name:	Turn on Responder (RSPNDR) driver
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The Responder (RSPNDR) network protocol driver is turned off.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.6.10 Microsoft Peer-to-Peer Networking Services

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `P2P-pnnp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.11 Network Connections

This section contains recommendations for Network Connections settings.

This Group Policy section is provided by the Group Policy template `NetworkConnections.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.11.1 Windows Defender Firewall (formerly Windows Firewall)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsFirewall.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Windows Firewall* but was renamed by Microsoft to *Windows Defender Firewall* starting with the Microsoft Windows 10 Release 1709 Administrative Templates.

18.6.11.2 (L1) Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

You can use this procedure to controls user's ability to install and configure a Network Bridge.

The recommended state for this setting is: `Enabled`.

Rationale:

The Network Bridge setting, if enabled, allows users to create a Layer 2 Media Access Control (MAC) bridge, enabling them to connect two or more physical network segments together. A Network Bridge thus allows a computer that has connections to two different networks to share data between those networks.

In an enterprise managed environment, where there is a need to control network traffic to only authorized paths, allowing users to create a Network Bridge increases the risk and attack surface from the bridged network.

Impact:

Users cannot create or configure a Network Bridge.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:ProhibitInstallationAndConfigurationOfNetworkBridge_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\GUID}\Default\Connectivity:ProhibitInstallationAndConfigurationOfNetworkBridge
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkConnections:NC_AllowNetBridge_NLA
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Network/Network Connections
Setting Name: Prohibit installation and configuration of Network Bridge on your DNS domain network
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users are able create and modify the configuration of Network Bridges. Membership in the local Administrators group, or equivalent, is the minimum required to complete this procedure.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.2 Establish and Maintain a Secure Configuration Process for Network Infrastructure</u> Establish and maintain a secure configuration process for network devices. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.			
v7	<u>11.3 Use Automated Tools to Verify Standard Device Configurations and Detect Changes</u> Compare all network device configuration against approved security configurations defined for each network device in use and alert when any deviations are discovered.			

18.6.11.3 (L1) Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Although this "legacy" setting traditionally applied to the use of Internet Connection Sharing (ICS) in Windows 2000, Windows XP & Server 2003, this setting now freshly applies to the Mobile Hotspot feature in Windows 10 & Server 2016.

The recommended state for this setting is: `Enabled`.

Rationale:

Non-administrators should not be able to turn on the Mobile Hotspot feature and open their Internet connectivity up to nearby mobile devices.

Impact:

Mobile Hotspot cannot be enabled or configured by Administrators and non-Administrators alike.

Audit:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Network  
Connections:NC_ShowSharedAccessUI
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Network Connections
Setting Name:	Prohibit use of Internet Connection Sharing on your DNS domain network
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (All users are allowed to turn on Mobile Hotspot.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.6.11.4 (L1) Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether to require domain users to elevate when setting a network's location.

The recommended state for this setting is: `Enabled`.

Rationale:

Allowing regular users to set a network location increases the risk and attack surface.

Impact:

Domain users must elevate when setting a network's location.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Network Connections:NC_StdDomainUserSetLocation

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Network Connections
Setting Name:	Require domain users to elevate when setting a network's location
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can set a network's location without elevating.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.3 <u>Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

18.6.12 Network Connectivity Status Indicator

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `NCSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.13 Network Isolation

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `NetworkIsolation.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.14 Network Provider

This section contains recommendations for Network Provider settings.

This Group Policy section is provided by the Group Policy template `NetworkProvider.admx/adml` that is included with the [MS15-011](#) / [MSKB 3000483](#) security update and the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.6.14.1 (L1) Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting configures secure access to UNC paths.

The recommended state for this setting is: Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares.

Note: If the environment exclusively contains Windows 8.0 / Server 2012 (non-R2) or newer systems, then the "Privacy" setting may (optionally) also be set to enable SMB encryption. However, using SMB encryption will render the targeted share paths completely inaccessible by older OSes, so only use this additional option with caution and thorough testing.

Rationale:

In February 2015, Microsoft released a new control mechanism to mitigate a security risk in Group Policy as part of the [MS15-011](#) / [MSKB 3000483](#) security update. This mechanism requires both the installation of the new security update and also the deployment of specific group policy settings to all computers on the domain from Windows Vista / Server 2008 (non-R2) or newer (the associated security patch to enable this feature was not released for Server 2003). A new group policy template (`NetworkProvider.admx/adml`) was also provided with the security update.

Once the new GPO template is in place, the following are the minimum requirements to remediate the Group Policy security risk:

```
\\*\NETLOGON RequireMutualAuthentication=1, RequireIntegrity=1
```

```
\\*\SYSVOL RequireMutualAuthentication=1, RequireIntegrity=1
```

Note: A reboot may be required after the setting is applied to a client machine to access the above paths.

Additional guidance on the deployment of this security setting is available from the Microsoft Premier Field Engineering (PFE) Platforms TechNet Blog here: [Guidance on Deployment of MS15-011 and MS15-014](#).

Impact:

Windows only allows access to the specified UNC paths after fulfilling additional security requirements.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:HardenedUNCPaths_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Pol_HardenedPaths" value="*\NETLOGON 1 *\SYSVOL 1" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Connectivity:HardenedUNCPaths
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:\\*\NETLOGON  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\NetworkProvider\HardenedPaths:\\*\SYSVOL
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/Network/Network Provider
Setting Name:  Hardened UNC Paths
Configuration: Enabled: \\*\NETLOGON RequireMutualAuthentication=1,
RequireIntegrity=1 and
\\*\SYSVOL RequireMutualAuthentication=1, RequireIntegrity=1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (No UNC paths are hardened.)

18.6.15 Offline Files

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `OfflineFiles.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.16 QoS Packet Scheduler

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `QOS.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.17 SNMP

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Snmp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.18 SSL Configuration Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `CipherSuiteOrder.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.19 TCP/IP Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `tcpip.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.6.20 Windows Connect Now

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsConnectNow.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.6.20.1 (L2) Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows the configuration of wireless settings using Windows Connect Now (WCN). The WCN Registrar enables the discovery and configuration of devices over Ethernet (UPnP) over in-band 802.11 Wi-Fi through the Windows Portable Device API (WPD) and via USB Flash drives. Additional options are available to allow discovery and configuration over a specific medium.

The recommended state for this setting is: `Disabled`.

Rationale:

This setting enhances the security of the environment and reduces the overall risk exposure related to user configuration of wireless settings.

Impact:

WCN operations are disabled over all media.

Audit:

Navigate to the following registry locations and confirm they are set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:EnableR  
egistrars  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:Disable  
UPnPRegistrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:Disable  
InBand802DOT11Registrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:Disable  
FlashConfigRegistrar  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\Registrars:Disable  
WPDRegistrar
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Windows Connect Now
Setting Name:	Configuration of wireless settings using Windows Connect Now
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

WCN operations are enabled and allowed over all media.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>15.4 Disable Wireless Access on Devices if Not Required</u> Disable wireless access on devices that do not have a business purpose for wireless access.			●
v7	<u>15.5 Limit Wireless Access on Client Devices</u> Configure wireless access on client machines that do have an essential wireless business purpose, to allow access only to authorized wireless networks and to restrict access to other wireless networks.			●

18.6.20.2 (L2) Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting prohibits access to Windows Connect Now (WCN) wizards.

The recommended state for this setting is: `Enabled`.

Rationale:

Allowing standard users to access the Windows Connect Now wizard increases the risk and attack surface.

Impact:

The WCN wizards are turned off and users have no access to any of the wizard tasks. All the configuration related tasks including "Set up a wireless router or access point" and "Add a wireless device" are disabled.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WCN\UI:DisableWcnUi
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Windows Connect Now
Setting Name:	Prohibit access of the Windows Connect Now wizards
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can access all WCN wizard tasks.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.6.21 Windows Connection Manager

This section contains recommendations for Windows Connection Manager settings.

This Group Policy section is provided by the Group Policy template `WCM.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.21.1 (L1) Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents computers from connecting to both a domain based network and a non-domain based network at the same time.

The recommended state for this setting is: *Enabled*.

Rationale:

The potential concern is that a user would unknowingly allow network traffic to flow between the insecure public network and the enterprise managed network.

Impact:

The computer responds to automatic and manual network connection attempts based on the following circumstances:

Automatic connection attempts - When the computer is already connected to a domain based network, all automatic connection attempts to non-domain networks are blocked.
- When the computer is already connected to a non-domain based network, automatic connection attempts to domain based networks are blocked.

Manual connection attempts - When the computer is already connected to either a non-domain based network or a domain based network over media other than Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing network connection is disconnected and the manual connection is allowed. - When the computer is already connected to either a non-domain based network or a domain based network over Ethernet, and a user attempts to create a manual connection to an additional network in violation of this policy setting, the existing Ethernet connection is maintained and the manual connection attempt is blocked.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Windows  
ConnectionManager:ProhibitConnectionToNonDomainNetworksWhenConnectedToDomainAut  
henticatedNetwork_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
Windows  
ConnectionManager:ProhibitConnectionToNonDomainNetworksWhenConnectedToDomainAut  
henticatedNetwork
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy:fBl  
ockNonDomain
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Network/Windows Connection Manager
Setting Name:	Prohibit connection to non-domain networks when connected to domain authenticated network
Setting:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Connections to both domain and non-domain networks are simultaneously allowed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	12.4 Deny Communication over Unauthorized Ports Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.			

18.6.21.2 (L1) Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled: 3 = Prevent Wi-Fi when on Ethernet' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents computers from establishing multiple simultaneous connections to either the Internet or to a Windows domain.

The recommended state for this setting is: Enabled: 3 = Prevent Wi-Fi when on Ethernet.

Rationale:

Preventing bridged network connections can help prevent a user unknowingly allowing traffic to route between internal and external networks, which risks exposure to sensitive internal data.

Impact:

While connected to an Ethernet connection, Windows won't allow use of a WLAN (automatically *or* manually) until Ethernet is disconnected. However, if a cellular data connection is available, it will always stay connected for services that require it, but no Internet traffic will be routed over cellular if an Ethernet or WLAN connection is present.

Audit:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WcmSvc\GroupPolicy:fMinimizeConnections
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 3 = Prevent Wi-Fi when on Ethernet:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Network\Windows Connection Manager
Setting Name:	Minimize the number of simultaneous connections to the Internet or a Windows Domain
Configuration:	Enabled: 3 = Prevent Wi-Fi when on Ethernet

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: 1 = Minimize simultaneous connections. (Any new automatic internet connection is blocked when the computer has at least one active internet connection to a preferred type of network. The order of preference (from most preferred to least preferred) is: Ethernet, WLAN, then cellular. Ethernet is always preferred when connected. Users can still manually connect to any network.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	15.5 <u>Limit Wireless Access on Client Devices</u> Configure wireless access on client machines that do have an essential wireless business purpose, to allow access only to authorized wireless networks and to restrict access to other wireless networks.			●

18.6.22 Wireless Display

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `wlansvc.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.6.23 WLAN Service

This section contains recommendations for WLAN Service settings.

This Group Policy section is provided by the Group Policy template `wlansvc.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.23.1 WLAN Media Cost

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `wlansvc.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.6.23.2 WLAN Settings

This setting contains recommendations for WLAN Settings.

This Group Policy section is provided by the Group Policy template `wlansvc.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.6.23.2.1 (L1) Ensure 'Allow Windows to automatically connect to suggested open hotspots, to networks shared by contacts, and to hotspots offering paid services' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can enable the following WLAN settings: "Connect to suggested open hotspots," "Connect to networks shared by my contacts," and "Enable paid services".

- "Connect to suggested open hotspots" enables Windows to automatically connect users to open hotspots it knows about by crowdsourcing networks that other people using Windows have connected to.
- "Connect to networks shared by my contacts" enables Windows to automatically connect to networks that the user's contacts have shared with them, and enables users on this device to share networks with their contacts.
- "Enable paid services" enables Windows to temporarily connect to open hotspots to determine if paid services are available.

The recommended state for this setting is: *Disabled*.

Note: These features are also known by the name "*Wi-Fi Sense*".

Rationale:

Automatically connecting to an open hotspot or network can introduce the system to a rogue network with malicious intent.

Impact:

Connect to suggested open hotspots, *Connect to networks shared by my contacts*, and *Enable paid services* will each be turned off and users on the device will be prevented from enabling them.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Wifi:AllowAutoConnectToWiFiSenseHotspots_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Wifi:AllowAutoConnectToWiFiSenseHotspots
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Wifi/AllowAutoConnectToWiFiSenseHotspots
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Users can choose to enable or disable either "Connect to suggested open hotspots" or "Connect to networks shared by my contacts".)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-wifi#allowautoconnecttowifisensehotspots>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	15.5 <u>Limit Wireless Access on Client Devices</u> Configure wireless access on client machines that do have an essential wireless business purpose, to allow access only to authorized wireless networks and to restrict access to other wireless networks.			

18.7 Printers

This section contains settings for configuring Printers.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.7.1 (L1) Ensure 'Allow Print Spooler to accept client connections' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether the Print Spooler service will accept client connections.

The recommended state for this setting is: `Disabled`.

Note: The Print Spooler service must be restarted for changes to this policy to take effect.

Rationale:

Disabling the ability for the Print Spooler service to accept client connections mitigates **remote** attacks against the PrintNightmare vulnerability ([CVE-2021-34527](#)) and other **remote** Print Spooler attacks. However, this recommendation *does not* mitigate against **local** attacks on the Print Spooler service.

Impact:

Provided that the Print Spooler service is not disabled, users will continue to be able to print *from their workstation*. However, the workstation's Print Spooler service will not accept client connections or allow users to share printers. Note that all printers that were already shared will continue to be shared.

Audit:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers:RegisterSpoolerRemoteRpcEndPoint
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Printers
Setting Name:	Allow Print Spooler to accept client connections
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (The Print Spooler will always accept client connections.)

References:

1. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.7.2 (L1) Ensure 'Point and Print Restrictions: When installing drivers for a new connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether computers will show a warning and a security elevation prompt when users create a new printer connection using Point and Print.

The recommended state for this setting is: `Enabled: Show warning and elevation prompt`.

Note: On August 10, 2021, Microsoft announced a [Point and Print Default Behavior Change](#) which modifies the default Point and Print driver installation and update behavior to require Administrator privileges. This is documented in [KB5005652—Manage new Point and Print default driver installation behavior \(CVE-2021-34481\)](#). This change overrides all Point and Print Group Policy settings and ensures that only Administrators can install printer drivers from a print server using Point and Print.

Rationale:

Enabling Windows User Account Control (UAC) for the installation of new print drivers can help mitigate the PrintNightmare vulnerability ([CVE-2021-34527](#)) and other Print Spooler attacks.

Although the Point and Print default driver installation behavior overrides this setting, it is important to configure this as a backstop in the event that behavior is reversed.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers\PointAndPrint:NoWarningNoElevationOnInstall
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled: Show warning and elevation prompt**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Printers
Setting Name: Point and Print Restrictions: When installing drivers for a new connection
Configuration: Enabled: Show warning and elevation prompt

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Windows computers will show a warning and a security elevation prompt when users create a new printer connection using Point and Print.)

References:

1. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-1675>
2. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34481>
3. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527>
4. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-36958>
5. <https://msrc-blog.microsoft.com/2021/08/10/point-and-print-default-behavior-change/>
6. <https://support.microsoft.com/en-us/topic/kb5005652-manage-new-point-and-print-default-driver-installation-behavior-cve-2021-34481-873642bf-2634-49c5-a23b-6d8e9a302872>

18.7.3 (L1) Ensure 'Point and Print Restrictions: When updating drivers for an existing connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether computers will show a warning and a security elevation prompt when users are updating drivers for an existing connection using Point and Print.

The recommended state for this setting is: `Enabled: Show warning and elevation prompt`.

Note: On August 10, 2021, Microsoft announced a [Point and Print Default Behavior Change](#) which modifies the default Point and Print driver installation and update behavior to require Administrator privileges. This is documented in [KB5005652—Manage new Point and Print default driver installation behavior \(CVE-2021-34481\)](#). This change overrides all Point and Print Group Policy settings and ensures that only Administrators can install printer drivers from a print server using Point and Print.

Rationale:

Enabling Windows User Account Control (UAC) for updating existing print drivers can help mitigate the PrintNightmare vulnerability ([CVE-2021-34527](#)) and other Print Spooler attacks.

Although the Point and Print default driver installation behavior overrides this setting, it is important to configure this as a backstop in the event that behavior is reversed.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Windows  
NT\Printers\PointAndPrint:UpdatePromptSettings
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Show warning and elevation prompt`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Printers
Setting Name: Point and Print Restrictions: When updating drivers for an existing connection
Configuration: Enabled: Show warning and elevation prompt

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Windows computers will show a warning and a security elevation prompt when users are updating drivers for an existing connection using Point and Print.)

References:

1. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-1675>
2. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34481>
3. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-34527>
4. <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2021-36958>
5. <https://msrc-blog.microsoft.com/2021/08/10/point-and-print-default-behavior-change/>
6. <https://support.microsoft.com/en-us/topic/kb5005652-manage-new-point-and-print-default-driver-installation-behavior-cve-2021-34481-873642bf-2634-49c5-a23b-6d8e9a302872>

18.8 Start Menu and Taskbar

This section contains recommendations for Start Menu and Taskbar.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.8.1 Notifications

This section contains recommendations for Start Menu and Taskbar Notifications.

This Group Policy section is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft 10 Release 1803 Administrative Templates (or newer).

18.8.1.1 (L2) Ensure 'Turn off notifications network usage' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting blocks applications from using the network to send notifications to update tiles, tile badges, toast, or raw notifications. This policy setting turns off the connection between Windows and the Windows Push Notification Service (WNS). This policy setting also stops applications from being able to poll application services to update tiles.

The recommended state for this setting is: `Enabled`.

Rationale:

Windows Push Notification Services (WNS) is a mechanism to receive 3rd-party notifications and updates from the cloud/Internet. In a high security environment, external systems, especially those hosted outside the organization, should be prevented from having an impact on the secure workstations.

Impact:

Applications and system features will not be able receive notifications from the network from WNS or via notification polling APIs.

Warning: This policy is designed for zero exhaust. This policy may cause some MDM processes to break because WNS notification is used by the MDM server to send real time tasks to the device, such as remote wipe, unenroll, remote find, and mandatory app installation. When this policy is set to disallow WNS, those real time processes will no longer work and some time-sensitive actions such as remote wipe when the device is stolen or unenrollment when the device is compromised will not work."

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Notifications:DisallowCloudNotification_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Notifications:DisallowCloudNotification
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Enabled':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Notifications/DisallowCloudNotification
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.9 System

This section contains recommendations for System settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.1 Access-Denied Assistance

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `srm-fci.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.2 App-V

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `appv.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.9.3 Audit Process Creation

This section contains settings related to Audit Process Creation.

This Group Policy section is provided by the Group Policy template `AuditSettings.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.9.3.1 (L1) Ensure 'Include command line in process creation events' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether the process creation command line text is logged in security audit events when a new process has been created.

The recommended state for this setting is: `Enabled`.

Note: This feature that this setting controls was not originally supported in workstation OSes older than Windows 8.1. However, in February 2015 Microsoft added support for the feature to Windows 7 and Windows 8.0 via an update - [KB3004375](#). Therefore, this setting is also important to set on those older OSes.

Rationale:

Capturing process command line information in event logs can be very valuable when performing forensic investigations of attack incidents.

Impact:

Process command line information will be included in the event logs, which can contain sensitive or private information such as passwords or user data.

Warning: There are potential risks of capturing credentials and sensitive information which could be exposed to users who have read-access to event logs. Microsoft provides a feature called "Protected Event Logging" to better secure event log data. For assistance with protecting event logging, visit: [About Logging Windows - PowerShell | Microsoft Docs](#).

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\
Audit:ProcessCreationIncludeCmdLine_Enabled
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Audit Process Creation
Setting Name:	Include command line in process creation events
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Process command line information will not be included in Audit Process Creation events.)

References:

1. https://docs.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging_windows?view=powershell-7.2#protected-event-logging

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.8 Collect Command-Line Audit Logs Collect command-line audit logs. Example implementations include collecting audit logs from PowerShell®, BASH™, and remote administrative terminals.			
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.			

18.9.4 Credentials Delegation

This section contains settings related to Credential Delegation.

This Group Policy section is provided by the Group Policy template `CredSsp.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.4.1 (L1) Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Some versions of the CredSSP protocol that is used by some applications (such as Remote Desktop Connection) are vulnerable to an encryption oracle attack against the client. This policy controls compatibility with vulnerable clients and servers and allows you to set the level of protection desired for the encryption oracle vulnerability.

The recommended state for this setting is: `Enabled: Force Updated Clients`.

Rationale:

This setting is important to mitigate the CredSSP encryption oracle vulnerability, for which information was published by Microsoft on 03/13/2018 in [CVE-2018-0886 | CredSSP Remote Code Execution Vulnerability](#). All versions of Windows from Windows Vista onwards are affected by this vulnerability, and will be compatible with this recommendation provided that they have been patched at least through May 2018 (or later).

Impact:

Client applications which use CredSSP will not be able to fall back to the insecure versions and services using CredSSP will not accept unpatched clients. This setting should not be deployed until all remote hosts support the newest version, which is achieved by ensuring that all Microsoft security updates at least through May 2018 are installed.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\CredSSP\Parameters:AllowEncryptionOracle
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Force Updated Clients:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Credentials Delegation
Setting Name:	Encryption Oracle Remediation
Configuration:	Enabled: Force Updated Clients

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Without the May 2018 security update: Enabled: Vulnerable (Client applications which use CredSSP will expose the remote servers to attacks by supporting fall back to the insecure versions and services using CredSSP will accept unpatched clients.)

With the May 2018 security update: Enabled: Mitigated (Client applications which use CredSSP will not be able to fall back to the insecure version but services using CredSSP will accept unpatched clients.)

References:

1. <https://docs.microsoft.com/en-us/windows/win32/secauthn/credential-security-support-provider>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	3.4 <u>Deploy Automated Operating System Patch Management Tools</u> Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●

18.9.4.2 (L1) Ensure 'Remote host allows delegation of non-exportable credentials' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Remote host allows delegation of non-exportable credentials. When using credential delegation, devices provide an exportable version of credentials to the remote host. This exposes users to the risk of credential theft from attackers on the remote host. The Restricted Admin Mode and Windows Defender Remote Credential Guard features are two options to help protect against this risk.

The recommended state for this setting is: `Enabled`.

Note: More detailed information on Windows Defender Remote Credential Guard and how it compares to Restricted Admin Mode can be found at this link: [Protect Remote Desktop credentials with Windows Defender Remote Credential Guard \(Windows 10\) | Microsoft Docs](#)

Rationale:

Restricted Admin Mode was designed to help protect administrator accounts by ensuring that reusable credentials are not stored in memory on remote devices that could potentially be compromised. *Windows Defender Remote Credential Guard* helps you protect your credentials over a Remote Desktop connection by redirecting Kerberos requests back to the device that is requesting the connection. Both features should be enabled and supported, as they reduce the chance of credential theft.

Impact:

The host will support the *Restricted Admin Mode* and *Windows Defender Remote Credential Guard* features.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\CredentialsDelegation:RemoteHostAllowsDelegationOfNonExportableCredentials_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\CredentialsDelegation:RemoteHostAllowsDelegationOfNonExportableCredentials
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CredentialsDelegation:AllowProtectedCreds
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Credentials Delegation
Setting Name:	Remote host allows delegation of non-exportable credentials
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.or newer).

Default Value:

Disabled. (*Restricted Admin Mode* and *Windows Defender Remote Credential Guard* are not supported. Users will always need to pass their credentials to the host.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	16.5 <u>Encrypt Transmittal of Username and Authentication Credentials</u> Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.		●	●

18.9.5 Device Guard

This section contains Device Guard settings.

This Group Policy section is provided by the Group Policy template `DeviceGuard.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.9.5.1 (NG) Ensure 'Turn On Virtualization Based Security' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + Next Generation Windows Security (NG)
- Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)
- Level 2 (L2) + Next Generation Windows Security (NG)
- Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)
- Next Generation Windows Security (NG) - optional add-on for use in the newest hardware and configuration environments

Description:

This policy setting specifies whether Virtualization Based Security is enabled. Virtualization Based Security uses the Windows Hypervisor to provide support for security services.

The recommended state for this setting is: `Enabled`.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at [Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#)

Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.

Rationale:

Kerberos, NTLM, and Credential manager isolate secrets by using virtualization-based security. Previous versions of Windows stored secrets in the Local Security Authority (LSA). Prior to Windows 10, the LSA stored secrets used by the operating system in its process memory. With Windows Defender Credential Guard enabled, the LSA process in the operating system talks to a new component called the isolated LSA process that stores and protects those secrets. Data stored by the isolated LSA process is protected using virtualization-based security and is not accessible to the rest of the operating system.

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process. An exception to this recommendation may be needed if Windows AutoPilot is used.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceGuard:EnableVirtualizationBasedSecurity_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\DeviceGuard:EnableVirtualizationBasedSecurity
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/DeviceGuard/EnableVirtualizationBasedSecurity
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled.

References:

1. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-deviceguard#enablevirtualizationbasedsecurity>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.9.5.2 (NG) Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot' or higher (Automated)

Profile Applicability:

- Level 1 (L1) + Next Generation Windows Security (NG)
- Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)
- Level 2 (L2) + Next Generation Windows Security (NG)
- Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)
- Next Generation Windows Security (NG) - optional add-on for use in the newest hardware and configuration environments

Description:

This policy setting specifies whether Virtualization Based Security is enabled. Virtualization Based Security uses the Windows Hypervisor to provide support for security services.

The recommended state for this setting is: `Secure Boot` or `Secure Boot and DMA Protection`.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at [Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#)

Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.

Rationale:

Secure Boot can help reduce the risk of bootloader attacks and in conjunction with DMA protections to help protect data from being scraped from memory.

Impact:

Choosing the `Secure Boot` option provides the system with as much protection as is supported by the computer's hardware. A system with input/output memory management units (IOMMUs) will have Secure Boot with DMA protection. A system without IOMMUs will simply have Secure Boot enabled without DMA protection.

Choosing the `Secure Boot with DMA protection` option requires the system to have IOMMUs in order to enable VBS. Without IOMMU hardware support, VBS will be disabled.

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceGuard:RequirePlatformSecurityFeatures_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1 or 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\DeviceGuard:RequirePlatformSecurityFeatures
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Secure Boot* or *Secure Boot and DMA Protection*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/DeviceGuard/RequirePlatformSecurityFeatures
Data type:     Integer
Value:         1 or 3
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled.

References:

1. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-deviceguard#enablevirtualizationbasedsecurity>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.9.5.3 (NG) Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (Automated)

Profile Applicability:

- Level 1 (L1) + Next Generation Windows Security (NG)
- Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)
- Level 2 (L2) + Next Generation Windows Security (NG)
- Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)
- Next Generation Windows Security (NG) - optional add-on for use in the newest hardware and configuration environments

Description:

This setting lets users turn on Credential Guard with virtualization-based security to help protect credentials. The "Enabled with UEFI lock" option ensures that Credential Guard cannot be disabled remotely. In order to disable the feature, you must set the Group Policy to "Disabled" as well as remove the security functionality from each computer, with a physically present user, in order to clear configuration persisted in UEFI.

The recommended state for this setting is: `Enabled with UEFI lock`.

Note: Virtualization Based Security requires a 64-bit version of Windows with Secure Boot enabled, which in turn requires that Windows was installed with a UEFI BIOS configuration, not a Legacy BIOS configuration. In addition, if running Windows on a virtual machine, the hardware-assisted CPU virtualization feature (Intel VT-x or AMD-V) must be exposed by the host to the guest VM.

More information on system requirements for this feature can be found at [Windows Defender Credential Guard Requirements \(Windows 10\) | Microsoft Docs](#)

Note #2: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.

Rationale:

The `Enabled with UEFI lock` option ensures that Credential Guard cannot be disabled remotely.

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: Once this setting is turned on and active, **Credential Guard cannot be disabled solely via GPO** or any other remote method. After removing the setting from GPO, the features must also be manually disabled *locally at the machine* using the steps provided at this link:

[Manage Windows Defender Credential Guard \(Windows 10\) | Microsoft Docs](#)

Warning #3: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceGuard:LsaCfgFlags_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\DeviceGuard:LsaCfgFlags
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled with UEFI lock`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/DeviceGuard/LsaCfgFlags
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled.

References:

1. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-deviceguard#enablevirtualizationbasedsecurity>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.9.5.4 (NG) Ensure 'Turn On Virtualization Based Security: Secure Launch Configuration' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + Next Generation Windows Security (NG)
- Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)
- Level 2 (L2) + Next Generation Windows Security (NG)
- Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)
- Next Generation Windows Security (NG) - optional add-on for use in the newest hardware and configuration environments

Description:

Secure Launch protects the Virtualization Based Security environment from exploited vulnerabilities in device firmware.

The recommended state for this setting is: *Enabled*.

Note: Credential Guard and Device Guard are not currently supported when using Azure IaaS VMs.

Rationale:

Secure Launch changes the way windows boots to use Intel Trusted Execution Technology (TXT) and Runtime BIOS Resilience features to prevent firmware exploits from being able to impact the security of the Windows Virtualization Based Security environment.

Impact:

Warning: All drivers on the system must be compatible with this feature or the system may crash. Ensure that this policy setting is only deployed to computers which are known to be compatible.

Warning #2: [Windows Autopilot - Policy Conflicts](#): This policy requires a reboot to apply. As a result, prompts may appear when modifying user account control (UAC) settings during the Out of the Box Experience (OOBE) using the device Enrollment Status Page (ESP). Increased prompts are more likely if the device reboots after policies are applied. To work around this issue, the policies can be targeted to users instead of devices so that they apply later in the process.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceGuard:ConfigureSystemGuardLaunch_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DeviceGuard:ConfigureSystemGuardLaunch
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/DeviceGuard/ConfigureSystemGuardLaunch
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Not Configured. (Administrative users can choose whether to enable or disable Secure Launch.)

References:

1. <https://learn.microsoft.com/en-us/mem/autopilot/policy-conflicts>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-deviceguard#enablevirtualizationbasedsecurity>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.9.6 Device Health Attestation Service

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TPM.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.9.7 Device Installation

This section contains recommendations related to device installation.

This Group Policy section is provided by the Group Policy template `DeviceInstallation.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.7.1 Device Installation Restrictions

This section contains recommendations related to device installation restrictions.

This Group Policy section is provided by the Group Policy template `DeviceInstallation.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.7.1.1 (BL) Ensure 'Prevent installation of devices that match any of these device IDs' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of Plug and Play hardware IDs and compatible IDs for devices that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing a device whose hardware ID or compatible ID appears in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, devices can be installed and updated as allowed or prevented by other policy settings.

The recommended state for this setting is: *Enabled*.

Note: In versions of Windows 10 Release 1803 (and newer), there is a new control named *Enumeration policy for external devices incompatible with Kernel DMA Protection* available that mitigates much of the risk for malicious devices that may perform Direct Memory Access (DMA) attacks. The newer control is also now part of the Windows 10 CIS benchmark, in section 18.8.26. However, if your environment still contains **any** Windows 10 Release 1709 (or older) workstations, then the newer control will not work, so this setting remains important to disable Thunderbolt devices on those systems.

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

Devices matching the specified device IDs will be prevented from installation.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DeviceInstall_IDs_Deny_List" value="1 [{"Name":null,"Data":"PCI\CC_0C0A"}]" /><data id="DeviceInstall_IDs_Deny_Retroactive" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions:DenyDeviceIDs
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/System/Device Installation/Device
Installation Restrictions
Setting Name:   Prevent installation of devices that match any of these device
IDs
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (Devices can be installed and updated as allowed or prevented by other policy settings.)

18.9.7.1.2 (BL) Ensure 'Prevent installation of devices that match any of these device IDs: Prevent installation of devices that match any of these device IDs' is set to 'PCI\CC_0C0A' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of Plug and Play hardware IDs and compatible IDs for devices that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing a device whose hardware ID or compatible ID appears in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, devices can be installed and updated as allowed or prevented by other policy settings.

The recommended state for this setting is: `PCI\CC_0C0A`

Note: This device ID is for Thunderbolt controllers. The USB Type-C (USB-C) port standard that is now common in many computers, especially laptops, utilizes Thunderbolt technology, and therefore may be affected by this restriction. If your organization needs to use USB-C extensively, you may need to decide, internally, to allow yourselves an exception to this recommendation. However, please ensure that all necessary decision-makers have accepted the increased risk of BitLocker encryption key theft (and therefore data theft) via malicious Thunderbolt devices (when left unattended), by doing so.

Note #2: In versions of Windows 10 Release 1803 (and newer), there is a new control named *Enumeration policy for external devices incompatible with Kernel DMA Protection* available that mitigates much of the risk for malicious devices that may perform Direct Memory Access (DMA) attacks. The newer control is also now part of the Windows 10 CIS benchmark, in section 18.8.26. However, if your environment still contains **any** Windows 10 Release 1709 (or older) workstations, then the newer control will not work, so this setting remains important to disable Thunderbolt devices on those systems.

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

Thunderbolt controllers will be prevented from being installed in Windows.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DeviceInstall_IDs_Deny_List" value="1 [{"Name":null,"Data":"PCI\CC_0C0A"}]" /><data id="DeviceInstall_IDs_Deny_Retroactive" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to

```
[{"Name":null,"Data":"PCI\CC_0C0A"}].
```

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions\DenyDeviceIDs:1
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled` with the following IDs `[{"Name":null,"Data":"PCI\\CC_0C0A"}]`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/System/Device Installation/Device
Installation Restrictions
Setting Name:   Prevent installation of devices that match any of these device
IDs
Configuration: [{"Name":null,"Data":"PCI\\CC_0C0A"}]
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

None. (No device ID types are prevented from installation.)

18.9.7.1.3 (BL) Ensure 'Prevent installation of devices that match any of these device IDs: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of Plug and Play hardware IDs and compatible IDs for devices that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing a device whose hardware ID or compatible ID appears in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, devices can be installed and updated as allowed or prevented by other policy settings.

The recommended state for this setting is: `True` (checked).

Note: In versions of Windows 10 Release 1803 (and newer), there is a new control named *Enumeration policy for external devices incompatible with Kernel DMA Protection* available that mitigates much of the risk for malicious devices that may perform Direct Memory Access (DMA) attacks. The newer control is also now part of the Windows 10 CIS benchmark, in section 18.8.26. However, if your environment still contains **any** Windows 10 Release 1709 (or older) workstations, then the newer control will not work, so this setting remains important to disable Thunderbolt devices on those systems.

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

Existing devices (that match the device IDs specified) that were previously installed prior to the hardening will be disabled or removed.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DeviceInstall_IDs_Deny_List" value="1 [{"Name":null,"Data":"PCI\CC_0C0A"}]" /><data id="DeviceInstall_IDs_Deny_Retroactive" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions:DenyDeviceIDsRetroactive
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`, and check the `Also apply to matching devices that are already installed.` checkbox:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/System/Device Installation/Device
Installation Restrictions
Setting Name:   Prevent installation of devices that match any of these device
IDs
Configuration: Also apply to matching devices that are already installed.
(checkered)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

False (unchecked). (Pre-existing devices matching the device IDs will not be disabled or removed.)

18.9.7.1.4 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings.

The recommended state for this setting is: `Enabled`.

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

Devices matching the specified device setup classes will be prevented from installation.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions:DenyDeviceClasses
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration/System/Device Installation/Device Installation Restrictions
Setting Name: Prevent installation of devices using drivers that match these device setup classes
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (Devices can be installed and updated as allowed or prevented by other policy settings.)

18.9.7.1.5 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings.

The recommended state for this setting is: `True (checked)`.

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

Existing devices (that match the device setup classes specified) that were previously installed prior to the hardening will be disabled or removed.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="DeviceInstall_IDs_Deny_List" value="1 [{"Name":null,"Data":"PCI\\CC_0C0A"}]" /><data id="DeviceInstall_IDs_Deny_Retroactive" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DeviceInstallation:PreventInstallationOfMatchingDeviceIDs
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions:DenyDeviceClassesRetroactive
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`, and check the `Also apply to matching devices that are already installed.` checkbox:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/System/Device Installation/Device
Installation Restrictions
Setting Name:   Prevent installation of devices using drivers that match these
device setup classes
Configuration:  Also apply to matching devices that are already installed.
(checkered)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

False (unchecked). (Pre-existing devices matching the device setup classes will not be disabled or removed.)

18.9.7.1.6 (BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Prevent installation of devices using drivers for these device setup' is set to 'IEEE 1394 device setup classes' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to specify a list of device setup class globally unique identifiers (GUIDs) for device drivers that Windows is prevented from installing. This policy setting takes precedence over any other policy setting that allows Windows to install a device.

If you enable this policy setting, Windows is prevented from installing or updating device drivers whose device setup class GUIDs appear in the list you create. If you enable this policy setting on a remote desktop server, the policy setting affects redirection of the specified devices from a remote desktop client to the remote desktop server.

If you disable or do not configure this policy setting, Windows can install and update devices as allowed or prevented by other policy settings.

Here are the four entries we recommend and what they translate to:

- {d48179be-ec20-11d1-b6b8-00c04fa372a7} - IEEE 1394 devices that support the SBP2 Protocol Class
- {7ebefbc0-3200-11d2-b4c2-00a0c9697d07} - IEEE 1394 devices that support the IEC-61883 Protocol Class
- {c06ff265-ae09-48f0-812c-16753d7cba83} - IEEE 1394 devices that support the AVC Protocol Class
- {6bdd1fc1-810f-11d0-bec7-08002be2092f} - IEEE 1394 Host Bus Controller Class

The full list of system-defined device setup classes available in Windows is here:

[System-Defined Device Setup Classes Available to Vendors | Microsoft Docs](#)

The recommended state for this setting is: {d48179be-ec20-11d1-b6b8-00c04fa372a7}, {7ebefbc0-3200-11d2-b4c2-00a0c9697d07}, {c06ff265-ae09-48f0-812c-16753d7cba83}, and {6bdd1fc1-810f-11d0-bec7-08002be2092f}

Note: IEEE 1394 has also been known/branded as *FireWire* (by Apple), *i.LINK* (by Sony) and *Lynx* (by Texas Instruments).

Rationale:

A BitLocker-protected computer may be vulnerable to Direct Memory Access (DMA) attacks when the computer is turned on or is in the Standby power state - this includes when the workstation is locked.

BitLocker with TPM-only authentication lets a computer enter the power-on state without any pre-boot authentication. Therefore, an attacker may be able to perform DMA attacks.

This issue is documented in Microsoft Knowledge Base article 2516445: [Blocking the SBP-2 driver and Thunderbolt controllers to reduce 1394 DMA and Thunderbolt DMA threats to BitLocker](#).

Impact:

IEEE 1394 drives & devices will be prevented from being installed in Windows.

Audit:

Navigate to the following registry location and confirm it is set to

```
{d48179be-ec20-11d1-b6b8-00c04fa372a7} {7ebefbc0-3200-11d2-b4c2-00a0C9697d07}  
{c06ff265-ae09-48f0-812c-16753d7cba83} {6bdd1fc1-810f-11d0-bec7-08002be2092f}.
```

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\DeviceInstall\Restrictions\DenyDeviceClasses:<numeric value>
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to {d48179be-ec20-11d1-b6b8-00c04fa372a7} {7ebefbc0-3200-11d2-b4c2-00a0c9697d07} {c06ff265-ae09-48f0-812c-16753d7cba83} {6bdd1fc1-810f-11d0-bec7-08002be2092f}::

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Device Installation\Device
Installation Restrictions
Setting Name:   Prevent installation of devices using drivers that match these
device setup classes: Prevent installation of devices using drivers for these
device setup
Configuration: {d48179be-ec20-11d1-b6b8-00c04fa372a7}, {7ebefbc0-3200-11d2-
b4c2-00a0c9697d07}, {c06ff265-ae09-48f0-812c-16753d7cba83}, and {6bdd1fc1-
810f-11d0-bec7-08002be2092f}
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

None. (No device setup classes are prevented from installation.)

Additional Information:

Documented in [MSKB 2516445](#).

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●

18.9.7.2 (L1) Ensure 'Prevent device metadata retrieval from the Internet' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to prevent Windows from retrieving device metadata from the Internet.

The recommended state for this setting is: `Enabled`.

Note: This will not prevent the installation of basic hardware drivers, but does prevent associated 3rd-party utility software from automatically being installed under the context of the `SYSTEM` account.

Rationale:

Installation of software should be conducted by an authorized system administrator and not a standard user. Allowing automatic 3rd-party software installations under the context of the `SYSTEM` account has potential for allowing unauthorized access via backdoors or installation software bugs.

Impact:

Standard users without administrator privileges will not be able to install associated 3rd-party utility software for peripheral devices. This may limit the use of advanced features of those devices unless/until an administrator installs the associated utility software for the device.

Audit:

Navigate to the following registry location and confirm it is set to `1`.

<code>HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Device Metadata:PreventDeviceMetadataFromNetwork</code>
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Device Installation
Setting Name:	Prevent device metadata retrieval from the Internet
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The setting in the Device Installation Settings dialog box controls whether Windows retrieves device metadata from the Internet.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 <u>Allowlist Authorized Software</u> Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.			
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			

18.9.8 Device Redirection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DeviceRedirection.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.9.9 Disk NV Cache

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DiskNVCache.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.10 Disk Quotas

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DiskQuota.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.11 Display

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Display.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.9.12 Distributed COM

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DCOM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.13 Driver Installation

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DeviceInstallation.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.14 Early Launch Antimalware

This section contains recommendations for configuring boot-start driver initialization settings.

This Group Policy section is provided by the Group Policy template `EarlyLaunchAM.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.14.1 (L1) Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good, unknown and bad but critical' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to specify which boot-start drivers are initialized based on a classification determined by an Early Launch Antimalware boot-start driver. The Early Launch Antimalware boot-start driver can return the following classifications for each boot-start driver:

- **Good:** The driver has been signed and has not been tampered with.
- **Bad:** The driver has been identified as malware. It is recommended that you do not allow known bad drivers to be initialized.
- **Bad, but required for boot:** The driver has been identified as malware, but the computer cannot successfully boot without loading this driver.
- **Unknown:** This driver has not been attested to by your malware detection application and has not been classified by the Early Launch Antimalware boot-start driver.

If you enable this policy setting you will be able to choose which boot-start drivers to initialize the next time the computer is started.

If your malware detection application does not include an Early Launch Antimalware boot-start driver or if your Early Launch Antimalware boot-start driver has been disabled, this setting has no effect and all boot-start drivers are initialized.

The recommended state for this setting is: `Enabled: Good, unknown and bad but critical`.

Rationale:

This policy setting helps reduce the impact of malware that has already infected your system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:BootStartDriverInitialization_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="SelectedDriverLoadPolicy" value="3" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\System:BootStartDriverInitialization
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Policies\EarlyLaunch:DriverLoadPolicy
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Good, unknown and bad but critical:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Early Launch Antimalware
Setting Name:	Boot-Start Driver Initialization Policy
Configuration:	Enabled: Good, unknown and bad but critical

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Boot-start drivers determined to be Good, Unknown or Bad but Boot Critical are initialized and the initialization of drivers determined to be bad is skipped.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.9.15 Enhanced Storage Access

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EnhancedStorage.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.9.16 File Classification Infrastructure

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `srm-fci.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.17 File Share Shadow Copy Agent

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FileServerVSSAgent.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.18 File Share Shadow Copy Provider

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy templates `FileServerVSSProvider.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.19 Filesystem (formerly NTFS Filesystem)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FileSys.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *NTFS Filesystem* but was renamed by Microsoft to *Filesystem* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

18.9.20 Folder Redirection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FolderRedirection.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.21 Group Policy

This section contains recommendations for Group Policy.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.21.1 (L1) Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The "Do not apply during periodic background processing" option prevents the system from updating affected policies in the background while the computer is in use. When background updates are disabled, policy changes will not take effect until the next user logon or system restart.

The recommended state for this setting is: `Enabled: FALSE` (unchecked).

Rationale:

Setting this option to false (unchecked) will ensure that domain policy changes take effect more quickly, as compared to waiting until the next user logon or system restart.

Impact:

Group Policies will be reapplied every time they are refreshed, which could have a slight impact on performance.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Group  
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}:NoBackgroundPolicy
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: FALSE (unchecked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Group Policy
Setting Name: Configure registry policy processing: Do not apply during periodic background processing
Configuration: Enabled: FALSE (unchecked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Group policies are not reapplied until the next login or restart.)

References:

1. [https://docs.microsoft.com/en-us/previous-versions/ms813374\(v=msdn.10\)?redirectedfrom=MSDN](https://docs.microsoft.com/en-us/previous-versions/ms813374(v=msdn.10)?redirectedfrom=MSDN)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	5.4 <u>Deploy System Configuration Management Tools</u> Deploy system configuration management tools that will automatically enforce and redeploy configuration settings to systems at regularly scheduled intervals.		●	●

18.9.21.2 (L1) Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

The "Process even if the Group Policy objects have not changed" option updates and reapplies policies even if the policies have not changed.

The recommended state for this setting is: `Enabled: TRUE` (checked).

Rationale:

Setting this option to true (checked) will ensure unauthorized changes that might have been configured locally are forced to match the domain-based Group Policy settings again.

Impact:

Group Policies will be reapplied even if they have not been changed, which could have a slight impact on performance.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Group  
Policy\{35378EAC-683F-11D2-A89A-00C04FBBCFA2}:NoGPListChanges
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: TRUE (checked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Group Policy
Setting Name: Configure registry policy processing: Process even if the Group Policy objects have not changed
Configuration: Enabled: TRUE (checked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Group policies are not reapplied if they have not been changed.)

References:

1. [https://docs.microsoft.com/en-us/previous-versions/ms813374\(v=msdn.10\)?redirectedfrom=MSDN](https://docs.microsoft.com/en-us/previous-versions/ms813374(v=msdn.10)?redirectedfrom=MSDN)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	5.4 <u>Deploy System Configuration Management Tools</u> Deploy system configuration management tools that will automatically enforce and redeploy configuration settings to systems at regularly scheduled intervals.		●	●

18.9.21.3 (L1) Ensure 'Continue experiences on this device' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether the Windows device is allowed to participate in cross-device experiences (continue experiences).

The recommended state for this setting is: `Disabled`.

Rationale:

A cross-device experience is when a system can access app and send messages to other devices. In an enterprise managed environment only trusted systems should be communicating within the network. Access to any other system should be prohibited.

Impact:

The Windows device will not be discoverable by other devices, and cannot participate in cross-device experiences.

Audit:

Navigate to the following registry location and confirm it is set to 0.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnableCdp

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Group Policy
Setting Name:	Continue experiences on this device
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

The default behavior depends on the Windows edition.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.9.21.4 (L1) Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents Group Policy from being updated while the computer is in use. This policy setting applies to Group Policy for computers, users and Domain Controllers.

The recommended state for this setting is: `Disabled`.

Rationale:

This setting ensures that group policy changes take effect more quickly, as compared to waiting until the next user logon or system restart.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm no key exists.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:  
DisableBkGndGroupPolicy
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Group Policy
Setting Name:	Turn off background refresh of Group Policy
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Updates can be applied while users are working.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	5.4 <u>Deploy System Configuration Management Tools</u> Deploy system configuration management tools that will automatically enforce and redeploy configuration settings to systems at regularly scheduled intervals.		●	●

18.9.22 Internet Communication Management

This section contains recommendations related to Internet Communication Management.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.22.1 Internet Communication settings

This section contains recommendations related to Internet Communication settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.22.1.1 (L2) Ensure 'Turn off access to the Store' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether to use the Store service for finding an application to open a file with an unhandled file type or protocol association. When a user opens a file type or protocol that is not associated with any applications on the computer, the user is given the choice to select a local application or use the Store service to find an application.

The recommended state for this setting is: `Enabled`.

Rationale:

The Store service is a retail outlet built into Windows, primarily for consumer use. In an enterprise managed environment the IT department should be managing the installation of all applications to reduce the risk of the installation of vulnerable software.

Impact:

The "Look for an app in the Store" item in the Open With dialog is removed.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoUseStoreOpenWith
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Internet Communication Management\Internet Communication settings Setting Name: Turn off access to the Store Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users are allowed to use the Store service and the Store item is available in the Open With dialog.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.2 (L1) Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether the computer can download print driver packages over HTTP. To set up HTTP printing, printer drivers that are not available in the standard operating system installation might need to be downloaded over HTTP.

The recommended state for this setting is: `Enabled`.

Rationale:

Users might download drivers that include malicious code.

Impact:

Print drivers cannot be downloaded over HTTP.

Note: This policy setting does not prevent the client computer from printing to printers on the intranet or the Internet over HTTP. It only prohibits downloading drivers that are not already installed locally.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:DisableDownloadingOfPrintDriversOverHTTP_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Connectivity:DisableDownloadingOfPrintDriversOverHTTP
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Printers:DisableWebPnPDownload
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/System/Internet Communication Management/Internet Communication settings
Setting Name: Turn off downloading of print drivers over HTTP
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can download print drivers over HTTP.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>2.7 Utilize Application Whitelisting</u> Utilize application whitelisting technology on all assets to ensure that only authorized software executes and all unauthorized software is blocked from executing on assets.			●

18.9.22.1.3 (L2) Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the Internet Connection Wizard can connect to Microsoft to download a list of Internet Service Providers (ISPs).

The recommended state for this setting is: *Enabled*.

Rationale:

In an enterprise managed environment we want to lower the risk of a user unknowingly exposing sensitive data.

Impact:

The "Choose a list of Internet Service Providers" path in the Internet Connection Wizard causes the wizard to exit. This prevents users from retrieving the list of ISPs, which resides on Microsoft servers.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Internet Connection Wizard:ExitOnMSICW
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Internet Communication
Management\Internet Communication settings
Setting Name:  Turn off Internet Connection Wizard if URL connection is
referring to Microsoft.com
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can connect to Microsoft to download a list of ISPs for their area.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.4 (L1) Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether Windows will download a list of providers for the Web publishing and online ordering wizards.

The recommended state for this setting is: `Enabled`.

Rationale:

Although the risk is minimal, enabling this setting will reduce the possibility of a user unknowingly downloading malicious content through this feature.

Impact:

Windows is prevented from downloading providers; only the service providers cached in the local registry are displayed.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:DisableInternetDownloadForWebPublishingAndOnlineOrderingWizards_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Connectivity:DisableInternetDownloadForWebPublishingAndOnlineOrderingWizards
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoWebServices
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/System/Internet Communication Management/Internet Communication settings Setting Name: Turn off Internet download for Web publishing and online ordering wizards Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (A list of providers is downloaded when the user uses the web publishing or online ordering wizards.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	7.4 <u>Maintain and Enforce Network-Based URL Filters</u> Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.			

18.9.22.1.5 (L2) Ensure 'Turn off printing over HTTP' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to disable the client computer's ability to print over HTTP, which allows the computer to print to printers on the intranet as well as the Internet.

The recommended state for this setting is: `Enabled`.

Note: This control affects printing over **both** HTTP and HTTPS.

Rationale:

Information that is transmitted over HTTP through this capability is not protected and can be intercepted by malicious users. For this reason, it is not often used in enterprise managed environments.

Impact:

The client computer will not be able to print to Internet printers over HTTP or HTTPS.

Note: This policy setting affects the client side of Internet printing only. Regardless of how it is configured, a computer could act as an Internet Printing server and make its shared printers available through HTTP.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Connectivity:DisablePrintingOverHTTP_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Connectivity:DisablePrintingOverHTTP
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Printers:DisableHTTPPrinting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/System/Internet Communication Management/Internet Communication settings Setting Name: Turn off printing over HTTP Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can choose to print to Internet printers over HTTP.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	13.3 <u>Monitor and Block Unauthorized Network Traffic</u> Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.			

18.9.22.1.6 (L2) Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the Windows Registration Wizard connects to Microsoft.com for online registration.

The recommended state for this setting is: `Enabled`.

Rationale:

Users in an enterprise managed environment should not be registering their own copies of Windows, providing their own PII in the process.

Impact:

Users are blocked from connecting to Microsoft.com for online registration and they cannot register their copy of Windows online.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Registration Wizard  
Control:NoRegistration
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Internet Communication
Management\Internet Communication settings
Setting Name:  Turn off Registration if URL connection is referring to
Microsoft.com
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can connect to Microsoft.com to complete the online Windows Registration.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.7 (L2) Ensure 'Turn off Search Companion content file updates' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether Search Companion should automatically download content updates during local and Internet searches.

The recommended state for this setting is: `Enabled`.

Rationale:

There is a small risk that users will unknowingly reveal sensitive information because of the topics they are searching for. This risk is very low because even if this setting is enabled users still must submit search queries to the desired search engine in order to perform searches.

Impact:

Search Companion does not download content updates during searches.

Note: Internet searches will still send the search text and information about the search to Microsoft and the chosen search provider. If you select Classic Search, the Search Companion feature will be unavailable. You can select Classic Search by clicking Start, Search, Change Preferences, and then Change Internet Search Behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\SearchCompanion:DisableContent  
FileUpdates
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Internet Communication Management\Internet Communication settings Setting Name: Turn off Search Companion content file updates Configuration: Enabled
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Search Companion downloads content updates unless the user is using Classic Search.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.8 (L2) Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the "Order Prints Online" task is available from Picture Tasks in Windows folders.

The Order Prints Online Wizard is used to download a list of providers and allow users to order prints online.

The recommended state for this setting is: `Enabled`.

Rationale:

In an enterprise managed environment we want to lower the risk of a user unknowingly exposing sensitive data.

Impact:

The task "Order Prints Online" is removed from Picture Tasks in File Explorer folders.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoOnlinePrintsWizard
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Internet Communication Management\Internet Communication settings Setting Name: Turn off the "Order Prints" picture task Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The "Order Prints Online" task is displayed in Picture Tasks in File Explorer folders.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.9 (L2) Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the tasks Publish this file to the Web, Publish this folder to the Web, and Publish the selected items to the Web are available from File and Folder Tasks in Windows folders. The Web Publishing wizard is used to download a list of providers and allow users to publish content to the Web.

The recommended state for this setting is: *Enabled*.

Rationale:

Users may publish confidential or sensitive information to a public service outside of the control of the organization.

Impact:

The "Publish to Web" task is removed from File and Folder tasks in Windows folders.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoPublishingWizard
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Internet Communication Management\Internet Communication settings Setting Name: Turn off the "Publish to Web" task for files and folders Configuration: Enabled
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The "Publish to Web" task is shown in File and Folder tasks in Windows folders.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.10 (L2) Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the Windows Customer Experience Improvement Program can collect anonymous information about how Windows is used.

Microsoft uses information collected through the Windows Customer Experience Improvement Program to improve features that are most used and to detect flaws so that they can be corrected more quickly. Enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose. The recommended state for this setting is: *Enabled*.

Rationale:

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers.

Impact:

Windows Messenger will not collect usage information, and the user settings to enable the collection of usage information will not be shown.

Audit:

Navigate to the following registry location and confirm it is set to 2.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Messenger\Client:CEIP
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Internet Communication
Management\Internet Communication settings
Setting Name:  Turn off the Windows Messenger Customer Experience Improvement
Program
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Users have the choice to opt-in and allow information to be collected.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.11 (L2) Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether Windows Messenger can collect anonymous information about how the Windows Messenger software and service is used.

Microsoft uses information collected through the Windows Customer Experience Improvement Program to detect software flaws so that they can be corrected more quickly, enabling this setting will reduce the amount of data Microsoft is able to gather for this purpose. The recommended state for this setting is: `Enabled`.

Rationale:

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers.

Impact:

All users are opted out of the Windows Customer Experience Improvement Program.

Audit:

Navigate to the following registry location and confirm it is set to 0.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\SQMClient\Windows:CEIPEnable

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\System\Internet Communication Management\Internet Communication settings Setting Name: Turn off Windows Customer Experience Improvement Program Configuration: Enabled
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

The Administrator can use the Problem Reports and Solutions component in Control Panel to enable Windows Customer Experience Improvement Program for all users.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.22.1.12 (L2) Ensure 'Turn off Windows Error Reporting' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting controls whether or not errors are reported to Microsoft.

Error Reporting is used to report information about a system or application that has failed or has stopped responding and is used to improve the quality of the product.

The recommended state for this setting is: `Enabled`.

Rationale:

If a Windows Error occurs in a secure, enterprise managed environment, the error should be reported directly to IT staff for troubleshooting and remediation. There is no benefit to the corporation to report these errors directly to Microsoft, and there is some risk of unknowingly exposing sensitive data as part of the error.

Impact:

Users are not given the option to report errors to Microsoft.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ErrorReporting:DisableWindowsErrorReporting_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ErrorReporting:DisableWindowsErrorReporting
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Windows Error Reporting:Disabled
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Windows Error Reporting
Setting Name:	Disable Windows Error Reporting
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Errors may be reported to Microsoft via the Internet or to a corporate file share.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.23 iSCSI

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `iSCSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.24 KDC

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `KDC.admx/adml` that is included with the Microsoft Windows Server 2008 (non-R2) Administrative Templates (or newer).

18.9.25 Kerberos

This section contains recommendations related to Kerberos.

This Group Policy section is provided by the Group Policy template `Kerberos.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.25.1 (L2) Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to set support for Kerberos to attempt authentication using the certificate for the device to the domain.

Support for device authentication using certificate will require connectivity to a DC in the device account domain which supports certificate authentication for computer accounts.

The recommended state for this setting is: `Enabled: Automatic`.

Rationale:

Having stronger device authentication with the use of certificates is strongly encouraged over standard username and password authentication. Having this set to Automatic will allow certificate based authentication to be used whenever possible.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0 (1st value) and 1 (2nd value).

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\kerberos\parameters:DevicePKInitBehavior
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System\kerberos\parameters:DevicePKInitEnabled
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Automatic`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Kerberos
Setting Name:	Support device authentication using certificate
Configuration:	Enabled: Automatic

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Automatic. (Devices will attempt to authenticate using their certificate. If the DC does not support computer account authentication using certificates then authentication with password will be attempted.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	1.6 Address Unauthorized Assets Ensure that unauthorized assets are either removed from the network, quarantined or the inventory is updated in a timely manner.			
v7	1.8 Utilize Client Certificates to Authenticate Hardware Assets Use client certificates to authenticate hardware assets connecting to the organization's trusted network.			

18.9.26 Kernel DMA Protection

This section contains recommendations related to Kernel DMA Protection.

This Group Policy section is provided by the Group Policy template `DmaGuard.admx/adml` that is included with the Microsoft Windows 10 Release 1809 and Server 2019 Administrative Templates (or newer).

18.9.26.1 (BL) Ensure 'Enumeration policy for external devices incompatible with Kernel DMA Protection' is set to 'Enabled: Block All' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 1 (L1) + BitLocker (BL) + Next Generation Windows Security (NG)
- Level 2 (L2) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL) + Next Generation Windows Security (NG)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy is intended to provide additional security against external DMA-capable devices. It allows for more control over the enumeration of external DMA-capable devices that are not compatible with DMA Remapping/device memory isolation and sandboxing.

The recommended state for this setting is: `Enabled: Block All`.

Note: This policy does not apply to 1394, PCMCIA or ExpressCard devices. The protection also only applies to Windows 10 R1803 or higher, and also requires a UEFI BIOS to function.

Note #2: More information on this feature is available at this link: [Kernel DMA Protection for Thunderbolt™ 3 \(Windows 10\) | Microsoft Docs](#).

Rationale:

Device memory sandboxing allows the OS to leverage the I/O Memory Management Unit (IOMMU) of a device to block unpermitted I/O, or memory access, by the peripheral.

Impact:

External devices that are not compatible with DMA-remapping will not be enumerated and will not function unless/until the user has logged in successfully *and* has an unlocked user session. Once enumerated, these devices will continue to function, regardless of the state of the session. Devices that **are** compatible with DMA-remapping will be enumerated immediately, with their device memory isolated.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\DmaGuard:DeviceEnumerationPolicy_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\DmaGuard:DeviceEnumerationPolicy
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Block All:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URL:      ./Device/Vendor/MSFT/Policy/Config/DmaGuard/DeviceEnumerationPolicy
Data Type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Windows 10 R1803 and newer: Enabled if UEFI BIOS is present. Disabled if using legacy BIOS.

Older OSes: Not supported (i.e. Disabled).

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-dmaguard#deviceenumerationpolicy>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	1.4 <u>Maintain Detailed Asset Inventory</u> Maintain an accurate and up-to-date inventory of all technology assets with the potential to store or process information. This inventory shall include all hardware assets, whether connected to the organization's network or not.			

18.9.27 Locale Services

This section contains recommendations related to Locale Services.

This Group Policy section is provided by the Group Policy template `Globalization.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.27.1 (L2) Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy prevents automatic copying of user input methods to the system account for use on the sign-in screen. The user is restricted to the set of input methods that are enabled in the system account.

The recommended state for this setting is: `Enabled`.

Rationale:

This is a way to increase the security of the system account.

Impact:

Users will have input methods enabled for the system account on the sign-in page.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Control  
Panel\International\BlockUserInputMethodsForSignIn
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Locale Services
Setting Name:	Disallow copying of user input methods to the system account for sign-in
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users will be able to use input methods enabled for their user account on the sign-in page.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.9.28 Logon

This section contains recommendations related to the logon process and lock screen.

This Group Policy section is provided by the Group Policy template `Logon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.28.1 (L1) Ensure 'Block user from showing account details on sign-in' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy prevents the user from showing account details (email address or user name) on the sign-in screen.

The recommended state for this setting is: `Enabled`.

Rationale:

An attacker with access to the console (for example, someone with physical access or someone who is able to connect to the workstation through Remote Desktop Services) could view the name of the last user who logged on to the server. The attacker could then try to guess the password, use a dictionary, or use a brute-force attack to try and log on.

Impact:

Users cannot choose to show account details on the sign-in screen.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:BlockUserFromShowingAccountDetailsOnSignin
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Logon
Setting Name:	Block user from showing account details on sign-in
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users may choose to show account details on the sign-in screen.)

18.9.28.2 (L1) Ensure 'Do not display network selection UI' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to control whether anyone can interact with available networks UI on the logon screen.

The recommended state for this setting is: `Enabled`.

Rationale:

An unauthorized user could disconnect the PC from the network or can connect the PC to other available networks without signing into Windows.

Impact:

The PC's network connectivity state cannot be changed without signing into Windows.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsLogon:DontDisplayNetworkSelectionUI_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\WindowsLogon:DontDisplayNetworkSelectionUI
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:DontDisplayNetworkSelectionUI
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Logon
Setting Name:	Do not display network selection UI
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Any user can disconnect the PC from the network or can connect the PC to other available networks without signing into Windows.)

18.9.28.3 (L1) Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents connected users from being enumerated on domain-joined computers.

The recommended state for this setting is: *Enabled*.

Rationale:

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

Impact:

The Logon UI will not enumerate any connected users on domain-joined computers.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:DontEnumerateConnectedUsers
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Logon
Setting Name:	Do not enumerate connected users on domain-joined computers
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Connected users will be enumerated on domain-joined computers.)

18.9.28.4 (L1) Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows local users to be enumerated on domain-joined computers.

The recommended state for this setting is: `Disabled`.

Rationale:

A malicious user could use this feature to gather account names of other users, that information could then be used in conjunction with other types of attacks such as guessing passwords or social engineering. The value of this countermeasure is small because a user with domain credentials could gather the same account information using other methods.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsLogon:EnumerateLocalUsersOnDomainJoinedComputers_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\WindowsLogon:EnumerateLocalUsersOnDomainJoinedComputers
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:EnumerateLocalUsers
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Logon
Setting Name:	Enumerate local users on domain-joined computers
Configuration:	Disabled

- Select *OK* or *Save*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The Logon UI will not enumerate local users on domain-joined computers.)

18.9.28.5 (L1) Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to prevent app notifications from appearing on the lock screen.

The recommended state for this setting is: `Enabled`.

Rationale:

App notifications might display sensitive business or personal data.

Impact:

No app notifications are displayed on the lock screen.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsLogon:DisableLockScreenAppNotifications_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\WindowsLogon:DisableLockScreenAppNotifications
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:DisableLockScreenAppNotifications
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Logon
Setting Name:	Turn off app notifications on the lock screen
Configured:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can choose which apps display notifications on the lock screen.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>16.11 Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.	●	●	●

18.9.28.6 (L1) Ensure 'Turn off picture password sign-in' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to control whether a domain user can sign in using a picture password.

The recommended state for this setting is: `Enabled`.

Note: If the picture password feature is permitted, the user's domain password is cached in the system vault when using it.

Rationale:

Picture passwords bypass the requirement for a typed complex password. In a shared work environment, a simple shoulder surf where someone observed the on-screen gestures would allow that person to gain access to the system without the need to know the complex password. Vertical monitor screens with an image are much more visible at a distance than horizontal key strokes, increasing the likelihood of a successful observation of the mouse gestures.

Impact:

Users will not be able to set up or sign in with a picture password.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Credential  
Providers\BlockPicturePassword_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
CredentialProviders\BlockPicturePassword
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System\BlockDomainPict  
urePassword
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Logon
Setting Name:	Turn off picture password sign-in
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can set up and use a picture password.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

18.9.28.7 (L1) Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to control whether a domain user can sign in using a convenience PIN. In Windows 10, convenience PIN was replaced with Passport, which has stronger security properties. To configure Passport for domain users, use the policies under Computer Configuration\Administrative Templates\Windows Components\Microsoft Passport for Work.

Note: The user's domain password will be cached in the system vault when using this feature.

The recommended state for this setting is: `Disabled`.

Rationale:

A PIN is created from a much smaller selection of characters than a password, so in most cases a PIN will be much less robust than a password.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Credential  
Providers:AllowPINLogon_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
CredentialProviders:AllowPINLogon
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:AllowDomainPINL  
ogon
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Logon
Setting Name:	Turn on convenience PIN sign-in
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (A domain user can't set up and use a convenience PIN.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

18.9.29 Mitigation Options

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.9.30 Net Logon

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Netlogon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.31 OS Policies

This section contains recommendations related to OS Policies.

This Group Policy section is provided by the Group Policy template `OSPolicy.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.9.31.1 (L2) Ensure 'Allow Clipboard synchronization across devices' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting determines whether Clipboard contents can be synchronized across devices.

The recommended state for this setting is: `Disabled`.

Rationale:

In high security environments, clipboard data should stay local to the system and not synced across devices, as it may contain very sensitive information that must be contained locally.

Impact:

Clipboard contents will not be shareable to other devices.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Privacy:AllowCrossDeviceClipboard_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Privacy:AllowCrossDeviceClipboard
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Privacy/AllowCrossDeviceClipboard
Data type:      Integer
Value:          0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Clipboard contents are allowed to be synchronized across devices logged in under the same Microsoft account or Azure AD account.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

18.9.31.2 (L2) Ensure 'Allow upload of User Activities' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting determines whether published User Activities can be uploaded to the cloud.

The recommended state for this setting is: `Disabled`.

Rationale:

Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information.

Impact:

Activities of type User Activity are not allowed to be uploaded to the cloud. The Timeline feature will not function across devices.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Privacy:UploadUserActivities_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Privacy:UploadUserActivities
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Privacy/UploadUserActivities
Data type:      Integer
Value:          0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Activities of type User Activity are allowed to be uploaded to the cloud.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.32 Performance Control Panel

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `PerfCenterCPL.admx/adml` that is only included with the Microsoft Windows Vista through the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

18.9.33 PIN Complexity

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Passport.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.9.34 Power Management

This section contains recommendations for Power Management settings.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.34.1 Button Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.34.2 Energy Saver Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.9.34.3 Hard Disk Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.34.4 Notification Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.34.5 Power Throttling Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.9.34.6 Sleep Settings

This section contains recommendations related to Power Management Sleep mode.

This Group Policy section is provided by the Group Policy template `Power.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.34.6.1 (L1) Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems.

The recommended state for this setting is: `Disabled`.

Rationale:

Disabling this setting ensures that the computer will not be accessible to attackers over a WLAN network while left unattended, on battery and in a sleep state.

Impact:

Network connectivity in standby (while on battery) is not guaranteed. This connectivity restriction currently only applies to WLAN networks only, but is subject to change (according to Microsoft).

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\f15576e8-98b7-4186-b944-eafa664402d9:DCSettingIndex
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Power Management\Sleep Settings
Setting Name:	Allow network connectivity during connected-standby (on battery)
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Network connectivity will be maintained in standby while on battery.)

References:

1. <https://docs.microsoft.com/en-us/windows-hardware/design/device-experiences/modern-standby>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.34.6.2 (L1) Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to control the network connectivity state in standby on modern standby-capable systems.

The recommended state for this setting is: `Disabled`.

Rationale:

Disabling this setting ensures that the computer will not be accessible to attackers over a WLAN network while left unattended, plugged in and in a sleep state.

Impact:

Network connectivity in standby (while plugged in) is not guaranteed. This connectivity restriction currently only applies to WLAN networks only, but is subject to change (according to Microsoft).

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\f15576e8-98b7-4186-b944-eafa664402d9:ACSettingIndex
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\System\Power Management\Sleep Settings
Setting Name:	Allow network connectivity during connected-standby (plugged in)
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Network connectivity will be maintained in standby while plugged in.)

References:

1. <https://docs.microsoft.com/en-us/windows-hardware/design/device-experiences/modern-standby>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.34.6.3 (BL) Ensure 'Allow standby states (S1-S3) when sleeping (on battery)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

Dictates whether or not Windows is allowed to use standby states when sleeping the computer.

The recommended state for this setting is: `Disabled`.

Rationale:

System sleep states (S1-S3) keep power to the RAM which may contain secrets, such as the BitLocker volume encryption key. An attacker finding a computer in sleep states (S1-S3) could directly attack the memory of the computer and gain access to the secrets through techniques such as RAM reminisce and direct memory access (DMA).

Impact:

Users will not be able to use Sleep (S3) while on battery, which resumes faster than Hibernation (S4).

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Power:AllowStandbyStatesWhenSleepingOnBattery_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Power:AllowStandbyStatesWhenSleepingOnBattery
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\abfc2519-3608-4c2a-94ea-171b0ed546ab:DCSettingIndex
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Power Management/Sleep Settings
Setting Name:	Allow standby states (S1-S3) when sleeping (on battery)
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Windows uses standby states to put the computer in a sleep state.)

18.9.34.6.4 (BL) Ensure 'Allow standby states (S1-S3) when sleeping (plugged in)' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

Dictates whether or not Windows is allowed to use standby states when sleeping the computer.

The recommended state for this setting is: `Disabled`.

Rationale:

System sleep states (S1-S3) keep power to the RAM which may contain secrets, such as the BitLocker volume encryption key. An attacker finding a computer in sleep states (S1-S3) could directly attack the memory of the computer and gain access to the secrets through techniques such as RAM reminisce and direct memory access (DMA).

Impact:

Users will not be able to use Sleep (S3) while plugged in, which resumes faster than Hibernation (S4).

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Power:AllowStandbyWhenSleepingPluggedIn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Power:AllowStandbyWhenSleepingPluggedIn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\abfc2519-3608-4c2a-94ea-171b0ed546ab:ACSettingIndex
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Power Management/Sleep Settings
Setting Name:	Allow standby states (S1-S3) when sleeping (plugged in)
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled. (Windows uses standby states to put the computer in a sleep state.)

18.9.34.6.5 (L1) Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Specifies whether or not the user is prompted for a password when the system resumes from sleep.

The recommended state for this setting is: `Enabled`.

Rationale:

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Power:RequirePasswordWhenComputerWakesOnBattery_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\GUID}\Default\Power:RequirePasswordWhenComputerWakesOnBattery
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51:DCSettingIndex
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Power Management/Sleep Settings
Setting Name:	Require a password when a computer wakes (on battery)
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled. (The user is prompted for a password when the system resumes from sleep while on battery.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.9.34.6.6 (L1) Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Specifies whether or not the user is prompted for a password when the system resumes from sleep.

The recommended state for this setting is: `Enabled`.

Rationale:

Enabling this setting ensures that anyone who wakes an unattended computer from sleep state will have to provide logon credentials before they can access the system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Power:RequirePasswordWhenComputerWakesPluggedIn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Power:RequirePasswordWhenComputerWakesPluggedIn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Power\PowerSettings\0e796bdb-100d-47d6-a2d5-f7d2daa51f51:ACSettingIndex
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Power Management/Sleep Settings
Setting Name:	Require a password when a computer wakes (plugged in)
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note 2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled. (The user is prompted for a password when the system resumes from sleep while plugged in.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.9.35 Recovery

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ReAgent.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.9.36 Remote Assistance

This section contains recommendations related to Remote Assistance.

This Group Policy section is provided by the Group Policy template `RemoteAssistance.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.36.1 (L1) Ensure 'Configure Offer Remote Assistance' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to turn on or turn off Offer (Unsolicited) Remote Assistance on this computer.

Help desk and support personnel will not be able to proactively offer assistance, although they can still respond to user assistance requests.

The recommended state for this setting is: `Disabled`.

Rationale:

A user might be tricked and accept an unsolicited Remote Assistance offer from a malicious user.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteAssistance:UnsolicitedRemoteAssistance_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\GUID}\Default\RemoteAssistance:UnsolicitedRemoteAssistance
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fAllowUnsolicited
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Remote Assistance
Setting Name:	Configure Offer Remote Assistance
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users on this computer cannot get help from their corporate technical support staff using Offer (Unsolicited) Remote Assistance.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.36.2 (L1) Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to turn on or turn off Solicited (Ask for) Remote Assistance on this computer.

The recommended state for this setting is: `Disabled`.

Rationale:

There is slight risk that a rogue administrator will gain access to another user's desktop session, however, they cannot connect to a user's computer unannounced or control it without permission from the user. When an expert tries to connect, the user can still choose to deny the connection or give the expert view-only privileges. The user must explicitly click the Yes button to allow the expert to remotely control the workstation.

Impact:

Users on this computer cannot use e-mail or file transfer to ask someone for help. Also, users cannot use instant messaging programs to allow connections to this computer.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteAssistance:SolicitedRemoteAssistance_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteAssistance:SolicitedRemoteAssistance
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:fAllowToGetHelp
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Remote Assistance
Setting Name:	Configure Solicited Remote Assistance
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Users can turn on or turn off Solicited (Ask for) Remote Assistance themselves in System Properties in Control Panel. Users can also configure Remote Assistance settings.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.37 Remote Procedure Call

This section contains recommendations related to Remote Procedure Call.

This Group Policy section is provided by the Group Policy template `RPC.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.37.1 (L1) Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether RPC clients authenticate with the Endpoint Mapper Service when the call they are making contains authentication information. The Endpoint Mapper Service on computers running Windows NT4 (all service packs) cannot process authentication information supplied in this manner. This policy setting can cause a specific issue with *1-way* forest trusts if it is applied to the *trusting* domain DCs (see Microsoft [KB3073942](#)), so we do not recommend applying it to Domain Controllers.

Note: This policy will not in effect until the system is rebooted.

The recommended state for this setting is: `Enabled`.

Rationale:

Anonymous access to RPC services could result in accidental disclosure of information to unauthenticated users.

Impact:

RPC clients will authenticate to the Endpoint Mapper Service for calls that contain authentication information. Clients making such calls will not be able to communicate with the Windows NT4 Server Endpoint Mapper Service.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteProcedureCall:RPCEndpointMapperClientAuthentication_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteProcedureCall:RPCEndpointMapperClientAuthentication
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Rpc:EnableAuthEpResolution
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Remote Procedure Call
Setting Name:	Enable RPC Endpoint Mapper Client Authentication
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (RPC clients will not authenticate to the Endpoint Mapper Service, but they will be able to communicate with the Windows NT4 Server Endpoint Mapper Service.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.9.37.2 (L1) Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls how the RPC server runtime handles unauthenticated RPC clients connecting to RPC servers.

This policy setting impacts all RPC applications. In a domain environment this policy setting should be used with caution as it can impact a wide range of functionality including group policy processing itself. Reverting a change to this policy setting can require manual intervention on each affected machine. **This policy setting should never be applied to a Domain Controller.**

A client will be considered an authenticated client if it uses a named pipe to communicate with the server or if it uses RPC Security. RPC Interfaces that have specifically requested to be accessible by unauthenticated clients may be exempt from this restriction, depending on the selected value for this policy setting.

-- **"None"** allows all RPC clients to connect to RPC Servers running on the machine on which the policy setting is applied.

-- **"Authenticated"** allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. Exemptions are granted to interfaces that have requested them.

-- **"Authenticated without exceptions"** allows only authenticated RPC Clients (per the definition above) to connect to RPC Servers running on the machine on which the policy setting is applied. No exceptions are allowed. **This value has the potential to cause serious problems and is not recommended.**

Note: This policy setting will not be applied until the system is rebooted.

The recommended state for this setting is: `Enabled: Authenticated`.

Rationale:

Unauthenticated RPC communication can create a security vulnerability.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteProcedureCall:RestrictUnauthenticatedRPCClients_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="RpcRestrictRemoteClientList" value="1" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteProcedureCall:RestrictUnauthenticatedRPCClients
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Rpc:RestrictRemoteClients
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled: Authenticated**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/System/Remote Procedure Call
Setting Name:	Restrict Unauthenticated RPC clients
Configuration:	Enabled: Authenticated

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: Authenticated. (Only authenticated RPC clients are allowed to connect to RPC servers running on the machine. Exemptions are granted to interfaces that have requested them.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.9.38 Removable Storage Access

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `RemovableStorage.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.39 Scripts

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Scripts.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.40 Security Account Manager

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SAM.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.9.41 Server Manager

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ServerManager.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.42 Service Control Manager Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ServiceControlManager.admx/adml` that is included with the Microsoft Windows 10 Release 1903 Administrative Templates (or newer).

18.9.43 Shutdown

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinInit.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.9.44 Shutdown Options

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Winsrv.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.45 Storage Health

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `StorageHealth.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.9.46 Storage Sense

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `StorageSense.admx/adml` that is included with the Microsoft Windows 10 Release 1903 Administrative Templates (or newer).

18.9.47 System Restore

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SystemRestore.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.48 Troubleshooting and Diagnostics

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.48.1 Microsoft Support Diagnostic Tool

This section contains recommendations related to the Microsoft Support Diagnostic Tool.

This Group Policy section is provided by the Group Policy template `MSDT.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.48.1.1 (L2) Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting configures Microsoft Support Diagnostic Tool (MSDT) interactive communication with the support provider. MSDT gathers diagnostic data for analysis by support professionals.

The recommended state for this setting is: `Disabled`.

Rationale:

Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information.

Impact:

MSDT cannot run in support mode, and no data can be collected or sent to the support provider.

Audit:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\ScriptedDiagnosticsProvider\Policy:DisableQueryRemoteServer
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Troubleshooting and
Diagnostics\Microsoft Support Diagnostic Tool
Setting Name:  Microsoft Support Diagnostic Tool: Turn on MSDT interactive
communication with support provider
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Users can use MSDT to collect and send diagnostic data to a support professional to resolve a problem. By default, the support provider is set to Microsoft Corporation.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.49 Trusted Platform Module Services

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TPM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.50 User Profiles

This section contains recommendations related to User Profiles.

This Group Policy section is provided by the Group Policy template `UserProfiles.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.50.1 (L2) Ensure 'Turn off the advertising ID' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting turns off the advertising ID, preventing apps from using the ID for experiences across apps.

The recommended state for this setting is: `Enabled`.

Rationale:

Tracking user activity for advertising purposes, even anonymously, may be a privacy concern. In an enterprise managed environment, applications should not need or require tracking for targeted advertising.

Impact:

The advertising ID is turned off. Apps can't use the ID for experiences across apps.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Privacy:DisableAdvertisingId_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Privacy:DisableAdvertisingID
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\AdvertisingInfo:DisabledByGroupPolicy
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Privacy/DisableAdvertisingID
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can control whether apps can use the advertising ID for experiences across apps.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.9.51 Windows File Protection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsFileProtection.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.52 Windows HotStart

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `HotStart.admx/adml` that is only included with the Microsoft Windows Vista through the Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

18.9.53 Windows Time Service

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.53.1 Windows Time Service

This section contains recommendations related to the Windows Time Service.

This Group Policy section is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.53.1.1 Time Providers

This section contains recommendations related to Time Providers.

This Group Policy section is provided by the Group Policy template `W32Time.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.9.53.1.1.1 (L2) Ensure 'Enable Windows NTP Client' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether the Windows NTP Client is enabled. Enabling the Windows NTP Client allows your computer to synchronize its computer clock with other NTP servers. You might want to disable this service if you decide to use a third-party time provider.

The recommended state for this setting is: *Enabled*.

Rationale:

A reliable and accurate account of time is important for a number of services and security requirements, including but not limited to distributed applications, authentication services, multi-user databases and logging services. The use of an NTP client (with secure operation) establishes functional accuracy and is a focal point when reviewing security relevant events.

Impact:

You can set the local computer clock to synchronize time with NTP servers.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\W32Time\TimeProviders\NtpClient:Enabled
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\System\Windows Time Service\Time
Providers
Setting Name:  Enable Windows NTP Client
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The local computer clock does not synchronize time with NTP servers.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.4 <u>Standardize Time Synchronization</u> Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.		●	●
v7	6.1 <u>Utilize Three Synchronized Time Sources</u> Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.		●	●

18.9.53.1.1.2 (L2) Ensure 'Enable Windows NTP Server' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to specify whether the Windows NTP Server is enabled.

The recommended state for this setting is: `Disabled`.

Rationale:

The configuration of proper time synchronization is critically important in an enterprise managed environment both due to the sensitivity of Kerberos authentication timestamps and also to ensure accurate security logging.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\W32Time\TimeProviders\NtpServer:Enabled
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\System\Windows Time Service\Time Providers
Setting Name: Enable Windows NTP Server
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The computer cannot service NTP requests from other computers.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.4 Standardize Time Synchronization Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.		●	●
v7	6.1 Utilize Three Synchronized Time Sources Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.		●	●

18.10 Windows Components

This section contains recommendations for Windows Component settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.1 ActiveX Installer Service

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ActiveXInstallService.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.2 Add features to Windows 10 (formerly Windows Anytime Upgrade)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsAnytimeUpgrade.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Note: This section was initially named *Windows Anytime Upgrade* but was renamed by Microsoft to *Add features to Windows x* starting with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

18.10.3 App Package Deployment

This section contains recommendations for App Package Deployment settings.

This Group Policy section is provided by the Group Policy template `AppxPackageManager.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.3.1 (L2) Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

Manages a Windows app's ability to share data between users who have installed the app. Data is shared through the `SharedLocal` folder. This folder is available through the `Windows.Storage` API.

The recommended state for this setting is: `Disabled`.

Rationale:

Users of a system could accidentally share sensitive data with other users on the same system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:AllowSharedUserAppData_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:AllowSharedUserAppData
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/AllowSharedUserAppData
Data type:      Integer
Value:          0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows apps won't be able to share app data with other instances of that app.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 <u>Protect Information through Access Control Lists</u> Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

18.10.4 App Privacy

This section contains recommendations for App Privacy settings.

This Group Policy section is provided by the Group Policy template `AppPrivacy.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.10.4.1 (L1) Ensure 'Let Windows apps activate with voice while the system is locked' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether Windows apps can be activated by voice (apps and Cortana) while the system is locked.

The recommended state for this setting is: `Disabled`.

Rationale:

Access to any computer resource should not be allowed when the device is locked.

Impact:

Users will not be able to activate apps while the computer is locked.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Privacy:LetAppsActivateWithVoiceAboveLock_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Privacy:LetAppsActivateWithVoiceAboveLock
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device Restrictions/Locked Screen Experience
Setting Name:	Voice activate apps from locked screen
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Not configured (The user can decide whether Windows apps can interact with applications using speech while the system is locked by using Settings > Privacy on the device.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.5 App runtime

This section contains recommendations for App runtime settings.

This Group Policy section is provided by the Group Policy template `AppXRuntime.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.5.1 (L1) Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting lets you control whether Microsoft accounts are optional for Windows Store apps that require an account to sign in. This policy only affects Windows Store apps that support it.

The recommended state for this setting is: *Enabled*.

Rationale:

Enabling this setting allows an organization to use their enterprise user accounts instead of using their Microsoft accounts when accessing Windows store apps. This provides the organization with greater control over relevant credentials. Microsoft accounts cannot be centrally managed and as such enterprise credential security policies cannot be applied to them, which could put any information accessed by using Microsoft accounts at risk.

Impact:

Windows Store apps that typically require a Microsoft account to sign in will allow users to sign in with an enterprise account instead.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\AppDataRuntime:AllowMicrosoftAccountsToBeOptional_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\GUID}\Default\AppDataRuntime:AllowMicrosoftAccountsToBeOptional
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:MSAOptional
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/App runtime
Setting Name:	Allow Microsoft accounts to be optional
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users will need to sign in with a Microsoft account.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.		●	●
v7	16.2 <u>Configure Centralized Point of Authentication</u> Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.		●	●

18.10.5.2 (L2) Ensure 'Block launching Universal Windows apps with Windows Runtime API access from hosted content.' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting controls whether Microsoft Store apps with Windows Runtime API access directly from web content can be launched.

The recommended state for this setting is: *Enabled*.

Rationale:

Blocking apps from the web with direct access to the Windows API can prevent malicious apps from being run on a system. Only system administrators should be installing approved applications.

Impact:

Universal Windows apps which declare Windows Runtime API access in the `ApplicationContentUriRules` section of the manifest cannot be launched (Universal Windows apps which have not declared Windows Runtime API access in the manifest will not be affected).

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:  
BlockHostedAppAccessWinRT
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\App Runtime
Setting Name: Block launching Universal Windows apps with Windows Runtime API access from hosted content
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (All Universal Windows apps can be launched.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.6 Application Compatibility

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `AppCompat.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.7 AutoPlay Policies

This section contains recommendations for AutoPlay policies.

This Group Policy section is provided by the Group Policy template `AutoPlay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.7.1 (L1) Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting disallows AutoPlay for MTP devices like cameras or phones.

The recommended state for this setting is: `Enabled`.

Rationale:

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

Impact:

AutoPlay will not be allowed for MTP devices like cameras or phones.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Autoplay:DisallowAutoplayForNonVolumeDevices_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Autoplay:DisallowAutoplayForNonVolumeDevices
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoAutoplayfor nonVolume
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/AutoPlay Policies
Setting Name:	Disallow Autoplay for non-volume devices
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (AutoPlay is enabled for non-volume devices.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 <u>Disable Autorun and Autoplay for Removable Media</u> Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	8.5 <u>Configure Devices Not To Auto-run Content</u> Configure devices to not auto-run content from removable media.	●	●	●

18.10.7.2 (L1) Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting sets the default behavior for Autorun commands. Autorun commands are generally stored in `autorun.inf` files. They often launch the installation program or other routines.

The recommended state for this setting is: `Enabled: Do not execute any autorun commands`.

Rationale:

Prior to Windows Vista, when media containing an autorun command is inserted, the system will automatically execute the program without user intervention. This creates a major security concern as code may be executed without user's knowledge. The default behavior starting with Windows Vista is to prompt the user whether autorun command is to be run. The autorun command is represented as a handler in the Autoplay dialog.

Impact:

AutoRun commands will be completely disabled.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Autoplay:SetDefaultAutoRunBehavior_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="NoAutorun_Dropdown" value="1" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Autoplay:SetDefaultAutoRunBehavior
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoAutorun
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Do not execute any autorun commands`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/AutoPlay Policies
Setting Name:	Set the default behavior for AutoRun
Configuration:	Enabled: Do not execute any autorun commands

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows will prompt the user whether autorun command is to be run.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>10.3 Disable Autorun and Autoplay for Removable Media</u> Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	<u>8.5 Configure Devices Not To Auto-run Content</u> Configure devices to not auto-run content from removable media.	●	●	●

18.10.7.3 (L1) Ensure 'Turn off Autoplay' is set to 'Enabled: All drives' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Autoplay starts to read from a drive as soon as you insert media in the drive, which causes the setup file for programs or audio media to start immediately. An attacker could use this feature to launch a program to damage the computer or data on the computer. Autoplay is disabled by default on some removable drive types, such as floppy disk and network drives, but not on CD-ROM drives.

Note: You cannot use this policy setting to enable Autoplay on computer drives in which it is disabled by default, such as floppy disk and network drives.

The recommended state for this setting is: `Enabled: All drives`.

Rationale:

An attacker could use this feature to launch a program to damage a client computer or data on the computer.

Impact:

Autoplay will be disabled - users will have to manually launch setup or installation programs that are provided on removable media.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Autoplay:TurnOffAutoPlay_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Autorun_Box" value="255" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Autoplay:TurnOffAutoPlay
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 255.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoDriveTypeAutoRun
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled: All drives**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/AutoPlay Policies
Setting Name:	Turn off Autoplay
Configuration:	Enabled: All drives

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Autoplay is enabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 <u>Disable Autorun and Autoplay for Removable Media</u> Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	8.5 <u>Configure Devices Not To Auto-run Content</u> Configure devices to not auto-run content from removable media.	●	●	●

18.10.8 Biometrics

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Biometrics.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.9 BitLocker Drive Encryption

This section contains recommendations for configuring BitLocker.

This Group Policy section is provided by the Group Policy template `VolumeEncryption.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.9.1 Fixed Data Drives

This section contains recommendations for configuring Fixed Data Drives in BitLocker.

This Group Policy section is provided by the Group Policy template `VolumeEncryption.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.9.1.1 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

The "Allow data recovery agent" check box is used to specify whether a Data Recovery Agent can be used with BitLocker-protected fixed data drives. Before a Data Recovery Agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding Data Recovery Agents.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting.

In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds.

Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated.

The recommended state for this setting is: *Enabled*.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

Impact:

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVRecovery
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives Setting Name: Choose how BitLocker-protected fixed drives can be recovered Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (The default recovery options are supported for BitLocker recovery - a DRA is allowed, and the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.2 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Allow data recovery agent' is set to 'Enabled: True' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

The "Allow data recovery agent" check box is used to specify whether a Data Recovery Agent can be used with BitLocker-protected fixed data drives. Before a Data Recovery Agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding Data Recovery Agents.

The recommended state for this setting is: `Enabled: True` (checked).

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVManageDRA

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Allow data recovery agent:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Check Allow data recovery agent

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled: True. (A DRA is allowed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.3 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Password' is set to 'Enabled: Allow 48-digit recovery password' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

The recommended state for this setting is: `Enabled: Allow 48-digit recovery password`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

A 48-digit recovery password will be permitted for fixed drives.

Audit:

Navigate to the following registry location and confirm it is set to 2.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVRecoveryPassword

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Allow 48-digit recovery password:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Allow 48-digit recovery password

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options are specified by the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.4 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Key' is set to 'Enabled: Allow 256-bit recovery key' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

The recommended state for this setting is: `Enabled: Allow 256-bit recovery key`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

A 256-bit recovery key will be permitted for fixed drives.

Audit:

Navigate to the following registry location and confirm it is set to 2.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVRecoveryKey

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Allow 256-bit recovery key`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Allow 256-digit recovery key

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options are specified by the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.5 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting.

The recommended state for this setting is: `Enabled: True` (checked).

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

The ability to manually select recovery options for fixed drives will not be presented to the user in the BitLocker setup wizard.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVHideRecoveryPage
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Omit recovery options from the BitLocker setup wizard` (checked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Omit recovery options from the BitLocker setup wizard (checked)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options for fixed drives are selectable by the user in the BitLocker setup wizard.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.6 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Save BitLocker recovery information to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

The recommended state for this setting is: `Enabled: False` (unchecked).

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVActiveDirectoryBackup

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Save BitLocker recovery information to AD DS for fixed data drives (unchecked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Save BitLocker recovery information to AD DS for fixed data drives (unchecked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

BitLocker recovery information for fixed drives is not backed up to AD DS.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.7 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Configure storage of BitLocker recovery information to AD DS' is set to 'Enabled: Backup recovery passwords and key packages' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

In "Save BitLocker recovery information to Active Directory Domain Services" choose which BitLocker recovery information to store in AD DS for fixed data drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

The recommended state for this setting is: `Enabled: Backup recovery passwords and key packages`.

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

None - this value is ignored when the checkbox above it (*Save BitLocker recovery information to AD DS for fixed data drives*) is False (unchecked), as is required in Rule 18.9.11.1.7. If that checkbox **is** set to True (checked), both recovery passwords and key packages for fixed drives will be saved to AD DS.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
FixedDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="FDVAllowDRA_Name" value="true" /><data id="FDVRecoveryPasswordUsageDropDown_Name" value="2" /><data id="FDVRecoveryKeyUsageDropDown_Name" value="2" /><data id="FDVHideRecoveryPage_Name" value="true" /><data id="FDVActiveDirectoryBackup_Name" value="false" /><data id="FDVActiveDirectoryBackupDropDown_Name" value="1" /><data id="FDVRequireActiveDirectoryBackup_Name" value="false" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:FixedDrivesRecoveryOptions
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVActiveDirectoryInfoToSt  
ore
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled: Backup recovery passwords and key packages**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives
Setting Name: Choose how BitLocker-protected fixed drives can be recovered
Configuration: Select Backup recovery passwords and key packages

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

BitLocker recovery information for fixed drives is not backed up to AD DS.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.1.8 (BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected fixed data drives are recovered in the absence of the required credentials. This policy setting is applied when you turn on BitLocker.

Select the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds.

Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for fixed data drives" check box is selected, a recovery password is automatically generated.

The recommended state for this setting is: `Enabled: False` (unchecked).

Rationale:

Administrators should always have a safe, secure way to access encrypted data in the event users cannot access their data.

Additionally, as with any authentication method, a drive can be compromised by guessing or finding the authentication information used to access the drive.

To use BitLocker, a Data Recovery Agent will need to be configured for fixed drives. To recover a drive will require highly-controlled access to the Data Recovery Agent private key.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:FixedDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="FDVAllowDRA_Name" value="true" /><data id="FDVRecoveryPasswordUsageDropDown_Name" value="2" /><data id="FDVRecoveryKeyUsageDropDown_Name" value="2" /><data id="FDVHideRecoveryPage_Name" value="true" /><data id="FDVActiveDirectoryBackup_Name" value="false" /><data id="FDVActiveDirectoryBackupDropDown_Name" value="1" /><data id="FDVRequireActiveDirectoryBackup_Name" value="false" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\BitLocker:FixedDrivesRecoveryOptions
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:FDVRequireActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives (unchecked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Fixed Data Drives Setting Name: Choose how BitLocker-protected fixed drives can be recovered Configuration: Uncheck Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

BitLocker can be enabled on fixed drives without the requirement of storing recovery information to Active Directory first.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2 Operating System Drives

This section contains recommendations for configuring Operating System Drives in BitLocker.

This Group Policy section is provided by the Group Policy template `VolumeEncryption.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.9.2.1 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

The "Allow certificate-based data recovery agent" check box is used to specify whether a Data Recovery Agent can be used with BitLocker-protected operating system drives. Before a Data Recovery Agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding Data Recovery Agents.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting.

In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds.

Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated.

The recommended state for this setting is: `Enabled`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSRecovery
```

Remediation:

To establish the recommended configuration via GP, set the following UI path to Enabled:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Save BitLocker recovery information to AD DS for operation system drives (checked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (The default recovery options are supported for BitLocker recovery - a DRA is allowed, and the recovery options can be specified by the user including the recovery password and recovery key, and recovery information is not backed up to AD DS.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.2 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Allow data recovery agent' is set to 'Enabled: False' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

The "Allow certificate-based data recovery agent" check box is used to specify whether a Data Recovery Agent can be used with BitLocker-protected operating system drives. Before a Data Recovery Agent can be used it must be added from the Public Key Policies item in either the Group Policy Management Console or the Local Group Policy Editor. Consult the BitLocker Drive Encryption Deployment Guide on Microsoft TechNet for more information about adding Data Recovery Agents.

The recommended state for this setting is: `Enabled: False` (unchecked).

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

A Data Recovery Agent will not be permitted for the operating system drive. Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSManageDRA
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Allow data recovery agent Enabled: False:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Allow data recovery agent (Unchecked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled: True. (A DRA is allowed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.3 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Password' is set to 'Enabled: Require 48-digit recovery password' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

The recommended state for this setting is: `Enabled: Require 48-digit recovery password`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

A 48-digit recovery password will be required for the operating system drive. Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSRecoveryPassword

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Require 48-digit recovery password:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Require 48-digit recovery password

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options are specified by the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.4 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Key' is set to 'Enabled: Do not allow 256-bit recovery key' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

In "Configure user storage of BitLocker recovery information" select whether users are allowed, required, or not allowed to generate a 48-digit recovery password or a 256-bit recovery key.

The recommended state for this setting is: `Enabled: Do not allow 256-bit recovery key`.

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

A 256-bit recovery key will not be permitted for the operating system drive. Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 0.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSRecoveryKey

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Do not allow 256-bit recovery key:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Do not allow 256-bit recovery key

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options are specified by the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.5 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

Select "Omit recovery options from the BitLocker setup wizard" to prevent users from specifying recovery options when they enable BitLocker on a drive. This means that you will not be able to specify which recovery option to use when you enable BitLocker, instead BitLocker recovery options for the drive are determined by the policy setting.

The recommended state for this setting is: `Enabled: True` (checked).

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

The ability to manually select recovery options for the operating drive will not be presented to the user in the BitLocker setup wizard.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSHideRecoveryPage
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Omit recovery options from the BitLocker setup wizard`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Omit recovery options from the BitLocker setup wizard (checked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Recovery options for the operating system drive are selectable by the user in the BitLocker setup wizard.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.6 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Save BitLocker recovery information to AD DS for operating system drives' is set to 'Enabled: True' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

The recommended state for this setting is: `Enabled: True` (checked).

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

BitLocker recovery information for the operating system drive will be backed up to AD DS. Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSActiveDirectoryBackup
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**: Save BitLocker recovery information to AD DS for operation system drives (checked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Save BitLocker recovery information to AD DS for operation system drives (checked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

BitLocker recovery information for the operating system drive is not backed up to AD DS.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.7 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Configure storage of BitLocker recovery information to AD DS:' is set to 'Enabled: Store recovery passwords and key packages' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

In "Save BitLocker recovery information to Active Directory Domain Services", choose which BitLocker recovery information to store in AD DS for operating system drives. If you select "Backup recovery password and key package", both the BitLocker recovery password and key package are stored in AD DS. Storing the key package supports recovering data from a drive that has been physically corrupted. If you select "Backup recovery password only", only the recovery password is stored in AD DS.

The recommended state for this setting is: `Enabled: Store recovery passwords and key packages.`

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Both the recovery password and the key package for the operating system drive will be saved to AD DS. Users will need to be domain connected to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSActiveDirectoryInfoToStore
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Store recovery passwords and key packages`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Store recovery passwords and key packages

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

BitLocker recovery information for the operating system drive is not backed up to AD DS.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.8 (BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' is set to 'Enabled: True' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to control how BitLocker-protected operating system drives are recovered in the absence of the required startup key information. This policy setting is applied when you turn on BitLocker.

Select the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box if you want to prevent users from enabling BitLocker unless the computer is connected to the domain and the backup of BitLocker recovery information to AD DS succeeds.

Note: If the "Do not enable BitLocker until recovery information is stored in AD DS for operating system drives" check box is selected, a recovery password is automatically generated.

The recommended state for this setting is: `Enabled: True` (checked).

Rationale:

Should a user lose their primary means for accessing an encrypted OS volume, or should the system not pass its boot time integrity checks, the system will go into recovery mode. If the recovery key has not been backed up to Active Directory, the user would need to have saved the recovery key to another location such as a USB flash drive, or have printed the recovery password, and now have access to one of those in order to recovery the system. If the user is unable to produce the recovery key, then the user will be denied access to the encrypted volume and subsequently any data that is stored there.

Impact:

Users will need to be domain connected and the back up of BitLocker recovery information for the operating system drive must succeed in order to turn on BitLocker. This policy is not FIPS complaint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRecoveryOptions_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="OSAllowDRA_Name" value="false" /><data id="OSRecoveryPasswordUsageDropDown_Name" value="2" /><data id="OSRecoveryKeyUsageDropDown_Name" value="0" /><data id="OSHideRecoveryPage_Name" value="true" /><data id="OSActiveDirectoryBackup_Name" value="true" /><data id="OSActiveDirectoryBackupDropDown_Name" value="1" /><data id="OSRequireActiveDirectoryBackup_Name" value="true" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRecoveryOptions_ProviderSet
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:OSRequireActiveDirectoryBa  
ckup
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**: Do not enable BitLocker until recovery information is stored to AD DS for operating system drives (checked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Choose how BitLocker-protected operating system drives can be recovered
Configuration: Do not enable BitLocker until recovery information is stored to AD DS for operating system drives` (checked)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

BitLocker can be enabled on the operating system drive without the requirement of storing recovery information to Active Directory first.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.6 <u>Encrypt Data on End-User Devices</u> Encrypt data on end-user devices containing sensitive data. Example implementations can include: Windows BitLocker®, Apple FileVault®, Linux® dm-crypt.			
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.2.9 (BL) Ensure 'Require additional authentication at startup' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to configure whether BitLocker requires additional authentication each time the computer starts and whether you are using BitLocker with or without a Trusted Platform Module (TPM). This policy setting is applied when you turn on BitLocker.

Note: Only one of the additional authentication options can be required at startup, otherwise a policy error occurs.

If you want to use BitLocker on a computer without a TPM, select the "Allow BitLocker without a compatible TPM" check box. In this mode a USB drive is required for start-up and the key information used to encrypt the drive is stored on the USB drive, creating a USB key. When the USB key is inserted the access to the drive is authenticated and the drive is accessible. If the USB key is lost or unavailable you will need to use one of the BitLocker recovery options to access the drive.

On a computer with a compatible TPM, four types of authentication methods can be used at startup to provide added protection for encrypted data. When the computer starts, it can use only the TPM for authentication, or it can also require insertion of a USB flash drive containing a startup key, the entry of a 4-digit to 20-digit personal identification number (PIN), or both.

Users can configure advanced startup options in the BitLocker setup wizard.

Note #2: If you want to require the use of a startup PIN and a USB flash drive, you must configure BitLocker settings using the command-line tool `manage-bde` instead of the BitLocker Drive Encryption setup wizard.

The recommended state for this setting is: `Enabled`.

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A PIN requires physical presence to restart the computer. This functionality is not compatible with Wake on LAN solutions.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRequireStartupAuthentication_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="ConfigureNonTPMStartupKeyUsage_Name" value="false" /><data id="ConfigureTPMUsageDropDown_Name" value="2" /><data id="ConfigurePINUsageDropDown_Name" value="2" /><data id="ConfigureTPMStartupKeyUsageDropDown_Name" value="2" /><data id="ConfigureTPMPINKeyUsageDropDown_Name" value="2" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRequireStartupAuthentication
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:UseAdvancedStartup
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Require additional authentication at startup
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (Users can configure only basic options on computers with a TPM.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.3 <u>Require Multi-factor Authentication</u> Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.			

18.10.9.2.10 (BL) Ensure 'Require additional authentication at startup: Allow BitLocker without a compatible TPM' is set to 'Enabled: False' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting allows you to configure whether you can use BitLocker without a Trusted Platform Module (TPM), instead using a password or startup key on a USB flash drive. This policy setting is applied when you turn on BitLocker.

The recommended state for this setting is: `Enabled: False` (unchecked).

Rationale:

TPM without use of a PIN will only validate early boot components and does not require a user to enter any additional authentication information. If a computer is lost or stolen in this configuration, BitLocker will not provide any additional measure of protection beyond what is provided by native Windows authentication unless the early boot components are tampered with or the encrypted drive is removed from the machine.

Impact:

A compatible TPM will be required in order to use BitLocker.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\BitLocker:  
SystemDrivesRequireStartupAuthentication_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="ConfigureNonTPMStartupKeyUsage_Name" value="false" /><data id="ConfigureTPMUsageDropDown_Name" value="2" /><data id="ConfigurePINUsageDropDown_Name" value="2" /><data id="ConfigureTPMStartupKeyUsageDropDown_Name" value="2" /><data id="ConfigureTPMPINKeyUsageDropDown_Name" value="2" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
BitLocker:SystemDrivesRequireStartupAuthentication
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:EnableBDEWithNoTPM
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Allow BitLocker without a compatible TPM (requires a password or a startup key on USB flash drive) (unchecked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/BitLocker Drive Encryption/Operating System Drives
Setting Name: Require additional authentication at startup
Configuration: Allow BitLocker without a compatible TPM (requires a password or a startup key on USB flash drive) - Unchecked

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

True (checked). (Users can use BitLocker without a compatible TPM by using a password or startup key on a USB flash drive.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.			

18.10.9.3 Removable Data Drives

This section contains recommendations for configuring Removable Data Drives in BitLocker.

This Group Policy section is provided by the Group Policy template `VolumeEncryption.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.9.3.1 (BL) Ensure 'Deny write access to removable drives not protected by BitLocker' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting configures whether BitLocker protection is required for a computer to be able to write data to a removable data drive.

All removable data drives that are not BitLocker-protected will be mounted as read-only. If the drive is protected by BitLocker, it will be mounted with read and write access.

The recommended state for this setting is: *Enabled*.

Rationale:

Users may not voluntarily encrypt removable drives prior to saving important data to the drive.

Impact:

All removable data drives that are not BitLocker-protected will be mounted as read-only. If the drive is protected by BitLocker, it will be mounted with read and write access.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Policies\Microsoft\FVE:RDVDenyWriteAccess
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/Windows Components/BitLocker Drive
Encryption/Removable Data Drives
Setting Name:  Deny write access to removable drives not protected by
BitLocker
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Disabled. (All removable data drives on the computer will be mounted with read and write access.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.9 <u>Encrypt Data on Removable Media</u> Encrypt data on removable media.		●	●
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.	●	●	●
v7	13.8 <u>Manage System's External Removable Media's Read/write Configurations</u> Configure systems not to write data to external removable media, if there is no business need for supporting such devices.			●

18.10.9.3.2 (BL) Ensure 'Deny write access to removable drives not protected by BitLocker: Do not allow write access to devices configured in another organization' is set to 'Enabled: False' (Automated)

Profile Applicability:

- Level 1 (L1) + BitLocker (BL)
- Level 2 (L2) + BitLocker (BL)
- BitLocker (BL) - optional add-on for when BitLocker is deployed

Description:

This policy setting configures whether the computer will be able to write data to BitLocker-protected removable drives that were configured in another organization.

The recommended state for this setting is: `Enabled: False` (unchecked).

Rationale:

Restricting write access to BitLocker-protected removable drives that were configured in another organization can hinder legitimate business operations where encrypted data sharing is necessary.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\FVE:RDVDenyCrossOrg
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Do not allow write access to devices configured in another organization (unchecked):

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/Windows Components/BitLocker Drive
Encryption/Removable Data Drives
Setting Name:  Deny write access to removable drives not protected by
BitLocker
Configuration: Enabled: False (unchecked)
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This recommendation can also be set using the *Endpoint protection* profile using *Windows Encryption* settings.

Default Value:

Enabled: False (unchecked). (Write access will be permitted to BitLocker-protected removable drives that were configured in another organization.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.9 <u>Encrypt Data on Removable Media</u> Encrypt data on removable media.		●	●
v7	13.6 <u>Encrypt the Hard Drive of All Mobile Devices.</u> Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.	●	●	●
v7	13.8 <u>Manage System's External Removable Media's Read/write Configurations</u> Configure systems not to write data to external removable media, if there is no business need for supporting such devices.			●

18.10.10 Camera

This section contains recommendations related to Camera.

This Group Policy section is provided by the Group Policy template `Camera.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.10.1 (L2) Ensure 'Allow Use of Camera' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting controls whether the use of Camera devices on the machine are permitted.

The recommended state for this setting is: `Disabled`.

Rationale:

Cameras in a high security environment can pose serious privacy and data exfiltration risks - they should be disabled to help mitigate that risk.

Impact:

Users will not be able to utilize the camera on a system.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Camera:AllowCamera_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Camera:AllowCamera
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Block**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/General
Setting Name:	Camera
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Camera/AllowCamera

Default Value:

Enabled. (Camera devices are enabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			

18.10.11 Chat

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Taskbar.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.12 Cloud Content

This section contains recommendations related to Cloud Content.

This Group Policy section is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.10.12.1 (L1) Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting turns off experiences that help consumers make the most of their devices and Microsoft account.

The recommended state for this setting is: *Enabled*.

Note: [Per Microsoft TechNet](#), this policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.

Rationale:

Having apps silently install in an enterprise managed environment is not good security practice - especially if the apps send data back to a 3rd party.

Impact:

Users will no longer see personalized recommendations from Microsoft and notifications about their Microsoft account.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Experience:AllowWindowsConsumerFeatures_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Experience:AllowWindowsConsumerFeatures
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Experience/AllowWindowsConsumerFeatures
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users may see suggestions from Microsoft and notifications about their Microsoft account.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-experience#experience-allowwindowsconsumerfeatures>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.13 Connect

This section contains recommendations related to Connect.

This Group Policy section is provided by the Group Policy template `WirelessDisplay.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.13.1 (L1) Ensure 'Require pin for pairing' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether or not a PIN is required for pairing to a wireless display device.

The recommended state for this setting is: `Enabled`.

Rationale:

If this setting is not configured or disabled then a PIN would not be required when pairing wireless display devices to the system, increasing the risk of unauthorized use.

Impact:

The pairing ceremony for connecting to new wireless display devices will always require a PIN.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WirelessDisplay:RequirePinForPairing_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `1` or `2`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\WirelessDisplay:RequirePinForPairing
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Require*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device restrictions/Projection
Setting Name:	Require PIN for pairing
Configuration:	Require

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2: This setting can also be created via a *Custom Configuration Profile* using the following OMA-URI:

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/WirelessDisplay/RequirePinForPairing

Default Value:

Disabled. (A PIN is not required for pairing to a wireless display device.)

18.10.14 Credential User Interface

This section contains recommendations related to the Credential User Interface.

This Group Policy section is provided by the Group Policy template `CredUI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.14.1 (L1) Ensure 'Do not display the password reveal button' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to configure the display of the password reveal button in password entry user experiences.

The recommended state for this setting is: `Enabled`.

Rationale:

This is a useful feature when entering a long and complex password, especially when using a touchscreen. The potential risk is that someone else may see your password while surreptitiously observing your screen.

Impact:

The password reveal button will not be displayed after a user types a password in the password entry text box.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\CredentialsUI:DisablePasswordReveal_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\CredentialsUI:DisablePasswordReveal
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\CredUI:DisablePasswordReveal
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Credential User Interface
Setting Name:	Do not display the password reveal button
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The password reveal button is displayed after a user types a password in the password entry text box. If the user clicks on the button, the typed password is displayed on-screen in plain text.)

18.10.14.2 (L1) Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether administrator accounts are displayed when a user attempts to elevate a running application.

The recommended state for this setting is: `Disabled`.

Rationale:

Users could see the list of administrator accounts, making it slightly easier for a malicious user who has logged onto a console session to try to crack the passwords of those accounts.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\CredentialsUI:EnumerateAdministrators_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\CredentialsUI:EnumerateAdministrators
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\CredUI:EnumerateAdministrators
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Credential User Interface
Setting Name:	Enumerate administrator accounts on elevation
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users will be required to always type in a username and password to elevate.)

18.10.14.3 (L1) Ensure 'Prevent the use of security questions for local accounts' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether security questions can be used to reset local account passwords. The security question feature does not apply to domain accounts, only local accounts on the workstation.

The recommended state for this setting is: `Enabled`.

Rationale:

Users could establish security questions that are easily guessed or sleuthed by observing the user's social media accounts, making it easier for a malicious actor to change the local user account password and gain access to the computer as that user account.

Impact:

Local user accounts will not be able to set up and use security questions to reset their passwords.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\System:NoLocalPasswordResetQuestions
```


Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Credential User Interface
Setting Name:	Prevent the use of security questions for local accounts
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Not Configured. (Local user accounts are able to set up and use security questions to reset their passwords.)

18.10.15 Data Collection and Preview Builds

This section contains settings for Data Collection and Preview Builds.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.15.1 (L1) Ensure 'Allow Diagnostic Data' is set to 'Enabled: Diagnostic data off (not recommended)' or 'Enabled: Send required diagnostic data' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines the amount of diagnostic and usage data reported to Microsoft:

- A value of (0) `Diagnostic data off (not recommended)`. Using this value, no diagnostic data is sent from the device. This value is only supported on Enterprise, Education, and Server editions. If you choose this setting, devices in your organization will still be secure.
- A value of (1) `Send required diagnostic data`. This is the minimum diagnostic data necessary to keep Windows secure, up to date, and performing as expected. Using this value disables the *Optional diagnostic data* control in the Settings app.
- A value of (3) `Send optional diagnostic data`. Additional diagnostic data is collected that helps us to detect, diagnose and fix issues, as well as make product improvements. Required diagnostic data will always be included when you choose to send optional diagnostic data. Optional diagnostic data can also include diagnostic log files and crash dumps. Use the *Limit Dump Collection* and the *Limit Diagnostic Log Collection* policies for more granular control of what optional diagnostic data is sent.

Windows telemetry settings apply to the Windows operating system and some first party apps. This setting does not apply to third party apps running on Windows 10/11.

The recommended state for this setting is: `Enabled: Diagnostic data off (not recommended)` OR `Enabled: Send required diagnostic data`.

Note: If your organization relies on Windows Update, the minimum recommended setting is `Required diagnostic data`. Because no Windows Update information is collected when diagnostic data is off, important information about update failures is not sent. Microsoft uses this information to fix the causes of those failures and improve the quality of updates.

Note #2: The *Configure diagnostic data opt-in settings user interface* group policy can be used to prevent end users from changing their data collection settings.

Note #3: Enhanced diagnostic data setting is not available on Windows 11 and Windows Server 2022 and has been replaced with policies that can control the amount of optional diagnostic data that is sent. For more information on these settings visit [Manage diagnostic data using Group Policy and MDM](#)

Rationale:

Sending any data to a 3rd party vendor is a security concern and should only be done on an as needed basis.

Impact:

Note that setting values of 0 or 1 will degrade certain experiences on the device.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:AllowTelemetry_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0 or 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\System:AllowTelemetry
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 0 - Security [Enterprise Only] OR Enabled: 1 - Basic

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/System/AllowTelemetry
Data type:	Integer
Value:	0 OR 1

Default Value:

Disabled. (Users can configure the Telemetry level in Settings.)

References:

1. <https://docs.microsoft.com/en-us/windows/privacy/configure-windows-diagnostic-data-in-your-organization>
2. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-system#allowtelemetry>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.15.2 (L2) Ensure 'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' is set to 'Enabled: Disable Authenticated Proxy usage' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting controls whether the Connected User Experience and Telemetry service can automatically use an authenticated proxy to send data back to Microsoft.

The recommended state for this setting is: Enabled: Disable Authenticated Proxy usage.

Rationale:

Sending any data to a 3rd party vendor is a security concern and should only be done on an as needed basis.

Impact:

The Connected User Experience and Telemetry service will be blocked from automatically using an authenticated proxy.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:DisableEnterpriseAuthProxy_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\System:DisableEnterpriseAuthProxy
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: `Disable Authenticated Proxy usage`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/System/DisableEnterpriseAuthProxy
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The Connected User Experience and Telemetry service will automatically use an authenticated proxy to send data back to Microsoft.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.15.3 (L1) Ensure 'Do not show feedback notifications' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows an organization to prevent its devices from showing feedback questions from Microsoft.

The recommended state for this setting is: *Enabled*.

Rationale:

Users should not be sending any feedback to 3rd party vendors in an enterprise managed environment.

Impact:

Users will no longer see feedback notifications through the Windows Feedback app.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Experience  
:DoNotShowFeedbackNotifications_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\  
Device\Experience:DoNotShowFeedbackNotifications
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Experience/DoNotShowFeedbackNotifications
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users may see notifications through the Windows Feedback app asking users for feedback. Users can control how often they receive feedback questions.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.15.4 (L1) Ensure 'Toggle user control over Insider builds' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can access the Insider build controls in the Advanced Options for Windows Update. These controls are located under "Get Insider builds," and enable users to make their devices available for downloading and installing Windows preview software.

The recommended state for this setting is: `Disabled`.

Note: This policy setting applies only to devices running Windows 10 Pro or Windows 10 Enterprise, up until Release 1703. For Release 1709 or newer, Microsoft encourages using the `Manage preview builds` setting (Rule 18.9.102.1.1). We have kept this setting in the benchmark to ensure that any older builds of Windows 10 in the environment are still enforced.

Rationale:

It can be risky for experimental features to be allowed in an enterprise managed environment because this can introduce bugs and security holes into systems, making it easier for an attacker to gain access. It is generally preferred to only use production-ready builds.

Impact:

The item "Get Insider builds" will be unavailable.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:AllowBuildPreview_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\System:AllowBuildPreview
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:        ./Device/Vendor/MSFT/Policy/Config/System/AllowBuildPreview
Data type:      Integer
Value:          0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Users can download and install Windows preview software on their devices.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.3 Address Unauthorized Software Ensure that unauthorized software is either removed from use on enterprise assets or receives a documented exception. Review monthly, or more frequently.			
v7	2.6 Address unapproved software Ensure that unauthorized software is either removed or the inventory is updated in a timely manner			

18.10.16 Delivery Optimization

This section contains settings for Delivery Optimization.

This Group Policy section is provided by the Group Policy template `DeliveryOptimization.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.17 Desktop App Installer

This section contains recommendations related to Desktop App Installer.

This Group Policy section is provided by the Group Policy template `DesktopAppInstaller.admx/adml` that is included with the Microsoft Windows 11 Release 22H2 Administrative Templates (or newer).

18.10.18 Desktop Gadgets

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sidebar.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.19 Desktop Window Manager

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DWM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.20 Device and Driver Compatibility

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DeviceCompat.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.21 Device Registration (formerly Workplace Join)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WorkplaceJoin.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Note: This section was initially named *Workplace Join* but was renamed by Microsoft to *Device Registration* starting with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates.

18.10.22 Digital Locker

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DigitalLocker.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.23 Edge UI

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EdgeUI.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.24 EMET

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EMET.admx/adml` that is included with Microsoft EMET.

EMET is free and supported security software developed by Microsoft that allows an enterprise to apply exploit mitigations to applications that run on Windows. Many of these mitigations were later coded directly into Windows 10 and Server 2016.

Note: Although EMET is quite effective at enhancing exploit protection on Windows workstation OSes prior to Windows 10, it is highly recommended that compatibility testing is done on typical workstation configurations (including all CIS-recommended EMET settings) before widespread deployment to your environment.

Note #2: EMET has been reported to be very problematic on 32-bit OSes - we only recommend using it with 64-bit OSes.

Note #3: Microsoft has announced that EMET will be End-Of-Life (EOL) on July 31, 2018. This does not mean the software will stop working, only that Microsoft will not update it any further past that date, nor troubleshoot new problems with it. They are instead recommending that workstations be upgraded to Windows 10.

18.10.25 Event Forwarding

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EventForwarding.admx/adml` that is included with the Microsoft Windows Server 2008 (non-R2) Administrative Templates (or newer).

18.10.26 Event Log Service

This section contains recommendations for configuring the Event Log Service.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.26.1 Application

This section contains recommendations for configuring the Application Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.26.1.1 (L1) Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size.

The recommended state for this setting is: *Disabled*.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Application:Retention

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/Windows Components/Event Log
Service/Application
Setting Name:   Control Event Log behavior when the log file reaches its
maximum size
Configuration:  Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (When a log file reaches its maximum size, new events overwrite old events.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

18.10.26.1.2 (L1) Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

The recommended state for this setting is: `Enabled: 32,768 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\EventLogService:SpecifyMaximumFileSizeApplicationLog_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Channel_LogMaxSize" value="32768" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\EventLogService:SpecifyMaximumFileSizeApplicationLog
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 8000 or 32768.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Application:MaxSize
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 32,768 or greater:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Event Log Service/Application
Setting Name: Specify the maximum log file size (KB)
Configuration: Enabled: 32,768 or greater

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The default log size is 20,480 KB - this value can be changed by the local administrator using the Log Properties dialog.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.10.26.2 Security

This section contains recommendations for configuring the Security Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.26.2.1 (L1) Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size.

The recommended state for this setting is: *Disabled*.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Security:Retention
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\Windows Components\Event Log
Service\Security
Setting Name:   Control Event Log behavior when the log file reaches its
maximum size
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (When a log file reaches its maximum size, new events overwrite old events.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.10.26.2.2 (L1) Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 196,608 or greater' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

The recommended state for this setting is: `Enabled: 196,608 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\EventLogService:SpecifyMaximumFileSizeSecurityLog_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Channel_LogMaxSize" value="196608" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\EventLogService:SpecifyMaximumFileSizeSecurityLog
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 30000 or 196608.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Security:MaxSize
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 196,608 or greater:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Event Log Service/Security
Setting Name: Specify the maximum log file size (KB)
Configuration: Enabled: 196,608 or greater

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The default log size is 20,480 KB - this value can be changed by the local administrator using the Log Properties dialog.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.10.26.3 Setup

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.26.3.1 (L1) Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size.

The recommended state for this setting is: *Disabled*.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Setup:Retention
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\Windows Components\Event Log
Service\Setup
Setting Name:   Control Event Log behavior when the log file reaches its
maximum size
Configuration:  Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (When a log file reaches its maximum size, new events overwrite old events.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

18.10.26.3.2 (L1) Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

The recommended state for this setting is: *Enabled: 32,768 or greater*.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the following registry location and confirm it is set to 8000 or 32768.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\Setup:MaxSize

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 32,768 or greater:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Event Log Service\Setup
Setting Name:	Specify the maximum log file size (KB)
Configuration:	Enabled: 32,768 or greater

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The default log size is 20,480 KB - this value can be changed by the local administrator using the Log Properties dialog.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.10.26.4 System

This section contains recommendations for configuring the System Event Log.

This Group Policy section is provided by the Group Policy template `EventLog.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.26.4.1 (L1) Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls Event Log behavior when the log file reaches its maximum size.

The recommended state for this setting is: *Disabled*.

Note: Old events may or may not be retained according to the *Backup log automatically when full* policy setting.

Rationale:

If new events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\System:Retention
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\Windows Components\Event Log
Service\System
Setting Name:   Control Event Log behavior when the log file reaches its
maximum size
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (When a log file reaches its maximum size, new events overwrite old events.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

18.10.26.4.2 (L1) Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies the maximum size of the log file in kilobytes. The maximum log file size can be configured between 1 megabyte (1,024 kilobytes) and 4 terabytes (4,194,240 kilobytes) in kilobyte increments.

The recommended state for this setting is: `Enabled: 32,768 or greater`.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users

Impact:

When event logs fill to capacity, they will stop recording information unless the retention method for each is set so that the computer will overwrite the oldest entries with the most recent ones. To mitigate the risk of loss of recent data, you can configure the retention method so that older events are overwritten as needed.

The consequence of this configuration is that older events will be removed from the logs. Attackers can take advantage of such a configuration, because they can generate a large number of extraneous events to overwrite any evidence of their attack. These risks can be somewhat reduced if you automate the archival and backup of event log data.

Ideally, all specifically monitored events should be sent to a server that uses Microsoft System Center Operations Manager (SCOM) or some other automated monitoring tool. Such a configuration is particularly important because an attacker who successfully compromises a server could clear the Security log. If all events are sent to a monitoring server, then you will be able to gather forensic information about the attacker's activities.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\EventLogService:SpecifyMaximumFileSizeSystemLog_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/><data id="Channel_LogMaxSize" value="32768" />.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\EventLogService:SpecifyMaximumFileSizeSystemLog
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 8000 or 32768.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\EventLog\System:MaxSize
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: 32,768 or greater:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Event Log Service/System
Setting Name:	Specify the maximum log file size (KB)
Configuration:	Enabled: 32,768 or greater

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The default log size is 20,480 KB - this value can be changed by the local administrator using the Log Properties dialog.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 <u>Ensure Adequate Audit Log Storage</u> Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.			
v7	6.4 <u>Ensure adequate storage for logs</u> Ensure that all systems that store logs have adequate storage space for the logs generated.			

18.10.27 Event Logging

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EventLogging.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.28 Event Viewer

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EventViewer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.29 File Explorer (formerly Windows Explorer)

This section contains recommendations to control the availability of options such as menu items and tabs in dialog boxes.

This Group Policy section is provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Windows Explorer* but was renamed by Microsoft to *File Explorer* starting with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

18.10.29.1 Previous Versions

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `PreviousVersions.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.29.2 (L1) Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Disabling Data Execution Prevention can allow certain legacy plug-in applications to function without terminating Explorer.

The recommended state for this setting is: `Disabled`.

Note: Some legacy plug-in applications and other software may not function with Data Execution Prevention and will require an exception to be defined for that specific plug-in/software.

Rationale:

Data Execution Prevention is an important security feature supported by Explorer that helps to limit the impact of certain types of malware.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\FileExplorer:TurnOffDataExecutionPreventionForExplorer_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\FileExplorer:TurnOffDataExecutionPreventionForExplorer
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoDataExecutionPrevention
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/File Explorer
Setting Name:	Turn off Data Execution Prevention for Explorer
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Data Execution Prevention will block certain types of malware from exploiting Explorer.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.29.3 (L1) Ensure 'Turn off heap termination on corruption' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Without heap termination on corruption, legacy plug-in applications may continue to function when a File Explorer session has become corrupt. Ensuring that heap termination on corruption is active will prevent this.

The recommended state for this setting is: `Disabled`.

Rationale:

Allowing an application to function after its session has become corrupt increases the risk posture to the system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\FileExplorer:TurnOffHeapTerminationOnCorruption_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\FileExplorer:TurnOffHeapTerminationOnCorruption
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\Explorer:NoHeapTerminationOnCorruption
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/File Explorer
Setting Name:	Turn off heap termination on corruption
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Heap termination on corruption is enabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

18.10.29.4 (L1) Ensure 'Turn off shell protocol protected mode' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to configure the amount of functionality that the shell protocol can have. When using the full functionality of this protocol, applications can open folders and launch files. The protected mode reduces the functionality of this protocol allowing applications to only open a limited set of folders. Applications are not able to open files with this protocol when it is in the protected mode. It is recommended to leave this protocol in the protected mode to increase the security of Windows.

The recommended state for this setting is: `Disabled`.

Rationale:

Limiting the opening of files and folders to a limited set reduces the attack surface of the system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:PreXPSP2ShellProtocolBehavior
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\File Explorer
Setting Name:	Turn off shell protocol protected mode
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The protocol is in the protected mode, allowing applications to only open a limited set of folders.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>8.3 Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.30 File History

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FileHistory.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.31 Find My Device

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FindMy.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.32 Handwriting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Handwriting.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.33 HomeGroup

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sharing.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.33.1 (L1) Ensure 'Prevent the computer from joining a homegroup' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

By default, users can add their computer to a HomeGroup on a home network.

The recommended state for this setting is: `Enabled`.

Note: The HomeGroup feature is available in all workstation releases of Windows from Windows 7 through Windows 10 Release 1709. Microsoft removed the feature completely starting with Windows 10 Release 1803. However, if your environment still contains **any** Windows 10 Release 1709 (or older) workstations, then this setting remains important to disable HomeGroup on those systems.

Rationale:

While resources on a domain-joined computer cannot be shared with a HomeGroup, information from the domain-joined computer can be leaked to other computers in the HomeGroup.

Impact:

A user on this computer will not be able to add this computer to a HomeGroup. This setting does not affect other network sharing features. Mobile users who access printers and other shared devices on their home networks will not be able to leverage the ease of use provided by HomeGroup functionality.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\HomeGroup:DisableHomeGroup

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/HomeGroup
Setting Name:	Prevent the computer from joining a homegroup
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (A user can add their computer to a HomeGroup. However, data on a domain-joined computer is not shared with the HomeGroup.)

References:

1. <https://support.microsoft.com/en-us/topic/9f802c8c-900f-60fb-826f-6fe06add8fe9#homegroup-start-to-finish=windows-81&v1h=win81tab6&v2h=win7tab1>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.34 Human Presence

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sensors.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.35 Internet Explorer

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.36 Internet Information Services

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `IIS.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.37 Location and Sensors

This section contains settings for Locations and Sensors.

This Group Policy section is provided by the Group Policy template `Sensors.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.37.1 (L2) Ensure 'Turn off location' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting turns off the location feature for the computer.

The recommended state for this setting is: `Enabled`.

Rationale:

This setting affects the location feature (e.g. GPS or other location tracking). From a security perspective, it's not a good idea to reveal your location to software in most cases, but there are legitimate uses, such as mapping software. However, they should not be used in high security environments.

Impact:

The location feature is turned off, and all programs on the computer are prevented from using location information from the location feature.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:AllowLocation_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\System:AllowLocation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Enabled':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/System/AllowLocation
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Programs on the computer are permitted to use location information from the location feature.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.38 Maintenance Scheduler

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `msched.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.39 Maps

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinMaps.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.10.40 MDM

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MDM.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.41 Messaging

This section contains messaging settings.

This Group Policy section is provided by the Group Policy template `Messaging.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.41.1 (L2) Ensure 'Allow Message Service Cloud Sync' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows backup and restore of cellular text messages to Microsoft's cloud services.

The recommended state for this setting is: `Disabled`.

Rationale:

In a high security environment, data should never be sent to any 3rd party since this data could contain sensitive information.

Impact:

Cellular text messages will not be backed up to (or restored from) Microsoft's cloud services.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Messaging:
AllowMessageSync_ProviderSet
```

To confirm that the policy was properly applied to the system, check following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\
Device\Messaging:AllowMessageSync
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Messaging/AllowMessageSync
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Cellular text messages can be backed up and restored to Microsoft's cloud services.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.42 Microsoft account

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MSAPolicy.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.42.1 (L1) Ensure 'Block all consumer Microsoft account user authentication' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting determines whether applications and services on the device can utilize new consumer Microsoft account authentication via the Windows `OnlineID` and `WebAccountManager` APIs.

The recommended state for this setting is: `Enabled`.

Rationale:

Organizations that want to effectively implement identity management policies and maintain firm control of what accounts are used on their computers will probably want to block Microsoft accounts. Organizations may also need to block Microsoft accounts in order to meet the requirements of compliance standards that apply to their information systems.

Impact:

All applications and services on the device will be prevented from *new* authentications using consumer Microsoft accounts via the Windows `OnlineID` and `WebAccountManager` APIs. Authentications performed directly by the user in web browsers or in apps that use `OAuth` will remain unaffected.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\MicrosoftAccount:DisableUserAuth
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Microsoft accounts
Setting Name:	Block all consumer Microsoft account user authentication
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Applications and services on the device will be permitted to authenticate using consumer Microsoft accounts via the Windows `OnlineID` and `WebAccountManager` APIs.)

References:

1. <https://docs.microsoft.com/en-us/windows/security/identity-protection/access-control/microsoft-accounts#bkmk-restrictuse>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.6 <u>Centralize Account Management</u> Centralize account management through a directory or identity service.		●	●
v7	16.8 <u>Disable Any Unassociated Accounts</u> Disable any account that cannot be associated with a business process or business owner.	●	●	●

18.10.43 Microsoft Defender Antivirus (formerly Windows Defender and Windows Defender Antivirus)

This section contains recommendations related to Microsoft Defender Antivirus.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was originally named *Windows Defender* but was renamed by Microsoft to *Windows Defender Antivirus* starting with the Microsoft Windows 10 Release 1703 Administrative Templates. It was renamed (again) to *Microsoft Defender Antivirus* starting with the Microsoft Windows 10 Release 2004 Administrative Templates.

18.10.43.1 Client Interface

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.2 Exclusions

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.3 MAPS

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.3.1 (L1) Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting configures a local override for the configuration to join Microsoft Active Protection Service (MAPS), which Microsoft renamed to *Windows Defender Antivirus Cloud Protection Service* and then *Microsoft Defender Antivirus Cloud Protection Service*. This setting can only be set by Group Policy.

The recommended state for this setting is: *Disabled*.

Rationale:

The decision on whether or not to participate in Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service for malicious software reporting should be made centrally in an enterprise managed environment, so that all computers within it behave consistently in that regard. Configuring this setting to Disabled ensures that the decision remains centrally managed.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Spynet:LocalSettingOverrideSpynetReporting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender
Antivirus\MAPS
Setting Name: Configure local setting override for reporting to Microsoft
MAPS
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Group Policy will take priority over the local preference setting.)

References:

1. <https://docs.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-cloud-protection-microsoft-defender-antivirus?view=o365-worldwide>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.43.3.2 (L2) Ensure 'Join Microsoft MAPS' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to join Microsoft Active Protection Service (MAPS), which Microsoft renamed to *Windows Defender Antivirus Cloud Protection Service* and then *Microsoft Defender Antivirus Cloud Protection Service*. Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service is the online community that helps you choose how to respond to potential threats. The community also helps stop the spread of new malicious software infections. You can choose to send basic or additional information about detected software. Additional information helps Microsoft create new definitions and help it to protect your computer.

Possible options are:

- (0x0) Disabled (default)
- (0x1) Basic membership
- (0x2) Advanced membership

Basic membership will send basic information to Microsoft about software that has been detected including where the software came from the actions that you apply or that are applied automatically and whether the actions were successful.

Advanced membership in addition to basic information will send more information to Microsoft about malicious software spyware and potentially unwanted software including the location of the software file names how the software operates and how it has impacted your computer.

The recommended state for this setting is: *Disabled*.

Rationale:

The information that would be sent can include things like location of detected items on your computer if harmful software was removed. The information would be automatically collected and sent. In some instances personal information might unintentionally be sent to Microsoft. However, Microsoft states that it will not use this information to identify you or contact you.

For privacy reasons in high security environments, it is best to prevent these data submissions altogether.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Spynet:SpynetReporting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Disabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender  
Antivirus\MAPS  
Setting Name: Join Microsoft MAPS  
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Microsoft MAPS / Microsoft Defender Antivirus Cloud Protection Service will not be joined.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.43.4 Microsoft Defender Exploit Guard (formerly Windows Defender Exploit Guard)

This section contains Microsoft Defender Exploit Guard settings.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

Note: This section was originally named *Windows Defender Exploit Guard* but was renamed by Microsoft to *Microsoft Defender Exploit Guard* starting with the Microsoft Windows 10 Release 2004 Administrative Templates.

18.10.43.4.1 Attack Surface Reduction

This section contains Attack Surface Reduction settings.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.4.1.1 (L1) Ensure 'Configure Attack Surface Reduction rules' is set to 'Enabled' (Manual)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls the state for the Attack Surface Reduction (ASR) rules.

The recommended state for this setting is: `Enabled`.

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

Please see recommendation 18.9.45.4.1.2.

Remediation:

Please see recommendation 18.9.45.4.1.2.

Default Value:

Disabled. (No ASR rules will be configured.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.43.4.1.2 (L1) Ensure 'Configure Attack Surface Reduction rules: Set the state for each ASR rule' is configured (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting sets the Attack Surface Reduction rules.

The recommended state for this setting is:

26190899-1602-49e8-8b27-eb1d0a1ce869 - 1 (Block Office communication application from creating child processes)
3b576869-a4ec-4529-8536-b80a7769e899 - 1 (Block Office applications from creating executable content)
56a863a9-875e-4185-98a7-b882c64b5ce5 - 1 (Block abuse of exploited vulnerable signed drivers)
5beb7efe-fd9a-4556-801d-275e5ffc04cc - 1 (Block execution of potentially obfuscated scripts)
75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84 - 1 (Block Office applications from injecting code into other processes)
7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c - 1 (Block Adobe Reader from creating child processes)
92e97fa1-2edf-4476-bdd6-9dd0b4dddc7b - 1 (Block Win32 API calls from Office macro)
9e6c4e1f-7d60-472f-ba1a-a39ef669e4b2 - 1 (Block credential stealing from the Windows local security authority subsystem (lsass.exe))
b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4 - 1 (Block untrusted and unsigned processes that run from USB)
be9ba2d9-53ea-4cdc-84e5-9b1eeee46550 - 1 (Block executable content from email client and webmail)
d3e037e1-3eb8-44c8-a917-57927947596d - 1 (Block JavaScript or VBScript from launching downloaded executable content)
d4f940ab-401b-4efc-aadc-ad5f3c50688a - 1 (Block Office applications from creating child processes)
e6db77e5-3df2-4cf1-b95a-636979351e5b - 1 (Block persistence through WMI event subscription)

Note: More information on ASR rules can be found at the following link: [Use Attack surface reduction rules to prevent malware infection | Microsoft Docs](#)

Rationale:

Attack surface reduction helps prevent actions and apps that are typically used by exploit-seeking malware to infect machines.

Impact:

When a rule is triggered, a notification will be displayed from the Action Center.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:26190899-1602-49e8-8b27-eb1d0a1ce869  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:3b576869-a4ec-4529-8536-b80a7769e899  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:56a863a9-875e-4185-98a7-b882c64b5ce5  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:5beb7efe-fd9a-4556-801d-275e5ffc04cc  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:7674ba52-37eb-4a4f-a9a1-f0f9a1619a2c  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:92e97fa1-2edf-4476-bdd6-9dd0b4dddc7b  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:9e6c4e1f-7d60-472f-bala-a39ef669e4b2  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:be9ba2d9-53ea-4cdc-84e5-9b1eeee46550  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:d3e037e1-3eb8-44c8-a917-57927947596d  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:d4f940ab-401b-4efc-aadc-ad5f3c50688a  
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Windows  
Defender Exploit Guard\ASR\Rules:e6db77e5-3df2-4cf1-b95a-636979351e5b
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled` with the below rules:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender
Antivirus\Microsoft Defender Exploit Guard\Attack Surface Reduction
Setting Name: Configure Attack Surface Reduction rules: Set the state for
each ASR rule
Configuration: Enabled: 26190899-1602-49e8-8b27-eb1d0a1ce869, 3b576869-a4ec-
4529-8536-b80a7769e899, 56a863a9-875e-4185-98a7-b882c64b5ce5, 5beb7efe-fd9a-
4556-801d-275e5ffc04cc, 75668c1f-73b5-4cf0-bb93-3ecf5cb7cc84, 7674ba52-37eb-
4a4f-a9a1-f0f9a1619a2c, 92e97fa1-2edf-4476-bdd6-9dd0b4dddc7b, 9e6c4e1f-7d60-
472f-bala-a39ef669e4b2, b2b3f03d-6a65-4f7b-a9c7-1c7ef74a9ba4, be9ba2d9-53ea-
4cdc-84e5-9b1eeee46550, d3e037e1-3eb8-44c8-a917-57927947596d, d4f940ab-401b-
4efc-aadc-ad5f3c50688a, and e6db77e5-3df2-4cf1-b95a-636979351e5b
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (No ASR rules will be configured.)

References:

1. <https://docs.microsoft.com/en-us/microsoft-365/security/defender-endpoint/enable-attack-surface-reduction?view=o365-worldwide>
2. <https://docs.microsoft.com/en-us/microsoft-365/security/defender-endpoint/attack-surface-reduction?view=o365-worldwide>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.43.4.2 Controlled Folder Access

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.4.3 Network Protection

This section contains Windows Network Protection settings.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.43.4.3.1 (L1) Ensure 'Prevent users and apps from accessing dangerous websites' is set to 'Enabled: Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls Microsoft Defender Exploit Guard network protection.

The recommended state for this setting is: `Enabled: Block`.

Rationale:

This setting can help prevent employees from using any application to access dangerous domains that may host phishing scams, exploit-hosting sites, and other malicious content on the Internet.

Impact:

Users and applications will not be able to access dangerous domains.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Defender:EnableNetworkProtection_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Defender:EnableNetworkProtection
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:EnableNetworkProtection
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to either `Enable`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Endpoint protection)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Endpoint protection/Microsoft Defender Exploit Guard/Network Filtering
Setting Name:	Network protection
Configuration:	Enable

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users and applications will not be blocked from connecting to dangerous domains.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.3 <u>Maintain and Enforce Network-Based URL Filters</u> Enforce and update network-based URL filters to limit an enterprise asset from connecting to potentially malicious or unapproved websites. Example implementations include category-based filtering, reputation-based filtering, or through the use of block lists. Enforce filters for all enterprise assets.			
v7	7.4 <u>Maintain and Enforce Network-Based URL Filters</u> Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.43.5 MpEngine

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.43.5.1 (L2) Ensure 'Enable file hash computation feature' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting determines whether hash values are computed for files scanned by Microsoft Defender.

The recommended state for this setting is: `Enabled`.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to monitor for suspicious and known malicious activity. File hashes are a reliable way of detecting changes to files, and can speed up the scan process by skipping files that have not changed since they were last scanned and determined to be safe. A changed file hash can also be cause for additional scrutiny.

Impact:

This setting could cause performance degradation during initial deployment and for users where new executable content is frequently being created (such as software developers), or where applications are frequently installed or updated.

For more information on this setting, please visit [Security baseline \(FINAL\): Windows 10 and Windows Server, version 2004 - Microsoft Tech Community - 1543631](#).

Note: The impact of this setting should be monitored closely during deployment to ensure user and system performance impact is within acceptable limits.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\MpEngine:EnableFileHashComputation
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender
Antivirus\MpEngine
Setting Name: Enable file hash computation feature
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (File hash values are not computed during scans.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.43.6 Network Inspection System

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.7 Quarantine

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.8 Real-time Protection

This section contains settings related to Real-time Protection.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.8.1 (L1) Ensure 'Scan all downloaded files and attachments' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting configures scanning for all downloaded files and attachments.

The recommended state for this setting is: `Enabled`.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:DisableIOAVProtection
```

Note: If using the Intune Settings Catalog, the registry key will be located in the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:DisableIOAVProtection
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Microsoft Defender Antivirus\Real-Time Protection Setting Name: Scan all downloaded files and attachments Configuration: Enabled
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (All downloaded files and attachments will be scanned.)

References:

1. <https://docs.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-antivirus/configure-real-time-protection-microsoft-defender-antivirus>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

18.10.43.8.2 (L1) Ensure 'Turn off real-time protection' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting configures real-time protection prompts for known malware detection.

Microsoft Defender Antivirus alerts you when malware or potentially unwanted software attempts to install itself or to run on your computer.

The recommended state for this setting is: `Disabled`.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

<code>HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection:DisableRealtimeMonitoring</code>

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\Windows Components\Microsoft Defender
Antivirus\Real-Time Protection
Setting Name:  Turn off real-time protection
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Microsoft Defender Antivirus will prompt users to take actions on malware detections.)

References:

1. <https://docs.microsoft.com/en-us/windows/security/threat-protection/microsoft-defender-antivirus/configure-real-time-protection-microsoft-defender-antivirus>
2. <https://docs.microsoft.com/en-us/microsoft-365/security/defender-endpoint/configure-protection-features-microsoft-defender-antivirus?view=o365-worldwide>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

18.10.43.8.3 (L1) Ensure 'Turn on behavior monitoring' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to configure behavior monitoring for Microsoft Defender Antivirus.

The recommended state for this setting is: `Enabled`.

Rationale:

When running an antivirus solution such as Microsoft Defender Antivirus, it is important to ensure that it is configured to heuristically monitor in real-time for suspicious and known malicious activity.

Impact:

None - this is the default configuration.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time  
Protection:DisableBehaviorMonitoring
```

Note: If using the Intune Settings Catalog, the registry key will be located in the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:DisableBehaviorMonitoring
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Microsoft Defender Antivirus\Real-Time Protection
Setting Name: Turn on behavior monitoring
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Behavior monitoring will be enabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.7 <u>Use Behavior-Based Anti-Malware Software</u> Use behavior-based anti-malware software.		●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.43.9 Remediation

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.10 Reporting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.10.1 (L2) Ensure 'Configure Watson events' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to configure whether or not Watson events are sent.

The recommended state for this setting is: `Disabled`.

Rationale:

Watson events are the reports that get sent to Microsoft when a program or service crashes or fails, including the possibility of automatic submission. Preventing this information from being sent can help reduce privacy concerns.

Impact:

Watson events will not be sent to Microsoft automatically when a program or service crashes or fails.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Reporting:DisableGenericRePorts
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender
Antivirus\Reporting
Setting Name: Configure Watson events
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Watson events *will* be sent to Microsoft automatically when a program or service crashes or fails.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	13.3 Monitor and Block Unauthorized Network Traffic Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.			●

18.10.43.11 Scan

This section contains settings related to Microsoft Defender scanning.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.11.1 (L1) Ensure 'Scan removable drives' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether or not to scan for malicious software and unwanted software in the contents of removable drives, such as USB flash drives, when running a full scan.

The recommended state for this setting is: *Enabled*.

Rationale:

It is important to ensure that any present removable drives are always included in any type of scan, as removable drives are more likely to contain malicious software brought in to the enterprise managed environment from an external, unmanaged computer.

Impact:

Removable drives will be scanned during any type of scan by Microsoft Defender Antivirus.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Scan:DisableRemovableDriveScanning
```

Note: If using the Intune Settings Catalog, the registry key will be located in the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:DisableRemovableDriveScanning
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Microsoft Defender Antivirus\Scan
Setting Name: Scan removable drives
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Removable drives will not be scanned during a full scan. Removable drives may still be scanned during quick scan and custom scan.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>10.4 Configure Automatic Anti-Malware Scanning of Removable Media</u> Configure anti-malware software to automatically scan removable media.		●	●
v7	<u>8.4 Configure Anti-Malware Scanning of Removable Devices</u> Configure devices so that they automatically conduct an anti-malware scan of removable media when inserted or connected.	●	●	●

18.10.43.11.2 (L1) Ensure 'Turn on e-mail scanning' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to configure e-mail scanning. When e-mail scanning is enabled, the engine will parse the mailbox and mail files, according to their specific format, in order to analyze the mail bodies and attachments. Several e-mail formats are currently supported, for example: pst (Outlook), dbx, mbx, mime (Outlook Express), binhex (Mac).

The recommended state for this setting is: `Enabled`.

Rationale:

Incoming e-mails should be scanned by an antivirus solution such as Microsoft Defender Antivirus, as email attachments are a commonly used attack vector to infiltrate computers with malicious software.

Impact:

E-mail scanning by Microsoft Defender Antivirus will be enabled.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender\Scan:DisableEmailScanning
```

Note: If using the Intune Settings Catalog, the registry key will be located in the following registry location:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy  
Manager:DisableEmailScanning
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Microsoft Defender
Antivirus\Scan
Setting Name: Turn on e-mail scanning
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (E-mail scanning by Microsoft Defender Antivirus will be disabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.43.12 Security Intelligence Updates (formerly Signature Updates)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Note: This section was initially named *Signature Updates* but was renamed by Microsoft to *Security Intelligence Updates* starting with the Microsoft Windows 10 Release 1903 Administrative Templates.

18.10.43.13 Threats

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefender.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

18.10.43.14 (L1) Ensure 'Configure detection for potentially unwanted applications' is set to 'Enabled: Block' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls detection and action for Potentially Unwanted Applications (PUA), which are sneaky unwanted application bundlers or their bundled applications, that can deliver adware or malware.

The recommended state for this setting is: `Enabled: Block`.

For more information, see this link: [Block potentially unwanted applications with Microsoft Defender Antivirus | Microsoft Docs](#)

Rationale:

Potentially unwanted applications can increase the risk of your network being infected with malware, cause malware infections to be harder to identify, and can waste IT resources in cleaning up the applications. They should be blocked from installation.

Impact:

Applications that are identified by Microsoft as PUA will be blocked at download and install time.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows Defender\Policy Manager:PUAProtection
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Block`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Defender/PUAProtection
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Applications that are identified by Microsoft as PUA will not be blocked.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-defender#puaprotection>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	2.7 <u>Utilize Application Whitelisting</u> Utilize application whitelisting technology on all assets to ensure that only authorized software executes and all unauthorized software is blocked from executing on assets.			●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.43.15 (L1) Ensure 'Turn off Microsoft Defender AntiVirus' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting turns off Microsoft Defender Antivirus. If the setting is configured to Disabled, Microsoft Defender Antivirus runs and computers are scanned for malware and other potentially unwanted software.

The recommended state for this setting is: `Disabled`.

Rationale:

It is important to ensure a current, updated antivirus product is scanning each computer for malicious file activity. Microsoft provides a competent solution out of the box in Microsoft Defender Antivirus.

Organizations that choose to purchase a reputable 3rd-party antivirus solution may choose to exempt themselves from this recommendation in lieu of the commercial alternative.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows  
Defender:DisableAntiSpyware
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Microsoft Defender Antivirus
Setting Name:	Turn off Microsoft Defender AntiVirus
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Microsoft Defender Antivirus runs and computers are scanned for malware and other potentially unwanted software.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 <u>Deploy and Maintain Anti-Malware Software</u> Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.44 Microsoft Defender Application Guard (formerly Windows Defender Application Guard)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `AppHVSI.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

Note: This section was originally named *Windows Defender Application Guard* but was renamed by Microsoft to *Microsoft Defender Application Guard* starting with the Microsoft Windows 10 Release 2004 Administrative Templates.

18.10.45 Microsoft Defender Exploit Guard (formerly Windows Defender Exploit Guard)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ExploitGuard.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

Note: This section was originally named *Windows Defender Exploit Guard*, but was renamed by Microsoft to *Microsoft Defender Exploit Guard* starting with the Microsoft Windows 10 Release 2004 Administrative Templates.

18.10.46 Microsoft Edge

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MicrosoftEdge.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.47 Microsoft FIDO Authentication

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FidoAuth.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.48 Microsoft Secondary Authentication Factor

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DeviceCredential.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.49 Microsoft User Experience Virtualization

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `UserExperienceVirtualization.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.50 NetMeeting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Conf.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.51 News and interests

This section contains recommendations related to News and interests.

This Group Policy section is provided by the Group Policy template `Feeds.admx/adml` that is included with the Microsoft Windows 10 Release 21H1 Administrative Templates (or newer).

18.10.52 OneDrive (formerly SkyDrive)

This section contains recommendations related to OneDrive.

The Group Policy settings contained within this section are provided by the Group Policy template `SkyDrive.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

Note: This section was initially named *SkyDrive* but was renamed by Microsoft to *OneDrive* starting with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates.

18.10.52.1 (L1) Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting lets you prevent apps and features from working with files on OneDrive using the Next Generation Sync Client.

The recommended state for this setting is: `Enabled`.

Rationale:

Enabling this setting prevents users from accidentally (or intentionally) uploading confidential or sensitive corporate information to the OneDrive cloud service using the Next Generation Sync Client.

Note: This security concern applies to *any* cloud-based file storage application installed on a workstation, not just the one supplied with Windows.

Impact:

Users can't access OneDrive from the OneDrive app and file picker. Windows Store apps can't access OneDrive using the `WinRT` API. OneDrive doesn't appear in the navigation pane in File Explorer. OneDrive files aren't kept in sync with the cloud. Users can't automatically upload photos and videos from the camera roll folder.

Note: If your organization uses Office 365, be aware that this setting will prevent users from saving files to OneDrive/SkyDrive.

Note #2: If your organization has decided to implement **OneDrive for Business** and therefore needs to except itself from this recommendation, we highly suggest that you also obtain and utilize the `OneDrive.admx/adml` template that is bundled with the latest OneDrive client, as noted [at this link](#) (this template is not included with the Windows Administrative Templates). Two alternative OneDrive settings in particular from that template are worth your consideration:

- *Allow syncing OneDrive accounts for only specific organizations* - a computer-based setting that restricts OneDrive client connections to only **approved** tenant IDs.
- *Prevent users from synchronizing personal OneDrive accounts* - a user-based setting that prevents use of consumer OneDrive (i.e. non-business).

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\System:DisableOneDriveFileSync_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\System:DisableOneDriveFileSync
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/System/DisableOneDriveFileSync
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Apps and features can work with OneDrive file storage using the Next Generation Sync Client.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>13.4 Only Allow Access to Authorized Cloud Storage or Email Providers</u> Only allow access to authorized cloud storage or email providers.			

18.10.53 Online Assistance

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `HelpAndSupport.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.54 OOBE

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `OOBE.admx/adml` that is included with the Microsoft Windows 10 Release 1809 and Server 2019 Administrative Templates (or newer).

18.10.55 Portable Operating System

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ExternalBoot.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.56 Presentation Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MobilePCPresentationSettings.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.57 Push To Install

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `PushToInstall.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.57.1 (L2) Ensure 'Turn off Push To Install service' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting controls whether users can push Apps to the device from the Microsoft Store App running on other devices or the web.

The recommended state for this setting is: *Enabled*.

Rationale:

In a high security managed environment, application installations should be managed centrally by IT staff, not by end users.

Impact:

Users will not be able to push Apps to this device from the Microsoft Store running on other devices or the web.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\PushToInstall:DisablePushToInstall
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Push to Install
Setting Name:	Turn off Push To Install service
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users are able to push Apps to this device from the Microsoft Store running on other devices or the web.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.58 Remote Desktop Services (formerly Terminal Services)

This section contains recommendations related to Remote Desktop Services.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Terminal Services* but was renamed by Microsoft to *Remote Desktop Services* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

18.10.58.1 RD Licensing (formerly TS Licensing)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *TS Licensing* but was renamed by Microsoft to *RD Licensing* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

18.10.58.2 Remote Desktop Connection Client

This section contains recommendations for the Remote Desktop Connection Client.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.2.1 RemoteFX USB Device Redirection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.58.2.2 (L1) Ensure 'Do not allow passwords to be saved' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting helps prevent Remote Desktop clients from saving passwords on a computer.

The recommended state for this setting is: `Enabled`.

Note: If this policy setting was previously configured as Disabled or Not configured, any previously saved passwords will be deleted the first time a Remote Desktop client disconnects from any server.

Rationale:

An attacker with physical access to the computer may be able to break the protection guarding saved passwords. An attacker who compromises a user's account and connects to their computer could use saved passwords to gain access to additional hosts.

Impact:

The password saving checkbox will be disabled for Remote Desktop clients and users will not be able to save passwords.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteDesktopServices:DoNotAllowPasswordSaving_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteDesktopServices:DoNotAllowPasswordSaving
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\TerminalServices:DisablePasswordSaving
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Remote Desktop Services/Remote Desktop Connection Client Setting Name: Do not allow passwords to be saved Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users will be able to save passwords using Remote Desktop Connection.)

18.10.58.3 Remote Desktop Session Host (formerly Terminal Server)

This section contains recommendations for the Remote Desktop Session Host.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Terminal Server* but was renamed by Microsoft to *Remote Desktop Session Host* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

18.10.58.3.1 Application Compatibility

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer-Server.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.58.3.2 Connections

This section contains recommendations for Connections to the Remote Desktop Session Host.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.2.1 (L2) Ensure 'Allow users to connect remotely by using Remote Desktop Services' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to configure remote access to computers by using Remote Desktop Services.

The recommended state for this setting is: `Disabled`.

Rationale:

Any account with the *Allow log on through Remote Desktop Services* user right can log on to the remote console of the computer. If you do not restrict access to legitimate users who need to log on to the console of the computer, unauthorized users could download and execute malicious code to elevate their privileges.

Impact:

None - this is the default configuration, unless Remote Desktop Services has been manually enabled on the Remote tab in the System Properties sheet.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fDenyTSConnections
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration/Windows Components/Remote Desktop
Services/Remote Desktop Session Host/Connections
Setting Name:  Allow users to connect remotely by using Remote Desktop
Services
Configuration: Disabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users cannot connect remotely to the target computer by using Remote Desktop Services, unless it has been manually enabled from the Remote tab in the System Properties sheet.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.3 Device and Resource Redirection

This section contains recommendations related to Remote Desktop Session Host Device and Resource Redirection.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.3.1 (L2) Ensure 'Do not allow COM port redirection' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether to prevent the redirection of data to client COM ports from the remote computer in a Remote Desktop Services session.

The recommended state for this setting is: `Enabled`.

Rationale:

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for COM port redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

Impact:

Users in a Remote Desktop Services session will not be able to redirect server data to local (client) COM ports.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fDisableCcm
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection
Setting Name: Do not allow COM port redirection
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services allows COM port redirection.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.3.2 (L1) Ensure 'Do not allow drive redirection' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents users from sharing the local drives on their client computers to Remote Desktop Servers that they access. Mapped drives appear in the session folder tree in Windows Explorer in the following format:

```
\\TSCClient\<driveletter>$
```

If local drives are shared they are left vulnerable to intruders who want to exploit the data that is stored on them.

The recommended state for this setting is: *Enabled*.

Rationale:

Data could be forwarded from the user's Remote Desktop Services session to the user's local computer without any direct user interaction. Malicious software already present on a compromised server would have direct and stealthy disk access to the user's local computer during the Remote Desktop session.

Impact:

Drive redirection will not be possible. In most situations, traditional network drive mapping to file shares (including administrative shares) performed manually by the connected user will serve as a capable substitute to still allow file transfers when needed.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fDisableCdm
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Remote Desktop Services/Remote Desktop Session Host/Device and Resource Redirection
Setting Name: Do not allow drive redirection
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (An RD Session Host maps client drives automatically upon connection.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.3.3 (L2) Ensure 'Do not allow LPT port redirection' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether to prevent the redirection of data to client LPT ports during a Remote Desktop Services session.

The recommended state for this setting is: `Enabled`.

Rationale:

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for LPT port redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

Impact:

Users in a Remote Desktop Services session will not be able to redirect server data to local (client) LPT ports.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fDisableLPT
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection
Setting Name: Do not allow LPT port redirection
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services allows LPT port redirection.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.3.4 (L2) Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to control the redirection of supported Plug and Play devices, such as Windows Portable Devices, to the remote computer in a Remote Desktop Services session.

The recommended state for this setting is: `Enabled`.

Rationale:

In a more security-sensitive environment, it is desirable to reduce the possible attack surface. The need for Plug and Play device redirection within a Remote Desktop session is very rare, so makes sense to reduce the number of unexpected avenues for data exfiltration and/or malicious code transfer.

Impact:

Users in a Remote Desktop Services session will not be able to redirect their supported (local client) Plug and Play devices to the remote computer.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fDisablePNPRedir
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Device and Resource Redirection Setting Name: Do not allow supported Plug and Play device redirection Configuration: Enabled
--

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services allows redirection of supported Plug and Play devices.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.4 Licensing

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.5 Printer Redirection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.6 Profiles

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.7 RD Connection Broker (formerly TS Connection Broker)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *TS Connection Broker* but was renamed by Microsoft to *RD Connection Broker* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

18.10.58.3.8 Remote Session Environment

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.9 Security

This section contains recommendations related to Remote Desktop Session Host Security.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.9.1 (L1) Ensure 'Always prompt for password upon connection' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether Remote Desktop Services always prompts the client computer for a password upon connection. You can use this policy setting to enforce a password prompt for users who log on to Remote Desktop Services, even if they already provided the password in the Remote Desktop Connection client.

The recommended state for this setting is: *Enabled*.

Rationale:

Users have the option to store both their username and password when they create a new Remote Desktop Connection shortcut. If the server that runs Remote Desktop Services allows users who have used this feature to log on to the server but not enter their password, then it is possible that an attacker who has gained physical access to the user's computer could connect to a Remote Desktop Server through the Remote Desktop Connection shortcut, even though they may not know the user's password.

Impact:

Users cannot automatically log on to Remote Desktop Services by supplying their passwords in the Remote Desktop Connection client. They will be prompted for a password to log on.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fPromptForPassword
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Remote Desktop Services/Remote Desktop Session Host/Security
Setting Name: Always prompt for password upon connection
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services allows users to automatically log on if they enter a password in the Remote Desktop Connection client.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.58.3.9.2 (L1) Ensure 'Require secure RPC communication' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to specify whether Remote Desktop Services requires secure Remote Procedure Call (RPC) communication with all clients or allows unsecured communication.

You can use this policy setting to strengthen the security of RPC communication with clients by allowing only authenticated and encrypted requests.

The recommended state for this setting is: *Enabled*.

Rationale:

Allowing unsecure RPC communication can exposes the server to man in the middle attacks and data disclosure attacks.

Impact:

Remote Desktop Services accepts requests from RPC clients that support secure requests, and does not allow unsecured communication with untrusted clients.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:fEncryptRPCTraffic
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Remote Desktop Services/Remote Desktop Session Host/Security
Setting Name: Require secure RPC communication
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services always requests security for all RPC traffic. However, unsecured communication is allowed for RPC clients that do not respond to the request.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.9.3 (L1) Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether to require the use of a specific security layer to secure communications between clients and RD Session Host servers during Remote Desktop Protocol (RDP) connections.

The recommended state for this setting is: `Enabled: SSL`.

Note: In spite of this setting being labeled *SSL*, it is actually enforcing Transport Layer Security (TLS) version 1.0, not the older (and less secure) SSL protocol.

Rationale:

The native Remote Desktop Protocol (RDP) encryption is now considered a weak protocol, so enforcing the use of stronger Transport Layer Security (TLS) encryption for all RDP communications between clients and RD Session Host servers is preferred.

Impact:

TLS 1.0 will be required to authenticate to the RD Session Host server. If TLS is not supported, the connection fails.

Note: By default, this setting will use a self-signed certificate for RDP connections. If your organization has established the use of a Public Key Infrastructure (PKI) for SSL/TLS encryption, then we recommend that you also configure the *Server authentication certificate template* setting to instruct RDP to use a certificate from your PKI instead of a self-signed one. Note that the certificate template used for this purpose must have “Client Authentication” configured as an Intended Purpose. Note also that a valid, non-expired certificate using the specified template must already be installed on the workstation for it to work.

Note #2: Some third party two-factor authentication solutions (e.g. RSA Authentication Agent) can be negatively affected by this setting, as the SSL/TLS security layer will expect the user's Windows password upon initial connection attempt (before the RDP logon screen), and once successfully authenticated, pass the credential along to that Windows session on the RDP host (to complete the login). If a two-factor agent is present and expecting a different credential at the RDP logon screen, this initial connection may result in a failed logon attempt, and also effectively cause a “double logon” requirement for each and every new RDP session.

Audit:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services\SecurityLayer
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: SSL:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path: Computer Configuration\Windows Components\Remote Desktop  
Services\Remote Desktop Session Host\Security  
Setting Name: Require use of specific security layer for remote (RDP)  
connections  
Configuration: Enabled: SSL
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Negotiate. (The most secure method that is supported by the client is enforced. If TLS is supported, it is used to authenticate the RD Session Host server. If TLS is not supported, native RDP encryption is used, but the RD Session Host server is not authenticated.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.9.4 (L1) Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to specify whether to require user authentication for remote connections to the RD Session Host server by using Network Level Authentication.

The recommended state for this setting is: `Enabled`.

Rationale:

Requiring that user authentication occur earlier in the remote connection process enhances security.

Impact:

Only client computers that support Network Level Authentication can connect to the RD Session Host server.

Note: Some third party two-factor authentication solutions (e.g. RSA Authentication Agent) can be negatively affected by this setting, as Network Level Authentication will expect the user's Windows password upon initial connection attempt (before the RDP logon screen), and once successfully authenticated, pass the credential along to that Windows session on the RDP host (to complete the login). If a two-factor agent is present and expecting a different credential at the RDP logon screen, this initial connection may result in a failed logon attempt, and also effectively cause a "double logon" requirement for each and every new RDP session.

Audit:

Navigate to the following registry location and confirm it is set to 1.

<code>HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services\UserAuthentication</code>

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Path:          Computer Configuration\Windows Components\Remote Desktop
Services\Remote Desktop Session Host\Security
Setting Name:  Require user authentication for remote connections by using
Network Level Authentication
Configuration: Enabled
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Windows 7 and older: Disabled.

Windows 8.0 and newer: Enabled.

References:

1. <https://social.technet.microsoft.com/wiki/contents/articles/5490.configure-network-level-authentication-for-remote-desktop-services-connections.aspx>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.9.5 (L1) Ensure 'Set client connection encryption level' is set to 'Enabled: High Level' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether to require the use of a specific encryption level to secure communications between client computers and RD Session Host servers during Remote Desktop Protocol (RDP) connections. This policy only applies when you are using native RDP encryption. However, native RDP encryption (as opposed to SSL encryption) is not recommended. This policy does not apply to SSL encryption.

The recommended state for this setting is: `Enabled: High Level`.

Rationale:

If Remote Desktop client connections that use low level encryption are allowed, it is more likely that an attacker will be able to decrypt any captured Remote Desktop Services network traffic.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:MinEncryptionLevel
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: High Level`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Remote Desktop Services/Remote Desktop Session Host/Security
Setting Name: Set client connection encryption level
Configuration: Enabled: High Level

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: High Level. (All communications between clients and RD Session Host servers during remote connections using native RDP encryption must be 128-bit strength. Clients that do not support 128-bit encryption will be unable to establish Remote Desktop Server sessions.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.58.3.10 Session Time Limits

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.10.1 (L2) Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 15 minutes or less, but not Never (0)' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to specify the maximum amount of time that an active Remote Desktop Services session can be idle (without user input) before it is automatically disconnected.

The recommended state for this setting is: `Enabled: 15 minutes or less, but not Never (0)`.

Rationale:

This setting helps to prevent active Remote Desktop sessions from tying up the computer for long periods of time while not in use, preventing computing resources from being consumed by large numbers of inactive sessions. In addition, old, forgotten Remote Desktop sessions that are still active can cause password lockouts if the user's password has changed but the old session is still running. For systems that limit the number of connected users (e.g. servers in the default Administrative mode - 2 sessions only), other users' old but still active sessions can prevent another user from connecting, resulting in an effective denial of service.

Impact:

Remote Desktop Services will automatically disconnect active but idle sessions after 15 minutes (or the specified amount of time). The user receives a warning two minutes before the session disconnects, which allows the user to press a key or move the mouse to keep the session active. Note that idle session time limits do not apply to console sessions.

Audit:

Navigate to the following registry location and confirm it is set to `9000` or higher, but not `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services:MaxIdleTime
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled:15 minutes or less, but not Never (0)`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Session Time Limits
Setting Name: Set time limit for active but idle Remote Desktop Services sessions
Configuration: Enabled: 15 minutes or less, but not Never (0)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Remote Desktop Services allows sessions to remain active but idle for an unlimited amount of time.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.10.58.3.10.2 (L2) Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 1 minute' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to configure a time limit for disconnected Remote Desktop Services sessions.

The recommended state for this setting is: `Enabled: 1 minute`.

Rationale:

This setting helps to prevent active Remote Desktop sessions from tying up the computer for long periods of time while not in use, preventing computing resources from being consumed by large numbers of disconnected but still active sessions. In addition, old, forgotten Remote Desktop sessions that are still active can cause password lockouts if the user's password has changed but the old session is still running. For systems that limit the number of connected users (e.g. servers in the default Administrative mode - 2 sessions only), other users' old but still active sessions can prevent another user from connecting, resulting in an effective denial of service. This setting is important to ensure a disconnected session is properly terminated.

Impact:

Disconnected Remote Desktop sessions are deleted from the server after 1 minute. Note that disconnected session time limits do not apply to console sessions.

Audit:

Navigate to the following registry location and confirm it is set to `60000`.

<code>HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal Services:MaxDisconnectionTime</code>

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled: 1 minute**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Session Time Limits
Setting Name: Set time limit for disconnected sessions
Configuration: Enabled: 1 minute

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Disconnected Remote Desktop sessions are maintained for an unlimited time on the server.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.10.58.3.11 Temporary folders

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.58.3.11.1 (L1) Ensure 'Do not delete temp folders upon exit' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether Remote Desktop Services retains a user's per-session temporary folders at logoff.

The recommended state for this setting is: `Disabled`.

Rationale:

Sensitive information could be contained inside the temporary folders and visible to other administrators that log into the system.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows NT\Terminal  
Services>DeleteTempDirsOnExit
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration\Windows Components\Remote Desktop Services\Remote Desktop Session Host\Temporary Folders
Setting Name: Do not delete temp folders upon exit
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Temporary folders are deleted when a user logs off.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.4 <u>Enforce Data Retention</u> Retain data according to the enterprise's data management process. Data retention must include both minimum and maximum timelines.			
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.59 RSS Feeds

This section contains recommendations related to RSS feeds.

This Group Policy section is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.59.1 (L1) Ensure 'Prevent downloading of enclosures' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents the user from having enclosures (file attachments) downloaded from an RSS feed to the user's computer.

The recommended state for this setting is: `Enabled`.

Rationale:

Allowing attachments to be downloaded through the RSS feed can introduce files that could have malicious intent.

Impact:

Users cannot set the Feed Sync Engine to download an enclosure through the Feed property page. Developers cannot change the download setting through feed APIs.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\InternetExplorer:DisableEnclosureDownloading_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\InternetExplorer:DisableEnclosureDownloading
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Internet Explorer\Feeds:DisableEnclosureDownload
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/RSS Feeds
Setting Name:	Prevent downloading of enclosures
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can set the Feed Sync Engine to download an enclosure through the Feed property page. Developers can change the download setting through the Feed APIs.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>9.4 Restrict Unnecessary or Unauthorized Browser and Email Client Extensions</u> Restrict, either through uninstalling or disabling, any unauthorized or unnecessary browser or email client plugins, extensions, and add-on applications.			
v7	<u>7.2 Disable Unnecessary or Unauthorized Browser or Email Client Plugins</u> Uninstall or disable any unauthorized browser or email client plugins or add-on applications.			

18.10.60 Search

This section contains recommendations for Search settings.

This Group Policy section is provided by the Group Policy template `Search.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.60.1 OCR

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SearchOCR.admx/adml` that is only included with the Microsoft Windows 7 & Server 2008 R2 through the Windows 10 Release 1511 Administrative Templates.

18.10.60.2 (L2) Ensure 'Allow Cloud Search' is set to 'Enabled: Disable Cloud Search' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows search and Cortana to search cloud sources like OneDrive and SharePoint.

The recommended state for this setting is: Enabled: Disable Cloud Search.

Rationale:

Due to privacy concerns, data should never be sent to any 3rd party since this data could contain sensitive information.

Impact:

Search and Cortana will not be permitted to search cloud sources like OneDrive and SharePoint.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Search:AllowCloudSearch_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Search:AllowCloudSearch
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: `Disable Cloud Search`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Search/AllowCloudSearch
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: Enable Cloud Search. (Allow search and Cortana to search cloud sources like OneDrive and SharePoint.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-search#allowcloudsearch>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.60.3 (L1) Ensure 'Allow Cortana' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether Cortana is allowed on the device.

The recommended state for this setting is: `Disabled`.

Rationale:

If Cortana is enabled, sensitive information could be contained in search history and sent out to Microsoft.

Impact:

Cortana will be turned off. Users will still be able to use search to find things on the device and on the Internet.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Experience:AllowCortana_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Experience:AllowCortana
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Experience/AllowCortana
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Cortana will be allowed on the device.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.60.4 (L1) Ensure 'Allow Cortana above lock screen' is set to 'Blocked' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether or not the user can interact with Cortana using speech while the system is locked.

The recommended state for this setting is: `Blocked`.

Rationale:

Access to any computer resource should not be allowed when the device is locked.

Impact:

The system will need to be unlocked for the user to interact with Cortana using speech.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\AboveLock:
AllowCortanaAboveLock_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\
Device\AboveLock:AllowCortanaAboveLock
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Blocked**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device Restrictions/Locked Screen Experience
Setting Name:	Cortana on locked screen (Desktop only)
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (The user can interact with Cortana using speech while the system is locked.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>16.11 Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.	●	●	●

18.10.60.5 (L1) Ensure 'Allow indexing of encrypted files' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether encrypted items are allowed to be indexed. When this setting is changed, the index is rebuilt completely. Full volume encryption (such as BitLocker Drive Encryption or a non-Microsoft solution) must be used for the location of the index to maintain security for encrypted files.

The recommended state for this setting is: *Disabled*.

Rationale:

Indexing and allowing users to search encrypted files could potentially reveal confidential data stored within the encrypted files.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Search:AllowIndexingEncryptedStoresOrItems_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Search\AllowIndexingEncryptedStoresOrItems:value
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Search/AllowIndexingEncryptedStoresOrItems
Data type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Search service components (including non-Microsoft components) are expected not to index encrypted items or encrypted stores.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 <u>Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	14.8 <u>Encrypt Sensitive Information at Rest</u> Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.			●

18.10.60.6 (L1) Ensure 'Allow search and Cortana to use location' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether search and Cortana can provide location aware search and Cortana results.

The recommended state for this setting is: `Disabled`.

Rationale:

In an enterprise managed environment, allowing Cortana and Search to have access to location data is unnecessary. Organizations likely do not want this information shared out.

Impact:

Search and Cortana will not have access to location information.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Search:AllowSearchToUseLocation_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Search\AllowSearchToUseLocation:value
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Search/AllowSearchToUseLocation
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Search and Cortana can access location information.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.61 Security Center

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SecurityCenter.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.62 Shutdown Options

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinInit.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.63 Smart Card

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SmartCard.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.64 Software Protection Platform

This section contains recommendations related to the Software Protection Platform.

This Group Policy section is provided by the Group Policy template `AVSValidationGP.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.64.1 (L2) Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

The Key Management Service (KMS) is a Microsoft license activation method that entails setting up a local server to store the software licenses. The KMS server itself needs to connect to Microsoft to activate the KMS service, but subsequent on-network clients can activate Microsoft Windows OS and/or their Microsoft Office via the KMS server instead of connecting directly to Microsoft. This policy setting lets you opt-out of sending KMS client activation data to Microsoft automatically.

The recommended state for this setting is: *Enabled*.

Rationale:

Even though the KMS licensing method does not *require* KMS clients to connect to Microsoft, they still send KMS client activation state data to Microsoft automatically. Preventing this information from being sent can help reduce privacy concerns in high security environments.

Impact:

The computer is prevented from sending data to Microsoft regarding its KMS client activation state.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Licensing:DisallowKMSClientOnlineAVSValidation_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Licensing:DisallowKMSClientOnlineAVSValidation
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Enabled':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Licensing/DisallowKMSClientOnlineAVSValidation
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (KMS client activation data will automatically be sent to Microsoft when the device activates.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	9.2 <u>Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.65 Sound Recorder

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SoundRec.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.66 Speech

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Speech.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.67 Store

This section contains recommendations related to the Microsoft Store.

This Group Policy section is provided by the Group Policy template `WinStoreUI.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates, or by the Group Policy template `WindowsStore.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

18.10.67.1 (L2) Ensure 'Disable all apps from Microsoft Store' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting configures the launch of all apps from the Microsoft Store that came pre-installed or were downloaded.

The recommended state for this setting is: `Disabled`.

Note: This policy setting only applies to Windows 10 Enterprise and Windows 10 Education editions.

Note #2: The name of this setting and the Enabled/Disabled values are incorrectly worded – logically, the title implies that configuring it to `Enabled` will disable all apps from the Microsoft Store, and configuring it to `Disabled` will enable all apps from the Microsoft Store. The opposite is true (and is consistent with the GPME help text). This is a logical wording mistake by Microsoft in the Administrative Template.

Rationale:

The Store service is a retail outlet built into Windows, primarily for consumer use. In an enterprise managed environment the IT department should be managing the installation of all applications to reduce the risk of the installation of vulnerable software.

Impact:

All apps from the Microsoft Store that came pre-installed or were downloaded are prevented from launching. Existing Microsoft Store apps will not be updated. Microsoft Store is disabled.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:DisableStoreOriginatedApps_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:DisableStoreOriginatedApps
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Disabled':

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/DisableStoreOriginat
edApps
Data type:      Integer
Value:          1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Microsoft Store apps are permitted to be launched and updated. Microsoft Store is enabled.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>2.5 Allowlist Authorized Software</u> Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.67.2 (L1) Ensure 'Only display the private store within the Microsoft Store' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting denies access to the retail catalog in the Microsoft Store, but displays the private store.

The recommended state for this setting is: `Enabled`.

Rationale:

Allowing the private store will allow an organization to control the apps that users have access to add to a system. This will help ensure that unapproved malicious apps are not running on a system.

Impact:

Users will not be able to view the retail catalog in the Microsoft Store, but they will be able to view apps in the private store.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:RequirePrivateStoreOnly_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `1`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:RequirePrivateStoreOnly
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/RequirePrivateStoreOnly
Data type:    Integer
Value:        1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can access the retail catalog in the Microsoft Store.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>2.5 Allowlist Authorized Software</u> Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.67.3 (L1) Ensure 'Turn off Automatic Download and Install of updates' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting enables or disables the automatic download and installation of Microsoft Store app updates.

The recommended state for this setting is: `Disabled`.

Rationale:

Keeping your system properly patched can help protect against 0 day vulnerabilities.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:AllowAppStoreAutoUpdate_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\default\Device\ApplicationManagement:AllowAppStoreAutoUpdate
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/AllowAppStoreAutoUpdate
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Microsoft Store automatically downloads and installs updates for Microsoft Store apps.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>7.3 Perform Automated Operating System Patch Management</u> Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.67.4 (L1) Ensure 'Turn off the offer to update to the latest version of Windows' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

Enables or disables the Microsoft Store offer to update to the latest version of Windows.

The recommended state for this setting is: `Enabled`.

Rationale:

Unplanned OS upgrades can lead to more preventable support calls. The IT department should be managing and approving all upgrades and updates.

Impact:

The Microsoft Store application will not offer updates to the latest version of Windows.

Audit:

Navigate to the following registry location and confirm it is set to 1.

HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsStore:DisableOSUpgrade
--

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Store
Setting Name:	Turn off the offer to update to the latest version of Windows
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The Microsoft Store application will offer updates to the latest version of Windows.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.67.5 (L2) Ensure 'Turn off the Store application' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This setting denies or allows access to the Store application.

The recommended state for this setting is: `Enabled`.

Note: [Per Microsoft TechNet](#) and [MSKB 3135657](#), this policy setting does not apply to any Windows 10 editions other than Enterprise and Education.

Rationale:

Only applications approved by an IT department should be installed. Allowing users to install 3rd party applications can lead to missed patches and potential zero day vulnerabilities.

Impact:

Access to the Microsoft Store application is denied.

Warning: Disabling this setting will cause Microsoft Store App (WinGet) new installations to fail.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\WindowsStore:RemoveWindowsStore
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Store
Setting Name:	Turn off the Store application
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Access to the Microsoft Store application is allowed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.			
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.68 Sync your settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SettingSync.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.69 Tablet PC

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.70 Task Scheduler

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TaskScheduler.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.71 Tenant Restrictions

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TenantRestrictions.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.72 Text Input

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TextInput.admx/adml` that is only included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates and Microsoft Windows 10 Release 1511 Administrative Templates.

18.10.73 Widgets

This section contains recommendations related to Widgets.

This Group Policy section is provided by the Group Policy template `NewsAndInterests.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.74 Windows Calendar

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinCal.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.75 Windows Color System

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsColorSystem.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.76 Windows Customer Experience Improvement Program

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `CEIPEnable.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.77 Windows Defender SmartScreen

This section contains Windows Defender SmartScreen settings.

This Group Policy section is provided by the Group Policy template `SmartScreen.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.77.1 Explorer

This section contains recommendations for Explorer-related Windows Defender SmartScreen settings.

The Group Policy settings contained within this section are provided by the Group Policy template `WindowsExplorer.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.77.1.1 (L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled: Warn and prevent bypass' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage the behavior of Windows Defender SmartScreen. Windows Defender SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. Some information is sent to Microsoft about files and programs run on PCs with this feature enabled.

The recommended state for this setting is: `Enabled: Warn and prevent bypass`.

Rationale:

Windows Defender SmartScreen helps keep PCs safer by warning users before running unrecognized programs downloaded from the Internet. However, due to the fact that some information is sent to Microsoft about files and programs run on PCs some organizations may prefer to disable it.

Impact:

Users will be warned and prevented from running unrecognized programs downloaded from the Internet.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\SmartScreen:EnableSmartScreenInShell
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Warn and prevent bypass

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/SmartScreen/EnableSmartScreenInShell
Data type:    Integer
Value:        1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows Defender SmartScreen behavior is managed by administrators on the PC by using Windows Defender SmartScreen Settings in Action Center.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-smartscreen#enablesmartscreeninshell>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.77.2 Microsoft Edge

This section contains recommendations for Microsoft Edge-related Windows Defender SmartScreen settings.

The Group Policy settings contained within this section are provided by the Group Policy template `SmartScreen.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

18.10.77.2.1 (L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting lets you decide whether to turn on SmartScreen Filter. SmartScreen Filter provides warning messages to help protect your employees from potential phishing scams and malicious software.

The recommended state for this setting is: `Enabled`.

Rationale:

SmartScreen serves an important purpose as it helps to warn users of possible malicious sites and files. Allowing users to turn off this setting can make the browser become more vulnerable to compromise.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Browser:AllowSmartScreen_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `1`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Browser:AllowSmartScreen
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Browser/AllowSmartScreen
Data type:	Integer
Value:	1

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (SmartScreen Filter is turned on.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-browser#allowsmartscreen>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

18.10.77.2.2 (L1) Ensure 'Prevent bypassing Windows Defender SmartScreen prompts for sites' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting lets you decide whether employees can override the SmartScreen Filter warnings about potentially malicious websites.

The recommended state for this setting is: *Enabled*.

Rationale:

SmartScreen will warn an employee if a website is potentially malicious. Enabling this setting prevents these warnings from being bypassed.

Impact:

Employees will not be able to ignore SmartScreen Filter warnings, and they will be blocked from going to potentially malicious websites that SmartScreen detects.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Browser:PreventSmartScreenPromptOverride_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Browser:PreventSmartScreenPromptOverride
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Browser/PreventSmartScreenPromptOverride
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Employees will be able to ignore SmartScreen Filter warnings about potentially malicious websites and continue to the site.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-browser#preventscreenscreenpromptoverride>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 <u>Enable Anti-Exploitation Features</u> Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.			
v7	8.1 <u>Utilize Centrally Managed Anti-malware Software</u> Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

18.10.78 Windows Error Reporting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ErrorReporting.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.79 Windows Game Recording and Broadcasting

This section contains settings for Windows Game Recording and Broadcasting.

This Group Policy section is provided by the Group Policy template `GameDVR.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

18.10.79.1 (L1) Ensure 'Enables or disables Windows Game Recording and Broadcasting' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting enables or disables the Windows Game Recording and Broadcasting features.

The recommended state for this setting is: `Disabled`.

Rationale:

If this setting is allowed users could record and broadcast session info to external sites which is a privacy concern.

Impact:

Windows Game Recording will not be allowed.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:AllowGameDVR_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:AllowGameDVR
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/AllowGameDVR
Data type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Recording and Broadcasting (streaming) is allowed.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-applicationmanagement#allowgamedvr>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.80 Windows Hello for Business (formerly Microsoft Passport for Work)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Passport.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note: This section was initially named *Microsoft Passport for Work* but was renamed by Microsoft to *Windows Hello for Business* starting with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates.

18.10.81 Windows Ink Workspace

This section contains recommendations related to the Windows Ink Workspace.

This Group Policy section is provided by the Group Policy template `WindowsInkWorkspace.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

18.10.81.1 (L2) Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting determines whether suggested apps in Windows Ink Workspace are allowed.

The recommended state for this setting is: `Disabled`.

Rationale:

This Microsoft feature is designed to collect data and suggest apps based on that data collected. Disabling this setting will help ensure your data is not shared with any third party.

Impact:

The suggested apps in Windows Ink Workspace will not be allowed.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsInkWorkspace:AllowSuggestedAppsInWindowsInkWorkspace_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\WindowsInkWorkspace:AllowSuggestedAppsInWindowsInkWorkspace
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/WindowsInkWorkspace/AllowSuggestedAppsInWindowsInkWorkspace
Data type:      Integer
Value:          0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (The suggested apps in Windows Ink Workspace will be allowed.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-windowsinkworkspace#allowsuggestedappsinwindowsinkworkspace>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.81.2 (L1) Ensure 'Allow Windows Ink Workspace' is set to 'Enabled: On, but disallow access above lock' OR 'Disabled' but not 'Enabled: On' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether Windows Ink items are allowed above the lock screen.

The recommended state for this setting is: Enabled: On, but disallow access above lock OR Disabled.

Rationale:

Allowing any apps to be accessed while system is locked is not recommended. If this feature is permitted, it should only be accessible once a user authenticates with the proper credentials.

Impact:

Windows Ink Workspace will not be permitted above the lock screen.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsInkWorkspace:AllowWindowsInkWorkspace_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0 OR 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\WindowsInkWorkspace:AllowWindowsInkWorkspace
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 'Enabled: On, but disallow access above lock OR Disabled

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/WindowsInkWorkspace/AllowWindowsInkWorkspa
ce
Data type:    Integer
Value:        0 OR 1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (Windows Ink Workspace is permitted above the lock screen.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-windowsinkworkspace#allowwindowsinkworkspace>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.82 Windows Installer

This section contains recommendations related to Windows Installer.

This Group Policy section is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.82.1 (L1) Ensure 'Allow user control over installs' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting controls whether users are permitted to change installation options that typically are available only to system administrators. The security features of Windows Installer normally prevent users from changing installation options that are typically reserved for system administrators, such as specifying the directory to which files are installed. If Windows Installer detects that an installation package has permitted the user to change a protected option, it stops the installation and displays a message. These security features operate only when the installation program is running in a privileged security context in which it has access to directories denied to the user.

The recommended state for this setting is: `Disabled`.

Rationale:

In an enterprise managed environment, only IT staff with administrative rights should be installing or changing software on a system. Allowing users the ability to have any control over installs can risk unapproved software from being installed or removed from a system, which could cause the system to become vulnerable to compromise.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:MSIAllowUserControlOverInstall_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:MSIAllowUserControlOverInstall
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/MSIAllowUserControlOverInstall
Data type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The security features of Windows Installer will prevent users from changing installation options typically reserved for system administrators, such as specifying the directory to which files are installed.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-applicationmanagement#msiallowusercontroloverinstall>

18.10.82.2 (L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting controls whether or not Windows Installer should use system permissions when it installs any program on the system.

Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders.

Caution: If enabled, skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure.

The recommended state for this setting is: `Disabled`.

Rationale:

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:MSIAlwaysInstallWithElevatedPrivileges_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:MSIAlwaysInstallWithElevatedPrivileges
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/ApplicationManagement/MSIAlwaysInstallWith
ElevatedPrivileges
Data type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Note #2 This recommendation can also be applied via the *Device restrictions/App Store/Install apps with elevated privileges* profile.

Default Value:

Disabled. (Windows Installer will apply the current user's permissions when it installs programs that a system administrator does not distribute or offer. This will prevent standard users from installing applications that affect system-wide configuration items.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-applicationmanagement#msialwaysinstallwithelevatedprivileges>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.3 <u>Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

18.10.83 Windows Logon Options

This section contains recommendations related to Windows Logon Options.

This Group Policy section is provided by the Group Policy template `WinLogon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.83.1 (L1) Ensure 'Sign-in and lock last interactive user automatically after a restart' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting controls whether a device will automatically sign-in the last interactive user after Windows Update restarts the system.

The recommended state for this setting is: `Disabled`.

Rationale:

Disabling this feature will prevent the caching of user's credentials and unauthorized use of the device, and also ensure the user is aware of the restart.

Impact:

The device does not store the user's credentials for automatic sign-in after a Windows Update restart. The users' lock screen apps are not restarted after the system restarts. The user is required to present the logon credentials in order to proceed after restart.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsLogon:AllowAutomaticRestartSignOn_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\WindowsLogon:AllowAutomaticRestartSignOn
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System:DisableAutomaticRestartSignOn
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Windows Logon Options
Setting Name:	Sign-in and lock last interactive user automatically after a restart
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (The device securely saves the user's credentials (including the user name, domain and encrypted password) to configure automatic sign-in after a Windows Update restart. After the Windows Update restart, the user is automatically signed-in and the session is automatically locked with all the lock screen apps configured for that user.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	16.11 <u>Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.			

18.10.84 Windows Media Digital Rights Management

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsMediaDRM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.85 Windows Media Player

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsMediaPlayer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.86 Windows Messenger

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsMessenger.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.87 Windows Mobility Center

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MobilePCMobilityCenter.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.88 Windows PowerShell

This section contains recommendations related to Windows PowerShell.

This Group Policy section is provided by the Group Policy template `PowerShellExecutionPolicy.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

18.10.88.1 (L1) Ensure 'Turn on PowerShell Script Block Logging' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting enables logging of all PowerShell script input to the `Applications and Services Logs\Microsoft\Windows\PowerShell\Operational` Event Log channel.

The recommended state for this setting is: `Enabled`.

Note: If logging of *Script Block Invocation Start/Stop Events* is enabled (option box checked), PowerShell will log additional events when invocation of a command, script block, function, or script starts or stops. Enabling this option generates a high volume of event logs. CIS has intentionally chosen not to make a recommendation for this option, since it generates a large volume of events. **If an organization chooses to enable the optional setting (checked), this also conforms to the benchmark.**

Rationale:

Logs of PowerShell script input can be very valuable when performing forensic investigations of PowerShell attack incidents to determine what occurred.

Impact:

PowerShell script input will be logged to the `Applications and Services Logs\Microsoft\Windows\PowerShell\Operational` Event Log channel, which can contain credentials and sensitive information.

Warning: There are potential risks of capturing credentials and sensitive information in the PowerShell logs, which could be exposed to users who have read-access to those logs. Microsoft provides a feature called "Protected Event Logging" to better secure event log data. For assistance with protecting event logging, visit: [About Logging Windows - PowerShell | Microsoft Docs](#).

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlock  
Logging:EnableScriptBlockLogging
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Windows PowerShell
Setting Name:	Turn on PowerShell Script Block Logging
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (PowerShell will log script blocks the first time they are used.)

References:

1. https://docs.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_logging_windows?view=powershell-7.2#protected-event-logging

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.8 <u>Collect Command-Line Audit Logs</u> Collect command-line audit logs. Example implementations include collecting audit logs from PowerShell®, BASH™, and remote administrative terminals.			
v7	8.8 <u>Enable Command-line Audit Logging</u> Enable command-line audit logging for command shells, such as Microsoft Powershell and Bash.			

18.10.88.2 (L1) Ensure 'Turn on PowerShell Transcription' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This Policy setting lets you capture the input and output of Windows PowerShell commands into text-based transcripts.

The recommended state for this setting is: `Enabled`.

Rationale:

PowerShell transcript input can be very valuable when performing forensic investigations of PowerShell attack incidents to determine what occurred.

Impact:

PowerShell transcript input will be logged to the `PowerShell_transcript` output file, which is saved to the My Documents folder of each users' profile by default.

Warning: There are potential risks of capturing credentials and sensitive information in the `PowerShell_transcript` output file, which could be exposed to users who have read-access to the file.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\PowerShell\Transcription:EnableTranscripting
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration\Windows Components\Windows PowerShell
Setting Name:	Turn on PowerShell Transcription
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Transcription of PowerShell-based applications is disabled by default, although transcription can still be enabled through the `Start-Transcript` cmdlet.)

References:

1. https://docs.microsoft.com/en-us/powershell/module/microsoft.powershell.core/about/about_group_policy_settings?view=powershell-7.2#turn-on-powershell-transcription

18.10.89 Windows Reliability Analysis

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `RacWmiProv.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

18.10.90 Windows Remote Management (WinRM)

This section contains recommendations related to Windows Remote Management (WinRM).

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.90.1 WinRM Client

This section contains recommendations related to the Windows Remote Management (WinRM) client.

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.90.1.1 (L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client uses Basic authentication.

The recommended state for this setting is: `Disabled`.

Note: Clients that use Microsoft's Exchange Online service (Office 365) will require an exception to this recommendation, to instead have this setting set to `Enabled`. Exchange Online uses Basic authentication over HTTPS, and so the Exchange Online authentication traffic will still be safely encrypted.

Rationale:

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:AllowBasicAuthentication_Client_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:AllowBasicAuthentication_Client
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowBasic
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Client
Setting Name: Allow Basic authentication
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM client does not use Basic authentication.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	16.5 <u>Encrypt Transmittal of Username and Authentication Credentials</u> Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.		●	●

18.10.90.1.2 (L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client sends and receives unencrypted messages over the network.

The recommended state for this setting is: `Disabled`.

Rationale:

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:AllowUnencryptedTraffic_Client_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:AllowUnencryptedTraffic_Client
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowUnencryptedTraffic
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Client
Setting Name: Allow unencrypted traffic
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM client sends or receives only encrypted messages over the network.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.		●	●

18.10.90.1.3 (L1) Ensure 'Disallow Digest authentication' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) client will not use Digest authentication.

The recommended state for this setting is: `Enabled`.

Rationale:

Digest authentication is less robust than other authentication methods available in WinRM, an attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Impact:

The WinRM client will not use Digest authentication.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:DisallowDigestAuthentication_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:DisallowDigestAuthentication
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Client:AllowDigest
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Client
Setting Name: Disallow Digest authentication
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM client will use Digest authentication.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	16.5 <u>Encrypt Transmittal of Username and Authentication Credentials</u> Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.			

18.10.90.2 WinRM Service

This section contains recommendations related to the Windows Remote Management (WinRM) service.

This Group Policy section is provided by the Group Policy template `WindowsRemoteManagement.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.90.2.1 (L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service accepts Basic authentication from a remote client.

The recommended state for this setting is: `Disabled`.

Rationale:

Basic authentication is less robust than other authentication methods available in WinRM because credentials including passwords are transmitted in plain text. An attacker who is able to capture packets on the network where WinRM is running may be able to determine the credentials used for accessing remote hosts via WinRM.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:AllowBasicAuthentication_Service_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:AllowBasicAuthentication_Service
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowBasic
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Service
Setting Name: Allow Basic authentication
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM service will not accept Basic authentication from a remote client.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	16.5 <u>Encrypt Transmittal of Username and Authentication Credentials</u> Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.			

18.10.90.2.2 (L2) Ensure 'Allow remote server management through WinRM' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service automatically listens on the network for requests on the HTTP transport over the default HTTP port.

The recommended state for this setting is: `Disabled`.

Rationale:

Any feature is a potential avenue of attack, those that enable inbound network connections are particularly risky. Only enable the use of the Windows Remote Management (WinRM) service on trusted networks and when feasible employ additional controls such as IPsec.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:AllowRemoteServerManagement_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\RemoteManagement:AllowRemoteServerManagement
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowAutoConfig
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Service
Setting Name: Allow remote server management through WinRM
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM service will not respond to requests from a remote computer, regardless of whether or not any WinRM listeners are configured.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

18.10.90.2.3 (L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service sends and receives unencrypted messages over the network.

The recommended state for this setting is: `Disabled`.

Rationale:

Encrypting WinRM network traffic reduces the risk of an attacker viewing or modifying WinRM messages as they transit the network.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:AllowUnencryptedTraffic_Service_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:AllowUnencryptedTraffic_Service
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:AllowUnencryptedTraffic
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Service
Setting Name: Allow unencrypted traffic
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM service sends or receives only encrypted messages over the network.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 <u>Encrypt Sensitive Data in Transit</u> Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).			
v7	14.4 <u>Encrypt All Sensitive Information in Transit</u> Encrypt all sensitive information in transit.			

18.10.90.2.4 (L1) Ensure 'Disallow WinRM from storing RunAs credentials' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether the Windows Remote Management (WinRM) service will allow RunAs credentials to be stored for any plug-ins.

The recommended state for this setting is: `Enabled`.

Note: If you enable and then disable this policy setting, any values that were previously configured for `RunAsPassword` will need to be reset.

Rationale:

Although the ability to store RunAs credentials is a convenient feature it increases the risk of account compromise slightly. For example, if you forget to lock your desktop before leaving it unattended for a few minutes another person could access not only the desktop of your computer but also any hosts you manage via WinRM with cached RunAs credentials.

Impact:

The WinRM service will not allow the `RunAsUser` or `RunAsPassword` configuration values to be set for any plug-ins. If a plug-in has already set the `RunAsUser` and `RunAsPassword` configuration values, the `RunAsPassword` configuration value will be erased from the credential store on the computer.

If this setting is later Disabled again, any values that were previously configured for `RunAsPassword` will need to be reset.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteManagement:DisallowStoringOfRunAsCredentials_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\RemoteManagement:DisallowStoringOfRunAsCredentials
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service:DisableRunAs
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Computer Configuration/Windows Components/Windows Remote Management (WinRM)/WinRM Service
Setting Name: Disallow WinRM from storing RunAs credentials
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (The WinRM service will allow the `RunAsUser` and `RunAsPassword` configuration values to be set for plug-ins and the `RunAsPassword` value will be stored securely.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.3 Disable Workstation to Workstation Communication Disable all workstation to workstation communication to limit an attacker's ability to move laterally and compromise neighboring systems, through technologies such as Private VLANs or microsegmentation.			

18.10.91 Windows Remote Shell

This section contains settings related to Windows Remote Shell (WinRS).

This Group Policy section is provided by the Group Policy template `WindowsRemoteShell.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.91.1 (L2) Ensure 'Allow Remote Shell Access' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting allows you to manage configuration of remote access to all supported shells to execute scripts and commands.

The recommended state for this setting is: `Disabled`.

Note: The GPME help text for this setting is incorrectly worded, implying that configuring it to `Enabled` will reject new Remote Shell connections, and setting it to `Disabled` will allow Remote Shell connections. The opposite is true (and is consistent with the title of the setting). This is a wording mistake by Microsoft in the Administrative Template.

Rationale:

Any feature is a potential avenue of attack, those that enable inbound network connections are particularly risky. Only enable the use of the Windows Remote Shell on trusted networks and when feasible employ additional controls such as IPsec.

Impact:

New Remote Shell connections are not allowed and are rejected by the workstation.

Audit:

Navigate to the following registry location and confirm it is set to 2. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\RemoteShell:AllowRemoteShellAccess_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <disabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\RemoteShell:AllowRemoteShellAccess
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Microsoft\Windows\WinRM\Service\WinRS:AllowRemoteShellAccess
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to *Disabled*:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Computer Configuration/Windows Components/Windows Remote Shell
Setting Name:	Allow Remote Shell Access
Configuration:	Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled. (New Remote Shell connections are allowed.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

18.10.92 Windows Sandbox

This section contains recommendations related to Windows Sandbox.

This Group Policy section is provided by the Group Policy template `WindowsSandbox.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.93 Windows Security (formerly Windows Defender Security Center)

This section contains recommendations related to the Windows Security Center console settings.

This Group Policy section is provided by the Group Policy template `WindowsDefenderSecurityCenter.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

Note: This section was originally named *Windows Defender Security Center* but was renamed by Microsoft to *Windows Security* starting with the Microsoft Windows 10 Release 1809 & Server 2019 Administrative Templates.

18.10.93.1 Account protection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsDefenderSecurityCenter.admx/adml` that is included with the Microsoft Windows 10 Release 1803 Administrative Templates (or newer).

18.10.93.2 App and browser protection

This section contains App and browser protection settings.

This Group Policy section is provided by the Group Policy template `WindowsDefenderSecurityCenter.admx/adml` that is included with the Microsoft Windows 10 Release 1709 Administrative Templates (or newer).

18.10.93.2.1 (L1) Ensure 'Prevent users from modifying settings' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting prevents users from making changes to the Exploit protection settings area in the Windows Security settings.

The recommended state for this setting is: *Enabled*.

Rationale:

Only authorized IT staff should be able to make changes to the exploit protection settings in order to ensure the organizations specific configuration is not modified.

Impact:

Local users cannot make changes in the Exploit protection settings area.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\WindowsDefenderSecurityCenter:DisallowExploitProtectionOverride_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\WindowsDefenderSecurityCenter:DisallowExploitProtectionOverride
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/WindowsDefenderSecurityCenter/DisallowExploitProtectionOverride
Data type:     Integer
Value:         1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Local users are allowed to make changes in the Exploit protection settings area.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-windowsdefendersecuritycenter#disallowexploitprotectionoverride>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	8.3 <u>Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies</u> Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.			

18.10.94 Windows Update

This section contains recommendations related to Windows Update.

This Group Policy section is provided by the Group Policy template `WindowsUpdate.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

18.10.94.1 Legacy Policies

This section contains recommendations related to legacy Windows Update policies.

This Group Policy section is provided by the Group Policy template `WindowsUpdate.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.94.2 Manage end user experience

This section contains recommendations related to managing Windows Update end user experience.

This Group Policy section is provided by the Group Policy template `WindowsUpdate.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.94.2.1 (L1) Ensure 'Configure Automatic Updates' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies whether computers in your environment will receive security updates from Windows Update or WSUS. If you configure this policy setting to Enabled, the operating system will recognize when a network connection is available and then use the network connection to search Windows Update or your designated intranet site for updates that apply to them.

After you configure this policy setting to Enabled, select one of the following three options in the Configure Automatic Updates Properties dialog box to specify how the service will work:

- 0: Notify the user before downloading the update.
- 1: Auto install the update and then notify the user to schedule a device restart.
- 2: Auto install and restart.
- 3: Auto install and restart at a specified time.
- 4: Auto install and restart at a specified time. (This option is the same as 3, but restricts end user controls on the settings page.)
- 5: Turn off automatic updates.
- 6: Updates automatically download and install at an optimal time determined by the device. (Default)

The recommended state for this setting is: Enabled: <Choose option from above> except for 5.

Note: The sub-setting "*Configure automatic updating*:" has 4 possible values – all of them are valid depending on specific organizational needs, however if feasible we suggest using a value of 4 - Auto download and schedule the install. This suggestion is not a scored requirement.

Note #2: Organizations that utilize a 3rd-party solution for patching may choose to exempt themselves from this recommendation, and instead configure it to Disabled so that the native Windows Update mechanism does not interfere with the 3rd-party patching process.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

Critical operating system updates and service packs will be installed as necessary.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Update:AllowAutoUpdate_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0 or 1 or 2 or 3 or 4 or 6.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Update:AllowAutoUpdate
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled <Choose option from above> except for 5.

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Update/AllowAutoUpdate
Data type:	Integer
Value:	0 or 1 or 2 or 3 or 4 or 6 (depending on the option chosen above)

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: 3 - Auto download and notify for install. (Windows finds updates that apply to the computer and downloads them in the background (the user is not notified or interrupted during this process). When the downloads are complete, users will be notified that they are ready to install. After going to Windows Update, users can install them.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-update#update-allowautoupdate>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>7.3 Perform Automated Operating System Patch Management</u> Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.			
v7	<u>3.4 Deploy Automated Operating System Patch Management Tools</u> Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.			

18.10.94.2.2 (L1) Ensure 'Configure Automatic Updates: Scheduled install day' is set to '0 - Every day' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting specifies when computers in your environment will receive security updates from Windows Update or WSUS.

The recommended state for this setting is: 0 - Every day.

Note: This setting is only applicable if 4 - Auto download and schedule the install is selected in Rule 18.9.102.2. It will have no impact if any other option is selected.

Rationale:

Although each version of Windows is thoroughly tested before release, it is possible that problems will be discovered after the products are shipped. The Configure Automatic Updates setting can help you ensure that the computers in your environment will always have the most recent critical operating system updates and service packs installed.

Impact:

If 4 - Auto download and schedule the install is selected in Rule 18.9.102.2, critical operating system updates and service packs will automatically download every day (at 3:00 A.M., by default).

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Update\ScheduledInstallDay_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Update\ScheduledInstallDay
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to 0 - Every day

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Update/ScheduledInstallDay
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Not Defined. (Since the default value of Configure Automatic Updates is 3 - Auto download and notify for install, this setting is not applicable by default.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-update#scheduledinstallday>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>7.3 Perform Automated Operating System Patch Management</u> Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.			
v7	<u>3.4 Deploy Automated Operating System Patch Management Tools</u> Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.			

18.10.94.2.3 (L1) Ensure 'Remove access to "Pause updates" feature' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy removes access to "Pause updates" feature.

The recommended state for this setting is: `Enabled`.

Rationale:

In order to ensure security and system updates are applied, system administrators should control when updates are applied to systems.

Impact:

Users will not be able to select the "Pause updates" option in Windows Update to prevent updates from being installed on a system.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Update:SetDisablePauseUXAccess_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `1`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Update:SetDisablePauseUXAccess
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./Device/Vendor/MSFT/Policy/Config/Update/SetDisablePauseUXAccess
Data type:    Integer
Value:        1
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users have access to the "Pause updates" feature.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-update#setdisablepauseuxaccess>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>7.3 Perform Automated Operating System Patch Management</u> Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.			
v7	<u>3.4 Deploy Automated Operating System Patch Management Tools</u> Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.			

18.10.94.3 Manage updates offered from Windows Server Update Service

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsUpdate.admx/adml` that is included with the Microsoft Windows 11 Release 21H2 Administrative Templates (or newer).

18.10.94.3.1 (L1) Ensure 'Manage preview builds' is set to 'Enabled: Disable preview builds' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can access the Windows Insider Program controls in Settings -> Update and Security. These controls enable users to make their devices available for downloading and installing preview (beta) builds of Windows software.

The recommended state for this setting is: `Enabled: Disable preview builds`.

Rationale:

It can be risky for experimental features to be allowed in an enterprise managed environment because this can introduce bugs and security holes into systems, making it easier for an attacker to gain access. It is generally preferred to only use production-ready builds.

Impact:

Preview builds are prevented from installing on the device.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Update:ManagePreviewBuilds_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Update:ManagePreviewBuilds
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to Enabled: Disable preview builds

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Name:	<Enter name>
Description:	<Enter Description>
OMA-URI:	./Device/Vendor/MSFT/Policy/Config/Update/ManagePreviewBuilds
Data type:	Integer
Value:	0

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Preview builds are not installed on the device, unless the user opts-in through Settings -> Update and Security)

References:

1. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-Update?WT.mc_id=Portal-fx#update-managepreviewbuilds

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.3 <u>Address Unauthorized Software</u> Ensure that unauthorized software is either removed from use on enterprise assets or receives a documented exception. Review monthly, or more frequently.			
v7	2.6 <u>Address unapproved software</u> Ensure that unauthorized software is either removed or the inventory is updated in a timely manner			

18.10.94.3.2 (L1) Ensure 'Select when Quality Updates are received' is set to 'Enabled: 0 days' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This settings controls when Quality Updates are received.

The recommended state for this setting is: `Enabled: 0 days`.

Note: If the "Allow Telemetry" policy is set to 0, this policy will have no effect.

Note #2: Starting with Windows 10 R1607, Microsoft introduced a new Windows Update (WU) client behavior called **Dual Scan**, with an eye to cloud-based update management. In some cases, this Dual Scan feature can interfere with Windows Updates from Windows Server Update Services (WSUS) and/or manual WU updates. If you are using WSUS in your environment, you may need to set the above setting to `Not Configured` or configure the setting *Do not allow update deferral policies to cause scans against Windows Update* (added in the Windows 10 Release 1709 Administrative Templates) in order to prevent the Dual Scan feature from interfering. More information on Dual Scan is available at these links:

- [Demystifying "Dual Scan" – WSUS Product Team Blog](#)
- [Improving Dual Scan on 1607 – WSUS Product Team Blog](#)

Rationale:

Quality Updates can contain important bug fixes and/or security patches, and should be installed as soon as possible.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\Update:PauseQualityUpdates_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\Update:PauseQualityUpdates
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled: Semi-Annual Channel, 180 or more days`

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:    <Enter Description>
OMA-URI:       ./Device/Vendor/MSFT/Policy/Config/Update/PauseQualityUpdates
Data type:     Integer
Value:         0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Enabled: 0 days. (Install new Quality Updates as soon as they are available.)

References:

1. https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-Update?WT.mc_id=Portal-fx#update-pausequalityupdates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 <u>Perform Automated Operating System Patch Management</u> Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.			
v7	3.4 <u>Deploy Automated Operating System Patch Management Tools</u> Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.			

18.10.94.4 Manage updates offered from Windows Update (formerly Defer Windows Updates and Windows Update for Business)

This section contains recommendations related to managing which updates are offered from Windows Update, and when.

This Group Policy section is provided by the Group Policy template `WindowsUpdate.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

Note: This section was initially named *Defer Windows Updates* but was renamed by Microsoft to *Windows Update for Business* starting with the Microsoft Windows 10 Release 1709 Administrative Templates. It was renamed (again) to *Manage updates offered from Windows Update* starting with the Microsoft Windows 11 Release 21H2 Administrative Templates.

19 Administrative Templates (User)

This section contains user-based recommendations from Group Policy Administrative Templates (ADMX).

19.1 Control Panel

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.2 Desktop

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.3 Network

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.4 Shared Folders

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SharedFolders.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.5 Start Menu and Taskbar

This section contains recommendations for Start Menu and Taskbar settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.5.1 Notifications

This section contains recommendations for Notification settings.

This Group Policy section is provided by the Group Policy template `WPN.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

19.5.1.1 (L1) Ensure 'Turn off toast notifications on the lock screen' is set to 'Blocked' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting turns off toast notifications on the lock screen.

The recommended state for this setting is `Blocked`.

Rationale:

While this feature can be handy for users, applications that provide toast notifications might display sensitive personal or business data while the device is left unattended.

Impact:

Applications will not be able to raise toast notifications on the lock screen.

Audit:

Navigate to the following registry location and confirm it is set to `1`. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\AboveLock:
AllowToasts_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to `0`.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\
Device\AboveLock:AllowToasts
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Blocked**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Device restrictions)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	Device Restrictions/Locked Screen Experience
Setting Name:	Toast notifications on lock screen
Configuration:	Block

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Toast notifications on the lock screen are enabled and can be turned off by the administrator or user.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	<u>16.11 Lock Workstation Sessions After Inactivity</u> Automatically lock workstation sessions after a standard period of inactivity.	●	●	●

19.6 System

This section contains recommendations for System settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.1 Ctrl+Alt+Del Options

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `CtrlAltDel.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.2 Display

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Display.admx/adml` that is included with the Microsoft Windows 10 Release 1803 Administrative Templates (or newer).

19.6.3 Driver Installation

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DeviceInstallation.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.4 Folder Redirection

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FolderRedirection.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.5 Group Policy

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `GroupPolicy.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.6 Internet Communication Management

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.6.1 Internet Communication settings

This section contains recommendations related to Internet Communication settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.6.6.1.1 (L2) Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 2 (L2) - High Security/Sensitive Data Environment (limited functionality)

Description:

This policy setting specifies whether users can participate in the Help Experience Improvement program. The Help Experience Improvement program collects information about how customers use Windows Help so that Microsoft can improve it.

The recommended state for this setting is: *Enabled*.

Rationale:

Large enterprise managed environments may not want to have information collected by Microsoft from managed client computers.

Impact:

Users cannot participate in the Help Experience Improvement program.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_USERS\[USER  
SID]\Software\Policies\Microsoft\Assistance\Client\1.0:NoImplicitFeedback
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: User Configuration\System\Internet Communication Management\Internet Communication Settings
Setting Name: Turn off Help Experience Improvement Program
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can turn on the Help Experience Improvement program feature from the Help and Support settings page.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	<u>4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software</u> Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.			
v7	<u>9.2 Ensure Only Approved Ports, Protocols and Services Are Running</u> Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.			

19.7 Windows Components

This section contains recommendations for Windows Component settings.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.1 Add features to Windows 8 / 8.1 / 10 (formerly Windows Anytime Upgrade)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsAnytimeUpgrade.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

Note: This section was initially named *Windows Anytime Upgrade* but was renamed by Microsoft to *Add features to Windows x* starting with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

19.7.2 App runtime

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `AppXRuntime.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

19.7.3 Application Compatibility

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `AppCompat.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.4 Attachment Manager

This section contains recommendations related to Attachment Manager.

This Group Policy section is provided by the Group Policy template `AttachmentManager.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.4.1 (L1) Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting allows you to manage whether Windows marks file attachments with information about their zone of origin (such as restricted, Internet, intranet, local). This requires NTFS in order to function correctly, and will fail without notice on FAT32. By not preserving the zone information, Windows cannot make proper risk assessments.

The recommended state for this setting is: *Disabled*.

Note: The Attachment Manager feature warns users when opening or executing files which are marked as being from an untrusted source, unless/until the file's zone information has been removed via the "Unblock" button on the file's properties or via a separate tool such as [Microsoft Sysinternals Streams](#).

Rationale:

A file that is downloaded from a computer in the Internet or Restricted Sites zone may be moved to a location that makes it appear safe, like an intranet file share, and executed by an unsuspecting user. The Attachment Manager feature will warn users when opening or executing files which are marked as being from an untrusted source, unless/until the file's zone information has been removed.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 2.

```
HKEY_USERS\[USER  
SID]\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments:SaveZoneI  
nformation
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Administrative Templates/User Configuration/Windows Components/Attachment Manager
Setting Name: Do not preserve zone information in file attachments
Configuration: Disabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows marks file attachments with their zone information.)

19.7.4.2 (L1) Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting manages the behavior for notifying registered antivirus programs. If multiple programs are registered, they will all be notified.

The recommended state for this setting is: `Enabled`.

Note: An updated antivirus program must be installed for this policy setting to function properly.

Rationale:

Antivirus programs that do not perform on-access checks may not be able to scan downloaded files.

Impact:

Windows tells the registered antivirus program(s) to scan the file when a user opens a file attachment. If the antivirus program fails, the attachment is blocked from being opened.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\{USER  
SID}\AttachmentManager:NotifyAntivirusProgram_ProviderSet
```

To confirm that the policy was properly applied to the system, check one of the following locations:

Navigate to the following registry location and confirm it is set to <enabled/>.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{USER  
SID}\AttachmentManager:NotifyAntivirusProgram
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

OR

Navigate to the following registry location and confirm it is set to 3.

```
HKEY_USERS\[USER  
SID]\Software\Microsoft\Windows\CurrentVersion\Policies\Attachments:ScanWithA  
ntiVirus
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Enabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path: Administrative Templates/User Configuration/Windows Components/Attachment Manager
Setting Name: Notify antivirus programs when opening attachments
Configuration: Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows does not call the registered antivirus program(s) when file attachments are opened.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.			
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.			

19.7.5 AutoPlay Policies

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `AutoPlay.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.6 Calculator

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Programs.admx/adml` that is included with the Microsoft Windows 10 Release 2004 Administrative Templates (or newer).

19.7.7 Cloud Content

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `CloudContent.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

19.7.8 Credential User Interface

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `CredUI.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

19.7.9 Data Collection and Preview Builds

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DataCollection.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

19.7.10 Desktop Gadgets

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sidebar.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

19.7.11 Desktop Window Manager

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DWM.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.12 Digital Locker

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `DigitalLocker.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.13 Edge UI

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EdgeUI.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

19.7.14 File Explorer (formerly Windows Explorer)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Windows Explorer* but was renamed by Microsoft to *File Explorer* starting with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates.

19.7.15 File Revocation

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `FileRevocation.admx/adml` that is included with the Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates (or newer).

19.7.16 IME

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `EAIME.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates (or newer).

19.7.17 Instant Search

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WordWheel.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.18 Internet Explorer

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.19 Location and Sensors

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sensors.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

19.7.20 Microsoft Edge

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MicrosoftEdge.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

19.7.21 Microsoft Management Console

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MMC.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.22 Microsoft User Experience Virtualization

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `UserExperienceVirtualization.admx/adml` that is included with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates (or newer).

19.7.23 NetMeeting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Conf.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.24 Network Sharing

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Sharing.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.24.1 (L1) Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This policy setting determines whether users can share files within their profile. By default, users are allowed to share files within their profile to other users on their network after an administrator opts in the computer. An administrator can opt in the computer by using the sharing wizard to share a file within their profile.

The recommended state for this setting is: `Enabled`.

Rationale:

If not properly configured, a user could accidentally share sensitive data with unauthorized users. In an enterprise managed environment, the company should provide a managed location for file sharing, such as a file server or SharePoint, instead of the user sharing files directly from their own user profile.

Impact:

Users cannot share files within their profile using the sharing wizard. Also, the sharing wizard cannot create a share at `%root%\Users` and can only be used to create SMB shares on folders.

Audit:

Navigate to the following registry location and confirm it is set to 1.

```
HKEY_USERS\[USER  
SID]\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\Explorer:NoInplaceSha  
ring
```

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to **Enabled**:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Administrative Templates)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

Path:	User Configuration\Windows Components\Network Sharing
Setting Name:	Prevent users from sharing files within their profile.
Configuration:	Enabled

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Users can share files out of their user profile after an administrator has opted in the computer.)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.			

19.7.25 OOB

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `OOBE.admx/adml` that is included with the Microsoft Windows 10 Release 1809 and Server 2019 Administrative Templates (or newer).

19.7.26 Presentation Settings

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `MobilePCPresentationSettings.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.27 Remote Desktop Services (formerly Terminal Services)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TerminalServer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Note: This section was initially named *Terminal Services* but was renamed by Microsoft to *Remote Desktop Services* starting with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates.

19.7.28 RSS Feeds

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `InetRes.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.29 Search

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Search.admx/adml` that is included with the Microsoft Windows 7 & Server 2008 R2 Administrative Templates (or newer).

19.7.30 Sound Recorder

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SoundRec.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.31 Store

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinStoreUI.admx/adml` that is included with the Microsoft Windows 8.0 & Server 2012 (non-R2) Administrative Templates and Microsoft Windows 8.1 & Server 2012 R2 Administrative Templates, or by the Group Policy template `WindowsStore.admx/adml` that is included with the Microsoft Windows 10 Release 1511 Administrative Templates (or newer).

19.7.32 Tablet PC

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Windows.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.33 Task Scheduler

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `TaskScheduler.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.34 Windows Calendar

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinCal.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.35 Windows Color System

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsColorSystem.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.36 Windows Defender SmartScreen

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `SmartScreen.admx/adml` that is included with the Microsoft Windows 10 Release 1703 Administrative Templates (or newer).

19.7.37 Windows Error Reporting

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `ErrorReporting.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.38 Windows Hello for Business (formerly Microsoft Passport for Work)

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `Passport.admx/adml` that is included with the Microsoft Windows 10 RTM (Release 1507) Administrative Templates (or newer).

Note: This section was initially named *Microsoft Passport for Work* but was renamed by Microsoft to *Windows Hello for Business* starting with the Microsoft Windows 10 Release 1607 & Server 2016 Administrative Templates.

19.7.39 Windows Installer

This section contains recommendations related to Windows Installer.

This Group Policy section is provided by the Group Policy template `MSI.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.39.1 (L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)

Profile Applicability:

- Level 1 (L1) - Corporate/Enterprise Environment (general use)

Description:

This setting controls whether or not Windows Installer should use system permissions when it installs any program on the system.

Note: This setting appears both in the Computer Configuration and User Configuration folders. To make this setting effective, you must enable the setting in both folders.

Caution: If enabled, skilled users can take advantage of the permissions this setting grants to change their privileges and gain permanent access to restricted files and folders. Note that the User Configuration version of this setting is not guaranteed to be secure.

The recommended state for this setting is: *Disabled*.

Rationale:

Users with limited privileges can exploit this feature by creating a Windows Installer installation package that creates a new local account that belongs to the local built-in Administrators group, adds their current account to the local built-in Administrators group, installs malicious software, or performs other unauthorized activities.

Impact:

None - this is the default behavior.

Audit:

Navigate to the following registry location and confirm it is set to 1. This location confirms that the *Device Configuration Policy* from Intune was received and can also confirm what the winning policy is.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\current\device\ApplicationManagement:MSIAlwaysInstallWithElevatedPrivileges_ProviderSet
```

To confirm that the policy was properly applied to the system, check the following location:

Navigate to the following registry location and confirm it is set to 0.

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\PolicyManager\Providers\{GUID}\Default\Device\ApplicationManagement:MSIAlwaysInstallWithElevatedPrivileges
```

Note: The GUID can be found in the first registry location mentioned above. The key will contain *ADMXInstanceData* in its name.

Remediation:

To establish the recommended configuration, set the following *Device Configuration Policy* to `Disabled`:

To access the *Device Configuration Policy* from the Intune Home page:

- Click *Devices*
- Click *Configuration profiles*
- Click *Create profile*
- Select the *platform* (Windows 10 and later)
- Select the *profile* (Custom)
- Click *Create*
- Enter a *Name*
- Click *Next*
- Configure the following *Setting*

```
Name:          <Enter name>
Description:   <Enter Description>
OMA-URI:
./User/Vendor/MSFT/Policy/Config/ApplicationManagement/MSIAlwaysInstallWithElevatedPrivileges
Data type:    Integer
Value:        0
```

- Select *OK*
- Continue through the *Wizard* to *complete* the creation of the profile (profile assignments, applicability etc.)

Note: More than one configuration setting from each of the *Configuration profiles* (ex: Administrative Templates, Custom etc.) can be added to each *Device Configuration Policy*.

Default Value:

Disabled. (Windows Installer will apply the current user's permissions when it installs programs that a system administrator does not distribute or offer. This will prevent standard users from installing applications that affect system-wide configuration items.)

References:

1. <https://learn.microsoft.com/en-us/windows/client-management/mdm/policy-csp-applicationmanagement#msialwaysinstallwithelevatedprivileges>

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.3 <u>Ensure the Use of Dedicated Administrative Accounts</u> Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.			

19.7.40 Windows Logon Options

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WinLogon.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

19.7.41 Windows Media Player

This section is intentionally blank and exists to ensure the structure of Windows benchmarks is consistent.

This Group Policy section is provided by the Group Policy template `WindowsMediaPlayer.admx/adml` that is included with all versions of the Microsoft Windows Administrative Templates.

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	Account Policies		
1.1	Password Policy		
1.1.1	(L1) Ensure 'Enforce password history' is set to '24 or more passwords' (Automated)	☐	☐
1.1.2	(L1) Ensure 'Maximum password age' is set to '365 or fewer days, but not 0' (Automated)	☐	☐
1.1.3	(L1) Ensure 'Minimum password age' is set to '1 or more day(s)' (Automated)	☐	☐
1.1.4	(L1) Ensure 'Minimum password length' is set to '14 or more characters' (Automated)	☐	☐
1.1.5	(L1) Ensure 'Password must meet complexity requirements' is set to 'Numbers and lowercase' (Automated)	☐	☐
2	Local Policies		
2.1	Audit Policy		
2.2	User Rights Assignment		
2.2.1	(L1) Ensure 'Access Credential Manager as a trusted caller' is set to 'No One' (Automated)	☐	☐
2.2.2	(L1) Ensure 'Access this computer from the network' is set to 'Administrators, Remote Desktop Users' (Automated)	☐	☐
2.2.3	(L1) Ensure 'Act as part of the operating system' is set to 'No One' (Automated)	☐	☐
2.2.4	(L1) Ensure 'Allow log on locally' is set to 'Administrators, Users' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.2.5	(L1) Ensure 'Back up files and directories' is set to 'Administrators' (Automated)	☐	☐
2.2.6	(L1) Ensure 'Change the system time' is set to 'Administrators, LOCAL SERVICE' (Automated)	☐	☐
2.2.7	(L1) Ensure 'Create a pagefile' is set to 'Administrators' (Automated)	☐	☐
2.2.8	(L1) Ensure 'Create a token object' is set to 'No One' (Automated)	☐	☐
2.2.9	(L1) Ensure 'Create global objects' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)	☐	☐
2.2.10	(L1) Ensure 'Create permanent shared objects' is set to 'No One' (Automated)	☐	☐
2.2.11	(L1) Configure 'Create symbolic links' is set to 'Administrators' (Automated)	☐	☐
2.2.12	(L1) Ensure 'Debug programs' is set to 'Administrators' (Automated)	☐	☐
2.2.13	(L1) Ensure 'Deny access to this computer from the network' to include 'Guests, Local account' (Automated)	☐	☐
2.2.14	(L1) Ensure 'Deny log on as a service' to include 'Guests' (Automated)	☐	☐
2.2.15	(L1) Ensure 'Deny log on locally' to include 'Guests' (Automated)	☐	☐
2.2.16	(L1) Ensure 'Deny log on through Remote Desktop Services' to include 'Guests, Local account' (Automated)	☐	☐
2.2.17	(L1) Ensure 'Enable computer and user accounts to be trusted for delegation' is set to 'No One' (Automated)	☐	☐
2.2.18	(L1) Ensure 'Force shutdown from a remote system' is set to 'Administrators' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.2.19	(L1) Ensure 'Generate security audits' is set to 'LOCAL SERVICE, NETWORK SERVICE' (Automated)	☐	☐
2.2.20	(L1) Ensure 'Impersonate a client after authentication' is set to 'Administrators, LOCAL SERVICE, NETWORK SERVICE, SERVICE' (Automated)	☐	☐
2.2.21	(L1) Ensure 'Increase scheduling priority' is set to 'Administrators, Window Manager\Window Manager Group' (Automated)	☐	☐
2.2.22	(L1) Ensure 'Load and unload device drivers' is set to 'Administrators' (Automated)	☐	☐
2.2.23	(L1) Ensure 'Lock pages in memory' is set to 'No One' (Automated)	☐	☐
2.2.24	(L1) Ensure 'Manage auditing and security log' is set to 'Administrators' (Automated)	☐	☐
2.2.25	(L1) Ensure 'Modify an object label' is set to 'No One' (Automated)	☐	☐
2.2.26	(L1) Ensure 'Modify firmware environment values' is set to 'Administrators' (Automated)	☐	☐
2.2.27	(L1) Ensure 'Perform volume maintenance tasks' is set to 'Administrators' (Automated)	☐	☐
2.2.28	(L1) Ensure 'Profile single process' is set to 'Administrators' (Automated)	☐	☐
2.2.29	(L1) Ensure 'Restore files and directories' is set to 'Administrators' (Automated)	☐	☐
2.2.30	(L1) Ensure 'Take ownership of files or other objects' is set to 'Administrators' (Automated)	☐	☐
2.3	Security Options		
2.3.1	Accounts		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.3.1.1	(L1) Ensure 'Accounts: Block Microsoft accounts' is set to 'Blocked' (Automated)	☐	☐
2.3.1.2	(L1) Ensure 'Accounts: Guest account status' is set to 'Disabled' (Automated)	☐	☐
2.3.1.3	(L1) Ensure 'Accounts: Limit local account use of blank passwords to console logon only' is set to 'Enabled' (Automated)	☐	☐
2.3.1.4	(L1) Configure 'Accounts: Rename administrator account' (Automated)	☐	☐
2.3.1.5	(L1) Configure 'Accounts: Rename guest account' (Automated)	☐	☐
2.3.2	Audit		
2.3.3	DCOM		
2.3.4	Devices		
2.3.4.1	(L2) Ensure 'Devices: Prevent users from installing printer drivers' is set to 'Enabled' (Automated)	☐	☐
2.3.5	Domain controller		
2.3.6	Domain member		
2.3.7	Interactive logon		
2.3.7.1	(L1) Ensure 'Interactive logon: Do not require CTRL+ALT+DEL' is set to 'Disabled' (Automated)	☐	☐
2.3.7.2	(L1) Ensure 'Interactive logon: Don't display last signed-in' is set to 'Enabled' (Automated)	☐	☐
2.3.7.3	(L1) Ensure 'Interactive logon: Machine inactivity limit' is set to '900 or fewer second(s), but not 0' (Automated)	☐	☐
2.3.7.4	(L1) Configure 'Interactive logon: Message text for users attempting to log on' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.3.7.5	(L1) Configure 'Interactive logon: Message title for users attempting to log on' (Automated)	☐	☐
2.3.7.6	(L1) Ensure 'Interactive logon: Smart card removal behavior' is set to 'Lock Workstation' or higher (Automated)	☐	☐
2.3.8	Microsoft network client		
2.3.8.1	(L1) Ensure 'Microsoft network client: Digitally sign communications (always)' is set to 'Enabled' (Automated)	☐	☐
2.3.8.2	(L1) Ensure 'Microsoft network client: Digitally sign communications (if server agrees)' is set to 'Enabled' (Automated)	☐	☐
2.3.8.3	(L1) Ensure 'Microsoft network client: Send unencrypted password to third-party SMB servers' is set to 'Disabled' (Automated)	☐	☐
2.3.9	Microsoft network server		
2.3.9.1	(L1) Ensure 'Microsoft network server: Digitally sign communications (always)' is set to 'Enabled' (Automated)	☐	☐
2.3.9.2	(L1) Ensure 'Microsoft network server: Digitally sign communications (if client agrees)' is set to 'Enabled' (Automated)	☐	☐
2.3.10	Network access		
2.3.10.1	(L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts' is set to 'Enabled' (Automated)	☐	☐
2.3.10.2	(L1) Ensure 'Network access: Do not allow anonymous enumeration of SAM accounts and shares' is set to 'Enabled' (Automated)	☐	☐
2.3.10.3	(L1) Ensure 'Network access: Restrict anonymous access to Named Pipes and Shares' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.3.10.4	(L1) Ensure 'Network access: Restrict clients allowed to make remote calls to SAM' is set to 'Administrators: Remote Access: Allow' (Automated)	☐	☐
2.3.11	Network security		
2.3.11.1	(L1) Ensure 'Network security: Allow Local System to use computer identity for NTLM' is set to 'Enabled' (Automated)	☐	☐
2.3.11.2	(L1) Ensure 'Network Security: Allow PKU2U authentication requests to this computer to use online identities' is set to 'Disabled' (Automated)	☐	☐
2.3.11.3	(L1) Ensure 'Network security: Do not store LAN Manager hash value on next password change' is set to 'Enabled' (Automated)	☐	☐
2.3.11.4	(L1) Ensure 'Network security: LAN Manager authentication level' is set to 'Send NTLMv2 response only. Refuse LM & NTLM' (Automated)	☐	☐
2.3.11.5	(L1) Ensure 'Network security: Minimum session security for NTLM SSP based (including secure RPC) clients' is set to 'Require NTLMv2 session security, Require 128-bit encryption' (Automated)	☐	☐
2.3.12	Recovery console		
2.3.13	Shutdown		
2.3.14	System cryptography		
2.3.15	System objects		
2.3.16	System settings		
2.3.17	User Account Control		
2.3.17.1	(L1) Ensure 'User Account Control: Admin Approval Mode for the Built-in Administrator account' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.3.17.2	(L1) Ensure 'User Account Control: Behavior of the elevation prompt for administrators in Admin Approval Mode' is set to 'Prompt for consent on the secure desktop' or higher (Automated)	☐	☐
2.3.17.3	(L1) Ensure 'User Account Control: Behavior of the elevation prompt for standard users' is set to 'Automatically deny elevation requests' (Automated)	☐	☐
2.3.17.4	(L1) Ensure 'User Account Control: Detect application installations and prompt for elevation' is set to 'Enabled' (Automated)	☐	☐
2.3.17.5	(L1) Ensure 'User Account Control: Only elevate UIAccess applications that are installed in secure locations' is set to 'Enabled' (Automated)	☐	☐
2.3.17.6	(L1) Ensure 'User Account Control: Run all administrators in Admin Approval Mode' is set to 'Enabled' (Automated)	☐	☐
2.3.17.7	(L1) Ensure 'User Account Control: Switch to the secure desktop when prompting for elevation' is set to 'Enabled' (Automated)	☐	☐
2.3.17.8	(L1) Ensure 'User Account Control: Virtualize file and registry write failures to per-user locations' is set to 'Enabled' (Automated)	☐	☐
3	Event Log		
4	Restricted Groups		
5	System Services		
5.1	(L1) Ensure 'Xbox Accessory Management Service (XboxGipSvc)' is set to 'Disabled' (Automated)	☐	☐
5.2	(L1) Ensure 'Xbox Live Auth Manager (XblAuthManager)' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.3	(L1) Ensure 'Xbox Live Game Save (XblGameSave)' is set to 'Disabled' (Automated)	☐	☐
5.4	(L1) Ensure 'Xbox Live Networking Service (XboxNetApiSvc)' is set to 'Disabled' (Automated)	☐	☐
6	Registry		
7	File System		
8	Wired Network (IEEE 802.3) Policies		
9	Windows Firewall with Advanced Security		
9.1	Domain Profile		
9.1.1	(L1) Ensure 'Windows Firewall: Domain: Firewall state' is set to 'Enabled' (Automated)	☐	☐
9.1.2	(L1) Ensure 'Windows Firewall: Domain: Inbound connections' is set to 'Block' (Automated)	☐	☐
9.1.3	(L1) Ensure 'Windows Firewall: Domain: Outbound connections' is set to 'Allow' (Automated)	☐	☐
9.1.4	(L1) Ensure 'Windows Firewall: Domain: Settings: Display a notification' is set to 'Block' (Automated)	☐	☐
9.2	Private Profile		
9.2.1	(L1) Ensure 'Windows Firewall: Private: Firewall state' is set to 'Enabled' (Automated)	☐	☐
9.2.2	(L1) Ensure 'Windows Firewall: Private: Inbound connections' is set to 'Block' (Automated)	☐	☐
9.2.3	(L1) Ensure 'Windows Firewall: Private: Outbound connections' is set to 'Allow' (Automated)	☐	☐
9.2.4	(L1) Ensure 'Windows Firewall: Private: Settings: Display a notification' is set to 'Block' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
9.3	Public Profile		
9.3.1	(L1) Ensure 'Windows Firewall: Public: Firewall state' is set to 'Enabled' (Automated)	☐	☐
9.3.2	(L1) Ensure 'Windows Firewall: Public: Inbound connections' is set to 'Block' (Automated)	☐	☐
9.3.3	(L1) Ensure 'Windows Firewall: Public: Outbound connections' is set to 'Allow' (Automated)	☐	☐
9.3.4	(L1) Ensure 'Windows Firewall: Public: Settings: Display a notification' is set to 'Block' (Automated)	☐	☐
9.3.5	(L1) Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No' (Automated)	☐	☐
10	Network List Manager Policies		
11	Wireless Network (IEEE 802.11) Policies		
12	Public Key Policies		
13	Software Restriction Policies		
14	Network Access Protection NAP Client Configuration		
15	Application Control Policies		
16	IP Security Policies		
17	Advanced Audit Policy Configuration		
17.1	Account Logon		
17.1.1	(L1) Ensure 'Audit Credential Validation' is set to 'Success and Failure' (Automated)	☐	☐
17.2	Account Management		
17.2.1	(L1) Ensure 'Audit Application Group Management' is set to 'Success and Failure' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
17.2.2	(L1) Ensure 'Audit Security Group Management' is set to include 'Success' (Automated)	☐	☐
17.2.3	(L1) Ensure 'Audit User Account Management' is set to 'Success and Failure' (Automated)	☐	☐
17.3	Detailed Tracking		
17.3.1	(L1) Ensure 'Audit PNP Activity' is set to include 'Success' (Automated)	☐	☐
17.3.2	(L1) Ensure 'Audit Process Creation' is set to include 'Success' (Automated)	☐	☐
17.4	DS Access		
17.5	Logon/Logoff		
17.5.1	(L1) Ensure 'Audit Account Lockout' is set to include 'Failure' (Automated)	☐	☐
17.5.2	(L1) Ensure 'Audit Group Membership' is set to include 'Success' (Automated)	☐	☐
17.5.3	(L1) Ensure 'Audit Logoff' is set to include 'Success' (Automated)	☐	☐
17.5.4	(L1) Ensure 'Audit Logon' is set to 'Success and Failure' (Automated)	☐	☐
17.5.5	(L1) Ensure 'Audit Other Logon/Logoff Events' is set to 'Success and Failure' (Automated)	☐	☐
17.5.6	(L1) Ensure 'Audit Special Logon' is set to include 'Success' (Automated)	☐	☐
17.6	Object Access		
17.6.1	(L1) Ensure 'Audit Detailed File Share' is set to include 'Failure' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
17.6.2	(L1) Ensure 'Audit File Share' is set to 'Success and Failure' (Automated)	☐	☐
17.6.3	(L1) Ensure 'Audit Other Object Access Events' is set to 'Success and Failure' (Automated)	☐	☐
17.6.4	(L1) Ensure 'Audit Removable Storage' is set to 'Success and Failure' (Automated)	☐	☐
17.7	Policy Change		
17.7.1	(L1) Ensure 'Audit Audit Policy Change' is set to include 'Success' (Automated)	☐	☐
17.7.2	(L1) Ensure 'Audit Authentication Policy Change' is set to include 'Success' (Automated)	☐	☐
17.7.3	(L1) Ensure 'Audit Authorization Policy Change' is set to include 'Success' (Automated)	☐	☐
17.7.4	(L1) Ensure 'Audit MPSSVC Rule-Level Policy Change' is set to 'Success and Failure' (Automated)	☐	☐
17.7.5	(L1) Ensure 'Audit Other Policy Change Events' is set to include 'Failure' (Automated)	☐	☐
17.8	Privilege Use		
17.8.1	(L1) Ensure 'Audit Sensitive Privilege Use' is set to 'Success and Failure' (Automated)	☐	☐
17.9	System		
17.9.1	(L1) Ensure 'Audit IPsec Driver' is set to 'Success and Failure' (Automated)	☐	☐
17.9.2	(L1) Ensure 'Audit Other System Events' is set to 'Success and Failure' (Automated)	☐	☐
17.9.3	(L1) Ensure 'Audit Security State Change' is set to include 'Success' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
17.9.4	(L1) Ensure 'Audit Security System Extension' is set to include 'Success' (Automated)	☐	☐
17.9.5	(L1) Ensure 'Audit System Integrity' is set to 'Success and Failure' (Automated)	☐	☐
18	Administrative Templates (Computer)		
18.1	Control Panel		
18.1.1	Personalization		
18.1.1.1	(L1) Ensure 'Prevent enabling lock screen camera' is set to 'Enabled' (Automated)	☐	☐
18.1.1.2	(L1) Ensure 'Prevent enabling lock screen slide show' is set to 'Enabled' (Automated)	☐	☐
18.1.2	Regional and Language Options		
18.1.2.1	Handwriting personalization		
18.1.2.2	(L1) Ensure 'Allow users to enable online speech recognition services' is set to 'Disabled' (Automated)	☐	☐
18.1.3	(L2) Ensure 'Allow Online Tips' is set to 'Disabled' (Automated)	☐	☐
18.2	Desktop		
18.3	LAPS		
18.3.1	(L1) Ensure LAPS AdmPwd GPO Extension / CSE is installed (Automated)	☐	☐
18.3.2	(L1) Ensure 'Do not allow password expiration time longer than required by policy' is set to 'Enabled' (Automated)	☐	☐
18.3.3	(L1) Ensure 'Enable Local Admin Password Management' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.3.4	(L1) Ensure 'Password Settings: Password Complexity' is set to 'Enabled: Large letters + small letters + numbers + special characters' (Automated)	☐	☐
18.3.5	(L1) Ensure 'Password Settings: Password Length' is set to 'Enabled: 15 or more' (Automated)	☐	☐
18.3.6	(L1) Ensure 'Password Settings: Password Age (Days)' is set to 'Enabled: 30 or fewer' (Automated)	☐	☐
18.4	MS Security Guide		
18.4.1	(L1) Ensure 'Apply UAC restrictions to local accounts on network logons' is set to 'Enabled' (Automated)	☐	☐
18.4.2	(L1) Ensure 'Configure SMB v1 client driver' is set to 'Enabled: Disable driver (recommended)' (Automated)	☐	☐
18.4.3	(L1) Ensure 'Configure SMB v1 server' is set to 'Disabled' (Automated)	☐	☐
18.4.4	(L1) Ensure 'Enable Structured Exception Handling Overwrite Protection (SEHOP)' is set to 'Enabled' (Automated)	☐	☐
18.4.5	(L1) Ensure 'WDigest Authentication' is set to 'Disabled' (Automated)	☐	☐
18.5	MSS (Legacy)		
18.5.1	(L1) Ensure 'MSS: (AutoAdminLogon) Enable Automatic Logon (not recommended)' is set to 'Disabled' (Automated)	☐	☐
18.5.2	(L1) Ensure 'MSS: (DisableIPSourceRouting IPv6) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.5.3	(L1) Ensure 'MSS: (DisableIPSourceRouting) IP source routing protection level (protects against packet spoofing)' is set to 'Enabled: Highest protection, source routing is completely disabled' (Automated)	☐	☐
18.5.4	(L2) Ensure 'MSS: (DisableSavePassword) Prevent the dial-up password from being saved' is set to 'Enabled' (Automated)	☐	☐
18.5.5	(L1) Ensure 'MSS: (EnableICMPRedirect) Allow ICMP redirects to override OSPF generated routes' is set to 'Disabled' (Automated)	☐	☐
18.5.6	(L2) Ensure 'MSS: (KeepAliveTime) How often keep-alive packets are sent in milliseconds' is set to 'Enabled: 300,000 or 5 minutes (recommended)' (Automated)	☐	☐
18.5.7	(L1) Ensure 'MSS: (NoNameReleaseOnDemand) Allow the computer to ignore NetBIOS name release requests except from WINS servers' is set to 'Enabled' (Automated)	☐	☐
18.5.8	(L1) Ensure 'MSS: (SafeDllSearchMode) Enable Safe DLL search mode (recommended)' is set to 'Enabled' (Automated)	☐	☐
18.5.9	(L2) Ensure 'MSS: (PerformRouterDiscovery) Allow IRDP to detect and configure Default Gateway addresses (could lead to DoS)' is set to 'Disabled' (Automated)	☐	☐
18.5.10	(L1) Ensure 'MSS: (ScreenSaverGracePeriod) The time in seconds before the screen saver grace period expires (0 recommended)' is set to 'Enabled: 5 or fewer seconds' (Automated)	☐	☐
18.5.11	(L2) Ensure 'MSS: (TcpMaxDataRetransmissions) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.5.12	(L2) Ensure 'MSS: (TcpMaxDataRetransmissions IPv6) How many times unacknowledged data is retransmitted' is set to 'Enabled: 3' (Automated)	☐	☐
18.5.13	(L1) Ensure 'MSS: (WarningLevel) Percentage threshold for the security event log at which the system will generate a warning' is set to 'Enabled: 90% or less' (Automated)	☐	☐
18.6	Network		
18.6.1	Background Intelligent Transfer Service (BITS)		
18.6.2	BranchCache		
18.6.3	DirectAccess Client Experience Settings		
18.6.4	DNS Client		
18.6.4.1	(L1) Ensure 'Turn off multicast name resolution' is set to 'Enabled' (Automated)	☐	☐
18.6.5	Fonts		
18.6.5.1	(L2) Ensure 'Enable Font Providers' is set to 'Disabled' (Automated)	☐	☐
18.6.6	Hotspot Authentication		
18.6.7	Lanman Server		
18.6.8	Lanman Workstation		
18.6.8.1	(L1) Ensure 'Enable insecure guest logons' is set to 'Disabled' (Automated)	☐	☐
18.6.9	Link-Layer Topology Discovery		
18.6.9.1	(L2) Ensure 'Turn on Mapper I/O (LLTDIO) driver' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.6.9.2	(L2) Ensure 'Turn on Responder (RSPNDR) driver' is set to 'Disabled' (Automated)	☐	☐
18.6.10	Microsoft Peer-to-Peer Networking Services		
18.6.11	Network Connections		
18.6.11.1	Windows Defender Firewall (formerly Windows Firewall)		
18.6.11.2	(L1) Ensure 'Prohibit installation and configuration of Network Bridge on your DNS domain network' is set to 'Enabled' (Automated)	☐	☐
18.6.11.3	(L1) Ensure 'Prohibit use of Internet Connection Sharing on your DNS domain network' is set to 'Enabled' (Automated)	☐	☐
18.6.11.4	(L1) Ensure 'Require domain users to elevate when setting a network's location' is set to 'Enabled' (Automated)	☐	☐
18.6.12	Network Connectivity Status Indicator		
18.6.13	Network Isolation		
18.6.14	Network Provider		
18.6.14.1	(L1) Ensure 'Hardened UNC Paths' is set to 'Enabled, with "Require Mutual Authentication" and "Require Integrity" set for all NETLOGON and SYSVOL shares' (Automated)	☐	☐
18.6.15	Offline Files		
18.6.16	QoS Packet Scheduler		
18.6.17	SNMP		
18.6.18	SSL Configuration Settings		
18.6.19	TCPIP Settings		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.6.20	Windows Connect Now		
18.6.20.1	(L2) Ensure 'Configuration of wireless settings using Windows Connect Now' is set to 'Disabled' (Automated)	☐	☐
18.6.20.2	(L2) Ensure 'Prohibit access of the Windows Connect Now wizards' is set to 'Enabled' (Automated)	☐	☐
18.6.21	Windows Connection Manager		
18.6.21.1	(L1) Ensure 'Prohibit connection to non-domain networks when connected to domain authenticated network' is set to 'Enabled' (Automated)	☐	☐
18.6.21.2	(L1) Ensure 'Minimize the number of simultaneous connections to the Internet or a Windows Domain' is set to 'Enabled: 3 = Prevent Wi-Fi when on Ethernet' (Automated)	☐	☐
18.6.22	Wireless Display		
18.6.23	WLAN Service		
18.6.23.1	WLAN Media Cost		
18.6.23.2	WLAN Settings		
18.6.23.2.1	(L1) Ensure 'Allow Windows to automatically connect to suggested open hotspots, to networks shared by contacts, and to hotspots offering paid services' is set to 'Disabled' (Automated)	☐	☐
18.7	Printers		
18.7.1	(L1) Ensure 'Allow Print Spooler to accept client connections' is set to 'Disabled' (Automated)	☐	☐
18.7.2	(L1) Ensure 'Point and Print Restrictions: When installing drivers for a new connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.7.3	(L1) Ensure 'Point and Print Restrictions: When updating drivers for an existing connection' is set to 'Enabled: Show warning and elevation prompt' (Automated)	☐	☐
18.8	Start Menu and Taskbar		
18.8.1	Notifications		
18.8.1.1	(L2) Ensure 'Turn off notifications network usage' is set to 'Enabled' (Automated)	☐	☐
18.9	System		
18.9.1	Access-Denied Assistance		
18.9.2	App-V		
18.9.3	Audit Process Creation		
18.9.3.1	(L1) Ensure 'Include command line in process creation events' is set to 'Enabled' (Automated)	☐	☐
18.9.4	Credentials Delegation		
18.9.4.1	(L1) Ensure 'Encryption Oracle Remediation' is set to 'Enabled: Force Updated Clients' (Automated)	☐	☐
18.9.4.2	(L1) Ensure 'Remote host allows delegation of non-exportable credentials' is set to 'Enabled' (Automated)	☐	☐
18.9.5	Device Guard		
18.9.5.1	(NG) Ensure 'Turn On Virtualization Based Security' is set to 'Enabled' (Automated)	☐	☐
18.9.5.2	(NG) Ensure 'Turn On Virtualization Based Security: Select Platform Security Level' is set to 'Secure Boot' or higher (Automated)	☐	☐
18.9.5.3	(NG) Ensure 'Turn On Virtualization Based Security: Credential Guard Configuration' is set to 'Enabled with UEFI lock' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.5.4	(NG) Ensure 'Turn On Virtualization Based Security: Secure Launch Configuration' is set to 'Enabled' (Automated)	☐	☐
18.9.6	Device Health Attestation Service		
18.9.7	Device Installation		
18.9.7.1	Device Installation Restrictions		
18.9.7.1.1	(BL) Ensure 'Prevent installation of devices that match any of these device IDs' is set to 'Enabled' (Automated)	☐	☐
18.9.7.1.2	(BL) Ensure 'Prevent installation of devices that match any of these device IDs: Prevent installation of devices that match any of these device IDs' is set to 'PCI\CC_0C0A' (Automated)	☐	☐
18.9.7.1.3	(BL) Ensure 'Prevent installation of devices that match any of these device IDs: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)	☐	☐
18.9.7.1.4	(BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes' is set to 'Enabled' (Automated)	☐	☐
18.9.7.1.5	(BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Also apply to matching devices that are already installed.' is set to 'True' (checked) (Automated)	☐	☐
18.9.7.1.6	(BL) Ensure 'Prevent installation of devices using drivers that match these device setup classes: Prevent installation of devices using drivers for these device setup' is set to 'IEEE 1394 device setup classes' (Automated)	☐	☐
18.9.7.2	(L1) Ensure 'Prevent device metadata retrieval from the Internet' is set to 'Enabled' (Automated)	☐	☐
18.9.8	Device Redirection		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.9	Disk NV Cache		
18.9.10	Disk Quotas		
18.9.11	Display		
18.9.12	Distributed COM		
18.9.13	Driver Installation		
18.9.14	Early Launch Antimalware		
18.9.14.1	(L1) Ensure 'Boot-Start Driver Initialization Policy' is set to 'Enabled: Good, unknown and bad but critical' (Automated)	☐	☐
18.9.15	Enhanced Storage Access		
18.9.16	File Classification Infrastructure		
18.9.17	File Share Shadow Copy Agent		
18.9.18	File Share Shadow Copy Provider		
18.9.19	Filesystem (formerly NTFS Filesystem)		
18.9.20	Folder Redirection		
18.9.21	Group Policy		
18.9.21.1	(L1) Ensure 'Configure registry policy processing: Do not apply during periodic background processing' is set to 'Enabled: FALSE' (Automated)	☐	☐
18.9.21.2	(L1) Ensure 'Configure registry policy processing: Process even if the Group Policy objects have not changed' is set to 'Enabled: TRUE' (Automated)	☐	☐
18.9.21.3	(L1) Ensure 'Continue experiences on this device' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.21.4	(L1) Ensure 'Turn off background refresh of Group Policy' is set to 'Disabled' (Automated)	☐	☐
18.9.22	Internet Communication Management		
18.9.22.1	Internet Communication settings		
18.9.22.1.1	(L2) Ensure 'Turn off access to the Store' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.2	(L1) Ensure 'Turn off downloading of print drivers over HTTP' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.3	(L2) Ensure 'Turn off Internet Connection Wizard if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.4	(L1) Ensure 'Turn off Internet download for Web publishing and online ordering wizards' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.5	(L2) Ensure 'Turn off printing over HTTP' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.6	(L2) Ensure 'Turn off Registration if URL connection is referring to Microsoft.com' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.7	(L2) Ensure 'Turn off Search Companion content file updates' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.8	(L2) Ensure 'Turn off the "Order Prints" picture task' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.9	(L2) Ensure 'Turn off the "Publish to Web" task for files and folders' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.10	(L2) Ensure 'Turn off the Windows Messenger Customer Experience Improvement Program' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.22.1.11	(L2) Ensure 'Turn off Windows Customer Experience Improvement Program' is set to 'Enabled' (Automated)	☐	☐
18.9.22.1.12	(L2) Ensure 'Turn off Windows Error Reporting' is set to 'Enabled' (Automated)	☐	☐
18.9.23	iSCSI		
18.9.24	KDC		
18.9.25	Kerberos		
18.9.25.1	(L2) Ensure 'Support device authentication using certificate' is set to 'Enabled: Automatic' (Automated)	☐	☐
18.9.26	Kernel DMA Protection		
18.9.26.1	(BL) Ensure 'Enumeration policy for external devices incompatible with Kernel DMA Protection' is set to 'Enabled: Block All' (Automated)	☐	☐
18.9.27	Locale Services		
18.9.27.1	(L2) Ensure 'Disallow copying of user input methods to the system account for sign-in' is set to 'Enabled' (Automated)	☐	☐
18.9.28	Logon		
18.9.28.1	(L1) Ensure 'Block user from showing account details on sign-in' is set to 'Enabled' (Automated)	☐	☐
18.9.28.2	(L1) Ensure 'Do not display network selection UI' is set to 'Enabled' (Automated)	☐	☐
18.9.28.3	(L1) Ensure 'Do not enumerate connected users on domain-joined computers' is set to 'Enabled' (Automated)	☐	☐
18.9.28.4	(L1) Ensure 'Enumerate local users on domain-joined computers' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.28.5	(L1) Ensure 'Turn off app notifications on the lock screen' is set to 'Enabled' (Automated)	☐	☐
18.9.28.6	(L1) Ensure 'Turn off picture password sign-in' is set to 'Enabled' (Automated)	☐	☐
18.9.28.7	(L1) Ensure 'Turn on convenience PIN sign-in' is set to 'Disabled' (Automated)	☐	☐
18.9.29	Mitigation Options		
18.9.30	Net Logon		
18.9.31	OS Policies		
18.9.31.1	(L2) Ensure 'Allow Clipboard synchronization across devices' is set to 'Disabled' (Automated)	☐	☐
18.9.31.2	(L2) Ensure 'Allow upload of User Activities' is set to 'Disabled' (Automated)	☐	☐
18.9.32	Performance Control Panel		
18.9.33	PIN Complexity		
18.9.34	Power Management		
18.9.34.1	Button Settings		
18.9.34.2	Energy Saver Settings		
18.9.34.3	Hard Disk Settings		
18.9.34.4	Notification Settings		
18.9.34.5	Power Throttling Settings		
18.9.34.6	Sleep Settings		
18.9.34.6.1	(L1) Ensure 'Allow network connectivity during connected-standby (on battery)' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.34.6.2	(L1) Ensure 'Allow network connectivity during connected-standby (plugged in)' is set to 'Disabled' (Automated)	☐	☐
18.9.34.6.3	(BL) Ensure 'Allow standby states (S1-S3) when sleeping (on battery)' is set to 'Disabled' (Automated)	☐	☐
18.9.34.6.4	(BL) Ensure 'Allow standby states (S1-S3) when sleeping (plugged in)' is set to 'Disabled' (Automated)	☐	☐
18.9.34.6.5	(L1) Ensure 'Require a password when a computer wakes (on battery)' is set to 'Enabled' (Automated)	☐	☐
18.9.34.6.6	(L1) Ensure 'Require a password when a computer wakes (plugged in)' is set to 'Enabled' (Automated)	☐	☐
18.9.35	Recovery		
18.9.36	Remote Assistance		
18.9.36.1	(L1) Ensure 'Configure Offer Remote Assistance' is set to 'Disabled' (Automated)	☐	☐
18.9.36.2	(L1) Ensure 'Configure Solicited Remote Assistance' is set to 'Disabled' (Automated)	☐	☐
18.9.37	Remote Procedure Call		
18.9.37.1	(L1) Ensure 'Enable RPC Endpoint Mapper Client Authentication' is set to 'Enabled' (Automated)	☐	☐
18.9.37.2	(L1) Ensure 'Restrict Unauthenticated RPC clients' is set to 'Enabled: Authenticated' (Automated)	☐	☐
18.9.38	Removable Storage Access		
18.9.39	Scripts		
18.9.40	Security Account Manager		
18.9.41	Server Manager		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.9.42	Service Control Manager Settings		
18.9.43	Shutdown		
18.9.44	Shutdown Options		
18.9.45	Storage Health		
18.9.46	Storage Sense		
18.9.47	System Restore		
18.9.48	Troubleshooting and Diagnostics		
18.9.48.1	Microsoft Support Diagnostic Tool		
18.9.48.1.1	(L2) Ensure 'Microsoft Support Diagnostic Tool: Turn on MSDT interactive communication with support provider' is set to 'Disabled' (Automated)	☐	☐
18.9.49	Trusted Platform Module Services		
18.9.50	User Profiles		
18.9.50.1	(L2) Ensure 'Turn off the advertising ID' is set to 'Enabled' (Automated)	☐	☐
18.9.51	Windows File Protection		
18.9.52	Windows HotStart		
18.9.53	Windows Time Service		
18.9.53.1	Windows Time Service		
18.9.53.1.1	Time Providers		
18.9.53.1.1.1	(L2) Ensure 'Enable Windows NTP Client' is set to 'Enabled' (Automated)	☐	☐
18.9.53.1.1.2	(L2) Ensure 'Enable Windows NTP Server' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10	Windows Components		
18.10.1	ActiveX Installer Service		
18.10.2	Add features to Windows 10 (formerly Windows Anytime Upgrade)		
18.10.3	App Package Deployment		
18.10.3.1	(L2) Ensure 'Allow a Windows app to share application data between users' is set to 'Disabled' (Automated)	☐	☐
18.10.4	App Privacy		
18.10.4.1	(L1) Ensure 'Let Windows apps activate with voice while the system is locked' is set to 'Disabled' (Automated)	☐	☐
18.10.5	App runtime		
18.10.5.1	(L1) Ensure 'Allow Microsoft accounts to be optional' is set to 'Enabled' (Automated)	☐	☐
18.10.5.2	(L2) Ensure 'Block launching Universal Windows apps with Windows Runtime API access from hosted content.' is set to 'Enabled' (Automated)	☐	☐
18.10.6	Application Compatibility		
18.10.7	AutoPlay Policies		
18.10.7.1	(L1) Ensure 'Disallow Autoplay for non-volume devices' is set to 'Enabled' (Automated)	☐	☐
18.10.7.2	(L1) Ensure 'Set the default behavior for AutoRun' is set to 'Enabled: Do not execute any autorun commands' (Automated)	☐	☐
18.10.7.3	(L1) Ensure 'Turn off Autoplay' is set to 'Enabled: All drives' (Automated)	☐	☐
18.10.8	Biometrics		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.9	BitLocker Drive Encryption		
18.10.9.1	Fixed Data Drives		
18.10.9.1.1	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered' is set to 'Enabled' (Automated)	☐	☐
18.10.9.1.2	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Allow data recovery agent' is set to 'Enabled: True' (Automated)	☐	☐
18.10.9.1.3	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Password' is set to 'Enabled: Allow 48-digit recovery password' (Automated)	☐	☐
18.10.9.1.4	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Recovery Key' is set to 'Enabled: Allow 256-bit recovery key' (Automated)	☐	☐
18.10.9.1.5	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)	☐	☐
18.10.9.1.6	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Save BitLocker recovery information to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)	☐	☐
18.10.9.1.7	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Configure storage of BitLocker recovery information to AD DS' is set to 'Enabled: Backup recovery passwords and key packages' (Automated)	☐	☐
18.10.9.1.8	(BL) Ensure 'Choose how BitLocker-protected fixed drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for fixed data drives' is set to 'Enabled: False' (Automated)	☐	☐
18.10.9.2	Operating System Drives		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.9.2.1	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered' is set to 'Enabled' (Automated)	☐	☐
18.10.9.2.2	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Allow data recovery agent' is set to 'Enabled: False' (Automated)	☐	☐
18.10.9.2.3	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Password' is set to 'Enabled: Require 48-digit recovery password' (Automated)	☐	☐
18.10.9.2.4	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Recovery Key' is set to 'Enabled: Do not allow 256-bit recovery key' (Automated)	☐	☐
18.10.9.2.5	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Omit recovery options from the BitLocker setup wizard' is set to 'Enabled: True' (Automated)	☐	☐
18.10.9.2.6	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Save BitLocker recovery information to AD DS for operating system drives' is set to 'Enabled: True' (Automated)	☐	☐
18.10.9.2.7	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Configure storage of BitLocker recovery information to AD DS:' is set to 'Enabled: Store recovery passwords and key packages' (Automated)	☐	☐
18.10.9.2.8	(BL) Ensure 'Choose how BitLocker-protected operating system drives can be recovered: Do not enable BitLocker until recovery information is stored to AD DS for operating system drives' is set to 'Enabled: True' (Automated)	☐	☐
18.10.9.2.9	(BL) Ensure 'Require additional authentication at startup' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.9.2.10	(BL) Ensure 'Require additional authentication at startup: Allow BitLocker without a compatible TPM' is set to 'Enabled: False' (Automated)	☐	☐
18.10.9.3	Removable Data Drives		
18.10.9.3.1	(BL) Ensure 'Deny write access to removable drives not protected by BitLocker' is set to 'Enabled' (Automated)	☐	☐
18.10.9.3.2	(BL) Ensure 'Deny write access to removable drives not protected by BitLocker: Do not allow write access to devices configured in another organization' is set to 'Enabled: False' (Automated)	☐	☐
18.10.10	Camera		
18.10.10.1	(L2) Ensure 'Allow Use of Camera' is set to 'Disabled' (Automated)	☐	☐
18.10.11	Chat		
18.10.12	Cloud Content		
18.10.12.1	(L1) Ensure 'Turn off Microsoft consumer experiences' is set to 'Enabled' (Automated)	☐	☐
18.10.13	Connect		
18.10.13.1	(L1) Ensure 'Require pin for pairing' is set to 'Enabled' (Automated)	☐	☐
18.10.14	Credential User Interface		
18.10.14.1	(L1) Ensure 'Do not display the password reveal button' is set to 'Enabled' (Automated)	☐	☐
18.10.14.2	(L1) Ensure 'Enumerate administrator accounts on elevation' is set to 'Disabled' (Automated)	☐	☐
18.10.14.3	(L1) Ensure 'Prevent the use of security questions for local accounts' is set to 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.15	Data Collection and Preview Builds		
18.10.15.1	(L1) Ensure 'Allow Diagnostic Data' is set to 'Enabled: Diagnostic data off (not recommended)' or 'Enabled: Send required diagnostic data' (Automated)	☐	☐
18.10.15.2	(L2) Ensure 'Configure Authenticated Proxy usage for the Connected User Experience and Telemetry service' is set to 'Enabled: Disable Authenticated Proxy usage' (Automated)	☐	☐
18.10.15.3	(L1) Ensure 'Do not show feedback notifications' is set to 'Enabled' (Automated)	☐	☐
18.10.15.4	(L1) Ensure 'Toggle user control over Insider builds' is set to 'Disabled' (Automated)	☐	☐
18.10.16	Delivery Optimization		
18.10.17	Desktop App Installer		
18.10.18	Desktop Gadgets		
18.10.19	Desktop Window Manager		
18.10.20	Device and Driver Compatibility		
18.10.21	Device Registration (formerly Workplace Join)		
18.10.22	Digital Locker		
18.10.23	Edge UI		
18.10.24	EMET		
18.10.25	Event Forwarding		
18.10.26	Event Log Service		
18.10.26.1	Application		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.26.1.1	(L1) Ensure 'Application: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)	☐	☐
18.10.26.1.2	(L1) Ensure 'Application: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	☐	☐
18.10.26.2	Security		
18.10.26.2.1	(L1) Ensure 'Security: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)	☐	☐
18.10.26.2.2	(L1) Ensure 'Security: Specify the maximum log file size (KB)' is set to 'Enabled: 196,608 or greater' (Automated)	☐	☐
18.10.26.3	Setup		
18.10.26.3.1	(L1) Ensure 'Setup: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)	☐	☐
18.10.26.3.2	(L1) Ensure 'Setup: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	☐	☐
18.10.26.4	System		
18.10.26.4.1	(L1) Ensure 'System: Control Event Log behavior when the log file reaches its maximum size' is set to 'Disabled' (Automated)	☐	☐
18.10.26.4.2	(L1) Ensure 'System: Specify the maximum log file size (KB)' is set to 'Enabled: 32,768 or greater' (Automated)	☐	☐
18.10.27	Event Logging		
18.10.28	Event Viewer		
18.10.29	File Explorer (formerly Windows Explorer)		
18.10.29.1	Previous Versions		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.29.2	(L1) Ensure 'Turn off Data Execution Prevention for Explorer' is set to 'Disabled' (Automated)	☐	☐
18.10.29.3	(L1) Ensure 'Turn off heap termination on corruption' is set to 'Disabled' (Automated)	☐	☐
18.10.29.4	(L1) Ensure 'Turn off shell protocol protected mode' is set to 'Disabled' (Automated)	☐	☐
18.10.30	File History		
18.10.31	Find My Device		
18.10.32	Handwriting		
18.10.33	HomeGroup		
18.10.33.1	(L1) Ensure 'Prevent the computer from joining a homegroup' is set to 'Enabled' (Automated)	☐	☐
18.10.34	Human Presence		
18.10.35	Internet Explorer		
18.10.36	Internet Information Services		
18.10.37	Location and Sensors		
18.10.37.1	(L2) Ensure 'Turn off location' is set to 'Enabled' (Automated)	☐	☐
18.10.38	Maintenance Scheduler		
18.10.39	Maps		
18.10.40	MDM		
18.10.41	Messaging		
18.10.41.1	(L2) Ensure 'Allow Message Service Cloud Sync' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.42	Microsoft account		
18.10.42.1	(L1) Ensure 'Block all consumer Microsoft account user authentication' is set to 'Enabled' (Automated)	☐	☐
18.10.43	Microsoft Defender Antivirus (formerly Windows Defender and Windows Defender Antivirus)		
18.10.43.1	Client Interface		
18.10.43.2	Exclusions		
18.10.43.3	MAPS		
18.10.43.3.1	(L1) Ensure 'Configure local setting override for reporting to Microsoft MAPS' is set to 'Disabled' (Automated)	☐	☐
18.10.43.3.2	(L2) Ensure 'Join Microsoft MAPS' is set to 'Disabled' (Automated)	☐	☐
18.10.43.4	Microsoft Defender Exploit Guard (formerly Windows Defender Exploit Guard)		
18.10.43.4.1	Attack Surface Reduction		
18.10.43.4.1.1	(L1) Ensure 'Configure Attack Surface Reduction rules' is set to 'Enabled' (Manual)	☐	☐
18.10.43.4.1.2	(L1) Ensure 'Configure Attack Surface Reduction rules: Set the state for each ASR rule' is configured (Automated)	☐	☐
18.10.43.4.2	Controlled Folder Access		
18.10.43.4.3	Network Protection		
18.10.43.4.3.1	(L1) Ensure 'Prevent users and apps from accessing dangerous websites' is set to 'Enabled: Block' (Automated)	☐	☐
18.10.43.5	MpEngine		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.43.5.1	(L2) Ensure 'Enable file hash computation feature' is set to 'Enabled' (Automated)	☐	☐
18.10.43.6	Network Inspection System		
18.10.43.7	Quarantine		
18.10.43.8	Real-time Protection		
18.10.43.8.1	(L1) Ensure 'Scan all downloaded files and attachments' is set to 'Enabled' (Automated)	☐	☐
18.10.43.8.2	(L1) Ensure 'Turn off real-time protection' is set to 'Disabled' (Automated)	☐	☐
18.10.43.8.3	(L1) Ensure 'Turn on behavior monitoring' is set to 'Enabled' (Automated)	☐	☐
18.10.43.9	Remediation		
18.10.43.10	Reporting		
18.10.43.10.1	(L2) Ensure 'Configure Watson events' is set to 'Disabled' (Automated)	☐	☐
18.10.43.11	Scan		
18.10.43.11.1	(L1) Ensure 'Scan removable drives' is set to 'Enabled' (Automated)	☐	☐
18.10.43.11.2	(L1) Ensure 'Turn on e-mail scanning' is set to 'Enabled' (Automated)	☐	☐
18.10.43.12	Security Intelligence Updates (formerly Signature Updates)		
18.10.43.13	Threats		
18.10.43.14	(L1) Ensure 'Configure detection for potentially unwanted applications' is set to 'Enabled: Block' (Automated)	☐	☐
18.10.43.15	(L1) Ensure 'Turn off Microsoft Defender AntiVirus' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.44	Microsoft Defender Application Guard (formerly Windows Defender Application Guard)		
18.10.45	Microsoft Defender Exploit Guard (formerly Windows Defender Exploit Guard)		
18.10.46	Microsoft Edge		
18.10.47	Microsoft FIDO Authentication		
18.10.48	Microsoft Secondary Authentication Factor		
18.10.49	Microsoft User Experience Virtualization		
18.10.50	NetMeeting		
18.10.51	News and interests		
18.10.52	OneDrive (formerly SkyDrive)		
18.10.52.1	(L1) Ensure 'Prevent the usage of OneDrive for file storage' is set to 'Enabled' (Automated)	☐	☐
18.10.53	Online Assistance		
18.10.54	OOBE		
18.10.55	Portable Operating System		
18.10.56	Presentation Settings		
18.10.57	Push To Install		
18.10.57.1	(L2) Ensure 'Turn off Push To Install service' is set to 'Enabled' (Automated)	☐	☐
18.10.58	Remote Desktop Services (formerly Terminal Services)		
18.10.58.1	RD Licensing (formerly TS Licensing)		
18.10.58.2	Remote Desktop Connection Client		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.58.2.1	RemoteFX USB Device Redirection		
18.10.58.2.2	(L1) Ensure 'Do not allow passwords to be saved' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3	Remote Desktop Session Host (formerly Terminal Server)		
18.10.58.3.1	Application Compatibility		
18.10.58.3.2	Connections		
18.10.58.3.2.1	(L2) Ensure 'Allow users to connect remotely by using Remote Desktop Services' is set to 'Disabled' (Automated)	☐	☐
18.10.58.3.3	Device and Resource Redirection		
18.10.58.3.3.1	(L2) Ensure 'Do not allow COM port redirection' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.3.2	(L1) Ensure 'Do not allow drive redirection' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.3.3	(L2) Ensure 'Do not allow LPT port redirection' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.3.4	(L2) Ensure 'Do not allow supported Plug and Play device redirection' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.4	Licensing		
18.10.58.3.5	Printer Redirection		
18.10.58.3.6	Profiles		
18.10.58.3.7	RD Connection Broker (formerly TS Connection Broker)		
18.10.58.3.8	Remote Session Environment		
18.10.58.3.9	Security		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.58.3.9.1	(L1) Ensure 'Always prompt for password upon connection' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.9.2	(L1) Ensure 'Require secure RPC communication' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.9.3	(L1) Ensure 'Require use of specific security layer for remote (RDP) connections' is set to 'Enabled: SSL' (Automated)	☐	☐
18.10.58.3.9.4	(L1) Ensure 'Require user authentication for remote connections by using Network Level Authentication' is set to 'Enabled' (Automated)	☐	☐
18.10.58.3.9.5	(L1) Ensure 'Set client connection encryption level' is set to 'Enabled: High Level' (Automated)	☐	☐
18.10.58.3.10	Session Time Limits		
18.10.58.3.10.1	(L2) Ensure 'Set time limit for active but idle Remote Desktop Services sessions' is set to 'Enabled: 15 minutes or less, but not Never (0)' (Automated)	☐	☐
18.10.58.3.10.2	(L2) Ensure 'Set time limit for disconnected sessions' is set to 'Enabled: 1 minute' (Automated)	☐	☐
18.10.58.3.11	Temporary folders		
18.10.58.3.11.1	(L1) Ensure 'Do not delete temp folders upon exit' is set to 'Disabled' (Automated)	☐	☐
18.10.59	RSS Feeds		
18.10.59.1	(L1) Ensure 'Prevent downloading of enclosures' is set to 'Enabled' (Automated)	☐	☐
18.10.60	Search		
18.10.60.1	OCR		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.60.2	(L2) Ensure 'Allow Cloud Search' is set to 'Enabled: Disable Cloud Search' (Automated)	☐	☐
18.10.60.3	(L1) Ensure 'Allow Cortana' is set to 'Disabled' (Automated)	☐	☐
18.10.60.4	(L1) Ensure 'Allow Cortana above lock screen' is set to 'Blocked' (Automated)	☐	☐
18.10.60.5	(L1) Ensure 'Allow indexing of encrypted files' is set to 'Disabled' (Automated)	☐	☐
18.10.60.6	(L1) Ensure 'Allow search and Cortana to use location' is set to 'Disabled' (Automated)	☐	☐
18.10.61	Security Center		
18.10.62	Shutdown Options		
18.10.63	Smart Card		
18.10.64	Software Protection Platform		
18.10.64.1	(L2) Ensure 'Turn off KMS Client Online AVS Validation' is set to 'Enabled' (Automated)	☐	☐
18.10.65	Sound Recorder		
18.10.66	Speech		
18.10.67	Store		
18.10.67.1	(L2) Ensure 'Disable all apps from Microsoft Store' is set to 'Disabled' (Automated)	☐	☐
18.10.67.2	(L1) Ensure 'Only display the private store within the Microsoft Store' is set to 'Enabled' (Automated)	☐	☐
18.10.67.3	(L1) Ensure 'Turn off Automatic Download and Install of updates' is set to 'Disabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.67.4	(L1) Ensure 'Turn off the offer to update to the latest version of Windows' is set to 'Enabled' (Automated)	☐	☐
18.10.67.5	(L2) Ensure 'Turn off the Store application' is set to 'Enabled' (Automated)	☐	☐
18.10.68	Sync your settings		
18.10.69	Tablet PC		
18.10.70	Task Scheduler		
18.10.71	Tenant Restrictions		
18.10.72	Text Input		
18.10.73	Widgets		
18.10.74	Windows Calendar		
18.10.75	Windows Color System		
18.10.76	Windows Customer Experience Improvement Program		
18.10.77	Windows Defender SmartScreen		
18.10.77.1	Explorer		
18.10.77.1.1	(L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled: Warn and prevent bypass' (Automated)	☐	☐
18.10.77.2	Microsoft Edge		
18.10.77.2.1	(L1) Ensure 'Configure Windows Defender SmartScreen' is set to 'Enabled' (Automated)	☐	☐
18.10.77.2.2	(L1) Ensure 'Prevent bypassing Windows Defender SmartScreen prompts for sites' is set to 'Enabled' (Automated)	☐	☐
18.10.78	Windows Error Reporting		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.79	Windows Game Recording and Broadcasting		
18.10.79.1	(L1) Ensure 'Enables or disables Windows Game Recording and Broadcasting' is set to 'Disabled' (Automated)	☐	☐
18.10.80	Windows Hello for Business (formerly Microsoft Passport for Work)		
18.10.81	Windows Ink Workspace		
18.10.81.1	(L2) Ensure 'Allow suggested apps in Windows Ink Workspace' is set to 'Disabled' (Automated)	☐	☐
18.10.81.2	(L1) Ensure 'Allow Windows Ink Workspace' is set to 'Enabled: On, but disallow access above lock' OR 'Disabled' but not 'Enabled: On' (Automated)	☐	☐
18.10.82	Windows Installer		
18.10.82.1	(L1) Ensure 'Allow user control over installs' is set to 'Disabled' (Automated)	☐	☐
18.10.82.2	(L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)	☐	☐
18.10.83	Windows Logon Options		
18.10.83.1	(L1) Ensure 'Sign-in and lock last interactive user automatically after a restart' is set to 'Disabled' (Automated)	☐	☐
18.10.84	Windows Media Digital Rights Management		
18.10.85	Windows Media Player		
18.10.86	Windows Messenger		
18.10.87	Windows Mobility Center		
18.10.88	Windows PowerShell		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.88.1	(L1) Ensure 'Turn on PowerShell Script Block Logging' is set to 'Enabled' (Automated)	☐	☐
18.10.88.2	(L1) Ensure 'Turn on PowerShell Transcription' is set to 'Enabled' (Automated)	☐	☐
18.10.89	Windows Reliability Analysis		
18.10.90	Windows Remote Management (WinRM)		
18.10.90.1	WinRM Client		
18.10.90.1.1	(L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)	☐	☐
18.10.90.1.2	(L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)	☐	☐
18.10.90.1.3	(L1) Ensure 'Disallow Digest authentication' is set to 'Enabled' (Automated)	☐	☐
18.10.90.2	WinRM Service		
18.10.90.2.1	(L1) Ensure 'Allow Basic authentication' is set to 'Disabled' (Automated)	☐	☐
18.10.90.2.2	(L2) Ensure 'Allow remote server management through WinRM' is set to 'Disabled' (Automated)	☐	☐
18.10.90.2.3	(L1) Ensure 'Allow unencrypted traffic' is set to 'Disabled' (Automated)	☐	☐
18.10.90.2.4	(L1) Ensure 'Disallow WinRM from storing RunAs credentials' is set to 'Enabled' (Automated)	☐	☐
18.10.91	Windows Remote Shell		
18.10.91.1	(L2) Ensure 'Allow Remote Shell Access' is set to 'Disabled' (Automated)	☐	☐
18.10.92	Windows Sandbox		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
18.10.93	Windows Security (formerly Windows Defender Security Center)		
18.10.93.1	Account protection		
18.10.93.2	App and browser protection		
18.10.93.2.1	(L1) Ensure 'Prevent users from modifying settings' is set to 'Enabled' (Automated)	☐	☐
18.10.94	Windows Update		
18.10.94.1	Legacy Policies		
18.10.94.2	Manage end user experience		
18.10.94.2.1	(L1) Ensure 'Configure Automatic Updates' is set to 'Enabled' (Automated)	☐	☐
18.10.94.2.2	(L1) Ensure 'Configure Automatic Updates: Scheduled install day' is set to '0 - Every day' (Automated)	☐	☐
18.10.94.2.3	(L1) Ensure 'Remove access to "Pause updates" feature' is set to 'Enabled' (Automated)	☐	☐
18.10.94.3	Manage updates offered from Windows Server Update Service		
18.10.94.3.1	(L1) Ensure 'Manage preview builds' is set to 'Enabled: Disable preview builds' (Automated)	☐	☐
18.10.94.3.2	(L1) Ensure 'Select when Quality Updates are received' is set to 'Enabled: 0 days' (Automated)	☐	☐
18.10.94.4	Manage updates offered from Windows Update (formerly Defer Windows Updates and Windows Update for Business)		
19	Administrative Templates (User)		
19.1	Control Panel		
19.1.1	Add or Remove Programs		
19.1.2	Display		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
19.1.3	Personalization (formerly Desktop Themes)		
19.2	Desktop		
19.3	Network		
19.4	Shared Folders		
19.5	Start Menu and Taskbar		
19.5.1	Notifications		
19.5.1.1	(L1) Ensure 'Turn off toast notifications on the lock screen' is set to 'Blocked' (Automated)	☐	☐
19.6	System		
19.6.1	Ctrl+Alt+Del Options		
19.6.2	Display		
19.6.3	Driver Installation		
19.6.4	Folder Redirection		
19.6.5	Group Policy		
19.6.6	Internet Communication Management		
19.6.6.1	Internet Communication settings		
19.6.6.1.1	(L2) Ensure 'Turn off Help Experience Improvement Program' is set to 'Enabled' (Automated)	☐	☐
19.7	Windows Components		
19.7.1	Add features to Windows 8 / 8.1 / 10 (formerly Windows Anytime Upgrade)		
19.7.2	App runtime		
19.7.3	Application Compatibility		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
19.7.4	Attachment Manager		
19.7.4.1	(L1) Ensure 'Do not preserve zone information in file attachments' is set to 'Disabled' (Automated)	☐	☐
19.7.4.2	(L1) Ensure 'Notify antivirus programs when opening attachments' is set to 'Enabled' (Automated)	☐	☐
19.7.5	AutoPlay Policies		
19.7.6	Calculator		
19.7.7	Cloud Content		
19.7.8	Credential User Interface		
19.7.9	Data Collection and Preview Builds		
19.7.10	Desktop Gadgets		
19.7.11	Desktop Window Manager		
19.7.12	Digital Locker		
19.7.13	Edge UI		
19.7.14	File Explorer (formerly Windows Explorer)		
19.7.15	File Revocation		
19.7.16	IME		
19.7.17	Instant Search		
19.7.18	Internet Explorer		
19.7.19	Location and Sensors		
19.7.20	Microsoft Edge		
19.7.21	Microsoft Management Console		
19.7.22	Microsoft User Experience Virtualization		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
19.7.23	NetMeeting		
19.7.24	Network Sharing		
19.7.24.1	(L1) Ensure 'Prevent users from sharing files within their profile.' is set to 'Enabled' (Automated)	☐	☐
19.7.25	Oobe		
19.7.26	Presentation Settings		
19.7.27	Remote Desktop Services (formerly Terminal Services)		
19.7.28	RSS Feeds		
19.7.29	Search		
19.7.30	Sound Recorder		
19.7.31	Store		
19.7.32	Tablet PC		
19.7.33	Task Scheduler		
19.7.34	Windows Calendar		
19.7.35	Windows Color System		
19.7.36	Windows Defender SmartScreen		
19.7.37	Windows Error Reporting		
19.7.38	Windows Hello for Business (formerly Microsoft Passport for Work)		
19.7.39	Windows Installer		
19.7.39.1	(L1) Ensure 'Always install with elevated privileges' is set to 'Disabled' (Automated)	☐	☐
19.7.40	Windows Logon Options		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
19.7.41	Windows Media Player		

Appendix: Change History

Date	Version	Changes for this version
1/12/2021	1.0.0	Initial Public Release
10/20/2023	2.0.0	REMOVE - 2.3.4.1 (L1) Ensure 'Devices: Allowed to format and eject removable media' is set to 'Administrators and Interactive Users' Ticket # 15199
10/20/2023	2.0.0	CHANGE - 1.1 (L1) Ensure 'Password must meet complexity requirements' is set to 'Numbers, lowercase, uppercase and special characters required' TO 'Numbers and lowercase' Ticket# 16994
10/20/2023	2.0.0	UPDATE - Section changes from Windows 11 Release 22H2 Administrative Templates Ticket# 17124
10/20/2023	2.0.0	UPDATE – 18.10.87 (L1) 'Turn on PowerShell Transcription' is set to 'Disabled' TO 'Enabled' Ticket# 17516
10/20/2023	2.0.0	REMOVE - 2.3.1 (L1) Ensure 'Accounts: Administrator account status' is set to 'Disabled' Ticket# 17565
10/20/2023	2.0.0	UPDATE - 18.10.43.6.1 (L1) Ensure 'Configure Attack Surface Reduction rules' with additional ASR rule for "Block abuse of exploited vulnerable signed drivers" Ticket # 17588
10/20/2023	2.0.0	ADD - 2.2 (L1) Ensure 'Deny log on as a service' to include 'Guests' Ticket # 19376

Date	Version	Changes for this version
10/20/2023	2.0.0	ADD - 9.3 (L1) Ensure 'Windows Firewall: Public: Settings: Apply local connection security rules' is set to 'No' Ticket # 19377
10/20/2023	2.0.0	ADD - 18.10.33 (L1) Ensure 'Prevent the computer from joining a homegroup' is set to 'Enabled' Ticket # 19379
10/20/2023	2.0.0	ADD - 18.10.67 (L1) Ensure 'Turn off Automatic Download and Install of updates' is set to 'Disabled' Ticket # 19380
10/20/2023	2.0.0	REMOVE - 18.10.3 (L1) Ensure 'Prevent non-admin users from installing packaged Windows apps' is set to 'Enabled' Ticket # 17562
10/20/2023	2.0.0	REMOVE - 19.7.7 (L1) Ensure 'Do not suggest third-party content in Windows spotlight' is set to 'Enabled' Ticket #20128
10/20/2023	2.0.0	REMOVE - 19.7.7 (L2) Ensure 'Do not use diagnostic data for tailored experiences' is set to 'Enabled' Ticket #20129
10/20/2023	2.0.0	REMOVE 19.1.3 (L1) Ensure 'Enable screen saver' is set to 'Enabled' Ticket #20131
10/20/2023	2.0.0	REMOVE 19.1.3 (L1) Ensure 'Password protect the screen saver' is set to 'Enabled' Ticket #20132
10/20/2023	2.0.0	REMOVE 19.1.3 (L1) Ensure 'Screen saver timeout' is set to 'Enabled: 900 seconds or fewer, but not 0' Ticket #20133
10/20/2023	2.0.0	REMOVE - 18.10 (L1) Ensure 'Download Mode' is NOT set to 'Enabled: Internet' Ticket #20134

